

THE CYBERSECURITY ANALYST PLAYBOOK: REAL WORLD DETECTION & RESPONSE SCENARIOS

BY IZZMIER IZZUDDIN

PLAYBOOK 1 — AI-Generated Phishing Campaign

Attack Theme: AI-Crafted Phishing → Credential Harvesting → MFA Fatigue → Account Takeover → Data Exfiltration / Fraud

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Phishing for Information (T1598.003) + Gather Victim Identity Info (T1589)	Identify valid email accounts & login portals	Spike in email validation probes, password reset enumeration	Attacker mapping valid users	Source IP reputation, TOR/VPN usage, rate anomalies, user-agent uniformity	Correlate WAF logs, failed login spikes, email gateway telemetry, automation signatures	Enumeration targeting privileged accounts	Enable rate limiting, block IP temporarily	Volume is less important than pattern. Look for structured automation.
Resource Development	Acquire Infrastructure (T1583.001) + Develop Capabilities (T1587)	Register lookalike domain & prepare AI phishing kit	Newly registered domain resembling brand	Phishing infrastructure staging	Domain age, WHOIS, TLS cert reuse, passive DNS, MX setup	Check internal DNS queries for domain resolution, sandbox phishing payload, check brand abuse feeds	Internal user resolved domain + email click event	Block domain globally	AI content reduces grammar errors — detection must focus on infrastructure signals.

Initial Access	Phishing (T1566.002 Spearphishing Link)	Harvest credentials	User clicks phishing link + login attempt from unfamiliar ASN	Credential capture succeeded	Login source ASN, impossible travel, device fingerprint mismatch	Correlate phishing click timestamp with login, inspect OAuth grants, analyse browser & OS anomalies	Privileged login from unfamiliar network	Force password reset + revoke tokens	Login success ≠ legitimate user. Validate context.
Credential Access	Brute Force (T1110.003 Password Spraying) + MFA Request Generation (T1621)	MFA fatigue approval	>10 MFA push attempts followed by approval	Stolen credentials + user fatigue	MFA logs, push timing, repeated denies before approval	Compare push timestamps with user activity, check IP changes mid-attempt	Successful login after MFA spam	Revoke all sessions, reset password	MFA approval does NOT confirm legitimacy. Context validation is mandatory.
Execution	Use of Valid Accounts (T1078)	Establish authenticated session	New session token issued from rare ASN	Attacker now inside environment	Token issuance logs, session creation time, ASN change	Analyse API calls immediately after login, abnormal admin page access	High-risk API calls within minutes	Invalidate all sessions	Speed after login indicates automation.
Persistence	Modify Authentication Process (T1556) + Account	Add backup MFA or API key	New MFA factor registered	Ensuring re-entry	Audit logs for MFA enrollment, recovery	Compare against change approval workflow,	MFA device added outside business hours	Remove new MFA, disable keys	Recovery options are often overlooked

	Manipulation (T1098)				email change	time-of-day anomaly			persistence points.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group)	Gain admin role	User added to Global Admin / Domain Admins	Privilege abuse	AD event IDs 4728 / 4732, IAM role change logs	Trace login source before change, check approval chain	Non-IT user granted admin	Remove privilege immediately	Privilege escalation is impact multiplier stage.
Defense Evasion	Indicator Removal (T1070) + Impair Defenses (T1562.001)	Disable logging or EDR	Audit logging disabled, SIEM agent offline	Covering tracks	EDR health logs, security policy changes	Analyse tamper protection logs, ingestion gaps	Logging disabled post-priv escalation	Treat as confirmed compromise	Log tampering rarely legitimate in this context.
Discovery	Account Discovery (T1087) + Permission Group Discovery (T1069.002)	Map high-value accounts	PowerShell Get-ADUser, net group Domain Admins	Internal reconnaissance	PowerShell 4104 logs, LDAP query spikes	Analyse unusual enumeration from non-admin device	Enumeration from compromised user	Monitor DC access tightly	Discovery indicates attacker confidence.
Lateral Movement	Remote Services (T1021.001 RDP / T1021.002 SMB)	Pivot to servers	Multiple RDP logins across hosts	Attempt to reach DC or DB	Logon Type 10, NTLM anomalies	Inspect Pass-the-Hash indicators, unusual admin token reuse	>3 hosts accessed in short window	Disable account + isolate host	Containment speed determines impact.
Collection	Data from Information Repositories (T1213.002)	Stage sensitive data	Large SQL query from non-DBA	Data staging	DB audit logs, archive creation	Detect SELECT * queries, unusual compression	Sensitive DB accessed + staging tools used	Monitor outbound channels	Large query alone ≠ theft. Look for staging signs.

	SharePoint / T1537)					n, abnormal access time			
Command & Control	Application Layer Protocol (T1071.001 Web / T1071.004 DNS)	Maintain external control	Periodic DNS beacon every 60 sec	Active operator control	DNS entropy analysis, JA3 TLS fingerprint	Inspect DNS tunnelling patterns, suspicious ASN	Known malicious C2 infrastructure	Scope before blocking	Removing persistence before blocking prevents re-entry.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Upload data to cloud storage	3–5GB outbound to unknown storage	Data theft in progress	Proxy logs, DLP alerts	Correlate DB access spike with outbound transfer	DB spike + outbound spike	Notify legal/compliance	Regulatory impact assessment critical (PDPA / RMIT).
Impact	Data Encrypted for Impact (T1486) OR Financial Theft (T1657 Fraud)	Business disruption	File encryption or unauthorised fund transfer	Attack objective achieved	Backup health, abnormal transaction logs	Check shadow copy deletion (T1490), ransomware note, transaction anomaly review	Multiple systems encrypted or funds transferred	Activate IR plan immediately	Impact phase is failure of earlier containment layers.

PLAYBOOK 2 — Spear Phishing Targeting Finance

Attack Theme: Executive Impersonation → Invoice Fraud → MFA Bypass / Account Takeover → Payment Redirection → Financial Loss

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Phishing for Information (T1598.003) + Gather Victim Identity Info (T1589.003 Email Addresses)	Identify finance staff & executives	LinkedIn scraping indicators, targeted email harvesting patterns	Attacker profiling finance workflow	OSINT footprint, executive email exposure, public document leaks	Check credential dumps for exposed finance accounts, correlate scraping IPs with WAF logs	Enumeration focused on CFO / finance roles	Alert fraud team	Finance teams are high-value targets. Recon is role-based.
Resource Development	Acquire Infrastructure (T1583.001 Domains) + Compromise Accounts (T1586.002 Email Accounts)	Register lookalike domain & prepare impersonation mailbox	Newly registered domain similar to CEO	Fraud infrastructure staging	Domain age, SPF/DKIM/DMA RC misalignment, TLS cert reuse	Analyse passive DNS history, check for prior abuse reports	Domain passes SPF but fails alignment	Block domain at gateway	Display-name spoofing often bypasses weak DMARC enforcement.
Initial Access	Spearphishing Attachment (T1566.001)	Deliver fraudulent payment request	Email with urgent tone + invoice	Targeted executive impersonation	Header analysis, reply-to mismatch, sending ASN	Perform header trace, sandbox	Finance user replies or	Quarantine email + notify finance	Spear phishing often blends into

	or Spearphishing Link (T1566.002)		attachment			attachment , detonate URL	downloads attachment		ongoing legitimate email threads.
Credential Access	Brute Force (T1110) OR MFA Request Generation (T1621) (if credentials harvested)	Compromise mailbox to continue fraud	Failed logins + sudden success	Email account takeover	Impossible travel, session anomaly, OAuth grant	Correlate phishing click → login attempt → mailbox rule creation	Mailbox login from foreign ASN	Reset password + revoke sessions	Fraud often escalates after mailbox compromise.
Execution	Use of Valid Accounts (T1078.004 Cloud Accounts)	Send payment request from compromised mailbox	Internal email from CFO requesting urgent transfer	Account fully controlled	Check recent login history, mailbox audit logs	Identify inbox rule changes, forwarding setup	New external forwarding rule created	Disable forwarding + reset MFA	Attack becomes harder to detect once inside trusted mailbox.
Persistence	Account Manipulation (T1098.002 Email Forwarding Rule)	Maintain access to ongoing conversations	Hidden mailbox rule forwarding to external email	Silent monitoring of transactions	Audit inbox rules, OAuth app permissions	Compare rule creation timestamp to login source	Rule created immediately after login	Remove rule + revoke OAuth tokens	Forwarding rules are primary persistence in BEC.
Privilege Escalation	Valid Accounts (T1078) + Account Manipulation (T1098.003 Add	Access shared finance folders	User added to finance shared mailbox	Expanding fraud scope	Check AD / IAM group membership changes	Review approval chain, helpdesk logs	Non-finance user added to finance group	Remove privilege	Privilege creep increases financial impact.

	Account to Group)								
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Bypass email security alerts	Safe-links or anti-phishing policy disabled	Attempt to evade detection	Security policy modification logs	Inspect change management approval, correlate with compromised account	Security control changed without ticket	Restore policy immediately	Email security control tampering is high confidence compromise.
Discovery	Account Discovery (T1087) + Email Collection (T1114.002 Remote Email Collection)	Identify high-value invoice threads	Large mailbox search queries	Attacker mapping ongoing payments	Mailbox search audit logs	Review search terms like “invoice”, “payment”, “bank details”	Search terms targeting payment keywords	Monitor outgoing emails	Discovery in mailbox precedes fraud attempt.
Collection	Data from Information Repositories (T1213)	Extract vendor bank details	Export of contact list / invoice attachments	Preparing payment diversion	Attachment download logs	Compare vendor bank details with prior invoices	Vendor bank detail changes observed	Notify finance leadership	Vendor detail change is fraud red flag.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain control via webmail	Repeated OWA / M365 login from single ASN	Active external operator	ASN risk score, TOR/VPN use	Check session duration, browser fingerprint reuse	Login from anonymised ASN repeatedly	Block IP after scoping	Blocking prematurely may alert attacker; scope first.
Exfiltration	Exfiltration Over Web	Export mailbox content	Full mailbox	Data theft + fraud enablement	Check mailbox export logs	Review export size, suspicious	PST export > 500MB	Notify compliance	Email often contains contract &

	Services (T1567.002)		export activity			PST downloads			payment data.
Impact	Financial Fraud (T1657)	Unauthorised fund transfer	Outgoing payment outside normal approval flow	Fraud completed	Payment logs, approval workflow bypass	Trace payment approval chain, verify bank account change history	Payment executed without dual approval	Activate fraud response & legal	Payment confirmation timing is critical for fund recall.

BYZANTIUM

PLAYBOOK 3 — Business Email Compromise (BEC)

Attack Theme: Credential Compromise → Mailbox Takeover → Internal Thread Hijacking → Payment Redirection → Silent Financial Theft

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Phishing for Information (T1598.003) + Gather Victim Identity Info (T1589.003 Email Addresses)	Identify high-value finance & executive accounts	Targeted login probes against CFO/Finance mailbox	Attacker mapping financial authority	IP reputation, geo-distribution, TOR/VPN use	Correlate failed logins with finance accounts, inspect enumeration patterns	Enumeration focused on payment-authority users	Enable conditional access restrictions	Recon is role-based. Finance & approval chain accounts are primary targets.
Resource Development	Acquire Infrastructure (T1583.001 Domains) + Compromise Accounts (T1586.002 Email Accounts)	Prepare phishing infrastructure or use previously breached credentials	Lookalike domain + leaked credentials found in dump	Staging for mailbox takeover	Domain similarity, credential reuse risk	Cross-check exposed credentials against breach datasets, check prior phishing exposure	Credential reuse from breach database	Force password reset for exposed accounts	Many BEC attacks use recycled breach credentials.
Initial Access	Valid Accounts (T1078.004	Gain mailbox access	Successful login from new ASN	Account compromise likely	Impossible travel, ASN change,	Correlate login with prior	Login via legacy protocol	Revoke tokens + disable	Legacy auth remains

	Cloud Accounts) OR Spearphishing Link (T1566.002)		after multiple failures		device fingerprint mismatch	phishing click, check legacy auth usage	bypassing MFA	legacy protocols	common BEC entry point in 2026.
Credential Access	MFA Request Generation (T1621) OR Steal Web Session Cookie (T1550.003)	Maintain authenticated session	Multiple MFA pushes followed by approval	MFA fatigue succeeded	MFA logs, push timing anomaly	Check approval timing vs user device activity, session reuse	MFA approval outside business hours	Reset credentials + revoke refresh tokens	MFA approval does not confirm legitimacy . Context validation required.
Execution	Use of Valid Accounts (T1078)	Operate inside compromised mailbox	Internal email sent requesting payment update	Attacker now impersonating executive	Mailbox audit logs, send-as activity	Analyse IP used to send email, compare writing style & metadata	Executive email sent from foreign ASN	Suspend mailbox temporarily	Once internal email sent, fraud risk is immediate.
Persistence	Account Manipulation (T1098.002 Email Forwarding Rule) + Modify Authentication Process (T1556)	Ensure continuous monitoring	Hidden mailbox rule created	Silent interception of financial threads	Audit forwarding rules, hidden rule flags	Compare rule creation timestamp vs login origin	Rule forwards to external domain	Remove rules + reconfigure MFA	Forwarding rules are strongest BEC persistence signal.

Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group)	Access shared finance inbox	User added to shared mailbox or finance group	Expanding visibility into payments	AD event IDs 4728/4732, M365 role assignments	Trace who approved role change, correlate with compromised session	Non-finance user added to finance group	Remove role immediately	Privilege expansion increases fraud scale.
Defense Evasion	Indicator Removal (T1070.004 File Deletion) + Impair Defenses (T1562.001)	Delete sent emails or disable alerts	Deleted sent items + modified audit policy	Attempt to hide fraudulent communication	Unified audit log changes, mailbox deletion events	Compare deleted items with transaction logs	Audit logging disabled	Treat as confirmed compromise	Email deletion during payment workflow is high-confidence malicious activity.
Discovery	Email Collection (T1114.002 Remote Email Collection) + Account Discovery (T1087)	Identify ongoing payment threads	Mailbox search for “invoice”, “bank details”	Mapping vendor conversations	Mailbox search audit logs	Analyse search frequency, time-of-day anomaly	Search terms related to payment keywords	Monitor outgoing communication	Discovery phase precedes payment diversion.
Collection	Data from Information Repositories (T1213)	Extract vendor banking details	Attachment download spike from compromised account	Preparing invoice manipulation	Attachment logs, download patterns	Compare vendor bank detail change history	Bank detail changed before payment	Notify finance leadership immediately	Bank account change is decisive fraud pivot.

Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain control via webmail or API	Repeated OWA/M365 login sessions	Active operator	ASN risk score, TOR/VPN usage	Inspect session lifetime anomalies, browser fingerprint reuse	Same external ASN repeatedly accessing mailbox	Scope activity before blocking	Blocking without scoping may trigger attacker escalation .
Exfiltration	Exfiltration Over Web Services (T1567.002)	Export full mailbox	Mailbox export (PST) activity detected	Data theft beyond fraud	Export logs, DLP alerts	Correlate PST export with login source ASN	PST export > 1GB	Notify compliance & legal	BEC often combines fraud + intelligence collection .
Impact	Financial Fraud (T1657) + Data Manipulation (T1565.001 Stored Data Manipulation)	Redirect vendor payment	Payment made to new bank account	Fraud achieved	Payment workflow logs, dual-approval validation	Trace approval chain, verify bank modification timing	Payment processed without verbal verification	Activate fraud response & legal	Recovery window is short. Immediate bank recall critical.

PLAYBOOK 4 — Ransomware Deployment via Initial Access Broker

Attack Theme: Stolen VPN Credentials Purchased → Privileged Escalation → Lateral Movement → Backup Targeting → Ransomware Execution → Double Extortion

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Active Scanning (T1595.002 Vulnerability Scanning) + Gather Victim Network Info (T1590)	Identify exposed VPN/RDP services	External scanning spikes against VPN gateway	Attacker identifying access points	Source ASN reputation, scan frequency, targeted ports	Correlate perimeter firewall logs with scanning patterns, check exposed services inventory	Repeated scanning from known IAB infrastructure	Harden exposed services immediately	Initial Access Brokers (IABs) scan broadly before selling access.
Resource Development	Obtain Capabilities (T1588.001 Malware) + Compromise Accounts (T1586.002 Email/Cloud Accounts)	Acquire stolen credentials for resale	Credentials found in breach intel feed	Access likely sold on dark web	Threat intel validation, password reuse risk	Cross-check leaked credentials with internal accounts, check VPN logs for test login attempts	Credential matches active VPN user	Force password reset + enforce MFA	Many ransomware attacks start with purchased access.

Initial Access	Valid Accounts (T1078.004 Cloud Accounts) OR External Remote Services (T1133 VPN)	Gain VPN access using stolen creds	VPN login from rare geo/ASN	Initial foothold established	Impossible travel, ASN change, device fingerprint mismatch	Analyse VPN logs, session duration, simultaneous sessions	VPN login to privileged account from foreign ASN	Disable account + revoke sessions	VPN login anomaly is earliest containment opportunity.
Execution	Command and Scripting Interpreter (T1059.001 PowerShell)	Deploy tooling for lateral movement	Suspicious PowerShell spawning from VPN session	Post-access staging	EDR telemetry, parent-child process tree	Inspect encoded PowerShell, download cradle, external IP contact	Encoded PowerShell from admin account	Isolate endpoint immediately	Execution phase shows hands-on-keyboard attacker.
Persistence	Create Account (T1136.002 Domain Account) + Account Manipulation (T1098.003 Add to Group)	Create backdoor admin	New domain admin account created	Establish long-term access	AD event IDs 4720, 4728	Trace who created account, check approval chain	Admin account created outside IT change window	Remove account + audit all admins	Rogue admin creation is high-confidence compromise.
Privilege Escalation	Exploitation for Privilege Escalation (T1068) +	Obtain domain-level privileges	LSASS memory access alert	Credential harvesting	SeDebugPrivilege use, Mimikatz artefacts	Analyse process injection, memory dump	Domain Admin credential accessed	Reset enterprise privileged credentials	Domain admin compromise multiplies impact

	Credential Dumping (T1003.001 LSASS)					creation, admin token usage			exponentially.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools) + Indicator Removal (T1070.001 Clear Windows Event Logs)	Avoid detection before encryption	EDR service stopped, event logs cleared	Preparation for ransomware	EDR health logs, audit log gaps	Analyse service stop events, Sysmon restart, SIEM ingestion gap	Logging disabled after privilege escalation	Treat as confirmed ransomware staging	Defense tampering is immediate red flag.
Discovery	Network Share Discovery (T1135) + Account Discovery (T1087)	Identify file servers & backups	Net view, nltest, AD enumeration commands	Mapping high-value assets	PowerShell 4104 logs, SMB enumeration spikes	Analyse LDAP query volume, SMB session creation pattern	Enumeration from newly created admin	Monitor DC & file servers tightly	Discovery signals attacker confidence and planning.
Lateral Movement	Remote Services (T1021.001 RDP / T1021.002 SMB) + Pass-the-Hash (T1550.002)	Spread to servers	Multiple RDP logins across servers	Pivot toward DC & backups	Logon Type 10, NTLM anomalies	Inspect for reused NTLM hashes, token impersonation	>5 hosts accessed rapidly	Disable compromised accounts	Speed of movement determines encryption spread.

Collection	Data from Network Shared Drive (T1039)	Stage sensitive data before encryption	Archive creation on file server	Double extortion preparation	7zip / WinRAR execution logs	Check archive size, compression of sensitive directories	Archive >2GB before outbound traffic	Monitor outbound traffic	Staging precedes exfiltration.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Maintain operator control	Beacon to known ransomware C2	Active remote operator	Proxy logs, JA3 TLS fingerprint	Inspect beacon frequency, ASN reputation	Known ransomware C2 match	Block C2 after scoping	Scope first to avoid premature attacker detonation.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Upload staged data	Large outbound traffic to cloud storage	Data theft for leverage	DLP alerts, firewall logs	Correlate archive creation with outbound spike	Archive + outbound spike correlation	Notify legal & compliance	Regulatory exposure critical (PDPA / RMIT).
Impact	Data Encrypted for Impact (T1486) + Inhibit System Recovery (T1490)	Encrypt files & delete backups	Mass file rename, shadow copy deletion	Ransomware executed	Backup health, VSS deletion logs	Check vssadmin delete shadows, ransomware note, ransom extension pattern	Multiple servers encrypted simultaneously	Activate IR plan immediately	Encryption phase indicates containment failure earlier in chain.

PLAYBOOK 5 — Double Extortion with Data Leak

Attack Theme: Initial Access → Privilege Escalation → Data Staging → Large-Scale Exfiltration → Ransomware Encryption → Public Leak Threat

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Active Scanning (T1595.002) + Gather Victim Network Info (T1590)	Identify exposed services & sensitive repositories	External scan spike against VPN, Citrix, OWA	Target selection for intrusion	Source ASN, scan depth, repeated targeting of same endpoint	Correlate firewall logs with asset inventory exposure	Scanning from ransomware-linked ASN	Harden exposed services immediately	Ransomware groups pre-select targets based on data value.
Resource Development	Obtain Capabilities (T1588.001 Malware) + Compromise Accounts (T1586.002)	Acquire credentials or malware toolkit	Credentials seen in dark web intel	Access likely brokered or reused	Threat intel feed correlation, password reuse risk	Compare breached creds to internal accounts, check test logins	Credential matches privileged account	Force reset & enforce MFA	Double extortion actors often reuse breach credentials.
Initial Access	Valid Accounts (T1078.004) OR External Remote Services (T1133 VPN)	Establish foothold	VPN login from rare ASN/geo	Compromise likely	Impossible travel, device fingerprint mismatch	Analyse session overlap, login time anomaly	Privileged login outside region	Disable account immediately	Early containment prevents exfiltration stage.

Execution	Command and Scripting Interpreter (T1059.001 PowerShell)	Deploy reconnaissance & staging tools	Encoded PowerShell or remote tool execution	Hands-on-keyboard activity	Parent-child process tree, EDR telemetry	Inspect download cradle, suspicious external IP contact	Encoded commands from admin session	Isolate endpoint	Tooling deployment precedes staging.
Persistence	Create Account (T1136.002 Domain Account) + Account Manipulation (T1098.003)	Ensure re-entry	New domain admin created	Long-term foothold	AD logs (4720, 4728), IAM changes	Trace creation source, change ticket validation	Admin created outside change window	Remove rogue account	Persistence ensures leak leverage even after detection.
Privilege Escalation	Credential Dumping (T1003.001 LSASS) + Exploitation for Priv Esc (T1068)	Gain domain-level control	LSASS memory access alert	Credential harvesting	SeDebugPrivilege use, Mimikatz artefacts	Analyse memory access patterns, abnormal token usage	Domain Admin credentials accessed	Reset privileged credentials enterprise-wide	Domain control enables mass data access.
Defense Evasion	Impair Defenses (T1562.001) + Indicator Removal (T1070.001 Clear Logs)	Avoid detection during staging	EDR disabled, SIEM ingestion gap	Preparing for exfiltration	Tamper logs, audit log modifications	Inspect log deletion events, service stop commands	Logging disabled post-escalation	Treat as confirmed compromise	Log clearing during staging = high confidence malicious.
Discovery	File and Directory Discovery	Identify high-value data	Enumeration of finance,	Mapping data for exfiltration	PowerShell 4104 logs, SMB session spikes	Analyse access to sensitive	Access to HR/Finance shares by	Monitor data access patterns	Discovery shows attacker

	(T1083) + Network Share Discovery (T1135)		HR, legal folders			directories, unusual time window	non-business hours		prioritising valuable data.
Collection	Data from Network Shared Drive (T1039) + Archive Collected Data (T1560.001)	Stage data for upload	7zip / WinRAR compressing large directories	Data staging before exfiltration	Compression tool execution logs	Correlate archive creation with sensitive folder access	Archive >5GB created on file server	Monitor outbound traffic	Large archive = precursor to data leak.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Maintain remote control	Beacon to known ransomware leak-site ASN	Active operator presence	Proxy logs, JA3 TLS fingerprint	Inspect beacon intervals, ASN reputation	Known ransomware C2 infrastructure match	Scope activity before blocking	Blocking too early may trigger early encryption.
Exfiltration	Exfiltration Over Web Services (T1567.002) + Exfiltration Over C2 Channel (T1041)	Upload stolen data	10–50GB outbound to cloud storage	Data leak in progress	DLP alerts, firewall logs, unusual upload behaviour	Correlate archive timestamp with outbound spike	Archive creation + outbound spike correlation	Notify legal & compliance immediately	Regulatory exposure critical (PDPA / RMIT).
Impact	Data Encrypted for Impact	Encrypt systems &	Mass encryption + ransom	Double extortion executed	Backup integrity, VSS deletion logs	Check shadow copy	Encryption across	Activate IR & crisis management	Leak threat escalates legal and

	(T1486) + Inhibit System Recovery (T1490)	threaten public leak	note referencing leak site			deletion, ransom note hash, leak-site mention	multiple servers		reputational impact beyond encryption.
--	---	-------------------------	----------------------------------	--	--	--	---------------------	--	---

BYZANTINE

PLAYBOOK 6 — Credential Stuffing Attack

Attack Theme: Breached Credential Reuse → Automated Login Attempts → Successful Account Takeover → Fraud / Data Access

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Search Open Websites/Domains (T1593) + Gather Victim Identity Info (T1589.003 Email Addresses)	Collect target usernames from breach datasets	Credential dump referencing organisation domain	Attacker preparing credential list	Dark web monitoring alerts, breached credential correlation	Cross-check breached credentials against active users, assess password reuse rate	Breach list contains active privileged users	Force reset for exposed accounts	Credential stuffing depends on password reuse. Exposure mapping is critical.
Resource Development	Obtain Capabilities (T1588.001 Malware/Tools)	Acquire credential stuffing tools/bots	Traffic spike from automation frameworks	Automated login infrastructure prepared	Bot fingerprinting, user-agent anomalies	Analyse automation signatures (headless browsers, Selenium patterns), check ASN distribution	Known botnet ASN activity	Enable advanced bot mitigation	Modern stuffing uses distributed low-and-slow botnets.
Initial Access	Brute Force (T1110.004 Credential Stuffing)	Attempt logins using breached	High login attempts across many	Automated credential validation	Rate of login attempts per IP, ASN diversity	Correlate failed logins by password	Success rate above normal threshold	Enable CAPTCHA / rate limiting immediately	Success ratio matters more than

		credential s	accounts from multiple IPs			pattern, check sequential username attempts			failure volume.
Credential Access	Valid Accounts (T1078)	Gain access to accounts with reused passwords	Successful login from unfamiliar ASN after failures	Account takeover likely	Impossible travel, device fingerprint mismatch	Compare login pattern vs historical behaviour, check MFA bypass attempts	Privileged account login via stuffing	Force password reset + revoke sessions	Successfu l stuffing on admin accounts escalates risk rapidly.
Execution	Use of Valid Accounts (T1078.004 Cloud Accounts)	Access account dashboard	Sudden profile access + settings change	Attacker exploring account	Session token issuance logs, browser/OS anomalies	Analyse post-login behaviour (account details viewed, transaction attempts)	Immediate account detail access after login	Invalidate all sessions	Automate d attackers act quickly after login success.
Persistence	Account Manipulation (T1098)	Change recovery email or phone	Recovery email modified	Attacker securing account control	Audit logs for recovery detail changes	Compare change timestamp vs login origin	Recovery email changed within minutes of login	Restore original settings + enforce MFA	Recovery detail change confirms malicious intent.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group)	Exploit role-based access	Customer account upgraded to premium or admin (if internal system)	Attempt to elevate privileges	IAM logs, role assignment changes	Trace approval chain, correlate with compromis ed session	Role change outside workflow	Remove privilege immediately	Most stuffing aims at financial accounts, but internal

									systems must also be checked.
Defense Evasion	Modify Authentication Process (T1556) + Impair Defenses (T1562.001)	Disable MFA or alerts	MFA disabled after login	Attempt to avoid detection	MFA audit logs, alert suppression	Inspect policy changes, check notification settings altered	MFA removed without verification	Re-enable MFA + require re-authentication	MFA removal post-login is high-confidence malicious.
Discovery	Account Discovery (T1087)	Enumerate linked accounts or internal systems	Multiple profile lookups via API	Mapping potential financial gain	API access logs, endpoint usage pattern	Detect unusual API call volume after login	Account lookup spike from single session	Monitor session closely	Discovery signals attacker intent to monetise access.
Collection	Data from Information Repositories (T1213)	Extract stored personal or financial data	Bulk profile data export	Data harvesting	Download logs, unusual report generation	Compare export size vs typical usage	Large export from customer account	Trigger fraud monitoring	Large data export may indicate resale preparation.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain session control via automation	Repeated API calls every few seconds	Scripted activity	API rate metrics, token reuse pattern	Analyse consistent interval API usage, automation headers	Known automation signature detected	Block IP + rotate session tokens	Automation patterns distinguish stuffing from normal user behaviour.

Exfiltration	Exfiltration Over Web Services (T1567.002)	Extract sensitive data	Repeated download requests	Data theft in progress	DLP alerts, proxy logs	Correlate login success with outbound traffic spike	Data export + external IP anomaly	Notify compliance if PII involved	Regulatory exposure risk (PDPA / RMIT).
Impact	Financial Theft (T1657) OR Data Manipulation (T1565.001)	Perform fraudulent transactions	Unauthorised fund transfer or profile modification	Fraud achieved	Transaction logs, anomaly detection alerts	Verify transaction approval chain, geo-IP mismatch	Transaction executed from compromised session	Activate fraud response immediately	Detection must occur before transaction settlement window closes.

PLAYBOOK — Password Spraying

Attack Theme: Low-and-Slow Single Password Attempts → Broad Account Targeting → Privileged Account Compromise → Internal Access Expansion

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Identity Info (T1589.003 Email Addresses) + Search Open Websites/Domains (T1593)	Identify valid enterprise usernames	Multiple login attempts across many accounts using valid usernames	Attacker has user list	Source IP reputation, ASN type (residential/VPN), geographic spread	Correlate username pattern (alphabetical order, department grouping), check for privilege-targeted usernames	Spray includes admin/service accounts	Restrict authentication exposure	Spraying is username-driven, not password-driven.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare spraying tools	Low-frequency login attempts over extended time	Automated but throttled attack	Login frequency per IP, user-agent consistency	Detect distributed spraying (same password across many IPs), compare timing intervals	Same password pattern across accounts	Enable smart lockout policies	Modern spraying is distributed to avoid lockouts.
Initial Access	Brute Force (T1110.003)	Test one password across	1 failed attempt per user	Attempting to avoid	Check failure pattern	Analyse password guess timing	Successful login after wide spray	Disable compromise	Low volume does not

	Password Spraying)	many accounts	across 100+ accounts	account lockout	uniformity, IP diversity	vs policy thresholds		d account immediately	mean low risk. Pattern recognition is critical.
Credential Access	Valid Accounts (T1078)	Gain access via weak/common password	Successful login from same IP that attempted many accounts	Account takeover likely	Impossible travel, device fingerprint anomaly	Compare login against baseline user behaviour	Privileged account accessed via spray	Reset password + revoke sessions	One successful admin login changes risk level entirely.
Execution	Use of Valid Accounts (T1078.004 Cloud Accounts)	Access internal systems	Login followed by mailbox or VPN session	Initial foothold established	Session creation logs, source ASN	Check if login followed by internal reconnaissance activity	Session creation outside business hours	Invalidate all sessions	Successful spray often leads to hands-on activity quickly.
Persistence	Account Manipulation (T1098)	Add MFA device or change recovery details	New MFA enrollment after login	Attacker securing access	Audit MFA enrollment logs, recovery detail changes	Compare timestamp of MFA enrollment vs login origin	MFA added from foreign IP	Remove new MFA factor	Persistence may happen within minutes.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group) + Exploitation for Priv Esc (T1068)	Elevate privileges post-login	User added to privileged AD group	Expanding access	AD logs (4728/4732), IAM changes	Trace change initiator, check for ticket approval	Non-IT account added to admin group	Remove privilege immediately	Privilege escalation marks transition to enterprise-level threat.

Defense Evasion	Impair Defenses (T1562.001)	Modify security alerts to avoid detection	Alert thresholds changed	Attempt to avoid detection	Security policy audit logs	Check change window approval vs actual timestamp	Alert suppression without change ticket	Restore policy immediately	Alert threshold modification is malicious in this context.
Discovery	Account Discovery (T1087) + Permission Group Discovery (T1069.002)	Identify high-value groups	net group “Domain Admins” executed	Mapping admin accounts	PowerShell 4104 logs, LDAP query spikes	Analyse enumeration frequency from compromised account	Enumeration from newly compromised user	Monitor DC access closely	Discovery indicates attacker confidence.
Lateral Movement	Remote Services (T1021.001 RDP / T1021.002 SMB)	Move to critical servers	Multiple RDP sessions across hosts	Attempt to reach domain controller	Logon Type 10 events, NTLM anomalies	Detect pass-the-hash indicators, repeated admin token usage	>3 host logins in short period	Disable compromised account	Lateral speed determines ransomware potential.
Collection	Data from Information Repositories (T1213)	Access sensitive files	Large file share access by non-owner	Data staging	SMB logs, file audit logs	Detect unusual access to HR/Finance folders	Sensitive share accessed outside business hours	Monitor outbound channels	Sensitive folder access by non-owner is red flag.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain access via VPN or cloud	Repeated VPN sessions from same ASN	Ongoing external operator	VPN logs, ASN risk score	Analyse session frequency & overlap patterns	Repeated access from anonymised ASN	Block after scoping	Blocking without scoping may alert attacker.

Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer collected data	Outbound upload spike to cloud storage	Data theft in progress	Proxy logs, DLP alerts	Correlate file share access with outbound traffic	Data staging + outbound spike	Notify compliance if sensitive data involved	Exfiltration often follows successful spray of admin account.
Impact	Financial Theft (T1657) OR Data Encrypted for Impact (T1486)	Perform fraud or deploy ransomware	Unauthorized transaction or mass encryption	Attack objective achieved	Transaction logs, VSS deletion logs	Analyse shadow copy deletion, payment workflow bypass	Admin account used for encryption or transaction	Activate IR immediately	Early spray detection prevents catastrophic impact.

PLAYBOOK 8 — MFA Fatigue (Push Bombing)

Attack Theme: Stolen Credentials → Repeated MFA Push Requests → User Fatigue Approval → Account Takeover → Privilege Escalation / Fraud / Ransomware Staging

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Identity Info (T1589.003 Email Addresses) + Phishing for Information (T1598.003)	Identify valid users & obtain credentials	Phishing click followed by login attempts	Credentials likely harvested	Check phishing telemetry, email click logs, source ASN	Correlate phishing timestamp with authentication attempts	MFA attempts start shortly after phishing event	Flag account for monitoring	MFA fatigue often begins minutes after credential theft.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare automated MFA push tool	Rapid authentication attempts from single account	Automated MFA bombing	IP reputation, ASN type (VPN/residential proxy), login frequency	Analyse request intervals (every 10–20 sec), check distributed IP usage	Consistent interval push attempts	Enable MFA rate limiting	Automation interval consistency distinguishes from user error.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts)	Attempt login with stolen password	Correct password entered repeatedly	Attacker has valid credentials	Confirm password validation success events	Analyse failed MFA vs correct password sequence	Password correct but MFA denied repeatedly	Contact user immediately	Correct password + repeated MFA deny = high

									confidence compromise attempt.
Credential Access	MFA Request Generation (T1621)	Fatigue user into approving MFA	>10 MFA pushes in short window	Push bombing attack in progress	MFA logs, time-of-day anomaly	Compare push timing vs user device activity, inspect geolocation mismatch	MFA approval after repeated denial	Revoke sessions immediately	MFA approval does NOT equal legitimate authentication.
Execution	Use of Valid Accounts (T1078)	Establish authenticated session	Successful login from new ASN after MFA approval	Account takeover likely	Impossible travel, device fingerprint mismatch	Compare session token creation time vs last known device	Login from unfamiliar browser/OS	Invalidate session tokens	Post-approval context validation is critical.
Persistence	Account Manipulation (T1098) + Modify Authentication Process (T1556)	Add new MFA device or recovery option	New MFA method registered	Attacker securing long-term access	Audit logs for MFA enrollment, recovery email change	Compare enrollment timestamp vs login origin ASN	MFA device added outside business hours	Remove new MFA factor	Persistence often occurs within minutes of takeover.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group)	Elevate privileges	User added to admin/IAM role	Expanding control	AD event IDs 4728/4732, IAM role assignment logs	Trace privilege change initiator, correlate with compromised session	Non-IT user granted elevated role	Remove privilege immediately	Privilege change marks escalation from identity abuse to enterprise threat.

Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable MFA notifications or alerts	MFA alert emails disabled	Attempt to suppress detection	Audit notification preference logs	Compare alert setting change vs compromise timeline	MFA alerts disabled post-login	Restore settings + enforce re-authentication	Alert suppression indicates malicious control.
Discovery	Account Discovery (T1087) + Permission Group Discovery (T1069.002)	Identify high-value systems	PowerShell enumeration or API listing roles	Mapping environment	PowerShell 4104 logs, API call patterns	Detect abnormal role listing, admin group queries	Enumeration from newly compromised account	Monitor closely	Discovery phase indicates attacker planning next move.
Lateral Movement	Remote Services (T1021.001 RDP / T1021.002 SMB)	Pivot to internal servers	VPN session followed by RDP to server	Attempt to expand foothold	Logon Type 10, NTLM anomalies	Inspect pass-the-hash indicators, token reuse anomalies	Multiple server logins within short time	Disable account + isolate host	Speed of lateral movement determines impact scale.
Collection	Data from Information Repositories (T1213)	Access sensitive mailbox or files	Large mailbox search or file share access	Data staging	Mailbox audit logs, file access logs	Analyse abnormal query patterns (“invoice”, “admin”, “confidential”)	Sensitive folders accessed by non-owner	Monitor outbound channels	Data staging often follows identity takeover.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain session via cloud login	Repeated OWA / M365 session renewals	Ongoing external operator	ASN risk score, TOR/VPN usage	Analyse session refresh frequency, compare with	Persistent access from anonymised ASN	Block after scoping	Scope full activity before blocking.

						baseline behaviour			
Exfiltration	Exfiltration Over Web Services (T1567.002)	Extract data	Large outbound data transfer via browser/API	Data theft	Proxy logs, DLP alerts	Correlate mailbox export or file access with outbound spike	Data export + foreign ASN	Notify compliance if PII involved	Regulatory exposure risk significant (PDPA / RMIT).
Impact	Financial Theft (T1657) OR Data Encrypted for Impact (T1486)	Execute fraud or deploy ransomwar e	Unauthorise d transaction or system encryption	Attack objective achieved	Transaction logs, backup health, VSS deletion logs	Trace approval chain bypass, check shadow copy deletion	Admin account used for high-impact action	Activate IR immediately	MFA fatigue is identity- driven but can escalate to full ransomware incident.

PLAYBOOK 9 — OAuth Token Theft / Malicious App Consent

Attack Theme: Phishing or Consent Grant → Malicious OAuth App Authorised → Token Abuse → Silent Mailbox/Data Access → Long-Term Persistence

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Phishing for Information (T1598.003) + Gather Victim Identity Info (T1589.003 Email Addresses)	Identify high-value users to target with consent phishing	User receives app consent request email	Attacker preparing OAuth phishing	Sender domain legitimacy, app publisher verification	Correlate consent email with prior phishing telemetry	Consent email targeting finance/ad min users	Alert user + flag app ID	OAuth phishing bypasses password & MFA protections.
Resource Development	Obtain Capabilities (T1588.001 Tooling) + Acquire Infrastructure (T1583.001 Domains)	Register malicious OAuth app & hosting infrastructure	Newly registered app ID requesting Graph API access	Malicious app staging	App registration details, publisher verification, permission scope	Check app creation timestamp, consent history, prior abuse reports	App requests high-privilege API scopes	Block app registration immediately	High-privilege API scope is red flag.
Initial Access	User Execution (T1204.001 Malicious Link)	Trick user into granting consent	User grants OAuth permission to unknown app	Token issuance without	Consent logs, device fingerprint, IP ASN	Compare consent IP with normal login IP	Consent from foreign ASN	Revoke consent + invalidate tokens	Consent event replaces traditional credential

				password theft					compromise.
Credential Access	Use of Authentication Tokens (T1550.001 Application Access Token)	Obtain access tokens for mailbox/API	Access token issued to third-party app	Attacker now has API access	Token issuance logs, app client ID	Inspect token scope (Mail.Read, Files.ReadWrite, Directory.Read.All)	App granted admin-consent level permissions	Revoke all refresh tokens	Token theft bypasses password change.
Execution	Use of Valid Accounts (T1078.004 Cloud Accounts)	Access mailbox or files via API	Large API calls via Graph API	Silent mailbox access	API logs, endpoint usage, IP ASN	Analyse API call pattern frequency, detect scripted access	API calls immediately after consent	Disable malicious app	OAuth abuse often fully API-driven, no interactive login.
Persistence	Account Manipulation (T1098) + Modify Authentication Process (T1556)	Maintain long-term API access	Refresh token repeatedly used	Persistent access even after password reset	Refresh token lifetime, token reuse from foreign ASN	Compare refresh token usage interval, inspect abnormal device ID	Refresh token used after user password reset	Revoke all sessions + invalidate tokens	Password reset alone does NOT remove OAuth persistence.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group) OR Valid Accounts (T1078)	Escalate via API permissions	App granted Directory.ReadWrite.All	Full tenant access possible	IAM role assignments, app permission elevation logs	Trace admin consent approval workflow	Non-security admin approved high-risk scope	Remove app + review admin approval chain	Admin consent is pivot point to tenant-wide compromise.

Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Remove security alerts tied to app	Alert notification rules modified	Attempt to suppress detection	Audit logs for security configuration changes	Compare alert modification timestamp vs token usage	Alert suppression after consent	Restore monitoring immediately	Attackers modify alerts to prolong undetected access.
Discovery	Account Discovery (T1087) + Permission Group Discovery (T1069.002)	Enumerate tenant users/groups	API calls listing users, roles	Mapping tenant structure	API audit logs, Graph calls	Detect abnormal /users, /groups queries	Enumeration shortly after consent	Monitor for privilege abuse	Discovery indicates attacker exploring tenant-wide reach.
Collection	Data from Information Repositories (T1213.002 SharePoint) + Email Collection (T1114.002)	Extract mailbox & file data	Bulk mailbox read operations	Data harvesting	Mail.Read spikes, SharePoint access logs	Correlate mailbox read count vs baseline	High-volume API reads from single app ID	Monitor outbound activity	API data pull often precedes exfiltration.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain API session control	Periodic token refresh & API polling	Ongoing operator control	Token refresh logs, ASN risk score	Analyse refresh token cadence, IP consistency	Known malicious hosting ASN	Disable app + block ASN	OAuth C2 is disguised as legitimate API use.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Upload stolen data externally	Outbound uploads to external storage	Data theft in progress	Proxy logs, DLP alerts	Correlate Graph API read spike with outbound transfer	Data export + foreign ASN correlation	Notify compliance immediately	Regulatory exposure significant (PDPA / RMIT).

Impact	Data Manipulation (T1565.001 Stored Data Manipulation) OR Financial Theft (T1657)	Modify invoices or extract sensitive data	Invoice altered via SharePoint API	Fraud or espionage achieved	File version history, audit trail logs	Compare file version hash before/after modification	Financial document altered post-consent	Activate IR & legal	OAuth attacks are stealthier than password compromise and persist longer.
--------	---	---	------------------------------------	-----------------------------	--	---	---	---------------------	---

PLAYBOOK 10 — Session Hijacking / Web Session Cookie Theft

Attack Theme: Session Cookie Theft (Browser / Proxy / XSS / Malware) → Token Replay → Account Takeover Without Password → Privilege Abuse / Data Theft

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Identity Info (T1589.003) + Search Open Websites/Domains (T1593)	Identify authenticated targets	Targeted phishing or XSS attempt on logged-in users	Attacker preparing session theft	Phishing telemetry, web app logs	Correlate phishing/XSS indicators with authenticated sessions	Authenticated user targeted by XSS payload	Flag session for monitoring	Session hijack often follows active authenticated context.
Resource Development	Obtain Capabilities (T1588.001 Tooling) + Acquire Infrastructure (T1583.001 Domains)	Prepare cookie-stealing malware or proxy infra	Known stealer malware detected on endpoint	Session token harvesting	EDR alert for browser credential theft, malicious proxy	Analyse stealer family indicators, inspect C2 infrastructure	Info-stealer alert on privileged user device	Isolate endpoint immediately	Info-stealers frequently extract session cookies.
Initial Access	Steal Web Session Cookie (T1550.003 Web Session Cookie)	Obtain active authenticated session token	Login from new ASN without authentication event	Token replay detected	Check absence of password/MFA event before access	Compare session ID reuse across geolocation	Session reused from different country without re-auth	Invalidate all active sessions	Access without login event is primary hijack indicator.

Credential Access	Use of Authentication Tokens (T1550.001 Application Access Token)	Replay stolen token	Valid session from unfamiliar device	Token-based authentication bypass	Device fingerprint mismatch, ASN anomaly	Compare browser fingerprint, OS mismatch vs original session	Same session ID from multiple IPs	Revoke refresh tokens + force re-authentication	Password reset alone may not kill active session.
Execution	Use of Valid Accounts (T1078.004 Cloud Accounts)	Access account dashboard or admin console	Sudden admin panel access from new ASN	Account takeover in progress	Session creation time, IP ASN	Analyse high-risk API calls post-session reuse	High-risk action within minutes of session anomaly	Invalidate session immediately	Token replay attacks move fast.
Persistence	Account Manipulation (T1098) + Modify Authentication Process (T1556)	Add new recovery email or API key	Recovery email changed post-session reuse	Securing persistent access	Audit logs for account detail modification	Compare modification timestamp vs session replay event	Recovery detail changed outside baseline behaviour	Restore original details	Persistence may occur even without password knowledge.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group)	Elevate privileges	User assigned elevated IAM role	Escalation via hijacked session	IAM change logs, AD event IDs 4728/4732	Trace source IP for privilege change	Non-admin session assigned admin role	Remove privilege immediately	Hijacked session with admin rights is catastrophic.
Defense Evasion	Indicator Removal (T1070.004 File Deletion) + Impair Defenses (T1562.001)	Delete activity logs	User activity logs deleted	Covering tracks	Audit log integrity, retention checks	Compare audit trail gap vs session anomaly timeline	Logging disabled after session anomaly	Treat as confirmed compromise	Log deletion after replay confirms malicious activity.

Discovery	Account Discovery (T1087) + Permission Group Discovery (T1069.002)	Enumerate accessible resources	API calls listing roles and groups	Mapping environment	API audit logs, abnormal enumeration	Detect enumeration immediately after session replay	Enumeration within minutes of hijack	Monitor DC / IAM access closely	Discovery signals attacker exploring privileges.
Lateral Movement	Remote Services (T1021.001 RDP / T1021.002 SMB)	Pivot using hijacked credentials	VPN session initiated from hijacked cloud account	Expansion attempt	VPN logs, impossible travel analysis	Correlate cloud session replay with VPN login event	Cloud session reused then VPN login triggered	Disable account + isolate device	Session hijack can pivot into internal network.
Collection	Data from Information Repositories (T1213) + Email Collection (T1114.002)	Access sensitive data	Bulk mailbox read or file download	Data harvesting	File audit logs, mailbox access logs	Compare data volume vs baseline behaviour	High-volume read operations post-session anomaly	Monitor outbound traffic	Data staging often follows session hijack.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain active session	Session refresh from same foreign ASN	Ongoing attacker presence	Token refresh frequency, ASN risk score	Analyse refresh token cadence, concurrent session count	Persistent access from anonymised infrastructure	Block ASN after scoping	Scope entire activity before blocking to avoid blind spots.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer data externally	Outbound upload to cloud storage	Data theft in progress	Proxy logs, DLP alerts	Correlate data access spike with outbound transfer	Data export + session replay correlation	Notify compliance immediately	Regulatory exposure critical (PDPA / RMIT).

Impact	Financial Theft (T1657) OR Data Manipulation (T1565.001 Stored Data Manipulation)	Execute fraud or alter data	Unauthorised transaction without login event	Business impact achieved	Transaction logs, version history checks	Verify transaction approval chain vs session anomaly	High-risk transaction executed via replayed session	Activate IR immediately	Absence of login event before impact is hallmark of hijacking.
--------	---	-----------------------------	--	--------------------------	--	--	---	-------------------------	--

BYZANTIUM

PLAYBOOK 11 — SQL Injection on Public API

Attack Theme: Exploit Public-Facing API → Inject Malicious SQL Payload → Database Enumeration → Data Extraction → Potential Ransom / Data Leak

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Active Scanning (T1595.002 Vulnerability Scanning) + Search Open Technical Databases (T1596)	Identify vulnerable API endpoints	Repeated probing of /api/search?id=1' OR 1=1--	Attacker testing injection points	Source IP reputation, payload pattern, WAF alerts	Correlate multiple payload variants, inspect time-based injection attempts	Multiple SQL error responses from same IP	Enable WAF blocking rules	Injection testing often precedes data extraction within minutes.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Use SQLi automation tools (e.g., sqlmap-like behaviour)	High-frequency parameter manipulation attempts	Automated SQLi scanning	Check user-agent anomalies, request frequency	Analyse payload diversity, timing patterns, ASN type	Known SQLi tool signature detected	Rate limit + temporary IP block	Automation tools test many payload types rapidly.
Initial Access	Exploit Public-Facing Application (T1190)	Successfully inject SQL query	API response returns abnormal large dataset	Injection successful	Review API logs, DB query logs	Compare normal vs malicious query structure	API returns excessive records without auth	Block IP + isolate endpoint	Successful injection is confirmed breach attempt.

Execution	Command and Scripting Interpreter (T1059.005 SQL)	Execute arbitrary SQL commands	Suspicious UNION SELECT or xp_cmdshell calls	Database command execution	Database audit logs, unusual SQL keywords	Inspect for stacked queries, privilege escalation commands	xp_cmdshell or OS command triggered	Disable vulnerable API immediately	OS command execution via DB escalates risk significantly.
Persistence	Create Account (T1136.003 Local Account via DB)	Create hidden DB user	New DB admin account created	Backdoor access established	DB user creation logs	Verify change approval vs timeline	DB account created without change ticket	Remove rogue DB account	Database-level persistence often overlooked.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	Elevate DB privileges	Role changed to db_owner	Expanding database control	DB role assignment logs	Trace login origin tied to privilege escalation	Web app account elevated unexpectedly	Revoke elevated privileges	Privilege escalation amplifies data exposure risk.
Defense Evasion	Indicator Removal (T1070.004 File Deletion) + Impair Defenses (T1562.001)	Disable logging or truncate DB logs	DB audit logging disabled	Attempt to hide extraction	Audit config logs, DB log integrity	Compare log retention gap vs injection timeline	Logging disabled after SQLi success	Treat as confirmed compromise	Logging disablement indicates malicious intent.
Discovery	Database Schema Discovery (T1087-like via DB)	Enumerate tables & columns	Repeated INFORMATION_SCHEMA queries	Mapping database structure	DB query logs, query frequency	Detect abnormal schema enumeration patterns	Multiple schema queries in short window	Monitor DB closely	Schema mapping signals preparation for mass extraction.

	enumeration)								
Collection	Data from Information Repositories (T1213)	Extract customer records	SELECT * FROM customers large result sets	Data harvesting	DB audit logs, query volume analysis	Compare result size vs baseline usage	Query returns >100k records	Trigger DLP monitoring	Large result sets from API context is abnormal.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain connection via API	Repeated automated API requests	Ongoing data scraping	Proxy logs, ASN risk score	Analyse request frequency, detect automation intervals	Persistent high-volume scraping	Block IP after scoping	Scraping pattern reveals attacker persistence.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Download database content	Large outbound API responses	Data leak in progress	DLP alerts, outbound traffic spikes	Correlate DB query spike with outbound transfer	DB query spike + outbound spike	Notify compliance immediately	Regulatory exposure critical (PDPA / RMIT).
Impact	Data Manipulation (T1565.001 Stored Data Manipulation) OR Data Encrypted for Impact (T1486)	Modify or ransom database	Customer records altered or DB encrypted	Business disruption or fraud	DB integrity checks, backup health	Verify data integrity hash, check ransomware note	Critical data modified or encrypted	Activate IR & database recovery plan	Integrity compromise can be as damaging as theft.

PLAYBOOK 12 — Cross-Site Scripting (XSS) Leading to Session Theft

Attack Theme: Inject Malicious Script → Execute in Victim Browser → Steal Session Cookie → Replay Session → Account Takeover / Data Access

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Active Scanning (T1595.002) + Search Open Technical Databases (T1596)	Identify vulnerable input fields in web app	Repeated payloads like <script>alert(1)</script> in form fields	Attacker testing for XSS injection	Source IP reputation, WAF logs, payload patterns	Analyse payload variations (stored vs reflected attempts), check frequency & endpoints targeted	Repeated script injection attempts on same endpoint	Enable strict WAF rule	Injection testing often escalates quickly once vulnerability confirmed.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare XSS exploitation kit / exfil server	Script payload referencing external domain	Data exfiltration infra prepared	Domain age, ASN reputation, TLS cert reuse	Inspect malicious domain passive DNS, check prior abuse reports	External domain embedded in payload resolves internally	Block malicious domain	Exfil domain presence is high-confidence malicious signal.
Initial Access	Exploit Public-Facing	Inject malicious JavaScript	Stored XSS payload saved in	Persistent script	Web app logs, input validation	Identify affected pages,	Stored script visible to	Disable vulnerable	Stored XSS has broader

	Application (T1190)		comment/profile field	execution possible	bypass evidence	determine stored vs reflected XSS	multiple users	endpoint immediately	impact than reflected.
Execution	Command and Scripting Interpreter (T1059.007 JavaScript)	Execute script in victim browser	Suspicious outbound HTTP requests triggered from user browser	Malicious JS executed client-side	Browser telemetry (if available), proxy logs	Analyse outbound calls containing session tokens or cookies	Outbound request contains encoded session ID	Invalidate affected sessions	Execution happens on client side; server logs may not show injection clearly.
Credential Access	Steal Web Session Cookie (T1550.003 Web Session Cookie)	Capture authenticated session token	Access to account without login event	Session hijacking in progress	Absence of login event before session use	Compare session ID across different geolocations	Same session ID from multiple IPs	Revoke all sessions for affected users	Token replay bypasses password & MFA.
Persistence	Account Manipulation (T1098)	Change account recovery details	Recovery email or MFA method changed	Attacker securing access	Audit logs for account modification	Compare change time vs session replay event	Account detail change shortly after replay	Restore settings immediately	Persistence may occur quickly after session theft.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group)	Elevate privileges via hijacked session	User added to elevated role	Expanding control	IAM logs, AD event IDs 4728/4732	Trace IP source for privilege change	Non-admin account granted admin rights	Remove privilege immediately	Privilege change marks escalation beyond data theft.

Defense Evasion	Indicator Removal (T1070.004 File Deletion) + Impair Defenses (T1562.001)	Delete malicious script evidence	Logs for vulnerable endpoint truncated	Covering tracks	Audit log retention validation	Compare log gap vs injection timeline	Logging disabled after injection detection	Treat as confirmed compromise	Log deletion indicates deliberate concealment.
Discovery	Account Discovery (T1087) + Permission Group Discovery (T1069.002)	Enumerate accessible resources	API calls listing roles/groups from hijacked session	Mapping environment	API audit logs	Detect abnormal enumeration from affected account	Enumeration shortly after session replay	Monitor privileged systems	Discovery indicates attacker planning expansion.
Collection	Data from Information Repositories (T1213) + Email Collection (T1114.002)	Access mailbox/files	Large file download or mailbox read	Data harvesting	File audit logs, mailbox access logs	Compare data volume vs baseline behaviour	High-volume read from hijacked session	Monitor outbound traffic	Staging may occur entirely via browser session.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain communication via injected script	Periodic browser-based callbacks to malicious domain	Active client-side C2	Proxy logs, DNS logs	Analyse callback interval & user-agent patterns	Persistent callbacks from multiple users	Block malicious domain globally	Client-side C2 spreads if stored XSS exists.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Send stolen session or data externally	Outbound POST requests containing encoded data	Data theft in progress	DLP alerts, proxy logs	Correlate injection event with outbound data size	Encoded payload exfil from multiple users	Notify compliance immediately	Regulatory exposure significant (PDPA / RMIT).

Impact	Financial Theft (T1657) OR Data Manipulation (T1565.001 Stored Data Manipulation)	Execute fraud or alter records	Unauthorised transaction without login	Business impact achieved	Transaction logs, file integrity monitoring	Validate approval chain vs session anomaly	High-risk action from hijacked session	Activate IR immediately	Lack of login event is hallmark of session-based compromise.
--------	---	--------------------------------	--	--------------------------	---	--	--	-------------------------	--

PLAYBOOK 13 — Distributed Denial of Service (DDoS) Against Internet Banking

Attack Theme: Botnet Traffic Flood → Application / Network Resource Exhaustion → Service Degradation → Business Disruption → Possible Diversion for Secondary Attack

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Active Scanning (T1595.002 Vulnerability Scanning) + Gather Victim Network Info (T1590)	Identify public-facing banking endpoints & capacity	Increased probing of login, OTP, API endpoints	Attacker mapping attack surface	Source ASN clustering, probing patterns	Correlate scan IPs with later flood IPs, analyse targeted endpoints	Repeated scan from botnet-associated ASN	Increase monitoring threshold	DDoS often preceded by endpoint reconnaissance.
Resource Development	Obtain Capabilities (T1588.001 Botnet Tooling) + Acquire Infrastructure (T1583.003 Virtual	Prepare botnet or rented DDoS infrastructure	Traffic from residential proxy networks	Distributed attack staging	ASN diversity, IP entropy, geolocation spread	Analyse botnet fingerprint, check known DDoS-for-hire signatures	Sudden global ASN spread targeting one endpoint	Activate DDoS protection	Modern botnets use residential IPs to evade filtering.

	Private Servers)								
Initial Access	Network Denial of Service (T1498.001 Direct Network Flood)	Overwhelm network layer	Spike in SYN packets or UDP flood	Volumetric attack beginning	Bandwidth utilisation, firewall counters	Inspect packet type distribution, SYN/ACK imbalance	Bandwidth > baseline threshold (e.g., 5x normal)	Engage ISP mitigation	Early network-level containment prevents service outage.
Execution	Endpoint Denial of Service (T1499.004 Application Exhaustion)	Exhaust application resources	High volume POST requests to login/API	Application-layer DDoS	Request rate per IP, identical payload patterns	Analyse HTTP headers, user-agent uniformity, rate anomalies	API CPU usage spike > 80% sustained	Enable WAF rate limiting	Application-layer attacks are harder to detect than volumetric floods.
Persistence	Application Layer Protocol (T1071.001 Web)	Sustain flood via distributed nodes	Continuous requests every few milliseconds	Automated traffic persistence	Request interval pattern, session-less requests	Identify consistent interval automation, tokenless requests	Traffic sustained beyond 15 minutes	Maintain mitigation until stabilised	Persistence shows botnet coordination.
Privilege Escalation	N/A (Impact-driven tactic)	Not applicable in DDoS context	N/A	DDoS focuses on availability	N/A	Monitor for secondary attack attempts during outage	Suspicious login attempts during DDoS	Increase monitoring of auth systems	DDoS often used as distraction for intrusion attempts.
Defense Evasion	Impair Defenses (T1562.001 Disable)	Attempt to disable WAF or DDoS mitigation	Repeated targeting of mitigation endpoints	Attempt to overwhelm protection layer	WAF health logs, mitigation system status	Analyse targeted flood against specific	WAF node resource exhaustion	Failover mitigation nodes	Attackers may attempt to blind protective controls.

	Security Tools)					mitigation IPs			
Discovery	Network Service Discovery (T1046)	Identify backend services during disruption	Probing internal IPs via exposed endpoints	Attempt to pivot	IDS alerts, unusual internal scans	Check for scan attempts during high-traffic period	Internal scan detected during DDoS	Isolate suspicious traffic	DDoS can mask concurrent intrusion attempts.
Lateral Movement	Exploit Public-Facing Application (T1190) (if secondary attack)	Attempt exploit while SOC distracted	Suspicious exploit payload during DDoS	Potential blended attack	WAF exploit signature alerts	Correlate exploit attempt timestamp with traffic spike	Confirmed exploit attempt during flood	Elevate to blended incident	Treat DDoS + exploit as coordinated campaign.
Collection	N/A (Availability-focused)	Not primary goal	N/A	DDoS not typically data-focused	Monitor logs for anomalous data access	Verify no abnormal DB/API queries during outage	Data query spike during DDoS	Escalate to full compromise investigation	Always check for data activity during outage.
Command & Control	Application Layer Protocol (T1071.001 Web)	Botnet command coordination	Traffic pattern changes every few minutes	Botnet receiving updated commands	Traffic entropy analysis, pattern shift	Analyse wave-based surge behaviour	Coordinate d surge every fixed interval	Maintain mitigation posture	Pattern waves indicate centralised C2 coordination.
Exfiltration	N/A (unless diversion used)	Not typical DDoS objective	N/A	Focus on service outage	Review outbound traffic for anomalies	Correlate outbound spikes during DDoS window	Outbound data spike during DDoS	Escalate to data breach investigation	DDoS sometimes hides exfiltration.

Impact	Network Denial of Service (T1498) + Endpoint Denial of Service (T1499)	Disrupt Internet Banking availability	Customer unable to access login portal	Service outage	Availability metrics, uptime dashboards	Analyse SLA breach duration, customer complaint spike	Sustained outage > defined SLA threshold	Activate crisis communication plan	Availability attacks damage reputation and regulatory standing.
--------	--	---------------------------------------	--	----------------	---	---	--	------------------------------------	---

BYZANTIUM

PLAYBOOK 14 — Zero-Day Exploit on VPN Appliance

Attack Theme: Exploit Unknown VPN Vulnerability → Bypass Authentication → Gain Admin Access → Extract Credentials / Deploy Backdoor → Pivot into Internal Network

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Active Scanning (T1595.002 Vulnerability Scanning) + Gather Victim Network Info (T1590)	Identify exposed VPN version & fingerprint	Unusual crafted requests to VPN web portal	Attacker probing appliance behaviour	Source ASN, request pattern, unusual URI paths	Analyse HTTP headers, malformed parameters, firmware version leakage	Repeated malformed requests targeting same endpoint	Increase monitoring & restrict management access	Zero-day reconnaissance often includes version fingerprinting.
Resource Development	Obtain Capabilities (T1588.001 Exploit Code)	Prepare exploit for specific VPN firmware	Payload containing suspicious encoded parameters	Exploit staging	Known exploit IOC feeds, ASN risk profile	Compare request payload structure to emerging threat intel	Payload structure consistent with known exploit PoC	Block IP temporarily	Zero-day exploitation may initially resemble anomaly, not signature match.
Initial Access	Exploit Public-Facing	Achieve authentication bypass	Admin session created without	Authentication bypass likely	Absence of login logs, sudden admin	Correlate session ID creation with unusual	Admin session from foreign ASN	Disable VPN admin interface	Session without login event is high-

	Application (T1190)		login event		dashboard access	HTTP request	without auth		confidence compromise.
Execution	Command and Scripting Interpreter (T1059)	Execute system-level commands on appliance	Suspicious CLI or system command execution	Attacker gained shell access	Appliance command logs, config export activity	Inspect unusual system-level commands, check config backup downloads	Config export without change ticket	Isolate VPN from network	VPN config contains credentials and secrets.
Persistence	Create Account (T1136.001 Local Account) + Account Manipulation (T1098)	Create hidden admin account	New VPN admin user created	Long-term foothold	VPN admin audit logs	Compare user creation time vs exploit timestamp	Admin account created outside change window	Remove rogue account immediately	Appliance-level persistence enables re-entry.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	Escalate to root/system privileges	Privilege level changed to super-admin	Full appliance control	Privilege change logs	Verify approval chain, check exploit traces	Super-admin access granted without ticket	Treat as confirmed full compromise	Root access on VPN is catastrophic pivot point.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools) + Indicator Removal (T1070.001 Clear Logs)	Clear logs to hide intrusion	VPN log files truncated	Attempt to erase evidence	Log retention integrity, SIEM ingestion gaps	Compare log file size pre/post anomaly	Log gap immediately after admin session	Assume active compromise	Log clearing on security appliance is severe red flag.

Discovery	Network Service Discovery (T1046) + Account Discovery (T1087)	Identify internal reachable systems	VPN session connecting to internal DC or file servers	Preparing lateral movement	VPN session logs, internal firewall logs	Analyse internal network connections originating from VPN interface	VPN session accessing DC directly	Monitor internal high-value assets	VPN appliance can become internal pivot point.
Lateral Movement	Remote Services (T1021.001 RDP / T1021.002 SMB)	Pivot into internal environment	RDP sessions initiated from VPN IP	Expanding foothold	Logon Type 10 events, NTLM anomalies	Correlate VPN IP with internal authentication logs	Multiple internal logins from VPN IP	Disable VPN connectivity immediately	Speed of pivot determines enterprise impact.
Collection	Data from Network Shared Drive (T1039)	Access sensitive internal files	File server access via VPN session	Data staging	SMB logs, file access audit	Detect abnormal file access from VPN interface IP	Sensitive share accessed after exploit	Monitor outbound traffic	VPN compromise often leads to data theft before ransomware.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain remote management access	Persistent admin web access from same ASN	Active operator presence	ASN risk score, management interface access logs	Analyse admin session duration & frequency	Repeated admin login attempts from anonymised ASN	Block management access externally	Restrict VPN management plane access permanently.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Download VPN configuration or internal data	Config file download or outbound spike	Sensitive credential exposure	Proxy logs, firewall outbound logs	Correlate config export with outbound upload	Config export + external upload spike	Notify compliance & rotate credentials	VPN config often contains shared secrets and certificates.

Impact	Valid Accounts (T1078) + Inhibit System Recovery (T1490 if ransomware later)	Full network compromise or ransomware staging	Mass login attempts after VPN exploit	Enterprise compromise underway	Domain controller logs, backup health	Analyse shadow copy deletion, admin account usage	Multiple systems accessed post-VPN compromise	Activate enterprise IR immediately	VPN zero-day is high-impact perimeter breach requiring full scoping.
--------	--	---	---------------------------------------	--------------------------------	---------------------------------------	---	---	------------------------------------	--

BYZANTIUM

PLAYBOOK 15 — Supply Chain Malware Update Compromise

Attack Theme: Trusted Vendor Software Update → Trojanised Signed Binary → Internal Execution → Command & Control → Lateral Movement / Data Theft / Ransomware

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Org Information (T1591) + Search Open Websites/Domains (T1593)	Identify widely deployed enterprise software	Threat intel indicates vendor compromise	Organisation may be exposed via trusted vendor	Confirm affected product version, deployment footprint	Cross-reference asset inventory with vulnerable software list	High-risk vendor software present in core systems	Initiate threat hunting immediately	Supply chain attacks target trust relationships, not perimeter weaknesses.
Resource Development	Compromise Software Supply Chain (T1195.002 Compromise Software Dependencies and Development Tools)	Inject malicious code into vendor update	Vendor update hash mismatch reported by intel	Trojanised update distributed	Validate update hash, verify digital signature chain	Compare signed certificate chain, inspect unusual compilation timestamp	Binary signed but hash differs from vendor baseline	Quarantine update package	Signed malware is harder to detect via reputation-based controls.
Initial Access	Supply Chain Compromise (T1195)	Deliver malicious update to environment	Software auto-update triggered	Malicious code executed under	Check update logs, parent-child	Analyse execution context (SYSTEM/root), inspect	Update process spawning unexpected	Isolate affected systems	Execution under trusted process bypasses

			across hosts	trusted process	process tree	network connection s post- update	d child processes		many controls.
Execution	Command and Scripting Interpreter (T1059)	Execute embedded payload	Trusted binary spawning PowerShell or cmd	Malicious code execution inside environment	EDR telemetry, process lineage analysis	Identify encoded commands, suspicious DLL loading, memory injection	Signed process executing abnormal commands	Contain host immediately	Trusted parent process is key anomaly indicator.
Persistence	Create Account (T1136.002 Domain Account) + Modify Authentication Process (T1556)	Establish long-term access	New service account created by update process	Backdoor persistence	AD logs (4720), service installation logs	Trace account creation to update execution timeline	Service account created outside change window	Remove rogue accounts/services	Persistence through service installation is common tactic.
Privilege Escalation	Exploitation for Privilege Escalation (T1068) + Valid Accounts (T1078)	Escalate to admin/domain privileges	Update process modifying local admin group	Expanding control	Local group membership logs, IAM changes	Compare baseline admin membership vs current	Update process adds domain admin	Remove privilege immediately	Privilege escalation under trusted binary is severe indicator.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools) + Indicator Removal	Disable AV/EDR services	Security agent service stopped post-update	Attempt to evade detection	EDR health logs, service stop events	Correlate service disablement with update execution time	EDR disabled after software update	Treat as confirmed compromise	Supply chain malware often disables security before

	(T1070.001 Clear Logs)								lateral movement.
Discovery	Network Service Discovery (T1046) + Account Discovery (T1087)	Identify internal high-value systems	Update process initiating network scans	Internal reconnaissance	IDS alerts, unusual SMB/LDAP traffic	Analyse network connections initiated by update binary	Scanning activity from update host	Monitor high-value assets	Discovery via trusted binary reduces suspicion if not monitored.
Lateral Movement	Remote Services (T1021.001 RDP / T1021.002 SMB)	Spread across enterprise	Lateral login attempts from update host	Expansion attempt	Logon Type 10 events, NTLM anomalies	Detect pass-the-hash signs, unusual admin token reuse	Multiple hosts accessed within short period	Disable compromised accounts	Supply chain compromise can rapidly become enterprise-wide breach.
Collection	Data from Network Shared Drive (T1039) + Email Collection (T1114.002)	Access sensitive data	File share access spike from update process	Data staging	File audit logs, mailbox access logs	Correlate sensitive folder access with update execution timeline	Sensitive data accessed shortly after update	Monitor outbound traffic	Staging may precede ransomware or leak.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Maintain C2 via trusted binary	Signed process connecting to rare ASN	Active external operator	Proxy logs, JA3 fingerprint	Inspect TLS certificate anomalies, beacon intervals	Known malicious ASN contact	Block C2 after scoping	Signed binary C2 blends into legitimate traffic.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Upload collected data	Outbound upload to cloud storage from	Data theft	DLP alerts, firewall logs	Correlate data staging timestamp with	Archive creation + outbound transfer	Notify compliance immediately	Regulatory exposure critical (PDPA / RMIT).

			update host			outbound spike			
Impact	Data Encrypted for Impact (T1486) OR Data Manipulation (T1565.001 Stored Data Manipulation)	Deploy ransomwar e or alter core systems	Mass file encryptio n following update	Business disruption achieved	Backup health, VSS deletion logs	Verify shadow copy deletion, ransom note hash, system integrity	Multiple systems encrypted post- update	Activate enterprise IR	Supply chain attack impact often affects entire environment simultaneou sly.

PLAYBOOK 16 — Insider Data Theft

Attack Theme: Legitimate User Access → Abnormal Data Access Pattern → Mass Data Collection → External Transfer → Intellectual Property / Customer Data Theft

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Data from Information Repositories (T1213) + Account Discovery (T1087)	Identify accessible sensitive repositories	Employee browsing multiple restricted folders	User mapping valuable data	User role vs folder access alignment	Compare historical access baseline vs current spike	Access outside normal job function	Flag user for monitoring	Insider threat relies on legitimate access, not exploitation.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare external storage or compression tool	Installation of 7zip/WinRAR/Sync tools	Preparing for data staging	Endpoint software installation logs	Correlate tool installation with access spike	Compression tool installed before data access	Increase endpoint monitoring	Tooling preparation often precedes bulk data extraction.
Initial Access	Valid Accounts (T1078)	Use legitimate credentials	Normal login but outside business hours	Suspicious context of valid access	Login time anomaly, VPN use from unusual location	Compare login time/location vs employment pattern	Login from new location before resignation	Monitor closely	Insider attacks rarely trigger failed login alerts.
Execution	Command and Scripting	Automate file collection	PowerShell script	Bulk file harvesting	Script block logging (Event	Analyse recursive directory	Automated file enumeration detected	Contain workstation	Automation indicates

	Interpreter (T1059.001 PowerShell)		enumerating directories		4104), parent-child process tree	traversal commands			premeditated theft.
Persistence	Account Manipulation (T1098)	Maintain access post-employment	Forwarding corporate email to personal account	Preparing ongoing monitoring	Mailbox audit logs, forwarding rule checks	Compare forwarding creation time vs resignation timeline	External forwarding rule created	Remove forwarding immediately	Email forwarding is common insider persistence tactic.
Privilege Escalation	Exploitation for Privilege Escalation (T1068) OR Account Manipulation (T1098.003 Add Account to Group)	Access restricted repositories	User added to restricted AD group	Expanding data reach	AD logs (4728/4732) , IAM changes	Trace approval chain, correlate with HR events	Group change outside business approval	Remove privilege immediately	Privilege creep often signals malicious intent.
Defense Evasion	Indicator Removal (T1070.004 File Deletion)	Delete local audit logs	Log clearing or history deletion	Attempt to hide activity	Endpoint audit log integrity	Compare log gap vs file access timeline	Log deletion after large data access	Treat as malicious intent	Log clearing by employee is rarely benign.
Discovery	File and Directory Discovery (T1083)	Identify high-value documents	Large directory listing across departments	Mapping sensitive content	File server audit logs	Detect cross-departmental file access	HR/Finance/Legal accessed by unrelated role	Escalate investigation	Cross-functional access spike is red flag.

Collection	Data from Network Shared Drive (T1039) + Archive Collected Data (T1560.001)	Stage sensitive data	Large archive file created locally	Preparing for exfiltration	Endpoint file creation logs	Check archive size, compression ratio, source directories	Archive >5GB created	Isolate endpoint	Archive creation is decisive staging indicator.
Command & Control	Application Layer Protocol (T1071.001 Web)	Upload data to cloud storage	Large outbound upload to Dropbox/Google Drive	Data exfiltration in progress	Proxy logs, DLP alerts	Correlate archive creation timestamp with outbound transfer	Archive + outbound spike correlation	Block upload channel	Insider exfiltration often uses legitimate cloud services.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer corporate data externally	Sustained HTTPS upload from endpoint	Data theft	Firewall logs, DLP alerts	Inspect upload size, destination domain reputation	Upload exceeds policy threshold	Notify compliance immediately	Regulatory exposure (PDPA / RMIT) depends on data classification.
Impact	Exfiltration of Sensitive Data (T1041) OR Data Manipulation (T1565.001 Stored Data)	Intellectual property loss	Sensitive design or customer data leaked	Business and reputational damage	Data classification review, contractual impact analysis	Confirm scope of accessed data, check external leak forums	Confirmed leak on public forum	Activate legal & HR response	Insider cases require coordination with HR & legal teams.

Manipulation)

BYZANTINE

PLAYBOOK 17 — Privilege Escalation via Exploit

Attack Theme: Initial Foothold (User-Level Access) → Local Exploit Execution → SYSTEM / Root Privilege Gain → Credential Dumping → Domain Compromise

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Process Discovery (T1057) + System Information Discovery (T1082)	Identify OS version & vulnerable services	systeminfo or whoami /priv execution	Attacker checking privilege level	Parent process, user context	Correlate recon commands with unusual parent process (e.g., Word, browser)	Recon commands from non-admin context	Increase endpoint monitoring	Recon before escalation indicates exploit staging.
Resource Development	Obtain Capabilities (T1588.001 Exploit Code)	Download or drop local privilege escalation (LPE) exploit	Suspicious executable dropped in temp folder	Exploit preparation	File hash reputation, download source	Analyse file entropy, check compile timestamp anomalies	Exploit file written then executed	Isolate host immediately	Temp directory execution is common LPE pattern.
Initial Access	Valid Accounts (T1078)	Use compromised user credentials	Normal login but followed by suspicious activity	Attacker already inside as standard user	Login source, device baseline	Correlate login with phishing/malware infection	Login from unusual ASN prior to LPE	Monitor closely	Privilege escalation requires initial foothold.

Execution	Exploitation for Privilege Escalation (T1068)	Exploit OS/service vulnerability	Process spawned with SYSTEM privileges unexpectedly	Successful privilege escalation	Token elevation logs, parent-child process tree	Analyse exploit binary spawning cmd.exe as SYSTEM	User process spawning SYSTEM shell	Contain endpoint immediately	SYSTEM shell from user context is high-confidence exploit.
Persistence	Create Account (T1136.001 Local Account) + Account Manipulation (T1098)	Create local admin backdoor	New local admin user created	Establish persistence	Event ID 4720, local group modification logs	Trace account creation timestamp vs exploit execution	Admin account created without change request	Remove rogue account	Persistence often follows successful escalation.
Privilege Escalation	Access Token Manipulation (T1134)	Duplicate SYSTEM token	Token duplication alert	Attempt to maintain elevated context	EDR telemetry, token integrity logs	Inspect <code>SelfImpersonatePrivilege</code> usage, abnormal token handles	SYSTEM token reused by non-system process	Treat as confirmed compromise	Token manipulation is advanced escalation indicator.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools) + Indicator Removal (T1070.001 Clear Logs)	Disable AV/EDR before lateral movement	Security service stopped	Preparing further actions	EDR health logs, service stop events	Correlate service disablement with SYSTEM shell timeline	EDR disabled after escalation	Escalate to full incident response	Disabling controls confirms malicious intent.

Discovery	Account Discovery (T1087) + Permission Group Discovery (T1069.002)	Identify domain admin accounts	net group "Domain Admins" executed	Preparing lateral movement	PowerShell 4104 logs, LDAP query spikes	Detect enumeration from elevated context	Enumeration from newly escalated SYSTEM shell	Monitor DC closely	Discovery signals next pivot stage.
Lateral Movement	Remote Services (T1021.001 RDP / T1021.002 SMB) + Pass-the-Hash (T1550.002)	Pivot to domain controller	Logon Type 10 from escalated host	Attempt to spread	NTLM authentication logs, token reuse anomalies	Detect abnormal admin credential usage	Multiple internal logins post-escalation	Disable compromised account	Escalation + lateral movement is ransomware precursor.
Collection	Credential Dumping (T1003.001 LSASS)	Dump credentials from memory	LSASS memory access alert	Harvesting domain credentials	SeDebugPrivilege usage, Mimikatz artefacts	Analyse memory dump creation, abnormal process injection	Domain Admin credential accessed	Reset privileged credentials enterprise-wide	Credential dumping multiplies impact drastically.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Maintain remote control	Elevated process connecting to rare ASN	Active operator control	Proxy logs, JA3 fingerprint	Inspect TLS anomalies, beacon interval consistency	SYSTEM-level process beaconing externally	Block C2 after scoping	SYSTEM beaconing is high-severity indicator.
Exfiltration	Exfiltration Over Web Services	Transfer stolen	Outbound encrypted upload	Data theft	Firewall logs, DLP alerts	Correlate LSASS dump timestamp	Credential dump +	Notify compliance immediately	Credential exfiltration enables

	(T1567.002)	credentials or data	from escalated host			with outbound spike	outbound correlation		future attacks.
Impact	Valid Accounts (T1078) OR Data Encrypted for Impact (T1486)	Deploy ransomware or maintain long-term domain control	Multiple servers accessed post-escalation	Enterprise compromise underway	Domain controller logs, backup health	Detect shadow copy deletion (T1490), abnormal GPO changes	Domain-wide privilege abuse detected	Activate enterprise IR immediately	Privilege escalation is turning point to domain-level breach.

PLAYBOOK 18 — Lateral Movement via SMB

Attack Theme: Compromised Credentials → SMB Admin Share Access → Pass-the-Hash / Remote Service Execution → Pivot to Domain Controller → Ransomware / Data Theft Preparation

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Network Service Discovery (T1046) + Account Discovery (T1087)	Identify reachable hosts & admin shares	net view / SMB connection attempts across subnet	Mapping internal network	Source host role, unusual enumeration	Correlate enumeration with prior credential compromise	Enumeration from newly compromised workstation	Increase monitoring on source host	Enumeration before movement signals pivot planning.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Deploy lateral movement tool (e.g., PsExec-like behaviour)	Suspicious executable dropped in ADMIN\$ share	Tool staging for remote execution	File hash reputation, share access logs	Inspect file write events to \\HOSTADMIN\$	Executable written to admin share	Isolate source workstation	ADMIN\$ write is strong lateral movement signal.
Initial Access	Valid Accounts (T1078)	Use stolen admin credentials	Successful SMB authentication from user workstation to server	Credential abuse	Logon Type 3 events, NTLM authentication logs	Compare login source vs normal admin baseline	Admin account authenticating from non-admin workstation	Disable compromised account	Admin account misuse from unusual host is high-risk.
Execution	Remote Services (T1021.002 SMB/Windows)	Execute remote command via SMB	Service created remotely (sc.exe create)	Remote command execution	Event ID 7045 (Service installed), 4624 logons	Trace parent process initiating	New service installed from user workstation	Stop service + contain source	Remote service creation is decisive

	ws Admin Shares)					remote service creation			pivot indicator.
Persistence	Create Account (T1136.002 Domain Account) + Account Manipulation (T1098.003 Add to Group)	Establish admin persistence	New domain admin account created from remote host	Backdoor creation	AD logs (4720, 4728)	Correlate account creation with SMB session timeline	Domain admin created from compromised host	Remove rogue account immediately	Persistence often follows successful lateral movement.
Privilege Escalation	Access Token Manipulation (T1134) + Credential Dumping (T1003.001 LSASS)	Harvest credentials on new host	LSASS memory access on remote server	Preparing for broader spread	EDR telemetry, SeDebugPrivilege usage	Detect credential dump on multiple hosts sequentially	Domain Admin credential accessed on server	Reset privileged credentials enterprise-wide	Credential dumping amplifies spread capability.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools) + Indicator Removal (T1070.001 Clear Logs)	Disable logging on pivoted host	EDR agent stopped on server	Attempt to evade detection	EDR health logs, log truncation events	Compare service stop timeline vs SMB session	EDR disabled after remote service install	Escalate to enterprise incident	Defense tampering confirms malicious pivot.
Discovery	Permission Group	Identify high-value	net group "Domain	Preparing next pivot	PowerShell 4104 logs,	Analyse enumeration	Enumeration from new	Monitor domain	Discovery post-pivot

	Discovery (T1069.002) + Network Share Discovery (T1135)	servers (DC, DB)	Admins" on server		LDAP query spikes	n after remote execution	server immediately	controller closely	signals escalation phase.
Lateral Movement	Pass-the-Hash (T1550.002) + Remote Services (T1021.002)	Spread using NTLM hash reuse	NTLM authentication without Kerberos ticket	Credential replay attack	NTLM log analysis, unusual logon source	Detect same NTLM hash used across hosts	Same admin hash authenticating to multiple servers	Disable compromised accounts	Hash reuse across hosts is ransomware precursor.
Collection	Data from Network Shared Drive (T1039)	Access file shares from pivoted server	File server accessed via compromised server	Data staging	SMB audit logs, file access logs	Correlate access to sensitive shares post-pivot	Sensitive share accessed by server role that normally doesn't	Monitor outbound traffic	Server-to-server data access is suspicious in many environments.
Command & Control	Application Layer Protocol (T1071.001 Web)	Beacon from pivoted host	Elevated server process contacting rare ASN	Active operator presence	Proxy logs, JA3 TLS fingerprint	Analyse beacon interval & consistency	SYSTEM-level process beaconing	Block C2 after scoping	Server-based beaconing is high-severity indicator.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer staged data externally	Large outbound transfer from pivoted server	Data theft	Firewall logs, DLP alerts	Correlate data staging timestamp with outbound spike	Archive creation + outbound transfer	Notify compliance immediately	Regulatory exposure (PDPA / RMIT) may apply.

Impact	Data Encrypted for Impact (T1486) OR Valid Accounts (T1078)	Deploy ransomware or maintain domain dominance	Mass encryption starting from pivoted server	Enterprise compromise underway	Backup health, VSS deletion logs	Detect shadow copy deletion (T1490), abnormal GPO changes	Multiple hosts encrypted after SMB pivot	Activate enterprise IR immediately	Lateral movement is bridge between foothold and domain-wide impact.
--------	---	--	--	--------------------------------	----------------------------------	---	--	------------------------------------	---

BYZANTIUM

PLAYBOOK 19 — LSASS Credential Dumping

Attack Theme: Compromised Host → Privilege Escalation → LSASS Memory Access → Credential Extraction → Domain-Wide Compromise / Ransomware Staging

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Process Discovery (T1057) + System Information Discovery (T1082)	Identify security controls & privilege level	tasklist, whoami /priv, checking LSASS PID	Attacker preparing to dump credentials	Parent process, user context, privilege level	Correlate recon commands with phishing or malware alert	Recon from recently compromised host	Increase monitoring immediately	LSASS dumping rarely occurs without prior recon.
Resource Development	Obtain Capabilities (T1588.001 Credential Dumping Tooling)	Deploy Mimikatz or custom dumper	Suspicious binary dropped in temp folder	Tool staging	File hash reputation, download source	Inspect file metadata, entropy, compile timestamp anomalies	Known credential dumping tool hash	Isolate endpoint immediately	Temp directory execution is common dumping pattern.
Initial Access	Valid Accounts (T1078)	Operate using compromised user account	Normal login followed by privilege abuse	Attacker already inside environment	Login source ASN, device fingerprint	Correlate login with phishing/malware infection	Login anomaly preceding dumping attempt	Monitor closely	Dumping requires initial foothold.
Execution	OS Credential Dumping	Extract credentials	LSASS process	Credential dumping	SeDebugPrivilege usage, abnormal	Analyse parent-child process tree,	Non-system process	Contain endpoint immediately	LSASS access by non-

	(T1003.001 LSASS Memory)	from memory	memory read alert	in progress	process handle access	detect MiniDumpWriteDump usage	accessing LSASS		system process is high-confidence compromise.
Persistence	Create Account (T1136.002 Domain Account)	Create admin backdoor using dumped creds	New domain admin created shortly after LSASS access	Attacker leveraging harvested credentials	AD logs (4720, 4728)	Correlate account creation with LSASS dump timestamp	Domain admin created from compromised host	Remove rogue account immediately	Dumping + admin creation is escalation pivot.
Privilege Escalation	Access Token Manipulation (T1134) + Valid Accounts (T1078)	Reuse dumped domain credentials	Successful Domain Admin login from user workstation	Full domain compromise possible	Domain controller authentication logs	Detect admin login from abnormal workstation	Domain Admin login from non-admin endpoint	Reset privileged credentials enterprise-wide	Dumped credentials amplify attacker capability.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools) + Indicator Removal (T1070.001 Clear Logs)	Disable EDR before dumping	Security agent stopped prior to LSASS access	Attempt to evade detection	EDR health logs, service stop events	Correlate EDR disablement timeline with LSASS access	EDR disabled before memory access	Treat as confirmed malicious activity	Pre-dump defense tampering confirms intent.
Discovery	Permission Group Discovery (T1069.002	Identify high-value accounts	net group "Domain Admins" executed	Preparing to use stolen creds	PowerShell 4104 logs, LDAP query spikes	Detect enumeration immediately	Enumeration within minutes of dump	Monitor DC access closely	Discovery signals next stage pivot.

	) + Account Discovery (T1087)					after LSASS dump			
Lateral Movement	Pass-the-Hash (T1550.002) + Remote Services (T1021.002 SMB)	Move using dumped hashes	NTLM authentication from compromised host	Credential replay	NTLM logs, unusual logon source	Detect same hash authenticating across hosts	Multiple server logins after dump	Disable compromised accounts	Dumping enables rapid spread.
Collection	Data from Network Shared Drive (T1039)	Access sensitive files using stolen creds	File server accessed via admin account	Data staging	SMB logs, file access audit	Correlate admin login with sensitive folder access	Sensitive share accessed after dump	Monitor outbound traffic	Dumped admin creds often used for data theft.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Exfiltrate dumped credential file	Outbound upload shortly after dump	Credential exfiltration	Proxy logs, DLP alerts	Correlate LSASS dump file creation with outbound transfer	Dump file transmitted externally	Notify compliance immediately	Credential theft enables future intrusions.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer dump file to attacker	Large outbound HTTPS upload	Sensitive credential leak	Firewall logs, DLP alerts	Analyse upload size & destination ASN	Dump file + foreign ASN correlation	Block external destination	Dumped credentials are strategic asset for attacker.
Impact	Valid Accounts (T1078) OR Data Encrypted	Domain compromise or ransomware	Multiple admin logins across	Enterprise compromise underway	Domain controller logs, backup health	Detect shadow copy deletion (T1490), abnormal GPO changes	Domain-wide admin abuse detected	Activate enterprise IR immediately	LSASS dump is often turning point to full

for Impact
(T1486)

e
deployment

environmen
t

domain
breach.

BYZANTINE

PLAYBOOK 20 — DNS Tunnelling Command & Control

Attack Theme: Compromised Host → Encoded Data in DNS Queries → Covert C2 Channel → Data Exfiltration Over DNS → Stealth Persistence

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	System Information Discovery (T1082) + Network Service Discovery (T1046)	Identify egress filtering controls	Host testing DNS queries to uncommon domains	Attacker checking outbound DNS capability	DNS query frequency, domain entropy	Analyse query pattern against baseline DNS behaviour	Unusual subdomain patterns detected	Increase DNS logging level	DNS tunnelling often tested before full deployment.
Resource Development	Acquire Infrastructure (T1583.001 Domains) + Obtain Capabilities (T1588.001 Tooling)	Register attacker-controlled DNS domain	Newly registered domain with random subdomains	DNS exfiltration infrastructure prepared	Domain age, registrar reputation, passive DNS	Check if domain resolves internally, analyse NS records	Domain resolves to bulletproof hosting ASN	Flag domain for monitoring	High-entropy domain names are red flags.
Initial Access	Valid Accounts (T1078) OR Phishing (T1566)	Establish initial foothold before tunnelling	Host infected via malware alert	Malware preparing DNS channel	EDR alert correlation, process lineage	Identify malware family known for DNS C2	Malware with DNS beacon capability detected	Isolate host immediately	DNS tunnelling requires prior compromise.

Execution	Application Layer Protocol (T1071.004 DNS)	Initiate DNS-based C2 channel	High volume TXT or NULL DNS queries	Covert C2 established	DNS log frequency, query type analysis	Detect base64/hex encoded subdomains, long query strings	>100 DNS queries per minute to single domain	Contain endpoint immediately	Long encoded subdomains are decisive tunnelling indicator.
Persistence	Scheduled Task (T1053.005) + Modify Authentication Process (T1556)	Maintain DNS beacon after reboot	Scheduled task executing suspicious binary	Automatic reconnection	Task scheduler logs, startup registry entries	Correlate scheduled task creation with DNS activity	Task created shortly before tunnelling began	Remove task + clean persistence	Persistence ensures long-term covert channel.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	Gain SYSTEM/root to bypass DNS filtering	Elevated process generating DNS queries	Escalated C2 channel	Token elevation logs, privilege usage	Detect DNS queries from SYSTEM context unexpectedly	SYSTEM-level process issuing DNS beacons	Escalate to high severity	SYSTEM-level tunnelling indicates deeper compromise.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Bypass DNS monitoring	DNS logging disabled or modified	Attempt to hide channel	DNS server audit logs	Compare log retention gap with DNS spike timeline	DNS logs truncated after suspicious queries	Treat as confirmed compromise	DNS log tampering is severe red flag.
Discovery	Account Discovery (T1087) + File and Directory Discovery (T1083)	Identify data for exfiltration	Spike in file access followed by DNS spike	Data staging for DNS exfil	File audit logs, DNS logs	Correlate sensitive file access timestamp with DNS query volume	Sensitive folder accessed before DNS spike	Monitor outbound DNS closely	DNS spike after data access suggests encoded exfiltration.

Collection	Data from Network Shared Drive (T1039) + Archive Collected Data (T1560.001)	Prepare data for tunnelling	Archive file created before DNS spike	Data packaging	Endpoint file creation logs	Check archive size vs DNS data throughput	Archive created within same hour as DNS anomaly	Isolate host	DNS exfiltration bandwidth is low but persistent.
Command & Control	Application Layer Protocol (T1071.004 DNS)	Maintain interactive control	Regular 60-second DNS beacon	Active remote operator	Beacon interval analysis, entropy scoring	Detect consistent periodicity & encoded payload size	Fixed interval beaconing detected	Block malicious domain at DNS resolver	Periodicity is key detection factor.
Exfiltration	Exfiltration Over C2 Channel (T1041)	Transfer data via DNS responses	Large volume of DNS TXT responses	Data exfiltration	DNS traffic volume, response size	Analyse inbound TXT response payload size anomalies	DNS response size abnormal for standard queries	Notify compliance immediately	DNS exfil may bypass traditional proxy controls.
Impact	Exfiltration of Sensitive Data (T1041) OR Valid Accounts (T1078)	Credential theft or data leak	Confirmed data reconstruction from DNS logs	Business and regulatory impact	Data classification impact review	Confirm volume & type of exfiltrated data	Sensitive PII exfil confirmed	Activate IR + regulatory notification	DNS tunnelling is stealthy but traceable via entropy and periodicity.

PLAYBOOK 21 — API Business Logic Abuse

Attack Theme: Legitimate API Access → Manipulation of Business Workflow → Bypass of Validation Controls → Fraud / Financial Manipulation / Data Exposure

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Active Scanning (T1595.002) + Gather Victim Identity Info (T1589.003)	Identify API endpoints & workflow logic	Sequential calls to /api/v1/transfer/preview with varying parameters	Attacker mapping transaction flow	Source IP reputation, request sequence analysis	Analyse endpoint call order vs documented workflow	Repeated manipulation of transaction parameters	Increase API monitoring sensitivity	Business logic abuse focuses on workflow gaps, not injection flaws.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Develop automation script for API manipulation	High-frequency API calls from single account	Automated business logic testing	API rate per account, user-agent fingerprint	Detect scripted patterns (fixed intervals, identical headers)	Automation detected targeting financial APIs	Apply adaptive rate limiting	Automation is key enabler of logic abuse at scale.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts)	Use legitimate credentials to access API	Normal login followed by abnormal API usage pattern	Credential is valid but intent malicious	Login context vs API usage behaviour	Compare baseline transaction frequency vs current spike	High-value API calls immediately after login	Flag account for fraud monitoring	Abuse relies on valid authentication.

Execution	Exploit Public-Facing Application (T1190) (Logic-Level Exploit)	Manipulate transaction logic (e.g., negative values, race conditions)	Multiple rapid transfer requests with modified parameters	Attempt to bypass validation	API payload inspection, parameter anomalies	Analyse concurrency timing (race condition attempts), inconsistent request order	Transactions processed faster than business threshold	Temporarily suspend account	Business logic exploitation often exploits timing gaps.
Persistence	Account Manipulation (T1098)	Modify profile limits or linked accounts	Change of daily transfer limit via API	Expanding fraud potential	Audit logs for account limit changes	Compare change timestamp vs suspicious API pattern	Transfer limit increased before fraud spike	Revert limits immediately	Limit changes often precede large fraud execution.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group) OR Valid Accounts (T1078)	Abuse elevated user privileges	API token used to access admin-only endpoints	Privilege misuse	IAM role validation, token scope inspection	Check OAuth scope vs endpoint accessed	Standard user accessing admin endpoint	Revoke token immediately	Token scope misuse is strong logic abuse indicator.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Attempt to disable fraud alerts via API	Fraud alert notification toggled off	Attempt to bypass detection	Audit logs for notification preference change	Correlate notification disablement with fraud timeline	Alert suppression before transaction spike	Restore alerts immediately	Disabling fraud alerts indicates clear malicious intent.

Discovery	Account Discovery (T1087) + Permission Group Discovery (T1069.002)	Enumerate accessible account IDs	API requests cycling through account numbers	Mapping potential victim accounts	API query pattern analysis	Detect incremental ID enumeration	Sequential account ID access detected	Increase monitoring of API session	Enumeration precedes exploitation.
Collection	Data from Information Repositories (T1213)	Extract financial or customer data	Large API response payload size anomaly	Data harvesting	API response size baseline comparison	Analyse response size vs normal transaction flow	Abnormally large response payloads	Enable DLP & monitor outbound	Data leakage can accompany fraud attempts.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain API abuse session	Continuous automated API calls	Active fraud session	API session duration, IP ASN	Detect persistent scripted calls without user interaction	Session active beyond normal user duration	Terminate session	Long-lived automated API sessions are suspicious.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Download transaction data via API	Repeated export/download endpoint usage	Data theft in progress	API audit logs, DLP alerts	Correlate export endpoint calls with automation pattern	Data export + abnormal login context	Notify compliance immediately	Regulatory exposure significant (PDPA / RMIT).
Impact	Financial Theft (T1657) OR Data Manipulation (T1565.001 Stored Data)	Execute fraudulent transfers	Unauthorised fund transfer within business rule limits	Business loss	Transaction approval chain, fraud analytics review	Identify race-condition success or threshold bypass	Confirmed fraud transaction	Activate fraud response + IR	Logic abuse may not trigger traditional security signatures.

	Manipulation)								
--	---------------	--	--	--	--	--	--	--	--

BYZANTINE

PLAYBOOK 22 — Cloud IAM Misconfiguration Abuse

Attack Theme: Over-Permissive IAM Role → Token Abuse → Privilege Escalation → Data Access / Infrastructure Manipulation → Potential Cloud-Wide Impact

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Cloud Infrastructure Discovery (T1580) + Account Discovery (T1087)	Identify IAM roles and accessible cloud resources	API calls listing IAM roles and policies	Attacker mapping cloud permissions	Source IP ASN, access key ID used	Analyse ListRoles, ListPolicies, GetCallerIdentity patterns	Enumeration from newly created or unused access key	Increase monitoring on identity	Enumeration in cloud often precedes privilege abuse.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare automation (CLI/SDK scripts)	High-frequency IAM API calls	Automated permission testing	API rate anomalies, user-agent fingerprint	Detect scripted CLI usage (aws-cli, cloud SDK)	Burst of IAM permission evaluation calls	Apply temporary rate limit	Automation enables rapid privilege mapping.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts)	Use exposed access key / token	Successful API authentication from new ASN	Credential exposure likely	Check key age, MFA enforcement, IP reputation	Correlate with recent Git leak, phishing, or token reuse	API key used from foreign ASN	Disable compromised key immediately	Cloud compromise often starts with exposed keys.
Execution	Exploitation of IAM Misconfiguration (T1078 +	Assume over-permissive role	AssumeRole success on high-privilege role	Role trust policy too broad	Review role trust relationships	Analyse cross-account trust,	Non-admin user assumes admin role	Remove trust policy immediately	Overly broad trust policy is root cause.

	Privilege Misuse)					wildcard permissions			
Persistence	Create Account (T1136.003 Cloud Account)	Create new IAM user or access key	New access key generated for high-privilege role	Backdoor cloud access	Cloud audit logs for CreateUser, CreateAccessKey	Trace key creation to assumed role session	Key created outside change window	Delete rogue key/user	Persistence via API key ensures silent re-entry.
Privilege Escalation	Privilege Escalation via Cloud Role Abuse (T1068 Equivalent in Cloud Context)	Attach admin policy to self	AttachUserPolicy to AdministratorAccess	Full cloud control	IAM change logs, policy attachment history	Compare baseline IAM policy vs new attachment	Standard user attached admin policy	Detach policy immediately	Policy attachment is decisive privilege pivot.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable logging (e.g., CloudTrail)	StopLogging or DeleteTrail API call	Attempt to blind monitoring	Cloud audit logs	Correlate logging disablement with privilege escalation	Logging disabled post-role assumption	Re-enable logging + escalate	Logging disablement confirms malicious intent.
Discovery	Cloud Service Discovery (T1580) + Account Discovery (T1087)	Enumerate storage buckets, databases	ListBuckets, DescribeDBInstances spike	Mapping valuable assets	API logs, unusual enumeration volume	Analyse query frequency vs baseline usage	Sensitive service enumeration post-escalation	Monitor critical resources	Enumeration signals preparation for data theft.
Collection	Data from Cloud Storage (T1530)	Access sensitive S3 / blob storage	GetObject spike on restricted bucket	Data harvesting	Storage access logs, object	Compare accessed objects vs	Sensitive bucket accessed by unusual role	Enable DLP & isolate role	Storage access by non-owner is

					size analysis	role baseline			strong signal.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain API control channel	Continuous API calls from single ASN	Active operator in cloud	ASN risk score, token session duration	Analyse session refresh & API cadence	Long-lived assumed role session	Revoke session tokens	Cloud C2 blends into normal API traffic.
Exfiltration	Exfiltration to Cloud Storage (T1567.002) OR Transfer Data to External Account (T1537)	Copy data to attacker-controlled bucket	PutObject to external account	Data exfiltration	Cross-account transfer logs	Detect unusual cross-account copy activity	Sensitive data copied cross-account	Notify compliance immediately	Cross-account copy is high-risk indicator.
Impact	Data Manipulation (T1565.001 Stored Data Manipulation) OR Resource Hijacking (T1496)	Delete/modify resources or spin crypto-mining instances	Mass instance creation or bucket deletion	Financial or operational damage	Cloud cost anomaly alerts, deletion logs	Correlate instance creation with assumed role session	AdministratorAccess role used for mass changes	Activate cloud IR immediately	IAM misconfiguration can lead to total cloud takeover.

PLAYBOOK 23 — Cryptojacking in Kubernetes Cluster

Attack Theme: Exposed Kubernetes API / Compromised Pod → Malicious Container Deployment → Crypto-Mining Process Execution → Resource Hijacking → Cloud Cost & Performance Impact

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Cloud Infrastructure Discovery (T1580) + Network Service Discovery (T1046)	Identify exposed Kubernetes API or misconfigured dashboard	Repeated access attempts to /api/v1/namespaces	Attacker probing K8s control plane	Source ASN, authentication method used	Analyse API server logs, check anonymous access attempts	API accessed without proper authentication	Restrict API exposure immediately	Publicly exposed K8s API is primary entry vector.
Resource Development	Obtain Capabilities (T1588.001 Tooling) + Acquire Infrastructure (T1583.003 VPS)	Prepare crypto-mining container image	Pull request to suspicious container registry	Malicious container staging	Image registry reputation, image hash	Inspect image layers, detect embedded mining binaries	Image pulled from unknown registry	Block image registry	Container image source validation is critical.
Initial Access	Exploit Public-Facing Application (T1190) OR Valid Accounts (T1078.004)	Gain access to cluster	Successful kubectl auth from foreign ASN	Compromised K8s credentials	Review kubeconfig use, RBAC permissions	Correlate access with Git leak or exposed token	Cluster access from new geolocation	Rotate cluster credentials	Exposed service account tokens common in

	Cloud Accounts)								2026 breaches.
Execution	Deploy Container (T1610) + Command and Scripting Interpreter (T1059)	Deploy crypto-mining pod	New pod deployed with high CPU request	Mining workload execution	Pod creation logs, container runtime telemetry	Inspect pod spec for suspicious commands (xmrig, minerd)	Pod consuming >80% CPU persistently	Delete malicious pod	Sudden sustained CPU spike is key cryptojacking signal.
Persistence	Create or Modify System Process (T1543) + Kubernetes CronJob Abuse (T1053.003 Cron)	Maintain mining workload	CronJob creating recurring mining pods	Automatic redeployment	Check for suspicious CronJobs or DaemonSets	Analyse RBAC privileges enabling pod recreation	CronJob deploying unknown image	Remove CronJob immediately	Cron-based redeployment ensures resilience.
Privilege Escalation	Exploitation for Privilege Escalation (T1068) + Abuse of ClusterRoleBinding (T1098.003 Add to Group Equivalent)	Escalate to cluster-admin	New ClusterRoleBinding granting admin rights	Full cluster compromise	RBAC change logs	Compare role bindings before/after intrusion	Non-admin service account granted cluster-admin	Revoke elevated role immediately	ClusterRoleBinding abuse is critical escalation pivot.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable monitoring agent in cluster	Security sidecar container terminated	Attempt to evade detection	Pod deletion logs, DaemonSet health	Correlate monitoring pod deletion with mining	Monitoring pods deleted before mining spike	Restore monitoring immediately	Disabling monitoring confirms malicious intent.

						deployment			
Discovery	Container and Cluster Discovery (T1613)	Enumerate namespaces and secrets	kubectlgetspikesecrets	Mapping sensitive credentials	API server audit logs	Detect secret enumeration patterns	Secret access shortly after cluster access	Rotate exposed secrets	Secret enumeration can lead to cloud account compromise.
Collection	Data from Cloud Storage (T1530) OR Data from Container Volume	Access sensitive mounted volumes	Container reading mounted config maps or secrets	Data harvesting	Volume access logs	Inspect unusual read access to secret files	Secret file read by mining container	Investigate possible credential leak	Cryptojacking may mask broader data theft.
Command & Control	Application Layer Protocol (T1071.001 Web)	Connect to mining pool server	Outbound connection to known mining pool	Active crypto-mining	Egress firewall logs, DNS logs	Analyse mining pool domain, persistent TCP connections	Connection to known mining pool ASN	Block mining pool domain	Mining pool connection is definitive cryptojacking indicator.
Exfiltration	Exfiltration Over C2 Channel (T1041) (If combined attack)	Send harvested secrets externally	Outbound data transfer from pod	Data exfiltration	Network monitoring, DLP	Correlate secret access with outbound spike	Secret enumeration + outbound traffic	Notify compliance if sensitive	Cryptojacking sometimes hides credential theft.
Impact	Resource Hijacking (T1496)	Consume cluster CPU for cryptocurrency mining	Sustained CPU >90% across nodes	Financial and performance impact	Cloud cost anomaly detection, node metrics	Analyse node scaling anomalies, check auto-	Sudden infrastructure cost spike	Remove malicious workloads immediately	Cryptojacking impacts availability and cost, not confidentiality primarily.

scaling
triggers

BYZANTINE

PLAYBOOK 24 — Deepfake CEO Voice Fraud

Attack Theme: AI-Generated Voice Impersonation → Social Engineering of Finance Team → Urgent Payment Request → Policy Bypass → Financial Fraud

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Identity Info (T1589.001 Credentials / T1589.003 Email Addresses) + Gather Victim Org Information (T1591)	Identify CEO voice samples & finance staff targets	External scraping of public speeches / earnings calls	Attacker preparing deepfake model	Monitor OSINT exposure, executive public content	Review abnormal downloads of executive media files	Targeted reconnaissance on finance executives	Alert executive protection team	Deepfake fraud begins with data harvesting for voice training.
Resource Development	Obtain Capabilities (T1588.001 Tooling) + Develop AI-Generated Content	Generate synthetic CEO voice model	Threat intel report referencing deepfake fraud campaign	Voice impersonation infrastructure prepared	Check recent fraud advisories, known VoIP abuse	Analyse call metadata from suspicious VoIP provider	VoIP numbers tied to fraud campaigns	Notify finance department proactively	AI voice cloning now highly realistic in 2026.
Initial Access	Phishing for Information (T1598.003)	Contact finance staff	Urgent payment	Social engineering in progress	Validate call origin number,	Cross-check request against	Urgent high-value transfer requested	Freeze transaction	Urgency is primary

	OR Valid Accounts (T1078)	posing as CEO	instruction via phone		request call-back verification	documented approval workflow	outside normal process	pending verification	manipulation tactic.
Execution	Social Engineering (T1204 User Execution Equivalent)	Convince staff to execute fund transfer	Payment initiated without secondary approval	Fraud attempt in progress	Verify dual-approval enforcement logs	Check if payment bypassed policy threshold	Payment initiated outside business hours	Suspend payment immediately	Voice legitimacy does not replace policy validation.
Persistence	Account Manipulation (T1098) (If email compromise combined)	Modify email forwarding or contact details	Email rule forwarding finance approvals externally	Preparing future fraud attempts	Audit mailbox rules, forwarding settings	Correlate email rule creation with suspicious calls	New forwarding rule on finance mailbox	Remove rule immediately	Fraud often combines voice + email compromise.
Privilege Escalation	Valid Accounts (T1078) (If internal collusion or account compromise)	Gain access to finance approval portal	CEO account login anomaly	Credential compromise combined with voice fraud	Check login ASN, impossible travel	Correlate CEO login anomaly with payment request timing	CEO login from foreign ASN before payment	Disable account immediately	Multi-vector fraud increases impact severity.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Attempt to suppress fraud alerts	Alert notifications disabled before transfer	Attempt to bypass detection	Audit notification settings, fraud alert logs	Compare alert disablement vs transfer timestamp	Fraud alert suppression before transfer	Restore alerts immediately	Alert tampering indicates malicious coordination.
Discovery	Account Discovery (T1087)	Identify payment approval chain	Request for internal approval	Mapping control weaknesses	Monitor internal information disclosure	Detect unusual internal queries	Staff asked for policy details by impersonator	Escalate awareness immediately	Fraudsters exploit policy

			process details			about approval workflow			knowledge gaps.
Collection	Data from Information Repositories (T1213) (If combined with email compromise)	Access invoice templates & vendor lists	Finance shared drive access spike	Preparing convincing payment scenario	File access logs	Correlate invoice template access with fraud timeline	Vendor data accessed before fraud call	Investigate possible data staging	Real invoice data increases fraud success rate.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain coordination via VoIP / encrypted messaging	Repeated VoIP calls to finance staff	Ongoing social engineering attempt	Call metadata, repeated contact attempts	Analyse call timing vs transfer workflow steps	Multiple calls reinforcing urgency	Block suspicious number	Repeated contact escalates psychological pressure.
Exfiltration	Exfiltration Over Web Services (T1567.002) (Funds transfer context)	Transfer funds to attacker-controlled account	Large outbound wire transfer	Financial loss in progress	Bank transaction logs, beneficiary account verification	Check beneficiary account history, first-time payment indicator	New beneficiary added before transfer	Freeze beneficiary immediately	First-time beneficiary for high-value transfer is strong red flag.
Impact	Financial Theft (T1657)	Successful fraudulent transfer	Confirmed funds sent to fraudulent account	Direct financial impact	Fraud recovery process, bank liaison	Trace funds flow, notify correspondent banks	Funds unrecoverable after settlement window	Activate crisis & legal response	Human-layer attack bypasses technical controls if policy ignored.



PLAYBOOK 25 — Harvest Now, Decrypt Later (Post-Quantum Cryptography Risk)

Attack Theme: Long-Term Encrypted Data Collection → Storage of RSA/ECC-Protected Traffic → Future Decryption via Quantum Capability → Delayed Confidentiality Breach

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Org Information (T1591) + Network Service Discovery (T1046)	Identify high-value encrypted data flows (VPN, TLS, backups)	Traffic pattern analysis against banking VPN endpoints	Attacker mapping long-term valuable encrypted traffic	Review exposed TLS services, VPN endpoints, certificate types	Inventory cryptographic algorithms (RSA-2048, ECC-P256), assess quantum-vulnerable assets	Critical systems using legacy crypto without PQC plan	Initiate crypto asset inventory	Quantum threat targets long-term confidentiality, not immediate breach.
Resource Development	Acquire Infrastructure (T1583.003 VPS) + Obtain Capabilities (T1588.001 Data)	Prepare infrastructure for passive traffic capture	Large sustained outbound traffic mirrored to external IP	Possible traffic interception or logging	Check for unusual packet capture processes or mirrored traffic	Inspect network devices for SPAN/mirror or config changes	Traffic replication detected without change approval	Disable unauthorized mirror sessions	Passive collection often invisible without crypto telemetry.

	Collection Tooling)								
Initial Access	Adversary-in-the-Middle (T1557.002 ARP Poisoning / T1557.001 LLMNR/NBT-NS Poisoning) OR Compromise Network Device	Intercept encrypted communications	Suspicious certificate warning anomalies	Possible TLS interception	Validate certificate chain integrity, check rogue cert installation	Compare certificate fingerprints across endpoints	Internal rogue CA certificate detected	Remove rogue certificate authority	MITM can enable harvesting of encrypted sessions.
Execution	Network Sniffing (T1040)	Capture encrypted VPN/TLS traffic	Unusual packet capture process on server	Data harvesting in progress	Identify tcpdump/Wireshark-like processes	Inspect process owner, capture file location	Large PCAP files stored on server	Isolate affected device	Harvesting encrypted data is stealthy but detectable via process telemetry.
Persistence	Modify Authentication Process (T1556) + Create Account (T1136)	Maintain network-level access	New admin account on firewall or VPN device	Long-term interception capability	Audit network device admin logs	Compare new admin account vs change request	Admin created without approval	Remove rogue admin immediately	Persistence ensures long-term encrypted data capture.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	Gain root access on network appliance	Firewall root login anomaly	Full packet inspection capability	Appliance login logs, config modification history	Detect unauthorized firmware	Root access gained without	Escalate to critical severity	Root-level access enables

						modification	maintenance window		silent harvesting.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable TLS inspection alerts	Logging disabled on network appliance	Attempt to avoid detection	SIEM ingestion gaps, appliance log retention	Correlate log disablement with packet capture activity	Logging disabled after suspicious network changes	Treat as confirmed compromise	Logging disablement on crypto infrastructure is severe indicator.
Discovery	Data from Information Repositories (T1213)	Identify high-value encrypted backups	Access to encrypted backup storage	Harvesting long-term data assets	Backup access logs, unusual read activity	Correlate large backup reads with suspicious admin activity	Sensitive backup read outside schedule	Increase monitoring	Backups are prime “harvest now” targets.
Collection	Archive Collected Data (T1560.001)	Store encrypted data for future decryption	Large encrypted archive created	Long-term retention of encrypted data	Check archive creation on network devices	Inspect storage utilisation spikes	Archive created on device not used for storage	Remove archive & investigate	Encrypted data today may be plaintext tomorrow.
Command & Control	Application Layer Protocol (T1071.001 Web)	Transfer harvested encrypted data to attacker storage	Large outbound encrypted upload to rare ASN	Data exfiltration for future decryption	Firewall logs, DLP alerts	Correlate packet capture timestamp with outbound transfer	Multi-GB outbound spike from network device	Block destination & notify compliance	Long-term confidentiality risk.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Move captured encrypted traffic externally	Sustained encrypted outbound	Sensitive encrypted data exfiltration	Traffic volume analysis, ASN reputation	Identify unusual high-volume TLS transfers from	Network device communicating externally	Escalate to regulatory reporting review	Even encrypted data theft may require reporting.

			d transfer			infrastructure devices	unexpectedly		
Impact	Data from Information Repositories (T1213) (Future Decryption Risk)	Future compromise of sensitive data	No immediate operational impact	Delayed confidentiality breach risk	Assess data retention classification (10–20 year sensitivity)	Conduct crypto inventory & PQC migration gap analysis	Critical systems still using vulnerable crypto	Initiate PQC migration roadmap	Harvest Now, Decrypt Later is strategic, not tactical threat.

PLAYBOOK 26 — SIM Swap Fraud

Attack Theme: Social Engineering of Telco → Victim Phone Number Ported to Attacker SIM → SMS OTP Interception → Account Takeover → Financial Fraud / Crypto Theft

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Identity Info (T1589.001 Credentials / T1589.002 Personal Data) + Gather Victim Org Information (T1591)	Collect personal details for telco verification	OSINT scraping of victim social media	Attacker preparing identity impersonation	Monitor breached data correlation, dark web alerts	Correlate personal data exposure with high-value account holders	High-net-worth or privileged users targeted	Flag account for enhanced monitoring	SIM swap fraud begins with identity data harvesting.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare spoofed caller ID & forged ID documents	VoIP calls to telecom provider from suspicious ASN	Social engineering infrastructure ready	Telco fraud advisory alerts, VoIP ASN reputation	Analyse call metadata and fraud campaign indicators	Telco reports unusual port-out request	Coordinate with telecom immediately	Telco layer is external but critical dependency.
Initial Access	Social Engineering (T1204 Equivalent – User	Convince telco to port victim number	Mobile number deactivated unexpectedly	SIM swap likely occurred	Confirm SIM status with telco, check timestamp of port	Correlate SIM deactivation with login attempts	SIM deactivated followed by OTP-	Lock user accounts immediately	SIM deactivation + login attempts

	Execution / Human Manipulation)						based login attempt		is decisive signal.
Execution	Valid Accounts (T1078) + Multi-Factor Authentication Interception	Use SMS OTP to bypass MFA	Successful login after SMS OTP	Account takeover in progress	Login ASN, device fingerprint mismatch	Compare pre-swap device fingerprint vs new login context	Login from foreign ASN after SIM change	Revoke sessions immediately	SMS-based MFA is vulnerable to SIM swap.
Persistence	Account Manipulation (T1098)	Change account recovery email or password	Password reset + recovery email updated	Attacker securing access	Audit logs for profile modification	Compare change time vs SIM swap timestamp	Account details changed immediately after login	Restore original settings	Persistence often occurs within minutes.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group) OR Valid Accounts (T1078)	Abuse elevated privileges	Admin account takeover via SIM swap	Expanding control	IAM logs, privileged account review	Trace login source and approval chain	Privileged user accessed via SIM-based OTP	Reset privileged credentials immediately	SIM swap on admin account is critical severity.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable SMS alerts & notifications	Security alerts disabled in settings	Attempt to hide fraud activity	Audit notification settings	Correlate alert suppression with login anomaly	Alert settings modified post-SIM swap	Restore notifications immediately	Alert suppression confirms malicious control.

Discovery	Account Discovery (T1087)	Identify linked financial accounts	API queries listing linked wallets/bank accounts	Mapping potential fraud targets	API logs, abnormal enumeration	Detect rapid navigation across financial sections	Enumeration immediately after login	Monitor financial endpoints closely	Discovery signals intent to monetise access.
Collection	Data from Information Repositories (T1213)	Access personal or financial records	Download of statements or ID documents	Data harvesting	File download logs	Correlate download spike with login anomaly	Sensitive document download post-login	Trigger fraud alert	Data theft may accompany financial fraud.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain control via authenticated session	Continuous session refresh from new ASN	Active attacker presence	Session duration, IP reputation	Detect long-lived session with no device change	Persistent foreign session active	Terminate session	Speed of containment determines fraud window.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer funds or crypto assets	High-value transfer to new beneficiary/wallet	Financial loss in progress	Transaction logs, beneficiary validation	Check first-time beneficiary rule, geo-IP mismatch	First-time beneficiary + SIM swap correlation	Freeze transaction immediately	Beneficiary anomaly is decisive fraud indicator.
Impact	Financial Theft (T1657)	Successful fraudulent transfer	Confirmed funds moved to attacker-controlled account	Direct financial impact	Fraud recovery workflow, bank liaison	Trace funds movement across correspondent banks	Funds settled beyond recovery window	Activate crisis response	SIM swap fraud is identity-layer compromise with financial impact.

PLAYBOOK 27 — ATM Jackpotting

Attack Theme: Physical Access / Malware Deployment → ATM Control Override → Cash Dispenser Command Abuse → Coordinated Cash-Out → Financial Loss

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Org Information (T1591) + Network Service Discovery (T1046)	Identify ATM model, OS version & network segmentation	Repeated remote connectivity probes to ATM management network	Attacker mapping ATM infrastructure	Source ASN, management interface exposure	Analyse ATM fleet inventory, patch level & remote access exposure	ATM model with known malware campaign association	Increase monitoring of affected fleet	ATM attacks often target specific OS or vendor firmware.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare ATM malware & dispensing commands	Suspicious executable signature known in ATM malware intel	Malware staging	Compare file hash against known ATM malware families	Analyse malware behaviour in sandbox (offline lab)	Malware signature match in environment	Alert ATM operations team immediately	ATM malware often customised per vendor.
Initial Access	Exploit Public-Facing Application (T1190) OR Valid Accounts	Gain access to ATM internal system	ATM enters maintenance mode unexpectedly	Possible unauthorised maintenance access	Check remote admin session logs, local access logs	Correlate maintenance mode entry with network activity	Maintenance mode activated outside scheduled window	Disable remote access immediately	Maintenance mode misuse is common jackpotting precursor.

	(T1078) OR Physical Access								
Execution	Command and Scripting Interpreter (T1059) + Inhibit System Recovery (T1490 equivalent for ATM controls)	Execute malware to control dispenser	Unusual cash dispense command without card transaction	Jackpotting in progress	ATM transaction logs, dispenser command logs	Analyse dispense events vs legitimate transaction authorisation	Cash dispense event without backend authorisation	Shut down affected ATM	Dispense without core banking validation is decisive indicator.
Persistence	Create or Modify System Process (T1543)	Install persistent ATM service	New system service created on ATM OS	Backdoor persistence	OS service logs, file integrity monitoring	Compare baseline services vs current snapshot	Unknown service installed recently	Remove malicious service	Persistence enables repeated cash-outs.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	Gain SYSTEM-level control on ATM OS	SYSTEM shell opened on ATM terminal	Full device compromise	Local privilege logs, process lineage	Trace parent process initiating SYSTEM shell	SYSTEM process spawned outside vendor software	Treat as confirmed compromise	SYSTEM control enables direct dispenser manipulation.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable ATM security agent	Security monitoring service stopped	Attempt to avoid detection	Agent health monitoring logs	Correlate service disablement with jackpotting attempt	Monitoring disabled prior to dispense event	Escalate to high severity	Disabling monitoring confirms malicious activity.

Discovery	Account Discovery (T1087)	Identify admin credentials stored locally	Access to credential store files	Mapping privileged access	File access logs on ATM OS	Inspect unusual read access to config/credential files	Credential file accessed before jackpot event	Rotate local admin credentials	Local credential theft can scale attack.
Collection	Data from Information Repositories (T1213)	Access ATM configuration & encryption keys	Config file export detected	Preparing large-scale attack	Monitor file export and USB activity	Correlate config export with multiple ATM incidents	Config file accessed from multiple ATMs	Investigate fleet-wide compromise	Config theft enables coordinated attacks.
Command & Control	Application Layer Protocol (T1071.001 Web) OR Encrypted Channel (T1573)	Trigger remote jackpot commands	ATM connecting to rare external IP	Possible remote C2	Firewall logs for ATM VLAN	Analyse outbound traffic from ATM network segment	ATM initiating outbound session unexpectedly	Block outbound connection	ATM should not initiate arbitrary outbound sessions.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer ATM logs or keys externally	Outbound encrypted transfer from ATM subnet	Potential broader breach	Network monitoring, DLP	Correlate config/key access with outbound spike	Key export + external traffic	Notify compliance if encryption keys involved	Key compromise can escalate to card data risk.
Impact	Financial Theft (T1657) + Resource Hijacking (Physical Cash)	Dispense large volume of cash without transaction	Multiple high-value cash dispenses within minutes	Direct financial loss	Cash reconciliation reports, CCTV review	Correlate dispense logs with CCTV and network logs	Multiple ATMs jackpotting simultaneously	Activate crisis & law enforcement coordination	ATM jackpotting blends cyber + physical attack vectors.



PLAYBOOK 28 — Card Skimming (Digital POS Malware)

Attack Theme: POS System Compromise → Memory Scraping Malware → Card Track Data Capture → Covert Exfiltration → Fraud & Card Dump Resale

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Org Information (T1591) + Active Scanning (T1595.002)	Identify exposed POS management servers	Repeated scan attempts to POS management port	Attacker mapping POS infrastructure	Source ASN, port scan patterns	Correlate scan IPs with known POS malware campaigns	Scan targeting POS-specific services	Increase monitoring on POS VLAN	POS networks are often flat and weakly segmented.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare POS memory-scraping malware	Suspicious executable flagged by threat intel	Malware staging	Compare file hash with known POS malware families	Sandbox detonation to observe Track1/Track2 scraping behaviour	Malware hash match with known skimmer family	Alert PCI compliance team immediately	POS malware often customised for specific vendor builds.
Initial Access	Valid Accounts (T1078) OR Exploit Public-Facing	Gain access to POS terminal	Remote desktop login to POS from unusual source	Credential compromise	Review RDP logs, local login events	Correlate login with phishing or reused admin credentials	Admin login from non-support workstation	Disable compromised credentials	POS remote access is common initial vector.

	Application (T1190)								
Execution	OS Credential Dumping (T1003) OR Memory Scraping (T1003.001 LSASS-like technique adapted for POS process memory)	Capture card track data in memory	POS process reading memory of payment application	Memory scraping in progress	EDR telemetry, unusual process handle access	Detect string patterns matching Track1/Track 2 format (%B...^)	Non-payment process accessing POS memory	Isolate POS terminal immediately	Memory scraping is hallmark of digital skimming.
Persistence	Create or Modify System Process (T1543)	Install persistent skimmer service	New service created with generic name	Long-term skimming	Windows service logs, file integrity monitoring	Compare baseline services vs current configuration	Unknown service installed recently	Remove malicious service	Persistent service ensures continuous card harvesting.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	Gain SYSTEM-level control of POS	Elevated process spawned from non-admin context	Full POS control	Token elevation logs, parent-child analysis	Trace exploit binary triggering SYSTEM shell	SYSTEM-level access without maintenance ticket	Escalate to high severity	SYSTEM control allows direct card data interception.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable POS antivirus or logging	Security agent stopped	Attempt to evade PCI monitoring	EDR health logs	Correlate agent disablement with memory access	Monitoring disabled before scraping spike	Treat as confirmed compromise	Disabling monitoring indicates deliberate fraud

									preparation
Discovery	File and Directory Discovery (T1083)	Identify payment processing directories	Unusual access to payment software folder	Mapping sensitive processes	File access audit logs	Detect process listing specific payment executables	Payment directory accessed by unknown process	Monitor closely	Malware must identify payment process memory.
Collection	Data from Information Repositories (T1213) + Archive Collected Data (T1560.001)	Store captured card data locally	Encrypted file growing steadily in temp directory	Card data staging	Endpoint file creation logs	Inspect file entropy and growth pattern	Encrypted log file increases per transaction	Isolate endpoint	Staging often done in encrypted local file before exfil.
Command & Control	Application Layer Protocol (T1071.001 Web)	Send card data to external server	Periodic HTTPS outbound to rare ASN	Active exfiltration channel	Proxy logs, DNS logs	Analyse beacon interval & payload size	Outbound to domain associated with carding forums	Block C2 immediately	POS should have highly restricted outbound connectivity.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer harvested card data	Sustained outbound encrypted transfer	Card data breach	DLP alerts, firewall logs	Correlate transaction volume with outbound data volume	Data transfer spike after business hours	Notify compliance & initiate PCI incident response	Card data exposure triggers regulatory obligations (PCI DSS).
Impact	Exfiltration of Sensitive Data (T1041)	Sale of stolen card data on dark web	Fraud alerts linked to merchant ID	Financial and reputational damage	Fraud monitoring, card brand notification	Correlate compromised POS terminal with	Confirmed card fraud tied to merchant	Activate full PCI breach protocol	Digital skimming directly impacts customers

						fraudulent card usage pattern			and brand trust.
--	--	--	--	--	--	-------------------------------------	--	--	---------------------

BYZIMMER

PLAYBOOK 29 — Payment Gateway Manipulation

Attack Theme: Compromised Merchant / Admin Access → API Parameter Manipulation → Transaction Redirection / Amount Tampering → Settlement Abuse → Financial Loss

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Active Scanning (T1595.002) + Gather Victim Org Information (T1591)	Identify exposed payment API endpoints & merchant dashboards	Repeated probing of /api/v2/payment/initiate	Attacker mapping transaction flow	Source ASN reputation, request pattern analysis	Correlate probe IPs with later manipulation attempts	Probing focused on payment parameters	Increase monitoring on gateway endpoints	Payment APIs are high-value financial targets.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Develop automation to modify API payloads	High-frequency API requests with modified JSON parameters	Automated tampering	API request rate, identical headers, token reuse	Detect scripted manipulation (amount field variance, currency mismatch)	Burst of malformed but valid requests	Apply adaptive rate limiting	Automation enables testing of validation gaps.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts)	Use compromised merchant/admin credentials	Successful login to payment admin portal from foreign ASN	Credential compromise	Login ASN, device fingerprint mismatch	Correlate login anomaly with credential leak indicators	Admin login outside normal geo	Force credential reset	Gateway compromise often starts with merchant credential theft.

Execution	Exploit Public-Facing Application (T1190) (Logic-Level Exploit)	Modify transaction parameters (amount, beneficiary, callback URL)	Transaction amount mismatch between request and settlement	Business logic manipulation	Compare API request vs settlement logs	Analyse discrepancies in signed payload vs backend validation	Payment approved despite parameter mismatch	Suspend affected merchant account	Business logic flaws bypass signature validation if misconfigured.
Persistence	Account Manipulation (T1098)	Add secondary API key or webhook endpoint	New webhook URL configured	Attacker securing long-term redirection	Audit logs for API key creation & webhook updates	Compare change timestamp vs suspicious transaction	Webhook changed before fraud spike	Remove rogue webhook immediately	Webhook redirection enables silent fund diversion.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group)	Elevate merchant to super-admin	Merchant account granted elevated API privileges	Expanding fraud capability	IAM logs, role assignment audit	Trace approval chain for privilege change	Non-finance user granted financial admin role	Remove privilege immediately	Elevated API roles enable settlement manipulation.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable fraud monitoring rules	Fraud detection threshold modified	Attempt to avoid alerts	Fraud rule configuration logs	Compare rule baseline vs modified settings	Fraud rules altered before suspicious transactions	Restore rules immediately	Fraud rule tampering is decisive malicious indicator.
Discovery	Account Discovery (T1087)	Enumerate merchant IDs & settlement accounts	Sequential access to merchant account IDs	Mapping high-volume targets	API logs for incremental ID access	Detect enumeration pattern	Multiple merchant IDs accessed from single session	Monitor gateway session closely	Enumeration precedes high-impact manipulation.

Collection	Data from Information Repositories (T1213)	Extract transaction history & customer data	Bulk export of transaction logs	Data harvesting	Export logs, API download activity	Correlate export spike with login anomaly	Large export prior to settlement fraud	Enable DLP monitoring	Data theft may accompany fund diversion.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain active API manipulation session	Continuous automated payment requests	Active fraud operation	API session duration, IP ASN analysis	Detect long-lived session with scripted interval requests	Session active > defined normal threshold	Terminate session	Persistent scripted calls indicate automation.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Redirect settlement funds to attacker-controlled account	New settlement account added before payout	Financial exfiltration	Beneficiary validation logs	Check first-time beneficiary & bank account reputation	New payout account + foreign ASN correlation	Freeze settlement immediately	Beneficiary anomaly strongest fraud indicator.
Impact	Financial Theft (T1657)	Funds diverted via manipulated gateway logic	Settlement discrepancy detected	Direct financial loss	Settlement reconciliation logs	Trace diverted funds across intermediary accounts	Confirmed payout to attacker account	Activate fraud & legal response	Payment gateway compromise directly impacts financial trust.

PLAYBOOK 30 — SWIFT Fraud Attack

Attack Theme: Compromise of SWIFT Environment → Operator Credential Abuse → Fraudulent MT103 / MT202 Messages → Funds Transfer to Mule Accounts → Log Manipulation

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Org Information (T1591) + Account Discovery (T1087)	Identify SWIFT operators & approval workflow	Enumeration of SWIFT user accounts	Attacker mapping transaction authority	Review access logs to SWIFT application	Correlate enumeration with unusual login activity	Enumeration from non-SWIFT workstation	Increase monitoring on SWIFT accounts	SWIFT attacks require knowledge of approval hierarchy.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare malware targeting SWIFT interface	Suspicious executable on SWIFT jump server	SWIFT-targeted malware staging	File hash reputation, endpoint telemetry	Analyse binary for SWIFT API interaction strings	Malware referencing SWIFT message formats	Isolate jump server	SWIFT malware often customised per bank.
Initial Access	Valid Accounts (T1078.004 Cloud/Enterprise Accounts) OR Spearphishing (T1566.001)	Gain access to SWIFT operator account	Successful SWIFT login from abnormal ASN	Credential compromise	Login source, device fingerprint mismatch	Compare login behaviour vs baseline operator pattern	SWIFT login outside approved location	Disable account immediately	SWIFT logins should be highly restricted.

Execution	Command and Scripting Interpreter (T1059) OR Exploit Public-Facing Application (T1190)	Generate fraudulent MT103 / MT202 messages	Outbound SWIFT transfer to new beneficiary bank	Fraud in progress	Transaction details, beneficiary validation	Compare transfer amount vs historical average	High-value transfer to first-time correspondent bank	Suspend transaction if possible	First-time correspondent bank is strong anomaly signal.
Persistence	Account Manipulation (T1098)	Create secondary SWIFT operator account	New operator account created	Long-term fraud access	SWIFT user management logs	Compare account creation vs change approval record	Operator account created outside change window	Remove rogue account	Persistence enables repeated fraud attempts.
Privilege Escalation	Account Manipulation (T1098.003 Add to Group)	Grant elevated approval rights	Single user gains dual-control rights	Control bypass	Review dual-control enforcement logs	Detect violation of 4-eyes principle	One user both initiates and approves transfer	Restore segregation of duties	Dual-control bypass is decisive fraud indicator.
Defense Evasion	Indicator Removal (T1070.001 Clear Logs) + Impair Defenses (T1562.001 Disable Security Tools)	Modify SWIFT logs or suppress alerts	SWIFT transaction log gap detected	Attempt to conceal fraud	Compare SIEM ingestion vs SWIFT internal logs	Detect discrepancy between SWIFT core & reconciliation logs	Missing transaction records	Treat as confirmed compromise	Log inconsistency is high-severity red flag.
Discovery	File and Directory Discovery (T1083)	Identify message storage directories	Access to SWIFT message archive folders	Mapping transaction history	File access audit logs	Correlate archive access with fraudulent message creation	Archive accessed before manipulation	Investigate further	Archive access may precede log tampering.

Collection	Data from Information Repositories (T1213)	Extract historical SWIFT messages	Export of SWIFT message logs	Data harvesting	Export logs, unusual file transfer activity	Correlate export with abnormal operator login	Large archive export from SWIFT server	Enable DLP & restrict server access	Data theft may accompany financial fraud.
Command & Control	Application Layer Protocol (T1071.001 Web) OR Encrypted Channel (T1573)	Maintain remote access to SWIFT jump server	Jump server outbound to rare ASN	Active operator control	Firewall logs, DNS logs	Analyse persistent outbound sessions	Jump server initiating external sessions	Block external communication	SWIFT servers should have strict outbound controls.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer stolen SWIFT data externally	Encrypted outbound traffic from SWIFT VLAN	Data breach	Network monitoring, DLP	Correlate archive export with outbound spike	SWIFT VLAN communicating externally	Notify compliance & regulator immediately	SWIFT breach has regulatory & international impact.
Impact	Financial Theft (T1657)	Fraudulent cross-border fund transfer	Funds transferred via MT103/MT202	Direct financial and reputational damage	Settlement tracking, correspondent bank notification	Trace funds across intermediaries, initiate recall	Funds credited to mule bank	Activate crisis & regulator notification	SWIFT fraud is high-impact, regulator-sensitive incident.

PLAYBOOK 31 — Domain Hijacking

Attack Theme: Registrar Account Compromise → DNS Record Manipulation → Traffic Redirection → Phishing / Email Interception / Brand Abuse → Data Theft & Fraud

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Org Information (T1591) + Domain Trust Discovery (T1482 equivalent context)	Identify domain registrar, DNS provider & admin contacts	WHOIS queries spike for corporate domain	Attacker mapping domain control layer	Check registrar exposure, DNSSEC status	Review domain expiration status & registrar lock status	Domain without registrar lock or DNSSEC	Enable registrar lock immediately	Domains are identity backbone of digital banking presence.
Resource Development	Acquire Infrastructure (T1583.001 Domains) + Obtain Capabilities (T1588.001 Tooling)	Register lookalike domain for fallback	Newly registered lookalike domain	Phishing infrastructure staging	Passive DNS & brand monitoring alerts	Compare TLS certificate reuse patterns	Lookalike resolving to same hosting ASN	Block via brand protection service	Lookalike domains often accompany hijacking.
Initial Access	Valid Accounts (T1078) OR Spearphishing	Compromise registrar account	Registrar login from foreign ASN	Registrar credential compromise	Review login logs, MFA enforcement	Correlate with phishing or	Registrar login outside	Reset registrar credentials immediately	Registrar account compromise is

	ng (T1566.001)					credential reuse	expected geography		decisive pivot.
Execution	Modify Domain Registration (T1565.001 Stored Data Manipulation)	Change A/NS/MX records	DNS A record changed to unknown IP	Traffic redirection in progress	Compare DNS change vs change request ticket	Validate new IP reputation	DNS records modified without approval	Revert DNS immediately	DNS changes can redirect all banking traffic.
Persistence	Account Manipulation (T1098)	Add secondary registrar admin	New registrar admin email added	Attacker ensuring re-entry	Audit registrar account changes	Compare admin addition vs approval workflow	New admin added post-login anomaly	Remove rogue admin	Persistence at registrar level is high-risk.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group)	Gain full domain management rights	Privilege upgrade inside registrar portal	Control of DNS, transfer, and lock settings	Review registrar role assignments	Detect elevation beyond baseline privileges	Standard contact elevated to super-admin	Revoke elevated access	Full registrar control enables total domain takeover.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable DNSSEC or registrar lock	DNSSEC disabled in registrar settings	Attempt to avoid validation checks	DNSSEC status logs	Correlate disablement with DNS change timing	DNSSEC disabled before record change	Re-enable DNSSEC immediately	DNSSEC removal is deliberate evasion tactic.
Discovery	Account Discovery (T1087)	Identify linked subdomains & mail routing	Enumeration of subdomain records	Mapping attack surface	Passive DNS logs, subdomain inventory	Detect bulk DNS queries post-compromise	Subdomain enumeration after registrar login	Monitor for further DNS changes	Subdomain hijack may precede phishing campaign.

Collection	Data from Information Repositories (T1213)	Access email routed via modified MX	Surge in inbound email to new MX server	Email interception	MX record validation, mail server logs	Correlate MX change with phishing emails	MX record changed + credential phishing reports	Restore MX immediately	Email interception enables BEC & password reset abuse.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain control of redirected traffic	Users connecting to attacker-controlled IP	Phishing site active	Web logs, certificate fingerprint mismatch	Compare TLS certificate thumbprint vs baseline	TLS certificate mismatch for banking domain	Notify customers & block IP	Certificate anomaly is high-confidence hijack signal.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Capture user credentials via phishing clone	Spike in login attempts to new IP	Credential harvesting	Monitor authentication failures & password reset requests	Correlate phishing campaign timeline	Increased password resets after DNS change	Force password reset campaign	Domain hijack often leads to mass credential theft.
Impact	Credential Access (T1078) + Financial Theft (T1657)	Use harvested credentials for fraud	Surge in account takeover cases	Downstream fraud impact	Fraud monitoring, login anomaly detection	Correlate ATO spike with DNS change event	ATO cluster after domain redirect	Activate crisis & public communication plan	Domain hijack impacts brand trust and customer safety.

PLAYBOOK 32 — DNS Cache Poisoning

Attack Theme: Recursive Resolver Manipulation → Forged DNS Response Injection → Malicious IP Resolution → Traffic Redirection → Credential Theft / Malware Delivery

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Network Service Discovery (T1046) + Active Scanning (T1595.002)	Identify vulnerable recursive DNS resolvers	High volume DNS queries with random subdomains	Attacker probing resolver behavior	Source ASN, query entropy pattern	Analyse for DNS spoofing attempts (random TXID patterns)	Resolver responding to external recursion	Restrict recursive access	Open recursive resolvers are primary target.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare DNS spoofing tool	Threat intel indicates DNS spoof campaign	Infrastructure ready for poisoning	Check if internal resolvers patched	Validate DNS software version & entropy protections	Resolver using outdated DNS service	Patch immediately	Weak TXID and predictable ports increase risk.
Initial Access	Exploit Public-Facing Application (T1190) OR Adversary-in-the-Middle (T1557.002)	Inject forged DNS response	DNS response with unexpected IP	Possible cache poisoning	Validate TTL value, check authoritative response	Compare resolver cache vs authoritative DNS	Cached IP mismatch from authoritative server	Flush resolver cache	IP mismatch is primary detection signal.

Execution	Modify System Configuration (T1565.001 Stored Data Manipulation)	Poison DNS cache entry	Domain resolves to unfamiliar IP	Traffic redirection active	Validate IP ownership & ASN	Inspect DNS logs for spoofed response acceptance	Critical domain resolving externally	Block malicious IP immediately	DNS poisoning enables transparent redirection.
Persistence	Modify Authentication Process (T1556) (If affecting internal services)	Maintain poisoned entry via low TTL refresh	Repeated forged DNS responses	Sustained poisoning	Monitor repeated cache updates	Detect abnormal repeated resolution attempts	Re-poison attempt after cache flush	Isolate resolver temporarily	Persistence often achieved via repeated injection.
Privilege Escalation	Exploitation for Privilege Escalation (T1068) (If DNS server compromised)	Gain admin control of DNS server	DNS service restarted unexpectedly	DNS server compromise	Server admin logs	Trace configuration changes in DNS zone files	Admin-level change without ticket	Escalate to critical	DNS server control equals domain control.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable DNS logging	DNS logging disabled	Attempt to conceal poisoning	SIEM ingestion gaps	Compare DNS log volume before/after event	DNS logs stopped post-cache anomaly	Treat as confirmed compromise	Logging disablement indicates malicious control.
Discovery	Domain Trust Discovery (T1482 equivalent context)	Identify high-value domains to poison	Repeated queries to banking login domain	Target selection	DNS query frequency analysis	Detect unusual spike in resolution requests	Targeted resolution of sensitive domain	Increase monitoring	High-value domain resolution spike precedes poisoning.

Collection	Data from Information Repositories (T1213)	Capture credentials via redirected site	Surge in failed login attempts	Users hitting phishing clone	Authentication logs	Compare TLS certificate fingerprint vs baseline	Certificate mismatch detected	Trigger password reset campaign	TLS mismatch confirms traffic redirection.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain phishing site	Continuous inbound traffic to malicious IP	Active credential harvesting	Web proxy logs	Correlate DNS poisoning timestamp with phishing traffic	Domain resolving to rare ASN	Block malicious ASN	DNS poisoning often short-lived but high impact.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer stolen credentials externally	Outbound data spike from phishing host	Credential theft	DLP alerts, firewall logs	Trace data flow to attacker infrastructure	High-volume outbound from spoofed host	Notify compliance immediately	DNS poisoning can lead to mass credential breach.
Impact	Credential Access (T1078) + Financial Theft (T1657)	Account takeover via harvested credentials	Spike in account takeover alerts	Downstream fraud impact	Fraud monitoring correlation	Correlate ATO spike with DNS anomaly	Multiple ATOs after DNS event	Activate crisis response	DNS poisoning impacts confidentiality & brand trust.

PLAYBOOK 33 — Kerberoasting (Successful Crack)

Attack Theme: Domain Foothold → Request Service Tickets (TGS) → Offline Password Cracking → Service Account Compromise → Lateral Movement / Privilege Escalation / Domain Impact

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Account Discovery (T1087) + Permission Group Discovery (T1069.002)	Identify service accounts with SPNs	Get-ADUser -Filter {ServicePrincipalName -like "*"}	Attacker enumerating kerberoastable accounts	Source host, user context, PowerShell logging (4104)	Correlate enumeration with recent phishing/malware activity	SPN enumeration from non-admin workstation	Monitor source host closely	Kerberoasting begins with SPN discovery.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare Kerberoasting tooling (e.g., Rubeus-like)	Known tooling artefacts detected	Tool staging	File hash reputation, process lineage	Inspect for in-memory execution patterns	Tool execution attempt on endpoint	Isolate endpoint if confirmed	Tooling often run in-memory to evade AV.
Initial Access	Valid Accounts (T1078)	Use initial compromised domain user	User login followed by abnormal AD queries	Foothold established	Login source, device baseline	Correlate initial login with suspicious endpoint activity	New domain user login from unusual host	Increase monitoring	Kerberoasting requires only standard domain access.
Execution	Steal or Forge Kerberos	Request TGS tickets	Burst of Event ID 4769	Ticket harvesting in progress	Review 4769 volume,	Identify “many services, one client” pattern	>N service tickets requested	Contain source host	High-volume 4769 from

	Tickets (T1558.003 Kerberoasting)	for service accounts	requests for many SPNs		service names, client host		in short window		one host is key indicator.
Persistence	Create Account (T1136.002 Domain Account) + Account Manipulation (T1098.003 Add Account to Group)	Maintain access after cracking	New service account created or existing modified	Establish long-term foothold	AD logs (4720, 4738, 4728/4732)	Correlate account changes with kerberoast timeline	New privileged account created post-4769 burst	Remove rogue account immediately	Attackers often create persistence once service creds obtained.
Privilege Escalation	Valid Accounts (T1078) + Exploitation for Privilege Escalation (T1068)	Use cracked service account to escalate	Service account used to access admin shares	Cracked password now being used	Logon Type 3/10, Kerberos vs NTLM pattern	Check if service account suddenly doing interactive logons	Service account interactive logon (unusual)	Disable service account temporarily	Service accounts should rarely log in interactively.
Defense Evasion	Indicator Removal (T1070.001 Clear Logs) + Impair Defenses (T1562.001 Disable Security Tools)	Hide Kerberoast activity	Security logs cleared or EDR disabled	Covering tracks	Event log integrity, EDR health	Correlate log gaps after 4769 spike	Log clearing after suspicious ticket requests	Treat as confirmed compromise	Log clearing confirms malicious intent.

Discovery	Network Service Discovery (T1046) + Remote System Discovery (T1018)	Identify systems where service account has access	SMB/RPC enumeration across servers	Preparing lateral movement	Firewall logs, SMB connection logs	Detect server enumeration after cracked credential use	Enumeration immediately after service account login	Monitor targeted servers	Cracked service creds enable broad access.
Lateral Movement	Remote Services (T1021.002 SMB) + Pass-the-Hash (T1550.002 if NTLM fallback)	Pivot using service account credentials	ADMIN\$ write attempts using service account	Spreading foothold	4624/4625, share write logs	Detect abnormal admin share access by service account	Service account accessing multiple hosts quickly	Disable credentials + isolate hosts	Rapid host-to-host access indicates active lateral movement.
Collection	Data from Information Repositories (T1213) + Data from Network Shared Drive (T1039)	Access sensitive data using elevated service access	File share access spike from service account	Data harvesting	File audit logs	Compare accessed directories vs service purpose	Service account reading HR/Finance shares	Monitor outbound traffic	Service access drift signals misuse.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Maintain remote operator control	Compromised host beaconing after service account use	Active operator presence	Proxy logs, JA3 TLS fingerprint	Correlate beacon start with cracked credential usage	Beaconing begins after service account login	Block C2 after scoping	Kerberoast often part of larger intrusion chain.

Exfiltration	Exfiltration Over Web Services (T1567.002)	Exfiltrate sensitive data or hashes	Outbound upload after file access spike	Data theft	DLP alerts, firewall logs	Correlate share access with outbound spike	Data staging + outbound transfer	Notify compliance immediately	Regulatory exposure may apply depending on data accessed.
Impact	Valid Accounts (T1078) OR Data Encrypted for Impact (T1486)	Domain-wide compromise or ransomware staging	Service account used to deploy tools widely	Enterprise compromise underway	DC logs, GPO change monitoring	Detect abnormal GPO deployment, shadow copy deletion (T1490)	Multiple systems impacted post-service compromise	Activate enterprise IR immediately	Successful crack turns kerberoast into full compromise vector.

PLAYBOOK 34 — NTLM Relay Attack

Attack Theme: Forced Authentication → NTLM Challenge-Response Capture → Relay to Target Service → Privileged Access Without Cracking Password → Lateral Movement / AD Abuse

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Network Service Discovery (T1046) + Account Discovery (T1087)	Identify hosts accepting NTLM authentication without signing	SMB connections to multiple hosts checking signing settings	Attacker mapping relayable services	SMB signing configuration, LDAP signing status	Review Group Policy for SMB/LDAP signing enforcement	SMB signing disabled on critical servers	Enforce signing immediately	NTLM relay relies on lack of signing enforcement.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare NTLM relay tooling	Known relay tool artefacts detected on host	Tool staging	Process lineage, file hash reputation	Detect in-memory execution of relay tooling	Tool executed on workstation/server	Isolate source host	Relay tooling often used after initial foothold.
Initial Access	Valid Accounts (T1078)	Establish initial foothold	Compromised workstation performing abnormal SMB queries	Attacker preparing forced authentication	Login context, device baseline	Correlate with phishing or malware infection	New workstation initiating unusual SMB traffic	Increase monitoring	NTLM relay requires internal presence.
Execution	Adversary-in-the-Middle (T1557.001)	Capture NTLM challenge-response	LLMNR/NBT-NS response anomalies	Forced authentication in progress	Network logs for spoofed	Detect abnormal responder behavior	Multiple LLMNR responses from single host	Isolate malicious responder	LLMNR poisoning is common

	LLMNR/NBT-NS Poisoning) + Use Alternate Authentication Material (T1550.002 Pass-the-Hash Equivalent Context)	and relay to target			name resolution				relay enabler.
Persistence	Account Manipulation (T1098.003 Add Account to Group)	Add relayed account to privileged group	User added to local Administrators group	Relay used for privilege gain	Event ID 4732/4728 logs	Correlate group addition with NTLM relay timestamp	Standard user added to admin group	Remove from group immediately	Relay often used to escalate privileges silently.
Privilege Escalation	Exploitation for Privilege Escalation (T1068) + Valid Accounts (T1078)	Relay privileged account to gain admin access	Domain Admin account authenticated unexpectedly	Privileged authentication relayed	4624 logon type analysis (Type 3)	Detect authentication to unusual host	Domain Admin authenticated to non-admin workstation	Disable relayed account temporarily	Privileged account relay is critical severity.
Defense Evasion	Indicator Removal (T1070.001 Clear Logs) + Impair Defenses (T1562.001 Disable	Hide relay traces	Security logs cleared after relay event	Covering tracks	Compare log continuity	Detect log gaps after suspicious authentication	Log clearing post-admin group change	Treat as confirmed compromise	Log manipulation indicates adversary control.

	Security Tools)								
Discovery	Remote System Discovery (T1018) + Permission Group Discovery (T1069.002)	Identify high-value relay targets (DC, file server)	Enumeration of domain controllers	Preparing next pivot	SMB and LDAP query logs	Detect enumeration immediately after group escalation	DC enumeration by non-admin user	Increase DC monitoring	Relay often stepping stone to domain compromise.
Lateral Movement	Remote Services (T1021.002 SMB)	Use relayed session to access remote host	ADMIN\$ access from compromised host	Lateral pivot	4624/5140 share access logs	Detect unusual admin share usage	Multiple hosts accessed rapidly	Disable compromised account	Speed of containment limits spread.
Collection	Data from Network Shared Drive (T1039)	Access sensitive shares via relayed access	Share access spike from unexpected host	Data harvesting	File access logs	Correlate sensitive directory access with relay activity	Sensitive file read by unexpected user	Monitor outbound traffic	Relay may lead to data theft or ransomware staging.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Maintain control over compromised host	Beaconing after relay event	Active attacker presence	Proxy logs, JA3 fingerprint	Correlate beacon start with relay timestamp	Beacon begins post-authentication anomaly	Block C2 after scoping	Relay often part of larger intrusion campaign.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer collected data externally	Outbound upload after share access	Data exfiltration	DLP alerts, firewall logs	Correlate share access spike with outbound transfer	Sensitive data staged + outbound traffic	Notify compliance immediately	NTLM relay can enable stealth data theft.

Impact	Valid Accounts (T1078) + Account Manipulation (T1098)	Enterprise privilege compromise	Domain-wide privilege escalation	Major AD security breach	DC logs, GPO change review	Detect abnormal GPO deployment or KRBTGT access	Domain Admin privileges obtained	Activate enterprise IR immediately	NTLM relay can lead directly to domain takeover if unchecked.
--------	---	---------------------------------	----------------------------------	--------------------------	----------------------------	---	----------------------------------	------------------------------------	---

BYZANTIUM

PLAYBOOK 35 — Azure AD / Entra ID Role Abuse

Attack Theme: Compromised Cloud Identity → Privileged Role Assignment Abuse → Global Admin / Privileged Role Escalation → Tenant-Wide Control → Data Exfiltration / Persistence

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Cloud Infrastructure Discovery (T1580) + Account Discovery (T1087)	Identify privileged roles & PIM configuration	Multiple GET roleAssignments API calls	Attacker mapping tenant privileges	Source IP ASN, token scope	Analyse audit logs for enumeration of directory roles	Role enumeration from newly authenticated session	Increase monitoring on identity	Enumeration of roles precedes privilege abuse.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare automation via Graph API / PowerShell	High-frequency Graph API calls	Scripted privilege manipulation	User-agent fingerprint, API rate anomalies	Detect scripted MS Graph calls from single session	Burst of Graph calls targeting role endpoints	Apply conditional access review	Automation accelerates privilege takeover.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts)	Use compromised user or admin account	Successful Entra ID login from foreign ASN	Account compromise	Login context, device compliance, MFA method used	Correlate login with impossible travel & token issuance logs	Privileged login from non-compliant device	Revoke sessions immediately	Cloud identity compromise is entry point.

Execution	Account Manipulation (T1098.003 Add Account to Group / Role Assignment)	Assign Global Admin or Privileged Role Admin	New role assignment to user	Privilege escalation in progress	Audit logs for Add member to role	Compare assignment vs PIM approval workflow	Global Admin role granted outside PIM	Remove role immediately	Role assignment is decisive privilege pivot.
Persistence	Create Account (T1136.003 Cloud Account) + Account Manipulation (T1098)	Create hidden cloud admin account	New cloud-only account with admin role	Long-term backdoor	Directory audit logs	Detect new account created shortly after role escalation	Admin account created outside change window	Delete rogue account	Cloud persistence often via secondary admin account.
Privilege Escalation	Account Manipulation (T1098.003) + Exploitation for Privilege Escalation (T1068 context cloud misconfig)	Elevate to Global Admin via misconfigured PIM	PIM activation without approval	Control bypass	PIM activation logs	Compare activation justification & approval chain	PIM activated outside defined approval policy	Disable PIM session	PIM misuse is major tenant risk.
Defense Evasion	Impair Defenses (T1562.001 Disable	Disable audit logging or	Conditional Access policy modified	Attempt to avoid detection	Policy modification logs	Correlate CA changes with role	Logging/CA policy disabled	Restore policy immediately	Conditional Access tampering confirms

	Security Tools)	conditional access				escalation timing	post-escalation		malicious intent.
Discovery	Permission Group Discovery (T1069.003 Cloud Groups)	Identify high-value resources (SharePoint, Exchange, Azure Subscriptions)	Enumeration of subscriptions & app registrations	Mapping data assets	Azure activity logs	Detect enumeration of Key Vault, Storage, and Exchange roles	Subscription listing after privilege gain	Increase resource monitoring	Discovery signals preparation for impact.
Collection	Data from Cloud Storage (T1530) + Data from Information Repositories (T1213)	Access mailbox, SharePoint, OneDrive data	Mass mailbox export initiated	Data harvesting	Audit logs for eDiscovery/export activity	Correlate export with admin role assignment	eDiscovery initiated by newly elevated account	Enable DLP & isolate account	Mailbox export is high-confidence exfil indicator.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain persistent API control via token	Continuous Graph API calls	Active attacker in tenant	Token lifetime, session activity	Detect token refresh without user interaction	Long-lived token active across regions	Revoke all tokens	Cloud C2 blends into normal API traffic.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Download data to external storage	Large outbound download via Graph API	Data exfiltration	Monitor unusual large downloads	Correlate export job with outbound IP ASN	Bulk data export after role escalation	Notify compliance immediately	Tenant-wide exfil may trigger regulatory reporting.
Impact	Valid Accounts (T1078) + Data Manipulation	Tenant takeover, data deletion,	Mass deletion of accounts or mailbox purge	Major business disruption	Audit logs for bulk deletion operations	Detect purge of logs or retention	Retention policy modified post-escalation	Activate enterprise cloud IR	Cloud role abuse can equal full tenant

	n (T1565.001 Stored Data Manipulation)	ransomware in cloud				policy change			compromis e.
--	---	------------------------	--	--	--	------------------	--	--	-----------------

BYZANTINE

PLAYBOOK 36 — OAuth Application Backdoor

Attack Theme: Malicious OAuth App Registration → Excessive API Permissions Granted → User/Admin Consent Abuse → Persistent Token-Based Access → Stealth Data Exfiltration

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Cloud Infrastructure Discovery (T1580) + Account Discovery (T1087)	Identify consent policies & app registration rights	Enumeration of existing enterprise applications	Attacker mapping OAuth landscape	Review audit logs for app listing activity	Detect unusual Graph API queries to /applications endpoint	Enumeration from non-admin user	Increase monitoring	OAuth backdoors start with app discovery.
Resource Development	Obtain Capabilities (T1588.001 Tooling) + Develop Capabilities (Custom OAuth App)	Prepare malicious OAuth application	New app registration created	Possible staging of backdoor	Check app owner, redirect URI, permissions requested	Compare app creation vs change management approval	App created outside approved workflow	Flag for review	App registration is core pivot for persistence.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts)	Use compromised user/admin	Successful login followed by Add application event	Compromised identity in use	Login ASN, device compliance, MFA context	Correlate app creation with login anomaly	App created after impossible travel login	Revoke session immediately	Identity compromise precedes app abuse.

		to register OAuth app							
Execution	Account Manipulation (T1098) + OAuth Token Abuse (T1550.001 Use of Web Tokens Equivalent Context)	Grant high-privilege API permissions	App granted Mail.Read, Files.Read.All, or Directory.ReadWrite.All	Excessive permission assignment	Review granted API scopes	Compare scope to business justification	Global consent granted by non-standard approver	Remove consent immediately	Excessive scopes are primary red flag.
Persistence	Create Account (T1136.003 Cloud Account context) + Account Manipulation (T1098)	Use refresh tokens for long-term access	OAuth refresh token active beyond user session	Persistent API-based backdoor	Token issuance logs, sign-in logs	Detect long-lived refresh tokens not tied to device	Refresh token used across regions	Revoke refresh tokens tenant-wide	OAuth persistence bypasses password resets.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Assign app elevated directory roles	App service principal granted Global Admin role	Tenant-wide control	Directory role assignment logs	Correlate role grant with app registration event	App assigned privileged directory role	Remove role immediately	App-based Global Admin is critical severity.
Defense Evasion	Impair Defenses (T1562.001 Disable	Modify audit logging or CA policy via app	Conditional Access policy updated via API	Attempt to avoid detection	Audit logs for policy changes	Correlate policy modification with	CA modified shortly after app consent	Restore policy immediately	App-level changes may bypass standard

	Security Tools)	permissions				service principal ID			user alerts.
Discovery	Permission Group Discovery (T1069.003 Cloud Groups)	Enumerate SharePoint, Exchange, Teams resources	Graph API calls listing mailboxes or drives	Mapping data assets	API audit logs	Detect systematic enumeration from service principal	High-volume /users and /drives queries	Monitor closely	Enumeration via service principal is suspicious.
Collection	Data from Cloud Storage (T1530) + Data from Information Repositories (T1213)	Extract mailbox, OneDrive, SharePoint data	Bulk export via Graph API	Data harvesting	Monitor export jobs, download volume	Correlate export volume with new OAuth app	High-volume API data extraction	Enable DLP & isolate app	API-based collection is stealthy and scalable.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain access via token refresh	Repeated API calls from cloud IP range	Active operator control	Token lifetime analysis, IP ASN reputation	Detect token refresh pattern independent of user login	Service principal active 24/7	Revoke tokens and disable app	OAuth C2 blends into legitimate API traffic.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer data to attacker-controlled cloud storage	Large download/upload pattern via API	Data exfiltration	Proxy logs, CASB alerts	Correlate API data extraction with external upload	Data extraction followed by cloud upload	Notify compliance immediately	Tenant-wide data exfil possible silently.
Impact	Valid Accounts (T1078) + Data Manipulation	Tenant persistence & mass data theft	OAuth app remains active despite password resets	Long-term compromise	Review enterprise app inventory	Identify dormant but highly privileged apps	App active months after compromise	Activate cloud IR & tenant-wide review	OAuth backdoors bypass traditional

	n (T1565.001)									credential controls.
--	------------------	--	--	--	--	--	--	--	--	-------------------------

BYZANTINE

PLAYBOOK 37 — SaaS Data Export Abuse

Attack Theme: Compromised SaaS Account → Abuse of Legitimate Data Export Function → Bulk Extraction of Sensitive Records → External Download → Regulatory & Confidentiality Impact

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Cloud Infrastructure Discovery (T1580) + Account Discovery (T1087)	Identify SaaS export capabilities & permission levels	Enumeration of reporting/export endpoints	Attacker mapping SaaS features	Source ASN, login context	Analyse audit logs for feature discovery activity	Export feature accessed by unusual user	Increase monitoring on account	Export abuse begins with feature exploration.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare automation to trigger export jobs	Repeated API calls to /export endpoint	Scripted export testing	API request rate, user-agent anomalies	Detect fixed-interval export calls	Burst of export job creation	Apply conditional access review	Automation enables large-scale extraction quickly.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts)	Use compromised SaaS credentials	Successful SaaS login from foreign ASN	Account compromise	Device fingerprint, MFA method used	Correlate login anomaly with data access spike	Login outside baseline geo	Revoke session immediately	SaaS breaches start with identity compromise.
Execution	Data from Information	Initiate bulk export of records	Large CSV/ZIP export job created	Data harvesting in progress	Review export size & data type	Compare export volume vs	Export size exceeds normal	Suspend export job	Export size anomaly is decisive

	Repositories (T1213)					historical baseline	operational range		early signal.
Persistence	Account Manipulation (T1098)	Add secondary email/API token for SaaS	New API token created	Backdoor access to SaaS	Audit logs for token generation	Correlate token creation with export activity	API token created post-login anomaly	Revoke token immediately	API tokens allow stealthy repeated exports.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Elevate to admin/reporting role	User granted reporting admin role	Expanding export capability	Role assignment audit logs	Detect privilege change outside approval workflow	Non-admin granted data export rights	Remove elevated role	Role escalation precedes mass export.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable audit alerts or DLP integration	SaaS alert notification settings modified	Attempt to avoid detection	Alert configuration logs	Correlate alert suppression with export job	Alerts disabled before export spike	Restore alerts immediately	Alert tampering confirms malicious intent.
Discovery	Permission Group Discovery (T1069.003 Cloud Groups)	Identify sensitive datasets (HR, Finance, CRM)	Navigation across multiple data modules	Target selection	Access logs per module	Detect unusual cross-department data browsing	Broad module access before export	Increase monitoring	Discovery phase signals intent to exfiltrate.
Collection	Data from Cloud Storage (T1530)	Export entire customer or employee dataset	Multi-GB export file generated	Mass data collection	Monitor file generation timestamps	Correlate export job with user session activity	High-value dataset exported	Enable DLP & account isolation	Legitimate export feature abused maliciously.

Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain session to download export	Persistent SaaS session active	Active attacker control	Session duration, ASN reputation	Detect session active beyond user working hours	Continuous activity overnight	Terminate session	Long-lived SaaS sessions are suspicious.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Download exported data externally	Large file download from SaaS	Data exfiltration	CASB alerts, proxy logs	Correlate export job with download IP ASN	Download from foreign cloud provider	Notify compliance immediately	SaaS exfil often fully encrypted & legitimate-looking.
Impact	Data Manipulation (T1565.001) + Exfiltration (T1041)	Confidential data exposure	Sensitive dataset found on dark web	Regulatory & reputational damage	Data classification review	Assess impact scope (PDPA, GDPR, RMIT)	Confirmed sensitive data leak	Activate incident & regulator notification	SaaS export abuse bypasses perimeter security controls.

PLAYBOOK 38 — Insider Trading via Data Leak

Attack Theme: Privileged Insider Access → Access to Material Non-Public Information (MNPI) → Covert Data Leak → External Trading Advantage → Regulatory & Criminal Exposure

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Account Discovery (T1087) + Permission Group Discovery (T1069.002)	Identify who has access to financial results / merger data	User browsing restricted “Board / M&A” folders	Mapping sensitive data access	User role legitimacy, business justification	Compare access pattern vs peer group baseline	Non-finance staff accessing MNPI folder	Increase monitoring immediately	Insider cases often begin with quiet reconnaissance.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare encrypted storage or covert channel	Installation of encryption/compression tool	Preparing for covert exfiltration	Endpoint software inventory	Detect newly installed archiving tools (7zip, rar variants)	Encryption tool installed before data access spike	Flag for review	Tool staging often precedes leak attempt.
Initial Access	Valid Accounts (T1078)	Use legitimate insider credentials	Normal login from corporate network	No external compromise – insider misuse	Verify device, login time, peer baseline	Correlate login timing with sensitive project	Access shortly before earnings release	Alert management discreetly	Insider misuse blends into legitimate access.

						milestones			
Execution	Data from Information Repositories (T1213)	Access confidential earnings / acquisition documents	Large file open/read activity in secure share	MNPI access in progress	File access logs, document sensitivity label	Compare document type vs job function	Access to board-level documents by non-board user	Restrict access temporarily	Access drift is primary detection signal.
Persistence	Account Manipulation (T1098)	Add secondary personal email to SaaS	Recovery email modified	Ensuring future access	Account settings audit logs	Correlate email change with sensitive data access	Account recovery updated before resignation notice	Restore original configuration	Insider may prepare for post-employment access.
Privilege Escalation	Account Manipulation (T1098.003 Add to Group)	Request temporary access to restricted project folder	Temporary access approved	Expanding data scope	Approval chain validation	Detect unusual access approval patterns	Short-term access granted outside standard workflow	Revoke elevated access	Short-lived access windows can enable large leak.
Defense Evasion	Indicator Removal (T1070.004 File Deletion)	Delete local copies after transfer	Sensitive file deleted shortly after access	Attempt to conceal activity	File deletion logs, shadow copy review	Detect deletion after archive creation	Archive created then source deleted	Preserve forensic image	Deletion post-access signals concealment attempt.
Discovery	File and Directory Discovery (T1083)	Browse multiple confidential directories	Access to multiple high-value shares	Mapping material information	File server logs	Detect lateral browsing across unrelated projects	Broad browsing outside business role	Increase user monitoring	Insider activity often broad before selective leak.

Collection	Archive Collected Data (T1560.001)	Compress sensitive documents	Large encrypted ZIP file created	Data staging	File creation logs, high entropy detection	Correlate archive creation with MNPI file access	Archive stored in temp directory	Isolate endpoint	Staging often detectable via entropy analysis.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain covert communication with external party	Frequent encrypted messaging app traffic	Potential coordination	Network logs, unusual outbound patterns	Detect encrypted messaging outside baseline usage	Spike in encrypted messaging before earnings release	Monitor communications	Timing correlation critical in insider cases.
Exfiltration	Exfiltration Over Web Services (T1567.002) OR Exfiltration to Cloud Storage (T1567.002)	Upload MNPI to personal cloud account	Large outbound upload to personal storage	Data leak in progress	Proxy logs, CASB alerts	Correlate archive creation with outbound upload	Upload to personal cloud within minutes of archive	Notify legal & compliance immediately	Insider trading exposure has severe regulatory impact.
Impact	Data Manipulation (T1565.001) + Financial Gain (T1657 contextual)	External trading based on leaked MNPI	Market movement before official announcement	Regulatory & criminal risk	Legal, compliance & audit coordination	Correlate data access timestamp with suspicious trading activity	Evidence of trading by related party	Activate executive crisis response	Insider leak risk extends beyond cybersecurity into legal domain.

BYZEMER

PLAYBOOK 39 — Ransomware Targeting Backups

Attack Theme: Initial Domain Compromise → Backup Infrastructure Discovery → Backup Deletion / Encryption → Shadow Copy Removal → Ransomware Deployment → Recovery Prevention

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Account Discovery (T1087) + Remote System Discovery (T1018)	Identify backup servers & storage repositories	Enumeration of servers named “BACKUP”, “VEEAM”, “DR”	Attacker mapping recovery infrastructure	Source host, user context, LDAP query logs	Correlate enumeration with earlier privilege escalation	Backup server queried by non-backup admin	Increase monitoring on backup assets	Backup discovery signals preparation for impact phase.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare ransomware payload & backup deletion scripts	Known ransomware tooling artefact detected	Staging destructive capability	File hash reputation, EDR telemetry	Detect script containing vssadmin, wbadmin, bcdedit commands	Script execution attempt on privileged host	Isolate source endpoint	Backup deletion tooling precedes encryption phase.
Initial Access	Valid Accounts (T1078) OR Exploitation for Privilege Escalation (T1068)	Use domain admin or backup admin credentials	Privileged login to backup server	Compromised administrative access	Login ASN, device fingerprint mismatch	Correlate login with suspicious lateral movement	Backup admin login from non-admin workstation	Disable compromised credentials	Backup admin accounts are Tier-0 assets.

Execution	Inhibit System Recovery (T1490)	Delete backups and shadow copies	vssadmin delete shadows executed	Recovery prevention in progress	Command-line logging (4688), EDR alerts	Detect execution of backup deletion commands	Backup repository deletion attempt	Immediately disconnect backup server	Shadow copy deletion is decisive ransomware precursor.
Persistence	Create or Modify System Process (T1543)	Install ransomware service across domain	New scheduled task or service deployed via GPO	Domain-wide ransomware staging	GPO change logs, task scheduler logs	Detect abnormal GPO update deploying executable	GPO linked to multiple OUs unexpectedly	Disable malicious GPO	GPO abuse enables mass deployment rapidly.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group)	Grant backup access to attacker-controlled account	User added to Backup Operators group	Expanding destructive capability	AD logs (4728/4732)	Correlate group addition with deletion commands	Non-IT user added to Backup Operators	Remove from group immediately	Backup group membership change is critical signal.
Defense Evasion	Indicator Removal (T1070.001 Clear Logs) + Impair Defenses (T1562.001 Disable Security Tools)	Disable backup alerts & logging	Backup job failure alerts disabled	Attempt to hide sabotage	Backup system audit logs	Detect alert suppression before deletion event	Backup alert configuration modified	Restore monitoring & escalate	Alert tampering confirms deliberate sabotage.
Discovery	File and Directory Discovery (T1083)	Identify backup repository paths	Access to backup storage directory	Mapping storage location	File access logs on backup server	Detect browsing of backup volumes	Non-backup user	Increase monitoring	Discovery of repository signals

							browsing repository		imminent deletion.
Collection	Data from Information Repositories (T1213) (Optional double extortion)	Access backup archives for data theft	Backup files copied before deletion	Preparing double extortion	Network transfer logs	Correlate large backup file read with outbound traffic	Archive read + external connection	Enable DLP & isolate system	Backups often contain full enterprise data.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Coordinate ransomware execution	Beaconing from backup server	Active operator control	Proxy logs, JA3 fingerprint	Correlate beacon start with deletion commands	C2 active on backup server	Block C2 after scoping	Backup server outbound traffic is high-risk anomaly.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer stolen backup data externally	Multi-GB outbound transfer from backup VLAN	Data exfiltration	Firewall logs, DLP alerts	Correlate transfer with archive access	Backup archive accessed + outbound spike	Notify compliance immediately	Backup exfil multiplies regulatory impact.
Impact	Data Encrypted for Impact (T1486) + Inhibit System Recovery (T1490)	Ransomware encrypts production & backups	All systems encrypted, no recoverable backups	Major business disruption	DR status, offline backup validation	Assess integrity of immutable/offline backups	Backup repository fully deleted or encrypted	Activate enterprise crisis response	Ransomware targeting backups aims to remove negotiation leverage.

PLAYBOOK 40 — Firmware Backdoor Implant

Attack Theme: Hardware / Firmware-Level Compromise → Implant in BIOS/UEFI/Network Device Firmware → Stealth Persistence Below OS → Long-Term Covert Access → Detection Evasion

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Org Information (T1591) + Network Service Discovery (T1046)	Identify high-value hardware targets (DCs, firewalls, HSMs)	Enumeration of management interfaces (iLO, iDRAC, SSH)	Attacker mapping firmware attack surface	Source ASN, management VLAN exposure	Review exposure of out-of-band management interfaces	Management interface accessible from user VLAN	Restrict management network access	Firmware attacks target Tier-0 infrastructure.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare malicious firmware image	Threat intel referencing firmware implant campaign	Staging supply chain-style implant	Verify firmware image hashes & vendor signature	Compare image hash vs vendor baseline	Firmware image not signed or checksum mismatch	Block update immediately	Unsigned firmware is high-risk indicator.
Initial Access	Valid Accounts (T1078) OR Exploit Public-Facing Application (T1190)	Gain admin access to firmware interface	Successful login to BMC/iLO from foreign ASN	Compromised management credentials	Review login history, MFA enforcement	Correlate login with prior phishing or lateral movement	Admin login outside maintenance window	Disable account immediately	Management plane compromise is critical severity.

Execution	Modify Firmware (T1542.001 BIOS/UEFI Firmware Modification)	Flash malicious firmware	Firmware update event outside change window	Implant deployment	Firmware update logs	Validate firmware signature, compare firmware version	Firmware updated without approved change	Isolate affected device	Unauthorized firmware change is decisive signal.
Persistence	Boot or Logon Autostart Execution (T1547.001) + Firmware-Level Persistence (T1542.001)	Maintain access below OS layer	Malware reappears after OS reinstall	OS-level remediation ineffective	Validate firmware integrity via trusted vendor tool	Perform firmware dump & integrity comparison	Persistence survives disk reimage	Reflash firmware from trusted image	Firmware persistence bypasses traditional EDR.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	Gain SYSTEM/kernel-level access post-boot	Kernel driver loaded unexpectedly	Firmware implant enabling kernel injection	Review driver signing status	Analyse unsigned driver loading sequence	Unsigned driver loaded during boot	Escalate to critical	Firmware implants often drop kernel drivers.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable EDR from below OS	EDR service fails repeatedly on reboot	Sub-OS tampering	EDR health logs, boot logs	Detect EDR failure after firmware update	EDR disabled after reboot cycle	Treat as confirmed compromise	Firmware implants evade OS-level monitoring.
Discovery	Remote System Discovery (T1018) +	Map network after implant activation	Host scanning behaviour	Implant activating C2	Network IDS logs	Correlate scan behaviour with	Trusted server scanning	Isolate system immediately	Trusted server scanning indicates

	File and Directory Discovery (T1083)		from trusted server			firmware event	internal network		deep compromise.
Collection	Data from Information Repositories (T1213)	Access sensitive system data post-implant	Sensitive file access from core server	Data harvesting	File access audit logs	Correlate access with firmware update timestamp	Access to security configs post-update	Monitor outbound traffic	Firmware implant may enable stealth collection.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Maintain covert communication	Outbound traffic from firmware/BMC interface	Hidden C2 channel	Firewall logs from management VLAN	Detect management interface initiating outbound sessions	BMC communicating externally	Block outbound immediately	Management interfaces should not initiate internet traffic.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer collected data externally	Data transfer from management interface	Data exfiltration	Network monitoring, DLP	Correlate exfiltration with firmware anomaly	Large transfer from management subnet	Notify compliance immediately	Firmware exfiltration bypasses endpoint monitoring.
Impact	Data Manipulation (T1565.001) + Resource Hijacking (T1496 contextual)	Long-term stealth control of infrastructure	Recurrent unexplained anomalies	Strategic infrastructure compromise	Enterprise-wide integrity validation	Validate firmware integrity across fleet	Multiple devices show firmware mismatch	Activate enterprise crisis response	Firmware compromise is Tier-0, long-term persistence threat.

PLAYBOOK 41 — Hypervisor Compromise

Attack Theme: Virtualization Host Exploitation → Hypervisor-Level Access → VM Snapshot Manipulation → Cross-VM Control → Stealth Infrastructure Takeover

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Network Service Discovery (T1046) + Gather Victim Org Information (T1591)	Identify hypervisor management interfaces (vCenter, ESXi, Hyper-V)	Repeated access attempts to management console	Attacker mapping virtualization layer	Source ASN, admin interface exposure	Review firewall rules for management VLAN	Management interface accessible beyond admin network	Restrict immediately	Hypervisor layer is Tier-0 infrastructure.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare exploit or credential theft tool	Known exploit targeting hypervisor version	Vulnerability targeting	Validate hypervisor patch level	Compare running version with CVE advisories	Unpatched hypervisor exposed	Patch or isolate host	Hypervisor vulnerabilities are high impact.
Initial Access	Valid Accounts (T1078) OR Exploit Public-Facing Application (T1190)	Gain admin access to hypervisor	Successful vCenter login from foreign ASN	Credential compromise or exploit success	Review login logs, MFA enforcement	Correlate login with previous phishing or lateral movement	Admin login outside change window	Disable compromised credentials	Hypervisor admin compromise equals infrastructure risk.

Execution	Exploitation for Privilege Escalation (T1068) OR Modify System Configuration (T1565.001)	Execute malicious commands on hypervisor	New administrative shell opened on ESXi	Hypervisor -level control achieved	Hypervisor shell logs, API activity	Detect command execution via esxcli or PowerCLI	Direct host command execution outside maintenance	Isolate host from network	Direct shell on hypervisor is decisive signal.
Persistence	Boot or Logon Autostart Execution (T1547)	Deploy malicious VM or startup script	New hidden VM created	Covert persistence within virtualization layer	VM inventory comparison	Detect VM created without ticket or naming convention	VM created outside provisioning workflow	Suspend malicious VM	Hypervisor persistence may be hidden as legitimate VM.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group)	Add attacker account to virtualization admin role	New admin role assignment in vCenter	Expanding control	Role assignment audit logs	Compare assignment vs change request	Non-infrastructure user granted hypervisor admin	Remove elevated role immediately	Role escalation is pivot for full infrastructure control.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable logging or tamper with snapshots	Logging disabled in vCenter	Attempt to conceal activity	SIEM ingestion gaps, hypervisor audit settings	Correlate logging disablement with suspicious VM activity	Audit logs stopped post-admin login	Restore logging immediately	Hypervisor log tampering is critical indicator.
Discovery	Remote System Discovery (T1018)	Enumerate VMs and internal network topology	Listing all VMs and datastore mappings	Mapping high-value targets	API logs for inventory listing	Detect enumeration of DCs, backup VMs, DB servers	Full VM inventory exported	Increase monitoring	Enumeration precedes ransomware or data theft.

Collection	Data from Virtual Machine Snapshot (T1538 contextual)	Access VM snapshots to extract data	Snapshot created outside backup schedule	Preparing offline data theft	Snapshot activity logs	Correlate snapshot creation with admin anomaly	Snapshot of sensitive VM outside window	Delete unauthorized snapshot	Snapshots can bypass guest-level monitoring.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain control via management API	Continuous API calls from foreign ASN	Active attacker control	API session logs, token lifetime	Detect persistent PowerCLI sessions	Long-lived session on hypervisor	Revoke tokens and isolate host	Hypervisor C2 may blend with admin activity.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Export VM images or snapshot files	Large datastore file transfer	Data exfiltration	Network monitoring, DLP	Correlate snapshot export with outbound spike	Multi-GB transfer from hypervisor VLAN	Notify compliance immediately	VM image theft exposes entire server contents.
Impact	Data Encrypted for Impact (T1486) + Inhibit System Recovery (T1490)	Encrypt or delete multiple VMs	Multiple VMs powered off or deleted	Enterprise-wide outage	VM state monitoring, DR validation	Detect abnormal VM shutdown across cluster	Multiple VMs affected simultaneously	Activate enterprise crisis response	Hypervisor compromise enables cross-VM ransomware in minutes.

PLAYBOOK 42 — Kubernetes Cluster Takeover

Attack Theme: Compromised Service Account / Exposed API → Privilege Escalation to Cluster-Admin → Control Plane Manipulation → Secret Access → Multi-Node Impact

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Cloud Infrastructure Discovery (T1580) + Container and Cluster Discovery (T1613)	Identify accessible Kubernetes API & RBAC permissions	Multiple kubectl get namespaces from new source	Attacker mapping cluster	Source ASN, auth method (token/cert)	Analyse API server audit logs for enumeration	Enumeration from service account not normally interactive	Increase monitoring	Early namespace enumeration signals probing.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare kubectl automation or exploit tool	Known Kubernetes exploitation tool artefact	Tool staging	Process lineage on admin workstation	Detect CLI-based cluster manipulation from non-admin host	CLI activity outside DevOps workstation baseline	Isolate host if malicious	Automation enables rapid cluster-wide changes.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) OR Exploit Public-	Access cluster via exposed API or stolen token	Successful API authentication from foreign ASN	Compromised kubeconfig or service token	Review token issuance & expiry	Correlate token with Git leak or pod compromise	Token used from new geographic region	Rotate service account tokens immediately	Service account tokens often exposed in CI/CD logs.

	Facing Application (T1190)								
Execution	Deploy Container (T1610) + Modify Cloud Compute Infrastructure (T1578.002 Create/Modify Cloud Instance)	Deploy malicious privileged pod	Pod created with privileged: true	Attempt to gain node-level control	Pod spec review, RBAC validation	Inspect container image, check for hostPath mounts	Privileged pod with host filesystem mount	Delete pod immediately	Privileged pods are major takeover signal.
Persistence	Create or Modify System Process (T1543) + Kubernetes CronJob Abuse (T1053.003)	Establish persistent backdoor pod	New DaemonSet deployed across nodes	Cluster-wide persistence	Audit logs for create daemonset	Compare deployment against change tickets	DaemonSet created outside maintenance window	Remove malicious DaemonSet	DaemonSet ensures presence on all nodes.
Privilege Escalation	Account Manipulation (T1098.003 Role Binding Abuse)	Bind service account to cluster-admin role	New ClusterRoleBinding granting cluster-admin	Full cluster takeover	RBAC audit logs	Correlate binding creation with token misuse	Non-admin account bound to cluster-admin	Revoke binding immediately	RBAC abuse is decisive escalation pivot.
Defense Evasion	Impair Defenses (T1562.001)	Disable admission	Audit logging disabled in cluster	Attempt to blind detection	API server configuration logs	Correlate logging disablement	Logging disabled	Restore logging immediately	Control plane log tampering

	Disable Security Tools)	controller or logging				nt with privilege escalation	post-role binding		indicates active adversary.
Discovery	Container and Cluster Discovery (T1613) + File and Directory Discovery (T1083)	Enumerate secrets and mounted volumes	kubectrl get secrets spike	Preparing credential theft	API logs for secret access	Detect bulk secret enumeration	Secret list requested immediately after escalation	Rotate exposed secrets	Secrets often contain cloud keys or DB credentials.
Collection	Data from Container Volume (T1530 contextual) + Data from Information Repositories (T1213)	Access application configs & DB credentials	Sensitive ConfigMap or Secret accessed	Data harvesting	Secret access logs	Correlate secret retrieval with new outbound connections	DB credentials retrieved then DB connection spike	Monitor DB and outbound traffic	Secret theft expands impact beyond cluster.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain reverse shell pod	Outbound connection from pod to rare ASN	Active C2	Network policy logs, egress traffic analysis	Detect long-lived reverse shell connection	Pod communicating with known malicious ASN	Block C2 after scoping	Pod egress should be tightly controlled.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer application data externally	Large outbound transfer from pod	Data exfiltration	Firewall logs, DLP alerts	Correlate secret access with outbound spike	Multi-GB transfer from cluster namespace	Notify compliance immediately	Cluster compromise may expose customer data.
Impact	Resource Hijacking	Encrypt or disrupt	Multiple deployments	Service outage	Deployment audit logs	Detect mass	Multiple pods	Activate enterprise IR	Cluster takeover

	(T1496) + Data Encrypted for Impact (T1486)	workloads cluster- wide	replaced with ransomware container			image replaceme nt across namespac es	terminated simultaneou sly		enables full service disruption quickly.
--	---	-------------------------------	--	--	--	---	----------------------------------	--	---

BYZANTINE

PLAYBOOK 43 — Container Escape Attack

Attack Theme: Compromised Container → Exploit Kernel / Misconfiguration → Escape to Host → Host-Level Privilege Escalation → Cross-Container & Infrastructure Impact

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Container and Cluster Discovery (T1613) + File and Directory Discovery (T1083)	Identify container runtime, privileges & host mounts	Container querying /proc, /sys, or /var/run/docker.sock	Attacker assessing escape path	Pod security context, container privileges	Analyse container spec for privileged: true or hostPath mounts	Access to /var/run/docker.sock detected	Increase monitoring immediately	Access to Docker socket is major escape risk.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare kernel exploit or breakout script	Known container escape exploit artefact detected	Exploit staging	Process lineage inside container	Detect download of exploit binary inside container	Exploit binary downloaded from external source	Isolate affected pod	Escape tools often staged via curl/wget.
Initial Access	Valid Accounts (T1078) OR Exploit Public-Facing Application (T1190)	Gain code execution inside container	Web application RCE leading to shell inside pod	Container compromised	Application logs, container runtime logs	Correlate RCE vulnerability with container shell spawn	Shell spawned inside container unexpectedly	Contain pod immediately	Container foothold is precursor to host escape.

Execution	Exploitation for Privilege Escalation (T1068) + Escape to Host (T1611 Escape to Host)	Break out from container to host OS	Container process spawning host-level shell	Successful container escape	Host process logs showing parent PID from container runtime	Trace process tree from container namespace to host namespace	Host-level process initiated by container	Isolate node from cluster	Host-level process from container is decisive indicator.
Persistence	Create or Modify System Process (T1543)	Install backdoor on host after escape	New system service on host	Persistence beyond container lifecycle	Host audit logs, service creation events	Compare baseline host services vs new entries	Unknown service created post-container event	Remove service & reimage if needed	Host persistence escalates impact significantly.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group)	Add attacker account to host admin group	User added to sudo or Administrators group	Expanding host control	Host security logs	Correlate group change with container escape timestamp	Non-admin account granted host admin rights	Remove privilege immediately	Host privilege escalation signals full compromise.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable EDR/monitoring agent on host	EDR service stopped on node	Attempt to avoid detection	EDR health logs	Correlate agent disablement with container exploit event	EDR disabled shortly after breakout	Treat as confirmed compromise	Agent disablement indicates attacker confidence.
Discovery	Remote System	Enumerate other	Host scanning cluster network	Preparing lateral movement	Network IDS logs	Detect host scanning	Node scanning	Increase monitoring cluster-wide	Escape often precedes

	Discovery (T1018)	containers & nodes				after breakout	internal IP range		cluster takeover.
Lateral Movement	Remote Services (T1021.002 SMB / SSH)	Pivot from host to other nodes	SSH attempts to peer nodes	Expanding compromise	SSH logs, failed/successful login events	Detect abnormal SSH usage from node	Multiple node access attempts	Disable compromised credentials	Rapid node-to-node movement increases blast radius.
Collection	Data from Information Repositories (T1213) + Data from Container Volume (T1530 contextual)	Access host secrets & mounted credentials	Access to /etc/kubernetes, /root/.kube	Credential harvesting	File access audit logs	Correlate secret access with breakout event	Kubeconfig accessed by unexpected process	Rotate exposed credentials	Host-level kubeconfig access is high-risk.
Command & Control	Application Layer Protocol (T1071.001 Web)	Establish reverse shell from host	Outbound connection from node to rare ASN	Active C2 channel	Firewall logs, DNS logs	Detect persistent connection from node	Node communicating externally outside baseline	Block C2 after scoping	Node egress should be tightly restricted.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer host or container data externally	Multi-GB transfer from node	Data exfiltration	Network monitoring, DLP alerts	Correlate sensitive file access with outbound traffic	Sensitive configs transferred externally	Notify compliance immediately	Host compromise may expose multiple applications.

Impact	Resource Hijacking (T1496) + Data Encrypted for Impact (T1486)	Encrypt containers & host workloads	Multiple containers terminated or encrypted	Service disruption	Deployment logs, container health metrics	Detect abnormal container restarts across cluster	Cluster instability post-escape	Activate enterprise IR	Container escape escalates isolated breach to infrastructure re-level crisis.
--------	--	-------------------------------------	---	--------------------	---	---	---------------------------------	------------------------	---

PLAYBOOK 44 — API Token Theft

Attack Theme: Token Exposure (Code Repo / Memory / Logs) → Reuse of Bearer Token → Privileged API Access → Silent Data Extraction / Configuration Manipulation

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Search Open Technical Databases (T1596) + Gather Victim Org Information (T1591)	Identify exposed API tokens in public/private repos	Threat intel alert of leaked token in Git repository	Token exposure detected	Validate token scope and expiry	Review repository access logs and commit history	Token committed to repo accessible externally	Revoke token immediately	Token scope determines potential blast radius.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare script to automate API abuse	High-frequency API calls from single IP	Automated token testing	User-agent fingerprint, request cadence	Detect scripted access using fixed intervals	Burst of API calls using single token	Apply rate limiting	Automation increases speed of exploitation.
Initial Access	Valid Accounts (T1078) + Use of Web Tokens (T1550.001)	Authenticate using stolen bearer token	Successful API authentication without interactive login	Token replay in progress	Token ID, issuing service, creation timestamp	Correlate API usage with absence of login event	API calls without matching login session	Revoke active tokens	Token use without login is key detection signal.

Execution	Exploit Public-Facing Application (T1190 contextual)	Invoke privileged API endpoints	Access to /admin/export endpoint	Privileged action via token	Check API scope vs endpoint accessed	Compare token scope against required permission	Low-privilege token accessing admin endpoint	Disable associated account	Scope mismatch signals misconfiguration or abuse.
Persistence	Account Manipulation (T1098)	Generate additional API tokens	New token created via API	Establishing backup access	Audit logs for token creation events	Correlate new token creation with suspicious API use	Secondary token created shortly after anomaly	Revoke all tokens	Token chaining enables silent persistence.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Use token to assign elevated role	Role assignment API call via token	Privilege escalation attempt	IAM audit logs	Detect role assignment triggered by service account token	Non-admin token granting admin rights	Remove role immediately	Role changes via token are high-severity events.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable audit logging via API	Logging configuration changed via API call	Attempt to blind monitoring	Configuration audit logs	Correlate log disablement with token use timeline	Logging disabled post-token abuse	Restore logging immediately	Logging tampering confirms malicious intent.
Discovery	Permission Group Discovery (T1069.003 Cloud Groups)	Enumerate accessible resources	API listing users, storage, or databases	Mapping accessible data	API audit logs	Detect broad enumeration using single token	Large volume GET calls across modules	Increase monitoring	Enumeration precedes data collection.
Collection	Data from Information Repositories	Extract data via API	Large data export via API	Data harvesting	Export logs, response	Correlate export size with	Multi-GB API	Enable DLP & isolate account	API-based collection appears

	s (T1213) + Data from Cloud Storage (T1530)				size monitoring	unusual token use	response volume		legitimate but abnormal in volume.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain API-based access channel	Continuous API calls from cloud IP range	Active remote operator	Token lifetime analysis, IP ASN	Detect token use across multiple geographies	Same token used across regions	Revoke token globally	Long-lived tokens increase stealth risk.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Download data to attacker-controlled storage	Data download from export endpoint	Data exfiltration	CASB alerts, firewall logs	Correlate export creation with external download	Export + foreign ASN download	Notify compliance immediately	Encrypted API traffic hides malicious exfiltration.
Impact	Valid Accounts (T1078) + Data Manipulation (T1565.001)	Modify configurations or delete data	Configuration or database modified via API	Service disruption or integrity loss	Change logs, configuration version history	Detect rollback or destructive API calls	Critical config deleted post-token abuse	Activate enterprise IR	API token theft bypasses password & MFA controls.

PLAYBOOK 45 — Git Repository Compromise

Attack Theme: Compromised Developer Account / Token → Source Code Manipulation → Secret Harvesting → Malicious Commit Injection → Supply Chain Risk

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Search Open Technical Databases (T1596) + Account Discovery (T1087)	Identify exposed repositories & developer accounts	Enumeration of organisation repositories via API	Attacker mapping code assets	Source ASN, token scope	Analyse API calls listing private repos	Repo listing from unusual IP	Increase monitoring	Repo enumeration precedes secret harvesting.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare automated Git cloning script	High-frequency git clone activity	Scripted repository download	Git audit logs, user-agent anomalies	Detect multiple repo clones in short window	Mass clone outside CI/CD baseline	Temporarily suspend account	Automation enables bulk code theft quickly.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) + Use of Web Tokens (T1550.001)	Use compromised developer credentials or token	Successful Git login from foreign ASN	Account compromise	Review login context, MFA method	Correlate with leaked PAT (Personal Access Token)	PAT used without interactive login	Revoke token immediately	PAT misuse is common Git compromise vector.

Execution	Modify Code (T1565.001 Stored Data Manipulation)	Inject malicious code into repository	Suspicious commit modifying authentication logic	Code tampering in progress	Review commit author, timestamp, branch	Inspect diff for backdoor insertion	Commit pushed directly to protected branch	Revert commit immediately	Direct push to protected branch is high-risk signal.
Persistence	Account Manipulation (T1098)	Add attacker SSH key to developer account	New SSH key added	Ensuring continued access	Account settings audit logs	Correlate SSH key addition with login anomaly	SSH key added post-login from foreign ASN	Remove SSH key	SSH key persistence bypasses password resets.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Grant elevated repo permissions	User promoted to repository admin	Expanding control	Role assignment logs	Detect role change outside change approval	Non-lead developer granted admin rights	Remove elevated role immediately	Role escalation enables branch protection bypass.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable branch protection rules	Branch protection settings modified	Attempt to allow malicious merge	Repository settings audit logs	Correlate rule change with suspicious commit	Protection disabled before code injection	Restore branch protection	Disabling branch protection is decisive malicious indicator.
Discovery	File and Directory Discovery (T1083)	Search for secrets in codebase	Access to .env, config files	Secret harvesting	File access logs, commit history review	Detect secret pattern scanning across repos	Secret files accessed in bulk	Rotate exposed secrets	Code repos often contain API keys & credentials.
Collection	Data from Information Repositories (T1213)	Download full repository archives	Large repository export via API	Code theft	Download logs, API audit trails	Correlate export with login anomaly	Multi-GB archive download	Enable DLP & notify legal	Code theft may lead to IP loss or supply chain risk.

Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain persistent Git API access	Continuous API calls from external ASN	Active remote operator	Token usage logs	Detect long-lived PAT use across time zones	Token used 24/7	Revoke all active tokens	Continuous API use without developer activity is suspicious.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer stolen source code externally	Repository clone to external IP	IP exfiltration	Proxy logs, CASB alerts	Correlate clone event with outbound traffic spike	Clone + external upload correlation	Notify compliance if sensitive	Intellectual property theft has strategic impact.
Impact	Supply Chain Compromise (T1195.002 Compromise Software Supply Chain) + Data Manipulation (T1565.001)	Deploy backdoored code into production	Malicious code reaches CI/CD pipeline	Downstream system compromise	CI/CD logs, artifact integrity validation	Detect unsigned or unexpected artifact hashes	Production artifact hash mismatch	Activate enterprise IR immediately	Git compromise can cascade into production breach.

PLAYBOOK 46 — Mobile Banking Trojan

Attack Theme: Malicious Mobile App Infection → Accessibility Abuse / Overlay Attack → Credential & OTP Theft → Transaction Manipulation → Financial Fraud

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Identity Information (T1589) + Search Open Technical Databases (T1596)	Identify banking app users & device profiles	Phishing SMS campaign impersonating bank	Target selection in progress	SMS gateway logs, domain age	Correlate SMS link with newly registered domain	Large-scale SMS campaign targeting customers	Block domain & notify customers	Smishing often precedes trojan infection.
Resource Development	Develop Capabilities (T1587.001 Malware)	Prepare malicious mobile banking trojan	Threat intel alert on trojan variant	Malware staging	Hash reputation, mobile threat intel feed	Compare APK signature vs known legitimate app	APK signed with unknown certificate	Block app distribution channel	Trojan variants often mimic official app branding.
Initial Access	User Execution (T1204.002 Malicious App)	User installs trojanized app	Mobile app installed from unofficial source	Device compromised	Device integrity status, OS version	Correlate installation timestamp with fraud activity	Banking app accessed after new app install	Flag device as high-risk	Side-loaded apps increase compromise probability.

Execution	Input Capture (T1056.001 Keylogging) + GUI Input Capture (T1056.002)	Capture credentials & OTP	Multiple failed login attempts followed by success	Stolen credentials replayed	Check device fingerprint & IP ASN	Compare login device ID vs known device baseline	New device login after repeated OTP failures	Force password reset	OTP reuse after multiple failures is decisive signal.
Persistence	Boot or Logon Autostart Execution (T1547)	Maintain trojan activity on reboot	App requesting accessibility permission	Accessibility abuse for overlay control	Device telemetry, permission logs	Detect unusual accessibility service activation	Banking app + unknown accessibility service active	Block compromised device access	Accessibility abuse enables silent transaction manipulation.
Privilege Escalation	Exploitation for Privilege Escalation (T1068 contextual mobile)	Gain additional device control	App requesting admin device privileges	Expanding control	Mobile MDM logs	Detect unusual privilege escalation requests	Admin privilege granted to unknown app	Remove device access immediately	Elevated device privileges enable deeper manipulation.
Defense Evasion	Obfuscated Files or Information (T1027)	Hide trojan from detection	Encrypted payload within APK	Malware concealment	Static & dynamic mobile analysis	Analyse runtime decryption patterns	Suspicious code loading at runtime	Treat as confirmed malware	Obfuscation common in banking trojans.
Discovery	System Information Discovery (T1082)	Identify installed banking apps	Trojan querying installed packages	Targeted overlay preparation	Device logs	Detect query for bank app package name	Banking package enumeration detected	Increase monitoring	Package enumeration signals banking targeting.
Collection	Input Capture (T1056) + Credentials	Harvest login credentials & OTP	Login attempt immediately	Real-time credential theft	Compare OTP request vs	Correlate OTP generation and	Transaction executed seconds	Suspend account immediately	Timing correlation critical in

	from Web Browsers (T1555.003 contextual mobile)		followed by fund transfer		transaction timing	transaction initiation	after OTP request		mobile fraud cases.
Command & Control	Application Layer Protocol (T1071.001 Web)	Send captured credentials to attacker server	Outbound encrypted connection to unknown ASN	Active exfiltration channel	DNS logs, mobile network logs	Detect consistent beacon interval from device	Device beaconing every fixed interval	Block C2 domain	Encrypted mobile C2 blends into normal traffic.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer captured data to attacker	Credential data uploaded to C2	Data theft	Network telemetry, fraud detection logs	Correlate credential exfil with login anomaly	Credential exfil before fraud event	Notify fraud & compliance teams	Coordination between SOC & fraud team essential.
Impact	Account Manipulation (T1098) + Financial Fraud (T1657 contextual)	Unauthorized fund transfer	Unusual transfer to mule account	Financial loss	Transaction logs, beneficiary account history	Analyse mule account linkage across cases	Multiple accounts transferring to same mule	Freeze transactions & activate IR	Mobile trojan impact measured in transaction velocity.

PLAYBOOK 47 — Deepfake Video Blackmail

Attack Theme: AI-Generated Synthetic Video → Executive Impersonation / Extortion → Psychological Pressure → Reputational Threat → Financial or Strategic Coercion

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Identity Information (T1589) + Gather Victim Org Information (T1591)	Collect executive photos, voice, public speeches	Scraping of executive social media & media appearances	Target profiling for synthetic generation	Web traffic logs, abnormal scraping patterns	Detect high-volume scraping from unknown ASN	Executive content scraped systematically	Notify executive protection team	Public media exposure increases deepfake risk.
Resource Development	Develop Capabilities (T1587.001 Malware / AI Tooling contextual)	Generate synthetic deepfake video	Threat intel indicating deepfake toolkit campaign	Synthetic media preparation	Check domain registration of blackmail email	Analyse sender domain age & WHOIS	Domain newly registered before extortion email	Block domain & monitor	Deepfake operations often use short-lived domains.
Initial Access	Phishing (T1566.001 Spearphishing Attachment)	Deliver blackmail email with deepfake link	Executive receives extortion email with video sample	Coercion attempt initiated	Validate sender authenticity, email header analysis	Sandbox video link, inspect hosting server	Email sent to multiple board members	Escalate to executive management immediately	Psychological pressure is main weapon.

Execution	Social Engineering (T1656 Impersonation contextual)	Force payment or confidential action	Email demands cryptocurrency or sensitive document	Extortion in progress	Review requested action type	Compare request vs typical executive behaviour	Payment demand with deadline pressure	Activate crisis management	Urgency & secrecy requests are red flags.
Persistence	Account Manipulation (T1098) (if attacker also compromises account)	Maintain leverage via compromised account	Executive account password reset email triggered	Possible parallel compromise	Check login anomalies & MFA logs	Correlate blackmail with login attempts	Login attempts after extortion email	Force password reset & session revoke	Deepfake campaign may accompany account takeover.
Privilege Escalation	Valid Accounts (T1078) (if executive account abused)	Access confidential board documents	Executive account accessing sensitive data unusually	Potential internal leak vector	Audit access logs	Compare file access timing vs blackmail email	Sensitive board files accessed before leak	Increase monitoring & restrict access	Combine extortion + data leak increases impact.
Defense Evasion	Obfuscated Files or Information (T1027)	Use encrypted hosting & anonymised domains	Video hosted on bulletproof hosting provider	Attempt to evade takedown	Hosting provider reputation, ASN analysis	Correlate infrastructure with known abuse IP ranges	Hosting provider linked to prior abuse	Coordinate with ISP & law enforcement	Rapid takedown reduces reputational damage.
Discovery	Permission Group Discovery (T1069.002)	Identify board or finance contacts	Email reconnaissance inside organisation	Mapping escalation targets	Mail logs for internal forwarding	Detect abnormal email forwarding rules	Executive mailbox rule created unexpectedly	Remove rule immediately	Forwarding rules signal possible mailbox compromise.
Collection	Data from Information Repositories	Collect sensitive internal	Unusual downloads from	Preparing additional pressure	Review attachment downloads	Correlate download spike with	Bulk download	Activate legal & compliance	Blackmail often escalates

	s (T1213) (if combined with data theft)	documents for leverage	executive mailbox			extortion timeline	before public threat		with real data leak.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain encrypted communication	Continued encrypted email exchanges	Active coercion channel	Email & messaging logs	Detect use of anonymous email providers	Communication via encrypted mail service	Preserve evidence	Preserve logs for legal proceedings.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Leak video publicly	Video appears on public platform	Reputational damage	Monitor social media & threat intel feeds	Correlate leak timestamp with negotiation breakdown	Leak after non-payment	Engage PR & legal immediately	Rapid response critical for brand protection.
Impact	Data Manipulation (T1565.001) + Financial Fraud (T1657 contextual)	Reputation damage, forced payment, strategic disruption	Board panic, media exposure	Organisational crisis	Activate executive crisis response plan	Assess financial, legal & market impact	Confirmed public distribution	Enterprise-wide crisis management	Deepfake risk is reputational and psychological more than technical.

PLAYBOOK 48 — Large-Scale Ad Fraud Botnet

Attack Theme: Malware-Infected Devices / Server Farm → Automated Ad Click Generation → Traffic Spoofing → Revenue Manipulation → Financial & Reputational Impact

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Org Information (T1591) + Network Service Discovery (T1046)	Identify high-value ad inventory & ad server endpoints	Enumeration of ad API endpoints	Mapping monetisation infrastructure	Source ASN, traffic origin diversity	Analyse repeated API probing patterns	Ad endpoints probed from bot-like IP ranges	Increase monitoring on ad services	Fraud operators profile monetisation flows first.
Resource Development	Develop Capabilities (T1587.001 Malware) + Obtain Capabilities (T1588.001 Tooling)	Build botnet or automation infrastructure	Threat intel linking domain to click-fraud kit	Botnet staging	Domain age, ASN reputation	Detect domain associated with prior ad fraud	Infrastructure tied to known fraud campaign	Block known malicious ASN	Botnets often reuse infrastructure patterns.
Initial Access	User Execution (T1204.002 Malicious	Infect devices or deploy server-	Multiple endpoints beaconing to	Botnet infection in progress	Endpoint EDR telemetry	Correlate malware detection with	High number of endpoints communicati	Isolate infected endpoints	Large infection footprint signals

	Link) OR Exploit Public-Facing Application (T1190)	based click bots	unknown domain			outbound traffic	ng with same C2		organised campaign.
Execution	Automated Web Interaction (T1059.007 JavaScript contextual)	Simulate ad impressions & clicks	Unusual spike in click events from internal IP range	Automated click generation	Traffic volume vs baseline	Analyse user-agent uniformity & session timing	Click events occurring at fixed intervals	Block suspicious IP ranges	Uniform timing patterns indicate automation.
Persistence	Boot or Logon Autostart Execution (T1547)	Maintain botnet presence on infected devices	Scheduled task created by unknown binary	Long-term click generation	Endpoint persistence logs	Detect unknown scheduled tasks or startup entries	Persistence mechanism across multiple endpoints	Remove malicious persistence	Botnets rely on stable foothold for revenue.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	Gain elevated access on infected host	SYSTEM-level process spawned by malware	Expanded device control	Process lineage analysis	Correlate privilege escalation with network traffic spike	Elevated privileges after infection	Reimage device if necessary	Elevated access enables deeper fraud manipulation.
Defense Evasion	Obfuscated Files or Information (T1027) + Impair Defenses (T1562.001)	Hide malware from detection	Encrypted C2 traffic with domain fronting	Concealed botnet communication	TLS inspection logs, JA3 fingerprint	Detect consistent TLS fingerprint across endpoints	Identical JA3 hash across many hosts	Block C2 & update signatures	Botnets use encryption to blend into normal traffic.

Discovery	System Information Discovery (T1082)	Identify device type & browser for click optimisation	Malware querying browser version	Profiling for ad fraud efficiency	Endpoint telemetry	Detect process enumerating browser details	Browser enumeration preceding click activity	Increase monitoring	Botnets tailor click patterns per browser fingerprint.
Collection	Data from Local System (T1005 contextual)	Harvest cookies for ad impersonation	Browser cookie access by unknown process	Cookie hijacking for fraud	Browser access logs	Correlate cookie access with abnormal ad sessions	Cookie file accessed before click burst	Clear cookies & isolate device	Cookie theft enables higher-value ad fraud.
Command & Control	Application Layer Protocol (T1071.001 Web)	Receive click instructions from C2	Periodic beacon every 60 seconds	Active remote control	DNS logs, outbound HTTP logs	Detect beaconing at fixed interval	Consistent beacon across hundreds of endpoints	Block C2 after scoping	Scale of beaconing defines botnet size.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Report click metrics back to attacker	Outbound POST traffic with encoded payload	Fraud performance reporting	Proxy logs	Correlate click spikes with outbound report traffic	Encoded traffic to suspicious domain	Block outbound traffic	Botnet profitability depends on reporting loop.
Impact	Resource Hijacking (T1496) + Financial Fraud (T1657 contextual)	Manipulate ad revenue & inflate metrics	Unexplained surge in ad revenue then advertiser complaints	Financial & reputational damage	Revenue analytics, fraud detection team coordination	Correlate internal traffic spike with revenue anomaly	Revenue spike inconsistent with user growth	Engage fraud & legal team	Ad fraud impacts trust with advertisers & partners.

PLAYBOOK 49 — Nation-State Intellectual Property Theft

Attack Theme: Advanced Persistent Threat (APT) Campaign → Long-Term Covert Access → R&D / Patent Repository Targeting → Strategic Data Exfiltration → Economic & National Security Impact

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Org Information (T1591) + Gather Victim Identity Information (T1589)	Identify R&D teams, patent owners, research leads	Spearphishing emails targeting engineering team	Targeted profiling	Sender domain age, impersonation indicators	Correlate targeting with public research publications	Emails sent to specific R&D roles only	Increase monitoring for those users	Nation-state actors conduct precise targeting.
Resource Development	Develop Capabilities (T1587.001 Malware) + Obtain Capabilities (T1588.002 Infrastructure)	Prepare custom malware & C2 infrastructure	Threat intel linking domain to known APT group	Staging long-term campaign	ASN reputation, TLS fingerprint	Compare infrastructure with historical APT clusters	Infrastructure overlaps prior campaign	Block and monitor related IOCs	Nation-state infrastructure reuse patterns exist.
Initial Access	Phishing (T1566.001 Spearphishing)	Gain initial foothold	Malicious attachment executed by R&D user	Compromise established	Endpoint EDR telemetry	Analyse process tree and parent-	Suspicious process spawned	Isolate host immediately	Initial foothold often low-

	Attachment) OR Exploit Public- Facing Application (T1190)					child execution	from Outlook		noise and targeted.
Execution	Command and Scripting Interpreter (T1059.001 PowerShell)	Deploy backdoor payload	PowerShell launching encoded command	Malware staging	Script block logging (4104), AMSI logs	Decode Base64 payload, inspect C2 beacon	Encoded PowerShell contacting rare ASN	Block C2 and scope laterally	Encoded PowerShell common in APT staging.
Persistence	Create or Modify System Process (T1543) + Scheduled Task (T1053.005)	Maintain long-term access	New scheduled task running obscure binary	Stealth persistenc e	Task scheduler logs, service creation logs	Compare task name vs baseline tasks	Task created outside patch window	Remove persistence & reimage if needed	Nation- state actors prioritise longevity over speed.
Privilege Escalation	Exploitation for Privilege Escalation (T1068) + Account Manipulatio n (T1098.003)	Gain admin rights to access R&D repositories	User added to engineering admin group	Expanding access to IP	AD logs (4728/4732)	Correlate role change with suspicious login source	Non-admin engineer granted repo-wide admin	Remove privilege immediately	IP theft requires elevated repository access.
Defense Evasion	Obfuscated Files or Information (T1027) + Impair	Avoid detection	Encrypted malware loader bypassing AV	Evasion technique active	EDR tamper alerts	Analyse malware for anti- analysis features	Security tool disabled post- compromis e	Treat as confirmed APT	Stealth over speed is hallmark of APT.

	Defenses (T1562.001)								
Discovery	File and Directory Discovery (T1083) + Permission Group Discovery (T1069.002)	Identify patent & R&D document repositories	Access to /R&D/Confidential directories	Mapping high-value IP	File access logs	Detect systematic traversal across R&D folders	Access outside normal working hours	Increase monitoring	Systematic traversal signals collection phase.
Collection	Data from Information Repositories (T1213) + Archive Collected Data (T1560.001)	Stage proprietary research files	Large encrypted archive created	Data staging	High-entropy file detection	Correlate archive creation with R&D folder access	Archive creation on engineering workstation	Isolate workstation	IP often compressed before stealth exfiltration.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Maintain covert communication	Beacon every 5 minutes to foreign ASN	Active APT C2	JA3 fingerprint, DNS logs	Detect low-and-slow beacon patterns	Beacon consistent over weeks	Block C2 after scoping	Low-and-slow traffic typical of espionage campaigns.
Exfiltration	Exfiltration Over Web Services (T1567.002) + Exfiltration Over C2 Channel (T1041)	Transfer R&D data externally	Gradual outbound data trickle over weeks	Stealth IP theft	NetFlow analysis, DLP logs	Correlate archive creation with outbound traffic over time	Data trickle from R&D subnet to rare ASN	Notify legal & national authorities if required	Slow exfiltration avoids threshold-based detection.

Impact	Data Manipulation (T1565.001) + Exfiltration (T1041)	Strategic IP loss	Competitor releases similar technology prematurely	Economic & strategic damage	Executive briefing, legal review	Assess IP scope & national security implications	Confirmed IP leak linked to APT	Activate enterprise crisis response	Nation-state IP theft impact extends beyond organisation to national economy.
--------	--	-------------------	--	-----------------------------	----------------------------------	--	---------------------------------	-------------------------------------	---

PLAYBOOK 50 — Long-Term Encrypted Traffic Harvesting

Attack Theme: Network-Level Access → Passive TLS Interception / Traffic Capture → Long-Term Storage of Encrypted Data → Future Decryption (Harvest Now, Decrypt Later) → Strategic Intelligence Gain

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Network Service Discovery (T1046) + Gather Victim Org Information (T1591)	Identify high-value encrypted communication channels (VPN, SWIFT, API, Email TLS)	Scanning of internal network segments	Mapping sensitive encrypted traffic paths	Source VLAN, device role	Analyse scans targeting VPN gateways & TLS endpoints	Recon activity focused on encryption endpoints	Increase monitoring	Traffic harvesting begins with mapping encrypted flows.
Resource Development	Obtain Capabilities (T1588.002 Infrastructure) + Develop Capabilities (T1587.001 Tooling)	Deploy packet capture infrastructure	Unknown device connected to core switch	Potential passive tap insertion	Network asset inventory check	Verify MAC address and switch port mapping	Unauthorized network device detected	Physically isolate device	Passive taps enable silent collection.
Initial Access	Valid Accounts (T1078) OR Exploit Public-Facing	Gain access to network monitoring device	Admin login to firewall or router from rare ASN	Network device compromise	Check device config & login logs	Correlate login with configuration export events	Network device config exported unexpectedly	Reset device credentials	Network device compromise enables large-scale capture.

	Application (T1190)								
Execution	Network Sniffing (T1040)	Capture encrypted traffic streams	Packet capture process running continuously	Traffic interception in progress	Check packet capture logs	Identify capture on high-value segments	Capture active on VPN or data centre VLAN	Disable capture immediately	Passive sniffing is often low-noise & persistent.
Persistence	Modify System Image (T1601.001 Firmware Modification contextual) OR Create or Modify System Process (T1543)	Embed capture capability in network device	Modified startup configuration on router	Long-term packet harvesting	Compare running config vs baseline	Detect persistent SPAN/mirror port configuration	Mirror port configured without approval	Remove configuration & audit device	Mirror ports can silently duplicate traffic.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	Gain root-level access to monitoring device	Root shell on network appliance	Full control of capture infrastructure	Process audit logs	Detect escalation on firewall/router	Root-level access from unusual IP	Isolate device & perform integrity check	Root control allows stealth harvesting.
Defense Evasion	Obfuscated Files or Information (T1027) + Impair Defenses (T1562.001)	Encrypt stored packet captures	Encrypted PCAP files stored on appliance	Concealing evidence	File integrity monitoring	Detect unusual encrypted file growth	Large encrypted files accumulating	Preserve forensic image	Encrypted PCAP storage indicates long-term strategy.

Discovery	Network Service Discovery (T1046)	Identify high-volume encrypted sessions	Mapping TLS-heavy servers	Selecting valuable capture targets	NetFlow logs	Detect targeted capture of specific subnets	Capture filter targeting R&D / banking VLAN	Increase monitoring	Selective capture signals intelligence focus.
Collection	Network Sniffing (T1040) + Data from Network Traffic (T1040 contextual)	Collect TLS, VPN, and API encrypted traffic	Sustained increase in outbound encrypted traffic duplication	Ongoing harvesting	Compare traffic mirror port stats	Detect abnormal traffic duplication ratio	Mirror port bandwidth equal to production VLAN	Remove mirror & audit switch configs	Duplication of traffic is definitive harvesting indicator.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Exfiltrate captured PCAP data periodically	Scheduled encrypted transfer to foreign ASN	Packet archive exfiltration	Firewall logs, transfer size analysis	Correlate PCAP file creation with outbound transfer	Multi-GB encrypted transfer from network device	Block transfer & notify compliance	Slow, periodic exfil avoids threshold alerts.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer harvested encrypted data externally	Continuous low-bandwidth encrypted stream	Strategic data theft	NetFlow anomaly detection	Detect consistent data trickle over months	Long-term outbound stream from network device	Activate executive IR	Harvested encrypted data may include future-decryptable secrets.
Impact	Exfiltration (T1041) + Data from Network	Strategic intelligence gain (future decryption)	No immediate visible impact	Silent long-term risk	Assess sensitivity of captured encrypted sessions	Identify use of quantum-vulnerable crypto (RSA/ECC)	Capture includes sensitive long-term	Begin PQC transition planning	Harvest Now, Decrypt Later risk

	Traffic (T1040)							encrypted archives		is delayed but severe.
--	--------------------	--	--	--	--	--	--	-----------------------	--	---------------------------

BYZANTINE

PLAYBOOK 51 — Ransomware-as-a-Service (Affiliate Model Success)

Attack Theme: Initial Access Broker Foothold → RaaS Affiliate Deployment → Lateral Movement → Backup Deletion → Double Extortion → Profit Sharing Model

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Account Discovery (T1087) + Remote System Discovery (T1018)	Identify high-value systems & admin accounts	LDAP enumeration spike from compromised host	Affiliate mapping domain assets	Source workstation, account role	Correlate enumeration with initial phishing or VPN anomaly	Enumeration from newly compromised account	Increase monitoring immediately	Affiliates prioritise speed after foothold purchase.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Download RaaS payload & lateral movement tools	Known ransomware loader hash detected	Payload staging	File hash, EDR telemetry	Detect Cobalt Strike / Sliver beacon dropper	Loader executed from temp directory	Isolate host immediately	Affiliates reuse common tooling kits.
Initial Access	Valid Accounts (T1078) OR Exploit Public-Facing Application (T1190)	Use purchased credentials or exploit to enter network	VPN login from foreign ASN	Initial access broker success	Check MFA status, login baseline	Correlate login with endpoint anomaly	Privileged VPN login after multiple failures	Disable compromised account	IAB + RaaS partnership common in 2026.

Execution	Command and Scripting Interpreter (T1059.001 PowerShell)	Deploy ransomware loader	Encoded PowerShell execution	Payload execution	Script block logs (4104)	Decode payload & identify C2 infrastructure	PowerShell contacting rare ASN	Block C2 after scoping	Encoded scripts typical in affiliate kits.
Persistence	Create or Modify System Process (T1543) + Scheduled Task (T1053.005)	Maintain foothold pre-encryption	New scheduled task launching unknown binary	Staging before mass encryption	Task scheduler logs	Correlate scheduled task with loader execution	Task deployed across multiple hosts	Remove persistence & isolate hosts	Affiliates often stage for coordinated detonation.
Privilege Escalation	Exploitation for Privilege Escalation (T1068) + Account Manipulation (T1098.003)	Gain domain admin rights	User added to Domain Admins group	Preparing for mass deployment	AD logs (4728/4732)	Trace group change to compromised account	Non-IT account added to Domain Admins	Remove privilege immediately	Domain admin is decisive turning point.
Defense Evasion	Inhibit System Recovery (T1490) + Impair Defenses (T1562.001)	Delete backups & disable EDR	vssadmin delete shadows executed	Recovery prevention	Command-line logs, EDR health alerts	Detect backup repository deletion attempt	EDR disabled shortly before encryption	Treat as confirmed ransomware	Backup deletion precedes encryption stage.
Discovery	File and Directory Discovery (T1083) +	Identify file servers for encryption	Access to multiple file shares	Selecting encryption targets	SMB logs, file server access logs	Detect broad file enumeration	Access to >5 file servers within minutes	Increase monitoring cluster-wide	Rapid discovery signals

	Network Share Discovery (T1135)					n from single host			imminent impact.
Lateral Movement	Remote Services (T1021.002 SMB / T1021.001 RDP)	Spread ransomware across network	RDP logins to multiple servers	Lateral pivot	Logon Type 10 events	Correlate RDP with admin credential misuse	>3 servers accessed in short window	Disable compromised account	Speed of containment determines blast radius.
Collection	Archive Collected Data (T1560.001) + Data from Information Repositories (T1213)	Stage sensitive data for double extortion	Large encrypted archive created	Data exfiltration staging	High-entropy file detection	Correlate archive creation with outbound traffic spike	Archive created in same host pre-encryption	Enable DLP & isolate host	Double extortion standard in RaaS model.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Maintain coordination with RaaS operator	Beaconing every few minutes	Active affiliate control	DNS logs, JA3 fingerprint	Detect consistent beacon interval pattern	C2 active on multiple endpoints	Block C2 after scoping	Affiliates maintain control until detonation.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer staged data to leak site operator	Multi-GB outbound transfer	Data theft confirmed	Firewall logs, DLP alerts	Correlate archive creation with foreign ASN upload	Data transfer completed before encryption	Notify legal & regulator immediately	Data theft increases negotiation pressure.
Impact	Data Encrypted for Impact	Encrypt enterprise systems &	Multiple hosts encrypted	Full ransomware	File extension change	Detect shadow copy	Encryption across multiple	Activate enterprise	RaaS success measured

	(T1486) + Inhibit System Recovery (T1490)	demand ransom	simultaneous ly	e detonation	alerts, ransom note detected	deletion & mass file modification	servers within minutes	crisis response	by encryption scale & payment rate.
--	---	------------------	--------------------	-----------------	------------------------------------	---	------------------------------	--------------------	---

BYZANTINE

PLAYBOOK 52 — Initial Access Broker Sale

Attack Theme: Stealth Network Compromise → Credential Harvesting → Privileged Access Validation → Marketplace Listing → Sale to Ransomware / APT Operator

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Search Open Technical Databases (T1596) + Gather Victim Org Information (T1591)	Identify exposed VPN, RDP, Citrix portals	Repeated login attempts to VPN gateway	Target profiling for access sale	Source ASN, brute-force pattern	Correlate scanning activity with credential stuffing attempts	Enumeration targeting VPN login endpoint	Enable rate limiting & geo restrictions	IABs target externally exposed services first.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare credential harvesting tools	Password spraying attempt across multiple users	Automated credential testing	Login failure pattern analysis	Detect same password attempt across multiple accounts	Password spraying across >20 users	Temporarily lock targeted accounts	Spray pattern is early IAB activity.
Initial Access	Valid Accounts (T1078) + Password Spraying (T1110.003)	Gain VPN or RDP access	Successful VPN login after repeated failures	Compromised credentials validated	Review MFA context, device fingerprint	Correlate login with known breached password list	Login from foreign ASN with reused password	Reset credentials immediately	Successful validation marks monetisable asset.

Execution	Remote Services (T1021.001 RDP / T1021.002 SMB)	Confirm level of access	RDP session opened to internal server	Access verification phase	Session duration, commands executed	Analyse commands for reconnaissance vs impact	Short session focused on “whoami”, “net user”	Increase monitoring	IAB verifies access quietly before sale.
Persistence	Account Manipulation (T1098)	Add new backdoor account or modify password	New admin account created	Ensuring long-term access	AD logs (4720)	Correlate account creation with VPN login anomaly	Admin account created outside change window	Remove account immediately	IAB ensures access remains sellable.
Privilege Escalation	Exploitation for Privilege Escalation (T1068) + Account Manipulation (T1098.003)	Obtain admin-level credentials	User added to local Administrators group	Expanding access value	Security logs for group membership changes	Correlate privilege escalation with compromised account	Non-IT account added to admin group	Revoke privileges immediately	Admin access increases sale price significantly.
Defense Evasion	Indicator Removal (T1070.001 Clear Logs)	Remove traces before listing access	Security logs cleared	Attempt to hide entry	Event ID 1102 (log cleared)	Correlate log clearing with suspicious login	Logs cleared shortly after admin login	Treat as confirmed compromise	Log clearing indicates malicious monetisation intent.
Discovery	Network Share Discovery (T1135) + File and Directory	Assess network value	Access to file shares and domain controllers	Evaluating organisational size	SMB logs, LDAP query logs	Detect enumeration of DCs & finance servers	Enumeration across sensitive servers	Increase monitoring	IAB evaluates environment before sale.

	Discovery (T1083)								
Collection	Credentials from Password Stores (T1555) + OS Credential Dumping (T1003.001 LSASS)	Harvest credentials for resale	LSASS memory access alert	Credential dumping	EDR telemetry, SeDebugPrivilege usage	Analyse process injection chain	LSASS accessed by unknown binary	Reset domain-wide credentials	Credential dump enables higher-value access listing.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain remote access channel	Beaconing to rare ASN	Ongoing access maintenance	DNS logs, JA3 fingerprint	Detect low-frequency beacon from compromised host	Beacon active for weeks without other impact	Block C2 after scoping	IAB keeps access dormant until sale.
Exfiltration	Exfiltration Over C2 Channel (T1041)	Transfer proof-of-access screenshots	Small outbound encrypted file transfer	Evidence sent to buyer	NetFlow logs	Correlate exfil with internal reconnaissance	Small encrypted archive from admin workstation	Preserve forensic image	Proof-of-access often shared with buyers.
Impact	Valid Accounts (T1078)	Access listed for sale on underground forum	Threat intel report listing org VPN access	Imminent secondary attack	Confirm listing authenticity	Compare access timestamps with listing details	Confirmed listing referencing internal IPs	Activate enterprise-wide credential reset	IAB sale often precursor to ransomware or APT intrusion.



PLAYBOOK 53 — Email Thread Hijacking

Attack Theme: Compromised Mailbox → Monitoring Active Conversations → Reply-In-Thread with Malicious Link / Payment Change → Financial Fraud or Malware Delivery

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Email Collection (T1114.002 Remote Email Collection) + Account Discovery (T1087)	Monitor existing email conversations	Unusual IMAP or Graph API mailbox access	Mailbox under surveillance	Login ASN, device fingerprint	Correlate login with impossible travel	Login from foreign ASN with no MFA challenge	Revoke sessions immediately	Thread hijacking requires silent mailbox access first.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare reply-in-thread phishing content	Draft emails saved automatically in mailbox	Attacker staging message	Mailbox audit logs	Detect drafts created from unusual IP	Draft created shortly after login anomaly	Force password reset	Draft staging is early sign of hijack attempt.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) + Password	Compromise business email account	Successful login after repeated failures	Account takeover achieved	Review MFA logs, session tokens	Correlate login with breached password lists	Login from residential proxy ASN	Disable account temporarily	Account compromise is foundation of thread hijack.

	Spraying (T1110.003)								
Execution	Phishing (T1566.002 Spearphishing Link)	Reply inside active email thread with malicious link	Email sent within legitimate thread but with new payment instruction	Social engineering within trusted context	Inspect email headers, link domain age	Compare writing style & reply-to address	Payment instruction change in active thread	Alert finance immediately	Trust of thread reduces suspicion.
Persistence	Account Manipulation (T1098)	Create mailbox forwarding rule	New forwarding rule to external email	Attacker maintaining monitoring capability	Mailbox rule audit logs	Detect rule creation post-login anomaly	Forwarding rule created silently	Remove rule immediately	Forwarding rules common in BEC & thread hijack.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Add compromised user to finance group	Role change in cloud IAM	Expanding access to financial approvals	IAM audit logs	Correlate group assignment with mailbox compromise	User granted payment approval rights unexpectedly	Remove privilege	Privilege expansion increases fraud value.
Defense Evasion	Indicator Removal (T1070.004 File Deletion)	Delete sent malicious emails	Sent items deleted immediately after reply	Concealment attempt	Mailbox audit logs	Detect deletion event seconds after send	Sent email deleted post-delivery	Preserve mailbox evidence	Deleting sent items signals malicious intent.
Discovery	Permission Group Discovery (T1069.002)	Identify finance & procurement contacts	Searching mailbox for keywords “invoice”, “payment”	Target selection	Mailbox search audit logs	Detect keyword searches in finance-related threads	Bulk search queries in mailbox	Increase monitoring	Keyword reconnaissance precedes payment fraud.

Collection	Email Collection (T1114.002) + Data from Information Repositories (T1213)	Extract invoice & payment details	Download of attachments from finance threads	Preparing fraudulent instruction	Attachment download logs	Correlate downloads with forwarding rule creation	Multiple finance attachments downloaded	Notify fraud & compliance	Attachment access expands fraud sophistication.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain mailbox access	Continuous API mailbox sync	Active monitoring by attacker	API logs, token lifetime	Detect long-lived token without user interaction	Mailbox accessed 24/7	Revoke all tokens	Persistent mailbox sync indicates monitoring phase.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer invoices & contacts externally	Outbound encrypted email to unknown domain	Data leak	DLP alerts	Correlate attachment forwarding with external email	Sensitive invoice forwarded externally	Notify legal & finance	Thread hijack often escalates into BEC fraud.
Impact	Financial Fraud (T1657 contextual) + Data Manipulation (T1565.001)	Fraudulent payment made to attacker-controlled account	Payment instruction changed mid-thread	Direct financial loss	Payment logs, beneficiary verification	Correlate payment timing with malicious reply	Payment executed shortly after hijacked reply	Activate crisis response	Timing & context analysis critical to detect fraud.

PLAYBOOK 54 — Cloud Metadata Service Exploitation

Attack Theme: SSRF / Remote Code Execution → Access to Cloud Instance Metadata (IMDS) → Credential Extraction → IAM Role Abuse → Cloud Environment Takeover

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Cloud Infrastructure Discovery (T1580) + Network Service Discovery (T1046)	Identify cloud-hosted app with SSRF vulnerability	Repeated HTTP requests with internal IP reference (169.254.169.254)	Attempt to probe metadata service	Web server logs, WAF alerts	Detect unusual requests to metadata endpoint	External request referencing metadata IP	Block suspicious IP & enable WAF rule	Metadata IP probing is high-confidence exploitation signal.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare SSRF payload or exploit chain	Crafted HTTP headers attempting metadata retrieval	Exploit preparation	Inspect HTTP headers for injection attempts	Correlate suspicious headers with unusual URI parameters	SSRF payload pattern detected	Patch vulnerable endpoint	Exploit kits automate metadata extraction attempts.
Initial Access	Exploit Public-Facing Application (T1190)	Achieve SSRF or RCE to reach IMDS	Successful HTTP response containing temporary credentials	Metadata service accessed	Web app logs & cloud audit logs	Validate if IMDSv1 is enabled	Metadata accessed externally	Disable IMDSv1 / enforce IMDSv2	IMDSv1 significantly increases risk.

Execution	Cloud Credential Abuse (T1552.005 Cloud Instance Metadata API)	Extract IAM role temporary credentials	API call retrieving security-credentials	Credential harvesting	CloudTrail / audit logs	Identify which IAM role credentials were retrieved	High-privilege IAM role associated with instance	Rotate credentials immediately	IAM role scope determines blast radius.
Persistence	Account Manipulation (T1098)	Create new IAM user or API key	New IAM access key created	Ensuring persistent cloud access	IAM audit logs	Correlate key creation with metadata access	API key created outside change window	Revoke key & disable account	Attackers convert temp creds into persistent access.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Assume higher-privilege role	AssumeRole API call from compromised instance	Privilege escalation within cloud	CloudTrail logs	Trace role assumption chain	Role assumed with broader privileges than instance baseline	Remove assumed role & investigate	Role chaining common in cloud escalation.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable logging or modify CloudTrail config	CloudTrail or logging bucket modified	Attempt to conceal cloud activity	Cloud config audit logs	Correlate log modification with role abuse	Logging disabled post-credential extraction	Restore logging immediately	Cloud log tampering is decisive malicious indicator.
Discovery	Permission Group Discovery (T1069.003 Cloud Groups)	Enumerate S3 buckets, DB instances	ListBuckets API spike	Mapping cloud assets	API activity logs	Detect systematic listing of resources	Broad enumeration across services	Increase monitoring	Enumeration signals movement beyond initial instance.

Collection	Data from Cloud Storage (T1530) + Data from Information Repositories (T1213)	Access sensitive S3 or database data	Large object download from S3 bucket	Data harvesting	S3 access logs, data transfer metrics	Correlate object read spike with metadata abuse	Sensitive bucket accessed by unusual role	Enable DLP & isolate role	Cloud storage often contains backups & IP.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain API-based control	Continuous API calls from cloud instance	Active cloud-level C2	CloudTrail frequency analysis	Detect repeated API calls at fixed interval	API call pattern persists beyond normal workload	Rotate credentials & isolate instance	API C2 blends into legitimate traffic.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer cloud data externally	High outbound data transfer from S3 to external IP	Data exfiltration	NetFlow, cloud egress logs	Correlate object download with internet transfer	Multi-GB egress spike from compromised region	Notify compliance & regulator if required	Cloud exfil often appears legitimate without context.
Impact	Data Manipulation (T1565.001) + Resource Hijacking (T1496)	Delete resources or deploy cryptominer	EC2 instances terminated or new instances launched	Operational disruption	Cloud config changes, billing spike	Detect abnormal resource creation or deletion	Sudden cost spike in billing dashboard	Activate enterprise IR	Metadata exploitation can escalate to full cloud takeover.

PLAYBOOK 55 — Backup Data Exfiltration

Attack Theme: Backup Repository Access → Archive Extraction → Covert Transfer of Full-System Backups → Double Extortion / Strategic Intelligence Exposure

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Remote System Discovery (T1018) + File and Directory Discovery (T1083)	Identify backup servers & storage paths	Enumeration of servers named “BACKUP”, “DR”, “VEEAM”	Mapping recovery infrastructure	Source host, user privilege level	Correlate enumeration with prior privilege escalation	Backup server accessed by non-backup admin	Increase monitoring	Backup access outside normal ops is high-risk.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare archive extraction tools	Installation of 7zip or custom extraction script	Preparing to access backup archives	Endpoint telemetry	Detect tool installation shortly before repository access	Extraction tool on admin workstation	Isolate workstation	Tool staging precedes archive extraction.
Initial Access	Valid Accounts (T1078) OR Account Manipulation (T1098)	Use compromised backup admin credentials	Successful login to backup console	Compromised privileged account	Review login ASN, MFA context	Correlate login with unusual RDP/VPN session	Backup admin login from rare ASN	Disable compromised account	Backup admins are Tier-0 assets.

Execution	Data from Information Repositories (T1213)	Access backup archive files	Backup restore/export job triggered	Attempt to extract backup data	Backup system audit logs	Compare restore/export vs approved ticket	Restore job outside maintenance window	Suspend restore job	Restore jobs can be abused for data extraction.
Persistence	Account Manipulation (T1098)	Create new backup service account	New service account added in backup console	Ensuring continued access	Backup platform audit logs	Correlate account creation with suspicious export	Service account created post-login anomaly	Remove account immediately	Persistent access increases risk of repeated theft.
Privilege Escalation	Account Manipulation (T1098.003 Add to Group)	Add attacker account to Backup Operators group	AD event 4728/4732 for Backup Operators	Expanding control	Group membership logs	Trace addition to compromised account	Non-IT account added to backup group	Remove privilege immediately	Backup group membership signals escalation.
Defense Evasion	Indicator Removal (T1070.001 Clear Logs) + Impair Defenses (T1562.001 Disable Security Tools)	Disable backup alerts or audit logging	Backup alert notifications disabled	Attempt to conceal exfiltration	Backup alert configuration logs	Correlate alert suppression with export job	Alerts disabled before large export	Restore alerts & escalate	Alert tampering confirms malicious intent.
Discovery	Network Share Discovery (T1135)	Identify storage repositories & retention tiers	Browsing of backup storage volumes	Selecting high-value archives	File access logs	Detect traversal across multiple backup volumes	Access to multiple backup snapshots rapidly	Increase monitoring	Backup archives often contain full enterprise images.

Collection	Archive Collected Data (T1560.001)	Extract backup files to staging location	Large .vbk / .bkf file copied	Data staging in progress	File transfer logs	Correlate copy event with outbound network spike	Multi-GB backup file moved to temp directory	Isolate host	Backup archives contain sensitive full-system data.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Maintain coordination for exfil	Beaconing from backup server	Active operator control	DNS logs, JA3 fingerprint	Detect persistent outbound connection from backup VLAN	Backup server contacting rare ASN	Block C2 after scoping	Backup servers rarely initiate internet traffic.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer backup archives externally	Multi-GB outbound transfer from backup VLAN	Full-system data exfiltration	Firewall logs, DLP alerts	Correlate archive copy with outbound transfer	Backup file transfer to foreign ASN	Notify legal & regulator immediately	Backup exfiltration amplifies regulatory exposure.
Impact	Exfiltration (T1041) + Data Manipulation (T1565.001)	Double extortion or strategic data theft	Backup data published on leak site	Severe confidentiality breach	Data classification review	Assess scope: customer data, credentials, IP	Confirmed publication of backup content	Activate enterprise crisis response	Backup theft bypasses endpoint monitoring entirely.

PLAYBOOK 56 — Privileged Access Management (PAM) Bypass

Attack Theme: Compromised Admin Credential → Circumvent PAM Controls → Direct Privileged Session Establishment → Credential Harvesting → Infrastructure Takeover

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Account Discovery (T1087) + Permission Group Discovery (T1069.002)	Identify privileged accounts protected by PAM	Enumeration of admin group membership	Mapping high-value identities	Source host, account role	Correlate enumeration with recent phishing/VPN anomaly	Non-admin account querying Domain Admins group	Increase monitoring	PAM bypass attempts begin with admin discovery.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare credential dumping or token theft tool	Suspicious binary staged on admin workstation	Tool preparation	File hash reputation, EDR telemetry	Detect credential dumping tool dropped in temp path	Tool staged on non-security workstation	Isolate workstation	Tool staging precedes privileged abuse.
Initial Access	Valid Accounts (T1078) OR Password Spraying (T1110.003)	Compromise privileged account outside PAM workflow	Direct login to server without PAM session broker	Bypass of PAM gateway	Review login source & authentication path	Verify if login passed through PAM proxy	Admin login not recorded in PAM logs	Disable compromised account	Login without PAM mediation is decisive anomaly.
Execution	Use of Alternate Authentication	Authenticate directly using stolen hash	Logon Type 3/10 using	Credential reuse	Security logs, NTLM events	Correlate hash-based login with	NTLM login from non-admin host	Force credential reset	Pass-the-hash often used to

	on Material (T1550.002 Pass-the-Hash)		NTLM without PAM approval	bypassing vault		LSASS access			bypass vault controls.
Persistence	Account Manipulation (T1098)	Create hidden privileged account	New admin account created outside PAM workflow	Ensuring fallback access	AD logs (4720, 4728)	Compare account creation vs PAM approval records	Admin account created without change ticket	Remove account immediately	Hidden admin accounts bypass vault oversight.
Privilege Escalation	Exploitation for Privilege Escalation (T1068) + Account Manipulation (T1098.003)	Escalate to higher privilege tier	Account added to Enterprise Admins	Tier-0 escalation	Group membership logs	Trace escalation chain from compromised account	Privilege escalation outside PAM workflow	Revoke elevated access	Tier-0 access indicates full infrastructure risk.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable PAM agent or session recording	PAM agent service stopped	Attempt to avoid recording	Endpoint logs, PAM health alerts	Correlate agent stop with admin login event	Session recording missing for privileged login	Treat as confirmed compromise	Missing PAM recording is high-confidence alert.
Discovery	Remote System Discovery (T1018) + Network Share Discovery (T1135)	Identify sensitive servers	Access to domain controllers or backup servers	Target selection for impact	Logon events across critical servers	Detect broad admin access post-PAM bypass	Admin accessing >5 critical servers quickly	Increase monitoring cluster-wide	Rapid admin movement signals malicious intent.

Lateral Movement	Remote Services (T1021.002 SMB / T1021.001 RDP)	Spread access across infrastructure	Multiple RDP sessions without PAM ticket	Unauthorised lateral movement	PAM session logs vs OS logs	Identify RDP sessions lacking vault approval	RDP without PAM correlation	Disable account & isolate endpoints	Correlation gap between PAM & OS logs is decisive signal.
Collection	Credentials from Password Stores (T1555) + OS Credential Dumping (T1003.001 LSASS)	Harvest additional privileged credentials	LSASS memory access alert	Credential dumping	EDR telemetry, SeDebugPrivilege usage	Analyse process injection patterns	LSASS accessed after PAM bypass	Reset domain-wide privileged credentials	Credential theft multiplies impact rapidly.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain covert communication	Beaconing from admin workstation	Active remote operator	DNS logs, JA3 fingerprint	Detect low-frequency beacon tied to admin host	Admin workstation beaconing to rare ASN	Block C2 after scoping	Admin host outbound traffic is high-risk anomaly.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer configuration or credential data	Outbound encrypted archive from admin workstation	Data exfiltration	Firewall logs, DLP alerts	Correlate archive creation with admin session	Archive transfer after PAM bypass	Notify compliance if sensitive data involved	PAM bypass often precedes ransomware or IP theft.
Impact	Valid Accounts (T1078) + Inhibit System Recovery	Full infrastructure compromise	Multiple critical servers accessed via direct	Enterprise-wide risk	Tier-0 asset review	Assess scope of unauthorised privileged sessions	Domain Admin used outside PAM control	Activate enterprise IR immediately	PAM bypass undermines entire privileged access

	(T1490 contextual)		admin login						control model.
--	-----------------------	--	----------------	--	--	--	--	--	-------------------

BYZANTINE

PLAYBOOK 57 — Shadow IT SaaS Compromise

Attack Theme: Unapproved SaaS Application Usage → Weak Authentication / No MFA → Credential Reuse → Data Exposure → Lateral Impact into Corporate Environment

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Identity Information (T1589) + Search Open Technical Databases (T1596)	Identify employees using unsanctioned SaaS	Employee email found in third-party SaaS breach dump	Target profiling	Validate domain exposure	Correlate breach data with internal user list	Multiple employees listed in SaaS breach	Increase monitoring for affected users	Shadow IT expands attack surface invisibly.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare credential stuffing automation	Login attempts across SaaS login portal	Automated credential testing	Source ASN, request frequency	Detect same password used across accounts	High-volume login attempts on SaaS platform	Enforce password reset for affected users	Credential reuse enables easy SaaS compromise.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) +	Compromise SaaS account	Successful SaaS login from rare ASN	Account takeover	Review login IP, device fingerprint	Correlate login with known password reuse	SaaS login without MFA from foreign ASN	Reset credentials immediately	Unsanctioned SaaS often lacks enterprise MFA.

	Credential Stuffing (T1110.004)								
Execution	Data from Information Repositories (T1213)	Access stored files & data in SaaS	Large file access/download activity	Data harvesting	SaaS audit logs	Compare file access volume vs baseline	Bulk download within short timeframe	Suspend SaaS account	SaaS logs critical for visibility.
Persistence	Account Manipulation (T1098)	Add new API token or recovery email	Recovery email changed	Ensuring continued access	SaaS account settings audit logs	Correlate change with login anomaly	Recovery email updated post-login	Restore account settings	Recovery changes are strong compromise indicators.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Grant self admin rights within SaaS	User promoted to SaaS admin role	Expanding access scope	SaaS role audit logs	Compare role change vs business need	Non-manager granted admin privileges	Remove role immediately	SaaS admin rights amplify data exposure risk.
Defense Evasion	Obfuscated Files or Information (T1027)	Compress or encrypt SaaS data before download	Encrypted archive created in SaaS	Concealing extracted data	SaaS activity logs	Detect archive creation before download spike	Archive creation in short session	Increase monitoring	Archive-then-download is common pattern.
Discovery	Permission Group Discovery (T1069.003 Cloud Groups)	Identify shared project spaces	Access to multiple project folders	Mapping accessible data	SaaS access logs	Detect cross-project browsing	Broad folder traversal outside role baseline	Increase monitoring	Broad traversal signals reconnaissance stage.

Collection	Data from Cloud Storage (T1530)	Export entire project repositories	SaaS export feature used	Data staging	Export job logs	Correlate export job with foreign login	Export outside working hours	Suspend export job	Export misuse indicates large-scale theft.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain SaaS API access	Repeated API calls from same token	Active remote control	Token lifetime, IP ASN	Detect persistent API usage without user interaction	API activity 24/7	Revoke API tokens	Long-lived API use is stealth persistence method.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer SaaS data externally	Large outbound transfer from SaaS platform	Data exfiltration	CASB alerts, SaaS audit trail	Correlate export with download to foreign ASN	Multi-GB download from SaaS	Notify legal & compliance	Shadow IT often bypasses corporate DLP.
Impact	Data Manipulation (T1565.001) + Valid Accounts (T1078)	Exposure of confidential data	SaaS project data leaked publicly	Confidentiality breach	Data classification review	Assess scope of exposed client/IP data	Confirmed data leak from shadow SaaS	Activate enterprise IR	Shadow IT compromises bypass central security controls.

PLAYBOOK 58 — Hardware Keylogger Deployment

Attack Theme: Physical Access to Workstation → USB / Inline Hardware Keylogger Installation → Credential Capture → Privileged Account Compromise → Lateral Movement

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Physical Reconnaissance (T1592 contextual) + Account Discovery (T1087)	Identify high-value workstation (Finance / Admin)	CCTV gap during after-hours access	Target profiling	Badge access logs, CCTV timeline	Correlate physical entry with privileged user schedule	After-hours physical access to admin office	Notify physical security	Hardware attacks require physical proximity.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare USB inline hardware keylogger	Suspicious USB device visually observed	Hardware implant staging	Endpoint device inventory	Verify unknown USB HID device	Unknown USB device between keyboard and PC	Physically inspect workstation	Inline keyloggers are small and easily hidden.
Initial Access	Hardware Additions (T1200 contextual)	Install keylogger on keyboard port	No immediate digital alert	Silent credential capture begins	Inspect USB device list	Identify unauthorized HID device enumeration	New HID device without change record	Remove device immediately	Hardware keyloggers bypass software monitoring.
Execution	Input Capture (T1056.001 Keylogging)	Capture keystrokes including credentials	No software-based detection	Passive credential harvesting	Validate privileged account	Correlate new admin login from	Admin account used from unusual IP	Reset affected credentials	Stolen credentials often used

					login patterns	different ASN			remotely later.
Persistence	External Remote Services (T1133 contextual)	Attacker periodically retrieves captured data physically or via wireless keylogger	Privileged account compromise without malware footprint	Credential replay from remote location	Login geo, impossible travel detection	Compare keystroke timeline vs login timestamp	Login shortly after office hours entry	Increase monitoring	Hardware keyloggers leave no endpoint malware traces.
Privilege Escalation	Valid Accounts (T1078) + Account Manipulation (T1098.003)	Use stolen admin credentials to escalate access	Admin account added to higher privilege group	Expanding compromise scope	AD logs (4728/4732)	Trace privilege change back to initial login source	Privilege escalation from rare ASN	Remove privileges immediately	Credential theft can escalate rapidly.
Defense Evasion	Obfuscated Files or Information (T1027 contextual)	Avoid software detection entirely	No malware detected on endpoint	Hardware-level stealth	Compare EDR logs vs suspicious login events	Identify mismatch between endpoint telemetry and account usage	Admin login with clean endpoint record	Treat as physical compromise	Absence of malware does not mean absence of compromise.
Discovery	Network Service Discovery (T1046)	Enumerate servers using stolen credentials	SMB or RDP attempts from external IP	Preparing lateral movement	Logon events (Type 10/3)	Detect admin scanning internal servers	Multiple internal servers accessed in short window	Disable compromised account	Rapid server access indicates malicious pivot.
Lateral Movement	Remote Services (T1021.001)	Pivot into sensitive systems	RDP sessions	Remote exploitation using	Correlate with MFA status	Validate if MFA	RDP login without PAM/MFA	Disable account &	MFA bypass detection

	RDP / T1021.002 SMB)		from foreign ASN	stolen credentials		bypass occurred		isolate systems	critical in hardware cases.
Collection	Data from Information Repositories (T1213)	Access confidential data using stolen credentials	Sensitive file access by admin outside hours	Data harvesting	File access logs	Correlate file access with login anomaly	Access outside role baseline	Increase monitoring	Hardware keylogging leads to legitimate credential misuse.
Command & Control	Application Layer Protocol (T1071.001 Web)	Use stolen credentials to maintain remote access	VPN session established repeatedly	Ongoing exploitation	VPN logs, device fingerprint	Detect repeated logins from same ASN	Consistent VPN login at unusual hours	Revoke VPN access	Credential replay patterns are decisive indicators.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer accessed data externally	Large outbound transfer post-login	Data exfiltration	NetFlow, DLP alerts	Correlate data transfer with admin login	Multi-GB transfer after admin login	Notify compliance immediately	Credential theft often culminates in data theft.
Impact	Valid Accounts (T1078) + Data Manipulation (T1565.001)	Infrastructure compromise or financial fraud	Unauthorised changes performed by admin account	Enterprise-wide risk	Privileged activity review	Identify full scope of actions taken with stolen credentials	Domain Admin activity from rare ASN	Activate enterprise IR	Physical security gaps can undermine digital controls.

PLAYBOOK 59 — Rogue Certificate Authority Issuance

Attack Theme: Compromise of Enterprise CA or AD CS → Unauthorized Certificate Template Abuse → Forged Authentication Certificates → Domain Persistence & Stealth Access

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Permission Group Discovery (T1069.002) + Remote System Discovery (T1018)	Identify Enterprise CA server & certificate templates	LDAP queries referencing pKIEnrollmentService	Mapping certificate infrastructure	Source host & account role	Correlate enumeration with privileged login anomaly	CA server queried by non-CA admin	Increase monitoring immediately	CA enumeration often precedes certificate abuse.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare certificate abuse tooling (e.g., cert request utilities)	Suspicious execution of cert request tool	Tool staging	Process execution logs on admin workstation	Detect abnormal usage of certutil or enrollment API	Cert request tool executed outside maintenance window	Isolate workstation	Certificate abuse tooling rarely used outside PKI team.
Initial Access	Valid Accounts (T1078) OR Exploitation for Privilege	Gain access to CA or template modification rights	Successful login to CA server from rare ASN	Privileged compromise	Review MFA & PAM mediation	Verify login passed through approved workflow	CA admin login without PAM record	Disable compromised account	CA admin compromise is Tier-0 severity.

	Escalation (T1068)								
Execution	Subvert Trust Controls (T1553.004 Install Root Certificate) + Account Manipulation (T1098 contextual template abuse)	Modify certificate template for client authentication	Certificate template permission changed	Template misconfiguration enabling abuse	AD CS audit logs	Compare template ACL vs baseline	Template modified outside approved change	Revert template immediately	Template abuse enables silent impersonation.
Persistence	Forge Web Credentials (T1606.002 SAML Token / Certificate Abuse contextual)	Issue authentication certificate for privileged user	Certificate issued for Domain Admin account	Certificate-based persistence	CA issuance logs	Trace certificate serial number & requester	Cert issued to high-privilege account unexpectedly	Revoke certificate & investigate	Certificates bypass password & MFA controls.
Privilege Escalation	Account Manipulation (T1098.003 Add Account to Group) +	Use forged cert to authenticate as Domain Admin	Kerberos authentication via certificate	Escalated domain access	AD logon events (4768/4769)	Detect smartcard/cert logon from unusual workstation	Cert-based logon from non-admin device	Remove elevated privileges	Certificate logons from unusual endpoints are decisive signals.

	Certificate Abuse								
Defense Evasion	Indicator Removal (T1070.001 Clear Logs)	Clear CA logs after issuance	Event log cleared on CA server	Attempt to hide rogue issuance	Event ID 1102 on CA server	Correlate log clearing with cert issuance timeline	Log cleared shortly after suspicious issuance	Preserve forensic image	Log clearing on CA is high-confidence malicious act.
Discovery	Account Discovery (T1087)	Identify high-value accounts to impersonate	Enumeration of Enterprise Admin accounts	Target selection	LDAP query logs	Detect queries targeting privileged accounts	Broad admin enumeration before issuance	Increase monitoring	Cert abuse often targets Tier-0 identities.
Lateral Movement	Remote Services (T1021.001 RDP / T1021.002 SMB)	Access domain controllers using forged certificate	RDP login using certificate auth	Domain pivot	Logon events showing certificate-based authentication	Correlate cert serial with CA logs	Domain controller login using newly issued cert	Disable affected accounts	Certificate-based lateral movement is stealthy.
Collection	Credentials from Password Stores (T1555) + Data from Information Repositories (T1213)	Harvest additional credentials & data	Access to AD database or sensitive shares	Expanding compromise	File access logs	Correlate access with certificate logon timeline	Sensitive share accessed post-cert login	Increase monitoring	Cert-based access may bypass detection rules.
Command & Control	Application Layer Protocol	Maintain domain persistence	Repeated certificate-based	Persistent backdoor	Kerberos & CA logs	Detect repeated logons using	Cert used across multiple systems	Revoke certificate globally	Certificate revocation critical

	(T1071.001 Web)	via cert auth	authentication s			same certificate			containment step.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer sensitive data externally	Outbound transfer after privileged access	Data exfiltration	NetFlow & DLP logs	Correlate cert-auth session with outbound spike	Data transfer post-DC login	Notify compliance immediately	Cert abuse can enable full domain data theft.
Impact	Subvert Trust Controls (T1553) + Valid Accounts (T1078)	Undermine enterprise trust model	Persistent admin access despite password resets	Long-term domain compromise	PKI integrity review	Validate CA root trust chain & revoke rogue certs	CA template compromised	Activate enterprise-wide PKI incident response	CA compromise undermines authentication trust foundation.

PLAYBOOK 60 — Code Signing Certificate Theft

Attack Theme: Compromise of Developer / Build Environment → Theft of Code Signing Certificate Private Key → Signing of Malicious Software → Trust Bypass → Supply Chain & Endpoint Compromise

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Account Discovery (T1087) + Permission Group Discovery (T1069.002)	Identify developers with signing rights	Enumeration of build server access groups	Mapping high-value signing accounts	Source host & user context	Correlate enumeration with unusual login	Non-build user querying signing permissions	Increase monitoring	Code signing rights are high-value assets.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare key extraction or memory dumping tool	Suspicious execution of credential dumping tool on build server	Tool staging	EDR telemetry, process lineage	Detect LSASS or private key store access	Dumping tool on CI/CD server	Isolate build server immediately	Build servers are Tier-0 supply chain assets.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) OR Exploit Public-Facing	Compromise developer or CI/CD account	Successful login to build server from rare ASN	Account takeover	MFA status, device fingerprint	Correlate login with phishing or token leak	Build server login outside maintenance window	Disable compromised account	Build environment access equals signing key access.

	Application (T1190)								
Execution	Steal Application Access Token (T1528 contextual) + Credentials from Password Stores (T1555)	Extract code signing certificate private key	Access to certificate store (certmgr, key vault)	Key harvesting	File integrity monitoring on key store	Detect private key export event	Private key exported outside approved change	Revoke certificate immediately	Private key export is decisive high-severity event.
Persistence	Account Manipulation (T1098)	Add attacker-controlled signing account	New service account granted signing rights	Ensuring continued signing capability	IAM / AD audit logs	Correlate role change with login anomaly	Non-dev account granted signing permission	Remove permission immediately	Signing permission expansion increases blast radius.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	Gain SYSTEM-level access on build server	SYSTEM process spawned from compromised account	Elevated control of signing environment	Process creation logs	Trace privilege escalation chain	SYSTEM-level process on build server	Reimage server if needed	SYSTEM access enables silent signing abuse.
Defense Evasion	Subvert Trust Controls (T1553.002 Code Signing)	Sign malicious payload with stolen cert	Malware sample signed with valid company certificate	Trust bypass	Verify certificate thumbprint	Compare signing certificate serial with internal inventory	Signed malware discovered externally	Immediate revocation of certificate	Signed malware bypasses endpoint trust controls.

Discovery	File and Directory Discovery (T1083)	Identify source code & release artifacts	Access to release pipeline artifacts	Targeting production software	CI/CD logs	Detect artifact manipulation before release	Build artifacts accessed outside release schedule	Suspend release pipeline	Artifact tampering signals supply chain risk.
Collection	Archive Collected Data (T1560.001)	Bundle malicious payload for signing	Unusual archive created in signing directory	Payload preparation	File hash comparison	Detect new unsigned binary introduced to signing path	Binary signed without change ticket	Halt deployment immediately	Signing path integrity must be strictly monitored.
Command & Control	Application Layer Protocol (T1071.001 Web)	Coordinate release of signed malware	Beaconing from build server	Active attacker presence	DNS logs, JA3 fingerprint	Detect outbound traffic from build environment	Build server contacting rare ASN	Block C2 after scoping	Build servers rarely require outbound internet access.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer stolen private key externally	Encrypted outbound transfer from build server	Key exfiltration	NetFlow logs, DLP alerts	Correlate private key export with outbound spike	Private key file transferred externally	Notify legal & regulators if required	Code signing key loss is regulatory & reputational crisis.
Impact	Subvert Trust Controls (T1553.002) + Supply Chain Compromis	Distribute malicious signed update	Customers install trusted but malicious software	Widespread compromise	Monitor telemetry from deployed software	Validate release artifact integrity	Signed malicious update in production	Activate enterprise crisis response	Code signing compromise undermines entire software trust chain.

	e (T1195.002)								
--	------------------	--	--	--	--	--	--	--	--

BYZIMMER

PLAYBOOK 61 — Social Media Account Takeover

Attack Theme: Credential Theft / MFA Bypass → Account Hijack → Brand Impersonation / Scam Campaign → Reputation Damage / Financial Fraud

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Identity Information (T1589) + Account Discovery (T1087 contextual)	Identify official corporate social media admins	Corporate email found in breach dump	Target profiling	Verify affected users	Correlate breach with social admin accounts	Social media admin listed in breach database	Increase monitoring for admin accounts	Social accounts often tied to corporate email identities.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare phishing kit or credential stuffing bot	Login attempts against social platform	Automated credential testing	Source ASN & rate patterns	Detect spray pattern across admin emails	Multiple login failures across social admins	Enforce password reset	Credential reuse common entry vector.
Initial Access	Valid Accounts (T1078) + Credential Stuffing (T1110.004)	Gain access to social media account	Successful login from foreign ASN	Account takeover	Review MFA logs & session tokens	Correlate login with impossible travel	Login from TOR / residential proxy	Force password reset & revoke sessions	Social logins from rare ASN are decisive indicators.

Execution	Phishing (T1566.002 Spearphishing Link contextual misuse of account)	Post malicious content or scam links	New post promoting crypto scam	Abuse of brand trust	Inspect post content & links	Analyse link domain age & TLS certificate reuse	Scam link posted from verified account	Remove post immediately	Hijacked accounts used for rapid scam campaigns.
Persistence	Account Manipulation (T1098)	Add attacker email as recovery contact	Recovery email changed	Ensuring continued control	Social account settings audit	Compare recovery change with login anomaly	Recovery email changed without approval	Restore original recovery details	Recovery change is strong compromise indicator.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Add attacker as page admin	New admin role assigned	Expanding control across brand pages	Platform role audit logs	Trace role addition source IP	Unknown admin added to verified account	Remove role immediately	Admin addition escalates brand-wide risk.
Defense Evasion	Indicator Removal (T1070.004 File/Message Deletion contextual)	Delete warning messages or security alerts	Security notification email deleted	Concealment attempt	Email audit logs	Correlate deletion with takeover timeline	Security email deleted post-login anomaly	Preserve evidence	Deleting alerts signals deliberate control.
Discovery	Permission Group Discovery (T1069 contextual)	Identify linked business manager accounts	Access to ad manager dashboard	Mapping monetisation channels	Audit linked accounts	Detect exploration of ad accounts & billing settings	Billing panel accessed unexpectedly	Increase monitoring	Hijackers target advertising accounts for fraud.
Collection	Data from Information Repositories (T1213)	Export follower list & analytics	Data export feature triggered	Harvesting audience data	Platform export logs	Correlate export with login anomaly	Export job executed outside business hours	Suspend export job	Follower data valuable for resale or phishing.

Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain persistent session	Repeated API calls from same ASN	Active operator control	Session token lifetime	Detect persistent API usage without user interaction	24/7 API activity on social account	Revoke tokens	Long-lived sessions indicate persistent compromise.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer analytics & contact data externally	Bulk data download	Data leak	DLP & CASB alerts	Correlate export with external IP	Multi-GB data download from social account	Notify legal & PR team	Reputation & privacy exposure must be assessed.
Impact	Impersonation (T1656 contextual) + Financial Fraud (T1657 contextual)	Launch scam campaign or market manipulation	Verified account promoting fraudulent scheme	Brand & financial damage	Incident timeline reconstruction	Assess financial loss & public impact	Scam widely circulated via official account	Activate crisis & PR response	Speed of response defines reputational damage.

PLAYBOOK 62 — AI-Driven Automated Trading Manipulation

Attack Theme: Compromise of Trading API / Algorithm → AI-Optimised Market Manipulation → Rapid Order Placement / Cancellation → Financial Gain & Market Distortion

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Identity Information (T1589) + Cloud Infrastructure Discovery (T1580)	Identify exposed trading APIs or algo endpoints	Repeated probing of /trade/api/v2 endpoint	API mapping for exploitation	Source ASN, request headers	Correlate probing with credential brute-force attempts	Enumeration of trading endpoints from foreign ASN	Enable WAF restrictions immediately	Trading APIs are high-value financial targets.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare AI trading bot & automation scripts	High-frequency API simulation activity	Testing manipulation algorithm	API rate logs	Detect pattern learning behaviour before live trades	Gradual increase in test orders	Increase monitoring	Attackers simulate market reaction before execution.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) + Steal Application	Compromise trading API credentials	Successful API authentication from rare ASN	Trading account takeover	Review API key usage & MFA enforcement	Correlate login with developer workstation compromise	API key used from new geography	Revoke API key immediately	API keys often lack behavioural monitoring.

	Access Token (T1528)								
Execution	Modify System Process (T1543 contextual algo modification)	Alter trading algorithm parameters	Sudden change in trading strategy configuration	Algorithm tampering	Change management logs	Compare config hash vs approved baseline	Trading logic changed outside release window	Suspend trading account	Algo changes outside CAB are critical alerts.
Persistence	Account Manipulation (T1098)	Generate new API token for continued access	New API token created	Ensuring ongoing control	IAM audit logs	Correlate token creation with login anomaly	API token generated post-compromise	Revoke all tokens	Multiple tokens increase attacker resilience.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Elevate trading limit permissions	Trading account limit increased	Expanding financial impact	Trading platform audit logs	Compare new limits vs risk profile	Limit increased without approval workflow	Revert limits immediately	Increased limits amplify manipulation scale.
Defense Evasion	Obfuscated Files or Information (T1027 contextual)	Randomise order patterns to evade detection	Orders placed at varying intervals	AI-driven evasion pattern	Trade anomaly detection logs	Identify subtle spoofing or layering behaviour	High-frequency order placement + cancellation spike	Flag account as suspicious	AI adapts to threshold-based detection.
Discovery	Permission Group Discovery	Identify linked brokerage or	Access to linked settlement accounts	Mapping settlement chain	Audit linked accounts	Detect access to multiple	Settlement account viewed	Increase monitoring	Broader financial mapping signals

	(T1069 contextual)	clearing accounts				financial channels	post-login anomaly		strategic intent.
Collection	Data from Information Repositories (T1213)	Extract historical market & client trade data	Bulk export of trading history	Intelligence gathering	Export logs & DLP alerts	Correlate export with algorithm modification	Data export before manipulation	Suspend export rights	Historical data fuels AI strategy optimisation.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain real-time control of AI trading bot	Continuous API calls at sub-second interval	Active automated trading manipulation	API traffic analysis	Detect anomaly in call frequency vs baseline	Sustained abnormal trade velocity	Throttle API access	Low-latency bot behaviour is high-risk indicator.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer financial intelligence externally	Encrypted outbound transfer from trading server	Data theft	NetFlow logs	Correlate data export with foreign IP	Trade data transferred externally	Notify compliance & regulator	Financial data exfil triggers regulatory reporting.
Impact	Data Manipulation (T1565.001) + Financial Fraud (T1657 contextual)	Artificially inflate/deflate asset price	Abnormal price volatility linked to internal account	Market manipulation achieved	Trade timeline reconstruction	Analyse order book layering, spoofing behaviour	Coordinated buy/sell waves triggered	Activate enterprise crisis & regulatory response	AI-driven manipulation can impact broader market integrity.

PLAYBOOK 63 — Deepfake HR Recruitment Scam

Attack Theme: Brand Impersonation → AI-Generated Recruiter Identity → Fake Interview / Offer Letter → Data Harvesting / Advance Fee Fraud / Malware Delivery

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Identity Information (T1589) + Gather Victim Org Information (T1591)	Collect HR staff names & job postings	Spike in scraping activity on careers page	Brand & recruiter profiling	Source ASN & scraping pattern	Correlate scraping with lookalike domain registration	Mass scraping of HR emails & job descriptions	Enable rate limiting	Public job portals provide attacker targeting data.
Resource Development	Acquire Infrastructure (T1583.001 Domains) + Develop Capabilities (T1587 contextual AI voice/video cloning)	Create lookalike recruitment domain & deepfake recruiter	Domain similar to company HR email domain	Phishing infrastructure staging	Domain age, WHOIS, TLS reuse	Check internal DNS queries resolving lookalike domain	Employees resolving suspicious HR domain	Block domain & warn staff	Lookalike domains support credibility of scam.

Initial Access	Phishing (T1566.002 Spearphishing Link)	Send fake job offer or interview link	External email claiming HR interview	Social engineering entry point	Email headers, SPF/DKIM results	Analyse link destination & sandbox attachments	Offer letter includes malicious attachment	Block email & notify users	HR-themed phishing has high engagement rate.
Execution	User Execution (T1204.002 Malicious File)	Victim opens attachment or downloads “HR form”	Attachment executed from Downloads folder	Malware deployment or credential harvesting	Endpoint telemetry	Inspect process tree & network connections	Attachment spawns PowerShell or browser credential prompt	Isolate endpoint	Deepfake recruitment scams may deliver malware.
Persistence	Account Manipulation (T1098)	Harvest personal data & create fraudulent payment channel	Victim submits passport / bank details	Identity harvesting	DLP alerts	Correlate outbound submission with phishing link	Sensitive documents uploaded externally	Alert legal & HR	Personal data theft exposes company to regulatory risk.
Privilege Escalation	Valid Accounts (T1078 contextual internal victim)	Use harvested corporate credentials if reused	Internal login attempt after recruitment phishing	Credential reuse	Review login ASN & impossible travel	Correlate login with phishing timeline	Corporate login from foreign ASN after HR email	Force password reset	Recruitment phishing can pivot into enterprise access.
Defense Evasion	Obfuscated Files or Information (T1027)	Use AI-generated video interview to avoid suspicion	Video interview with minor facial artifacts	Deepfake impersonation	Validate recruiter identity	Check metadata & AI artifact indicators	Video call from unknown domain with identity mismatch	Escalate to brand protection team	Deepfake realism increasing in 2026.
Discovery	Account Discovery	Identify additional employee	Multiple connections	Expanding victim pool	OSINT monitoring	Detect coordinated recruiter	Multiple employees approached	Issue corporate advisory	Attackers scale scams using brand

	(T1087 contextual)	contacts via LinkedIn	requests from fake recruiter			impersonation campaign	by same fake recruiter		impersonation.
Collection	Input Capture (T1056 contextual credential harvesting)	Harvest login credentials via fake portal	Credential submission page resembling SSO	Phishing credential capture	CASB / proxy logs	Compare login URL vs official SSO domain	Credentials entered into lookalike domain	Reset affected credentials	Lookalike SSO portals highly effective.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain phishing campaign coordination	Multiple outbound calls to VoIP number in offer letter	Active scam operator	VoIP trace & DNS logs	Identify reused infrastructure across scams	Shared infrastructure with prior campaigns	Share intel with law enforcement	Scam infrastructure often reused.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer collected candidate data	Bulk upload to external storage	Mass data harvesting	NetFlow & DLP logs	Correlate document upload with phishing campaign	Multiple uploads of ID documents	Notify legal & regulator if required	Candidate PII exposure triggers compliance obligations.
Impact	Impersonation (T1656 contextual) + Financial Fraud (T1657 contextual)	Reputation damage & monetary loss	Public reports of fake recruitment using brand name	Brand trust erosion	Media & threat intel monitoring	Assess financial & reputational impact	Media coverage of scam campaign	Activate crisis communication plan	Deepfake HR scams target both candidates and enterprise reputation.

PLAYBOOK 64 — Active Directory Replication Abuse (DCSync)

Attack Theme: Compromised Privileged Account → Grant Replication Rights → DCSync Attack → KRBTGT Hash Extraction → Domain-Wide Persistence

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Permission Group Discovery (T1069.002) + Account Discovery (T1087)	Identify accounts with replication privileges	LDAP queries for “Replicating Directory Changes”	Mapping AD replication rights	Source host & user role	Correlate enumeration with recent admin login anomaly	Non-DC host querying replication rights	Increase monitoring immediately	Replication privilege discovery precedes DCSync.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Stage credential dumping tool (e.g., replication abuse utility)	Suspicious execution of directory replication command	Tool staging	Process creation logs on admin workstation	Detect usage of replication APIs outside DC	Replication command from non-DC endpoint	Isolate endpoint	Replication requests should originate only from DCs.
Initial Access	Valid Accounts (T1078) OR Exploitation for Privilege Escalation (T1068)	Gain account with replication rights	Privileged login from rare ASN	Compromised admin credentials	MFA status, PAM mediation	Verify if login bypassed PAM	Admin login without ticket reference	Disable compromised account	DCSync requires elevated AD permissions.

Execution	OS Credential Dumping (T1003.006 DCSync)	Request replication of AD password hashes	Event ID 4662 with replication GUIDs	Directory replication abuse	Security logs for replication events	Identify source host issuing replication request	Replication request from non-DC host	Treat as confirmed compromise	DCSync from non-DC is high-confidence malicious.
Persistence	Golden Ticket (T1558.001 Kerberos Ticket Forging)	Use KRBTGT hash to forge TGT	Unusual long-lived Kerberos ticket	Domain persistence	Kerberos ticket lifetime analysis	Detect abnormal TGT validity period	TGT lifetime exceeding policy baseline	Reset KRBTGT account twice	Forged tickets survive password resets.
Privilege Escalation	Account Manipulation (T1098.003 Add to Group)	Add attacker account to Domain Admins	Event ID 4728 for Domain Admins	Escalated Tier-0 access	AD group membership logs	Correlate group change with replication abuse	Non-IT account granted Domain Admin	Remove privileges immediately	Tier-0 escalation signals full domain risk.
Defense Evasion	Indicator Removal (T1070.001 Clear Logs)	Clear security logs after DCSync	Event ID 1102 on domain controller	Attempt to hide replication abuse	Correlate log clearing with replication events	Detect ingestion gap in SIEM	Logs cleared shortly after replication request	Preserve forensic image	Log clearing on DC is critical incident.
Discovery	Remote System Discovery (T1018)	Enumerate domain controllers	Access to \\DC\$ shares	Mapping domain control points	SMB logs & host access	Detect traversal across DCs	Access to multiple DCs post-DCSync	Increase monitoring	Attackers validate hash usability across DCs.
Lateral Movement	Remote Services (T1021.002 SMB / T1021.001 RDP)	Pivot to additional servers using stolen hashes	NTLM logon Type 3 from admin account	Pass-the-Hash pivot	Logon events & NTLM authentication logs	Correlate NTLM login with replication timeline	Admin logins to >3 servers rapidly	Disable compromised account	Hash reuse spreads compromise quickly.

Collection	Credentials from Password Stores (T1555) + Data from Information Repositories (T1213)	Extract additional secrets & data	Access to SYSVOL & sensitive shares	Expanding compromise	File access logs	Detect access to Group Policy & backup shares	SYSVOL accessed outside baseline	Increase monitoring	SYSVOL contains policy & credential data.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain control post-DCSync	Beaconing from privileged workstation	Active operator presence	DNS logs, JA3 fingerprint	Detect outbound traffic from DC admin host	Admin host beaconing to rare ASN	Block C2 after scoping	DCSync often part of larger campaign.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer extracted hashes externally	Encrypted outbound transfer from admin workstation	Hash exfiltration	NetFlow & DLP alerts	Correlate file creation (NTDS dump/hash file) with outbound spike	Transfer of file containing “ntds” or hash dump	Notify enterprise IR immediately	Hash theft enables long-term domain persistence .
Impact	OS Credential Dumping (T1003.006) + Kerberos Ticket Forging (T1558.001)	Full domain compromise & persistent backdoor	Repeated forged ticket logons	Enterprise trust collapse	KRBTGT rotation status review	Validate no forged tickets active post-reset	Continued suspicious Kerberos auth after reset	Activate enterprise-wide AD recovery plan	DCSync equals total domain control if uncontained.

PLAYBOOK 65 — VPN Split-Tunnel Abuse

Attack Theme: Compromised Endpoint with Active VPN → Split-Tunnel Enabled → Simultaneous Internet & Corporate Access → Internal Pivot Without Perimeter Visibility

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Network Service Discovery (T1046) + Remote System Discovery (T1018)	Identify internal systems reachable via VPN	Internal port scanning from VPN-assigned IP	Internal mapping attempt	Source VPN user & device ID	Correlate scan with EDR telemetry on same endpoint	VPN user scanning multiple subnets	Increase monitoring immediately	Split tunnel allows internal + internet connectivity simultaneously.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Stage scanning or lateral movement tools	Nmap or PowerShell recon tool executed	Tool staging on VPN endpoint	Endpoint process creation logs	Detect recon tool shortly after VPN login	Recon tool launched within minutes of VPN connect	Isolate endpoint	Timing correlation is key signal.
Initial Access	Valid Accounts (T1078) OR Phishing (T1566.002)	Compromise user endpoint prior to VPN session	VPN login from usual location but abnormal behaviour	Endpoint already compromised	Validate EDR health & recent alerts	Correlate phishing event with VPN session start	VPN login followed by malicious process spawn	Disable VPN account temporarily	Compromise often occurs before VPN connection.

Execution	Command and Scripting Interpreter (T1059.001 PowerShell)	Execute commands against internal network	PowerShell remote execution attempts	Internal exploitation phase	Script block logs (4104)	Decode command & identify target systems	Encoded PowerShell contacting internal servers	Contain endpoint	Split tunnel hides C2 traffic from corporate firewall.
Persistence	Account Manipulation (T1098)	Create new VPN profile or store credentials locally	New saved VPN credential entry	Ensuring repeated access	VPN configuration logs	Detect additional VPN configuration changes	VPN profile altered without change ticket	Remove new profile	VPN credential storage increases exposure.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	Elevate privileges locally before internal pivot	SYSTEM-level process spawned	Elevated endpoint control	Process lineage analysis	Trace escalation exploit chain	SYSTEM privileges obtained post-VPN login	Reimage endpoint if necessary	Elevated local access amplifies pivot capability.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable endpoint firewall or EDR	EDR agent stopped during VPN session	Attempt to evade monitoring	Endpoint health logs	Correlate agent stop with internal scan activity	EDR disabled shortly after VPN connect	Treat as confirmed compromise	Endpoint agent disablement is decisive red flag.
Discovery	Permission Group Discovery (T1069.002)	Identify accessible internal groups	LDAP queries from VPN IP	Mapping domain privileges	AD query logs	Detect enumeration of admin groups	VPN user querying Domain Admins group	Increase monitoring	Privilege discovery signals intent escalation.
Lateral Movement	Remote Services (T1021.002 SMB /	Pivot from compromised VPN endpoint	RDP sessions to internal servers	Internal lateral movement	Logon Type 10 events	Correlate RDP events with VPN session timeline	Access to >3 internal servers quickly	Disable VPN account & isolate host	Speed of pivot defines impact scope.

	T1021.001 RDP)								
Collection	Data from Information Repositories (T1213)	Access sensitive file shares	Large file read operations from VPN IP	Data staging	File server audit logs	Correlate access with anomalous working hours	Sensitive share accessed outside baseline	Increase monitoring	Split tunnel may allow direct internet exfiltration.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain external C2 while inside VPN	Simultaneous internet beacon + internal access	Dual connectivity exploitation	Endpoint network logs	Detect concurrent external beacon during VPN session	C2 traffic active during internal pivot	Block C2 after scoping	Split tunnel allows bypass of perimeter detection.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Send internal data directly to internet	Outbound HTTPS transfer from VPN endpoint	Direct data exfiltration bypassing corporate firewall	NetFlow & EDR telemetry	Correlate file access with outbound transfer	Multi-GB outbound traffic during VPN session	Notify compliance immediately	Split tunnel weakens centralized monitoring controls.
Impact	Data Exfiltration (T1041) + Valid Accounts (T1078)	Internal compromise leading to breach	Sensitive data leaked or ransomware deployed	Enterprise exposure	Incident timeline reconstruction	Assess blast radius of accessed internal systems	Multiple systems accessed from VPN user	Activate enterprise IR	VPN configuration can amplify endpoint compromise risk.

PLAYBOOK 67 — Algorithm Poisoning Attack

Attack Theme: Data Pipeline Manipulation → Training Dataset Poisoning → Model Drift / Biased Output → Automated Decision Manipulation

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Org Information (T1591) + Search Open Technical Databases (T1596)	Identify ML model pipelines & data ingestion sources	Enumeration of /ml/train or /dataset/upload endpoints	Mapping model training workflow	Source ASN, API access pattern	Correlate probing with credential attempts	External probing of ML ingestion APIs	Enable strict access control immediately	Public ML endpoints increase exposure.
Resource Development	Develop Capabilities (T1587 contextual ML poisoning prep)	Craft adversarial dataset samples	Unusual data submissions to ingestion pipeline	Preparation of poisoned inputs	Data source origin validation	Detect anomalous data distribution patterns	Spike in specific label/category frequency	Suspend suspicious ingestion	Subtle bias injection harder to detect than large anomalies.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) OR Exploit Public-	Gain write access to dataset storage	Successful API authentication to data pipeline	Compromised data contributor account	Review IAM role permissions	Correlate login with unusual geography	Dataset contributor login from rare ASN	Disable compromised account	Data pipeline access equals model influence.

	Facing Application (T1190)								
Execution	Data Manipulation (T1565.001 Stored Data Manipulation)	Inject poisoned records into training set	Dataset checksum change outside update window	Training data altered	Compare dataset hash vs baseline	Perform statistical outlier detection	Training dataset modified without CAB approval	Roll back dataset immediately	Integrity validation critical in ML pipelines.
Persistence	Account Manipulation (T1098)	Add attacker-controlled data source	New ingestion source configured	Long-term poisoning channel	Pipeline configuration logs	Detect new data source without change ticket	Data source added outside maintenance window	Remove source immediately	Persistent ingestion channel amplifies attack.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Grant higher data modification rights	Role change in ML platform	Expanded data manipulation ability	IAM audit logs	Trace role assignment to compromised account	Non-ML engineer granted training write access	Revoke role immediately	Elevated ML permissions enable broader poisoning.
Defense Evasion	Obfuscated Files or Information (T1027 contextual)	Insert subtle poisoned data to avoid detection	Slight deviation in prediction accuracy	Stealth bias injection	Model performance monitoring dashboard	Compare model metrics pre/post dataset change	Gradual drift in classification thresholds	Increase monitoring	Gradual drift often signals sophisticated poisoning.
Discovery	Cloud Infrastructure Discovery (T1580)	Enumerate model deployment endpoints	Access to /model/deploy APIs	Mapping production pipeline	API audit logs	Detect broad access to ML config endpoints	Access beyond assigned role baseline	Increase monitoring	Model pipeline discovery precedes deployment

									manipulation.
Collection	Data from Information Repositories (T1213)	Extract proprietary training dataset	Bulk dataset download	Data harvesting for adversarial training	Storage audit logs	Correlate download with login anomaly	Multi-GB dataset export	Notify compliance	Dataset theft enables offline adversarial training.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain access to ML control plane	Repeated API calls modifying dataset	Active poisoning cycle	API frequency analysis	Detect repeated write operations at irregular intervals	Continuous ingestion anomalies	Suspend pipeline	Ongoing modifications signal persistent poisoning.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer model weights externally	Model artifact downloaded	IP theft	Storage logs & DLP alerts	Correlate artifact download with dataset modification	Model export post-poisoning	Notify legal & IP protection team	Model weights are strategic intellectual property.
Impact	Data Manipulation (T1565.001) + Resource Hijacking (T1496 contextual)	Biased decisions or automated financial impact	Model outputs deviate significantly from baseline	Business logic compromise	Re-run validation dataset testing	Identify which decisions were influenced	Model retraining required due to integrity breach	Activate enterprise IR & ML governance	Algorithm poisoning impacts automated decisions at scale.

PLAYBOOK 68 — Cloud Snapshot Theft

Attack Theme: Compromised Cloud IAM → Snapshot Creation of VM / Database → Share Snapshot Externally → Offline Data Extraction

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Cloud Infrastructure Discovery (T1580) + Permission Group Discovery (T1069.003 Cloud Groups)	Identify cloud instances & storage volumes	API calls listing EC2 / VM instances	Mapping snapshot targets	Source IAM user & IP ASN	Correlate enumeration with login anomaly	Cloud resource listing from rare ASN	Increase monitoring immediately	Snapshot theft begins with resource mapping.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare script to automate snapshot creation	Repeated API simulation calls	Snapshot automation staging	API activity logs	Detect unusual script-based snapshot testing	High-frequency describe/list API calls	Increase monitoring	Automation indicates intent to mass snapshot.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) OR Steal Application	Compromise IAM account with snapshot privileges	Successful cloud console login from foreign ASN	IAM compromise	MFA status, device fingerprint	Correlate login with impossible travel	Login bypassing usual device fingerprint	Disable compromised account	Snapshot privilege + login anomaly = critical signal.

	n Access Token (T1528)								
Execution	Data from Cloud Storage (T1530) + Data Manipulation (T1565.001 contextual snapshot creation)	Create snapshot of VM or database volume	Snapshot created outside backup schedule	Data staging for theft	Cloud audit logs (CreateSnapshots)	Compare snapshot time vs maintenance window	Snapshot created for production DB unexpectedly	Suspend snapshot & revoke privileges	Unauthorized snapshot creation is decisive indicator.
Persistence	Account Manipulation (T1098)	Create new IAM user with storage access	New access key generated	Ensuring long-term cloud access	IAM audit logs	Correlate new key with compromised account	Access key created after suspicious login	Revoke keys immediately	Snapshot theft often paired with persistent IAM abuse.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Attach higher-privilege policy to IAM user	Policy attachment event	Escalating cloud control	CloudTrail policy change logs	Detect policy granting ec2:CreateSnapshot or s3:*	Privilege escalation post-login anomaly	Revert policy immediately	IAM privilege escalation expands blast radius.
Defense Evasion	Impair Defenses (T1562.001 Disable Logging)	Disable CloudTrail or audit logging	CloudTrail stopped or modified	Conceal snapshot activity	Cloud config audit logs	Correlate log disablement with snapshot creation	Logging disabled shortly after snapshot event	Restore logging immediately	Logging disablement is high-confidence malicious.

Discovery	Cloud Infrastructure Discovery (T1580)	Identify backup retention policies	API calls describing snapshot permissions	Preparing cross-account sharing	Audit API logs	Detect DescribeSnapshotAttribute calls	Enumeration of snapshot sharing settings	Increase monitoring	Snapshot permission reconnaissance precedes theft.
Collection	Archive Collected Data (T1560.001 contextual)	Copy snapshot to attacker-controlled account	Snapshot shared with external account ID	Data staging for offline extraction	Snapshot attribute change logs	Identify external account ID & region	Snapshot shared outside organisation	Remove share immediately	Cross-account snapshot sharing is decisive red flag.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain cloud API control	Continuous API calls from foreign ASN	Active operator in cloud	API frequency analysis	Detect sustained API activity from rare IP	API usage persists after working hours	Rotate credentials & isolate account	Cloud API C2 blends into normal operations.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Extract data from attached snapshot externally	New instance launched from shared snapshot	Offline data extraction	Cloud provisioning logs	Correlate new instance launch in external account	Snapshot copied to unknown region/account	Notify compliance immediately	Snapshot theft bypasses endpoint DLP entirely.
Impact	Data Exfiltration (T1041) + Valid Accounts (T1078)	Full database / VM data exposed	Sensitive data appears externally	Confidentiality breach	Data classification review	Assess scope of data within snapshot	Snapshot contained production DB	Activate enterprise IR & regulator notification	Snapshots often contain entire system images including credentials.

BYZEMER

PLAYBOOK 69 — MFA Bypass via Legacy Protocol

Attack Theme: Credential Compromise → Authentication via Legacy Protocol (IMAP / POP3 / SMTP AUTH / NTLM) → MFA Not Enforced → Cloud & Internal Access

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Identity Information (T1589) + Account Discovery (T1087)	Identify accounts enabled for legacy authentication	Authentication attempts using IMAP/POP3	Testing legacy protocol access	Source ASN & user-agent	Correlate login attempts with breach database exposure	Multiple legacy auth attempts for same account	Enable monitoring & rate limit	Legacy protocols often bypass conditional access.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare credential stuffing or brute-force script	Repeated basic-auth login attempts	Automated testing of credentials	Authentication failure logs	Detect spray pattern across multiple accounts	Same password attempted across >20 users	Temporarily lock accounts	Basic-auth attempts are common MFA bypass vector.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) + Credential Stuffing	Authenticate via legacy protocol without MFA	Successful IMAP login from foreign ASN	MFA bypass achieved	Verify if conditional access applied	Confirm authentication method = legacy/basic	Successful legacy auth from rare ASN	Disable legacy protocol immediately	Successful legacy login = high-confidence compromise.

	(T1110.004)								
Execution	Email Collection (T1114.002 Remote Email Collection)	Access mailbox contents	Bulk email retrieval via IMAP	Data harvesting	Mailbox audit logs	Detect large mail sync from foreign IP	Full mailbox sync outside business hours	Revoke sessions & reset password	Mailbox access enables BEC & thread hijack.
Persistence	Account Manipulation (T1098)	Create app password or enable legacy auth	App password generated	Maintaining MFA bypass	Account settings audit logs	Correlate app password creation with login anomaly	App password created post-legacy login	Remove app password	App passwords circumvent MFA enforcement.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Add compromised account to privileged group	Role assignment event in cloud IAM	Expanding access scope	IAM audit logs	Trace privilege grant to compromised user	Non-admin account added to admin role	Remove privilege immediately	Role escalation amplifies impact.
Defense Evasion	Obfuscated Files or Information (T1027 contextual low-and-slow access)	Access mailbox slowly to avoid detection	Low-volume email access over days	Stealth mailbox monitoring	Access frequency baseline analysis	Detect subtle long-term IMAP sessions	Repeated off-hours legacy auth	Increase monitoring	Low-and-slow sync avoids threshold alerts.
Discovery	Permission Group Discovery (T1069.003)	Identify finance or admin contacts	Searching mailbox for keywords “invoice”, “password”	Preparing BEC or credential theft	Mailbox search audit logs	Detect suspicious keyword queries	Bulk search of finance-related emails	Increase monitoring	Mailbox reconnaissance signals financial targeting.

	Cloud Groups)								
Collection	Data from Information Repositories (T1213)	Extract attachments & sensitive data	Multiple attachment downloads	Data staging	Attachment access logs	Correlate downloads with foreign IP login	Sensitive attachment access post-legacy login	Enable DLP controls	Attachment harvesting often precedes fraud.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain access via legacy sessions	Persistent IMAP session from same ASN	Ongoing mailbox control	Session duration analysis	Detect continuous legacy authentication attempts	Legacy session active for extended period	Disable legacy protocol globally	Legacy protocols lack advanced telemetry.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Forward emails externally	Forwarding rule created to external account	Data exfiltration	Mailbox rule audit logs	Correlate rule creation with legacy login	Forwarding rule post-legacy auth	Remove rule & notify compliance	Forwarding rules common in mailbox compromise.
Impact	Valid Accounts (T1078) + Financial Fraud (T1657 contextual)	BEC, credential theft, internal pivot	Fraudulent payment request sent	Financial & reputational damage	Incident timeline reconstruction	Correlate legacy login with outbound scam email	Payment initiated after mailbox compromise	Activate crisis & IR response	MFA bypass via legacy protocol undermines identity controls.

PLAYBOOK 70 — Supply Chain CI/CD Pipeline Injection

Attack Theme: Compromised Developer / CI Account → Malicious Code Injected into Pipeline → Automated Build & Deployment → Signed Backdoored Release Distributed

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Account Discovery (T1087) + Permission Group Discovery (T1069.002)	Identify CI/CD admins & repository maintainers	Enumeration of repository permissions	Mapping high-value pipeline accounts	Source IP, user role	Correlate enumeration with login anomaly	Non-dev user querying pipeline permissions	Increase monitoring immediately	CI/CD admins are supply-chain Tier-0 assets.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare malicious build script or dependency	Suspicious commit adding obfuscated dependency	Staging injection payload	Review commit author & signing status	Compare dependency hash vs approved registry	New dependency from unknown registry	Suspend pipeline execution	Dependency injection is common supply-chain vector.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) OR Phishing (T1566.002)	Compromise developer or CI service account	Successful login to Git/CI platform from rare ASN	Account takeover	MFA enforcement & device fingerprint	Correlate login with impossible travel	CI admin login outside baseline	Disable compromised account	CI account compromise equals release control.

Execution	Modify System Process (T1543 contextual pipeline modification)	Inject malicious step into pipeline YAML	CI pipeline configuration modified	Build process tampering	Audit pipeline config changes	Compare YAML hash vs baseline	Pipeline modified without CAB approval	Revert change immediately	Pipeline YAML integrity critical.
Persistence	Account Manipulation (T1098)	Add attacker-controlled SSH key to repository	New SSH key added to maintainer account	Persistent repository access	Repository audit logs	Correlate SSH key addition with login anomaly	SSH key added outside change window	Remove key immediately	SSH key persistence bypasses password resets.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Grant elevated CI permissions	User promoted to repository owner	Expanded control over release process	IAM audit logs	Trace privilege assignment to compromised account	Non-maintainer granted owner rights	Revoke privileges	Owner rights enable silent injection.
Defense Evasion	Obfuscated Files or Information (T1027)	Insert subtle backdoor code to avoid detection	Small code change with obfuscated function	Stealthy backdoor	Code review logs	Analyse commit diff for encoded strings	Minor commit triggers major runtime behaviour	Suspend release	Small changes can hide major impact.
Discovery	Cloud Infrastructure Discovery (T1580)	Enumerate artifact repositories & container registries	API calls listing container images	Mapping distribution channels	Registry audit logs	Detect access beyond normal scope	Broad access to artifact repository	Increase monitoring	Attackers map distribution vectors before deployment.

Collection	Data from Information Repositories (T1213)	Access source code & secrets in pipeline	Access to secret environment variables	Secret harvesting	CI secret access logs	Detect environment variable dump in logs	Secrets accessed during anomalous pipeline run	Rotate exposed secrets	CI secrets often contain API keys & signing keys.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain control of injected backdoor	Build server beaconing externally	Active malicious component	Network telemetry from build host	Detect outbound traffic from CI environment	CI server contacting rare ASN	Block C2 after scoping	CI environments rarely need external outbound internet.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Exfiltrate source code or signing keys	Encrypted transfer from build server	IP theft	NetFlow & DLP alerts	Correlate file access with outbound spike	Transfer of .pem or signing artifacts	Notify legal & regulator if required	Signing keys & source code are critical IP assets.
Impact	Supply Chain Compromise (T1195.002) + Subvert Trust Controls (T1553.002 Code Signing)	Distribute malicious update to customers	Signed release contains malicious logic	Widespread downstream compromise	Validate artifact integrity & SBOM	Compare release hash with previous builds	Compromised release deployed to production	Activate enterprise crisis response	CI/CD compromise propagates trust breach to customers.

PLAYBOOK 71 — Router Configuration Hijacking

Attack Theme: Compromised Network Device Credentials → Router Config Modification → DNS / Route Manipulation → Traffic Interception & Internal Pivot

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Network Service Discovery (T1046) + Account Discovery (T1087)	Identify exposed router management interfaces	Repeated access to TCP 22/443 on router IP	Probing admin interface	Source ASN & login pattern	Correlate scan with credential brute-force attempts	Enumeration of network devices from foreign ASN	Restrict management interface immediately	Internet-exposed management ports are high-risk.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare credential brute-force or exploit script	Multiple failed SSH login attempts	Automated login testing	Authentication logs	Detect password spraying across router accounts	>20 failed logins in short window	Temporarily block IP	Basic auth brute-force common entry vector.
Initial Access	Valid Accounts (T1078) OR Exploit Public-Facing Application (T1190)	Gain router admin access	Successful SSH/HTTPS login from rare ASN	Router compromise	Verify MFA enforcement & source IP	Confirm if login passed through bastion host	Direct admin login to router from internet	Disable compromised credentials	Router admin login outside NOC baseline is critical.

Execution	Modify System Configuration (T1601.001 Modify Network Device Config)	Change DNS or routing rules	DNS server IP changed on router	Traffic redirection begins	Compare running config vs baseline	Identify modified sections in startup-config	DNS pointing to unknown resolver	Restore known-good config immediately	DNS change enables credential harvesting.
Persistence	Account Manipulation (T1098)	Create new hidden admin account	New local admin created on router	Persistent device access	Router account audit logs	Correlate account creation with suspicious login	Hidden admin added outside change window	Remove account	Hidden router accounts enable long-term control.
Privilege Escalation	Exploitation for Privilege Escalation (T1068 contextual firmware exploit)	Escalate to full root/system access	Firmware exploitation attempt logged	Deep device compromise	Firmware integrity check	Compare firmware hash vs vendor baseline	Firmware modified unexpectedly	Reflash firmware	Firmware compromise undermines entire network trust.
Defense Evasion	Impair Defenses (T1562.001 Disable Logging)	Disable router logging or SNMP alerts	Logging configuration modified	Concealment attempt	Syslog forwarding config	Detect removal of log forwarding	Syslog disabled post-login anomaly	Restore logging immediately	Loss of router logs is high-confidence malicious signal.
Discovery	Network Service Discovery (T1046)	Map internal subnets via router	Routing table queries	Internal mapping	Review route table access logs	Detect commands listing internal routes	Route inspection from non-NOC IP	Increase monitoring	Router-level visibility enables broad mapping.

Lateral Movement	Remote Services (T1021.002 SMB / T1021.001 RDP contextual pivot via MITM)	Pivot into internal systems via traffic interception	Internal credentials observed in logs	Credential interception via DNS redirect	Endpoint authentication anomalies	Correlate login events with DNS modification timeline	Multiple login failures post-DNS change	Reset affected credentials	DNS hijack can capture internal passwords.
Collection	Network Sniffing (T1040)	Capture sensitive traffic	ARP spoofing or port mirror change	Traffic monitoring enabled	Interface configuration logs	Detect new port mirroring configuration	Mirror port enabled without change ticket	Disable mirror configuration	Router-level sniffing bypasses endpoint controls.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain remote router control	Repeated HTTPS admin sessions	Active operator control	Session duration & IP correlation	Detect persistent login from foreign ASN	Router login at unusual hours	Block source IP & rotate credentials	Router control enables stealthy internal attack.
Exfiltration	Exfiltration Over C2 Channel (T1041)	Redirect or siphon traffic externally	Increased outbound DNS queries to rare resolver	Data exfil via DNS manipulation	DNS traffic analysis	Correlate resolver change with traffic spike	High DNS traffic to unknown IP	Notify compliance if data involved	DNS exfiltration can bypass traditional DLP.
Impact	Traffic Manipulation (T1565 contextual) + Valid Accounts (T1078)	Network-wide interception & compromise	Users redirected to phishing portals	Enterprise-wide exposure	Full config audit & password reset	Assess scope of intercepted traffic	DNS & route changes confirmed malicious	Activate enterprise IR & network isolation	Router compromise undermines perimeter trust model.

BYZEMER

PLAYBOOK 72 — Payment QR Code Replacement

Attack Theme: Compromise of Payment Portal / Physical Tampering → Replacement of Legitimate QR Code → Funds Redirected to Attacker Account

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Org Information (T1591) + Search Open Technical Databases (T1596)	Identify payment QR endpoints or merchant IDs	Repeated scraping of payment page	Target profiling of payment channel	Source ASN & scraping pattern	Correlate scraping with merchant ID enumeration	Enumeration of multiple merchant QR endpoints	Enable rate limiting & WAF rules	Public payment endpoints increase exposure.
Resource Development	Acquire Infrastructure (T1583.001 Domains)	Create attacker-controlled payment wallet	Newly registered merchant wallet ID	Fraud infrastructure staging	Validate merchant registration logs	Detect merchant ID similar to legitimate brand	Wallet created using lookalike business name	Alert fraud team	Attackers prepare wallet before replacement.
Initial Access	Valid Accounts (T1078) OR Exploit Public-Facing Application (T1190)	Compromise web CMS or payment portal	Successful CMS login from rare ASN	Admin account compromise	MFA enforcement & device fingerprint	Correlate login with impossible travel	CMS admin login outside baseline	Disable compromised account	CMS access enables QR replacement.

Execution	Data Manipulation (T1565.001 Stored Data Manipulation)	Replace legitimate QR image with attacker QR	File integrity monitoring alert on QR image	Payment redirection begins	Compare QR image hash vs baseline	Decode QR to verify merchant ID	QR code points to unknown wallet	Restore original QR immediately	QR code integrity must be validated regularly.
Persistence	Account Manipulation (T1098)	Add attacker admin to CMS	New admin account created	Maintaining control of portal	CMS audit logs	Correlate account creation with suspicious login	Admin created outside change window	Remove account immediately	Persistent CMS access enables repeated fraud.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Grant elevated rights to attacker account	Role upgraded to super-admin	Expanded portal control	Role change logs	Trace privilege change timeline	Non-IT account granted super-admin	Revoke privileges	Elevated CMS roles increase fraud impact.
Defense Evasion	Obfuscated Files or Information (T1027 contextual image overlay)	Embed QR overlay without obvious change	Slight visual change in QR area	Stealthy manipulation	Visual & hash comparison	Detect pixel-level change vs baseline	Minor image change but new QR content	Increase monitoring	Visual similarity hides financial redirection.
Discovery	Account Discovery (T1087 contextual)	Identify additional merchant accounts	Access to merchant configuration panel	Expanding fraud scope	Merchant audit logs	Detect browsing of multiple merchant profiles	Merchant panel accessed outside role baseline	Increase monitoring	Multi-merchant targeting increases impact.
Collection	Data from Information	Extract transaction logs	Bulk download	Revenue intelligence gathering	Export logs	Correlate export with	Transaction logs exported	Notify compliance	Transaction data aids

	Repositories (T1213)		of payment reports			CMS login anomaly	unexpectedly		strategic fraud.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain portal control	Repeated CMS sessions from foreign ASN	Active operator managing fraud	Session duration & frequency	Detect persistent login patterns	CMS session active at unusual hours	Block source IP & rotate credentials	Continuous portal access indicates active fraud.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer payment data externally	Encrypted outbound transfer from CMS server	Data leak	NetFlow & DLP alerts	Correlate data export with QR modification	Multi-GB data transfer post-modification	Notify legal & regulator if required	Payment data exposure triggers regulatory reporting.
Impact	Financial Fraud (T1657 contextual) + Data Manipulation (T1565.001)	Customers' payments redirected	Spike in payment disputes	Financial & reputational damage	Transaction reconciliation	Compare merchant ID before & after QR change	Multiple payments redirected to new wallet	Activate fraud & crisis response	Payment redirection causes immediate financial loss.

PLAYBOOK 73 — Smart Contract Exploit

Attack Theme: Vulnerable Smart Contract Logic → Exploit of Reentrancy / Access Control Flaw → Unauthorized Fund Transfer → On-Chain Asset Drain

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Search Open Technical Databases (T1596) + Gather Victim Org Information (T1591)	Identify deployed contract address & ABI	High-frequency read calls to contract	Mapping contract behaviour	Source wallet address & RPC endpoint	Correlate read-call spike with test transactions	Multiple small test transactions before exploit	Increase monitoring	Test transactions often precede main exploit.
Resource Development	Develop Capabilities (T1587 contextual exploit crafting)	Craft exploit transaction payload	Custom transaction with complex calldata	Preparing exploit function call	Decode calldata & method signature	Compare method selector vs contract ABI	Unknown function signature interaction	Increase monitoring	Abnormal calldata indicates crafted exploit attempt.
Initial Access	Exploit Public-Facing Application (T1190 contextual smart	Trigger vulnerable function (e.g., reentrancy)	Sudden large state change in contract	Vulnerability successfully triggered	Review recent contract interactions	Identify transaction hash & attacker wallet	Repeated function invocation in single block	Freeze contract if possible	Rapid recursive calls indicate reentrancy exploit.

	contract flaw)								
Execution	Data Manipulation (T1565.001 Stored Data Manipulation contextual on-chain state change)	Manipulate contract state to drain funds	Unexpected token balance decrease	Fund extraction in progress	Validate contract balance & internal ledger	Analyse block sequence & gas usage pattern	Multiple withdraw calls in single transaction	Halt related services	On-chain logic flow enables automated draining.
Persistence	Account Manipulation (T1098 contextual control over admin key)	Gain control of contract admin key	OwnershipTransferred event logged	Attacker gains admin rights	Check admin wallet integrity	Correlate ownership change with exploit timeline	Contract ownership changed unexpectedly	Revoke compromised admin key	Admin key compromise escalates exploit impact.
Privilege Escalation	Account Manipulation (T1098.003 contextual role change)	Assign privileged role within contract	RoleGranted event triggered	Expanded contract permissions	Review role assignment logs	Identify which wallet received role	Non-approved wallet granted elevated role	Remove role via governance	Role abuse enables future exploitation .
Defense Evasion	Obfuscated Files or Information (T1027 contextual	Encode exploit calls to evade detection	Unusual calldata encoding pattern	Conceal exploit intent	Decode raw transaction input	Compare encoded input with exploit pattern database	Obfuscated method calls across multiple	Increase monitoring	Encoded calldata hides exploit logic.

	calldata encoding)						transactions		
Discovery	Cloud Infrastructure Discovery (T1580 contextual RPC & node mapping)	Identify node endpoints & oracle feeds	Multiple queries to price oracle contract	Mapping dependent systems	Monitor oracle interaction logs	Detect unusual read patterns on oracle	Oracle queried outside baseline frequency	Increase monitoring	Oracle mapping may precede price manipulation.
Collection	Data from Information Repositories (T1213 contextual blockchain state dump)	Extract contract state for analysis	Large state queries via RPC	Preparing optimized exploit	RPC access logs	Correlate state dump with exploit attempts	Bulk state read before exploit execution	Limit RPC access	State knowledge enables precise draining.
Command & Control	Application Layer Protocol (T1071.001 Web)	Coordinate exploit via botnet wallets	Multiple attacker wallets interacting in sequence	Coordinated exploitation	Analyse wallet clustering	Identify wallet grouping & transaction timing	Multiple wallets draining funds in same block	Flag wallet cluster	Multi-wallet coordination increases speed of drain.
Exfiltration	Exfiltration Over Web Services (T1567.002 contextual crypto asset transfer)	Transfer drained tokens to mixer/exchange	Rapid token transfer to external wallet	Laundering funds	Monitor on-chain transfers	Trace fund flow via blockchain analytics	Funds moved to mixer service	Notify regulator if required	Speed of laundering reduces recovery probability.

Impact	Financial Fraud (T1657 contextual) + Data Manipulation (T1565.001)	On-chain asset drain & loss of funds	Contract balance reduced to near zero	Financial & reputational loss	Incident reconstruction & audit	Identify vulnerability root cause	Total Value Locked (TVL) drop detected	Activate crisis & disclosure plan	Smart contract flaws cause irreversible financial impact.
--------	--	--------------------------------------	---------------------------------------	-------------------------------	---------------------------------	-----------------------------------	--	-----------------------------------	---

PLAYBOOK 74 — IoT Botnet Recruitment

Attack Theme: Exploitation of Internet-Exposed IoT Devices → Default Credential Abuse / Firmware Exploit → Malware Implant → Enrollment into Botnet for DDoS / Proxy / C2 Relay

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Network Service Discovery (T1046) + Search Open Technical Databases (T1596)	Identify exposed IoT devices (camera, DVR, router, printer)	Repeated scanning of TCP 23/22/80 on IoT subnet	Probing for vulnerable IoT endpoints	Source ASN & scan rate	Correlate scan with failed login attempts	Multiple IoT IPs probed sequentially	Enable rate limiting & firewall rule	IoT devices often exposed unintentionally.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare exploit or credential brute-force script	Multiple default credential login attempts	Automated exploitation attempt	Device authentication logs	Detect repeated admin/admin login attempts	>20 login attempts across IoT fleet	Block offending IP	Default credentials remain primary IoT risk.
Initial Access	Valid Accounts (T1078) OR Exploit Public-Facing	Gain device access	Successful Telnet/SSH login to IoT device	Device compromise	Verify source IP & geo	Correlate login with scan pattern	IoT login from foreign ASN	Disable device access externally	IoT compromise often silent and unnoticed.

	Application (T1190)								
Execution	Command and Scripting Interpreter (T1059 contextual BusyBox / shell)	Download and execute botnet malware	Device download s binary from unknown URL	Malware deployment	Inspect outbound HTTP request	Validate binary hash against threat intel	IoT device connecting to rare ASN	Isolate device from network	IoT devices rarely need outbound internet access.
Persistence	Modify System Image (T1601.001 Firmware Modification)	Modify startup script for persistence	Startup config altered	Ensuring malware survives reboot	Compare firmware hash vs vendor baseline	Detect modified rc.local or startup service	Startup script changed unexpectedly	Reflash firmware	Firmware persistence increases botnet longevity.
Privilege Escalation	Exploitation for Privilege Escalation (T1068 contextual firmware vuln)	Gain root-level control	Root shell spawned	Full device control	Process tree & privilege level	Identify exploit chain used	Root shell post-login anomaly	Reimage device	Root access enables full network misuse.
Defense Evasion	Impair Defenses (T1562.001 Disable Logging)	Disable device logging	Syslog disabled or altered	Concealment attempt	Log forwarding configuration	Detect removal of central logging	IoT logs stop unexpectedly	Restore logging immediately	Loss of logs signals malicious tampering.
Discovery	Network Service Discovery (T1046)	Scan internal network from IoT device	Internal port scanning from IoT IP	Pivot attempt into corporate network	NetFlow & IDS logs	Correlate IoT device scanning activity	IoT device scanning >5 internal hosts	Isolate device	Compromised IoT can pivot internally.

Collection	Network Sniffing (T1040)	Capture traffic passing through network	ARP spoofing or unusual broadcast traffic	Traffic monitoring	Switch logs & ARP table inspection	Detect abnormal ARP traffic patterns	ARP anomalies after IoT compromise	Remove device	IoT devices may be used for traffic interception.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain botnet control	Beaconing every 60 seconds to C2 domain	Active botnet enrollment	DNS logs & JA3 fingerprint	Detect fixed-interval beacon pattern	Persistent C2 from IoT subnet	Block C2 domain/IP	Beacon interval consistency is strong indicator.
Exfiltration	Exfiltration Over C2 Channel (T1041)	Send captured data or device info	Outbound encrypted traffic spike	Data exfiltration or device reporting	NetFlow analysis	Correlate beaconing with data spike	Unusual data volume from IoT subnet	Notify compliance if data involved	IoT devices often outside DLP monitoring.
Impact	Resource Hijacking (T1496) + Network Denial of Service (T1498 contextual)	Use device in DDoS or proxy botnet	High outbound traffic from IoT device	Botnet participation	Traffic volume baseline comparison	Identify target IP of outbound flood	IoT device generating DDoS traffic	Block outbound traffic & isolate device	IoT botnets amplify attack scale externally.

PLAYBOOK 75 — Sensitive Meeting Eavesdropping

Attack Theme: Compromised Conferencing Account / Meeting Link Leakage → Unauthorized Silent Join → Recording & Intelligence Collection → Strategic Information Theft

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Identity Information (T1589) + Account Discovery (T1087)	Identify executives & recurring meeting links	Scraping of calendar invite links	Target profiling of sensitive meetings	Source ASN & email logs	Correlate scraping with external access attempts	External IP accessing calendar metadata	Enable meeting link protection	Meeting links often reused and exposed.
Resource Development	Acquire Infrastructure (T1583.001 Domains)	Prepare lookalike conferencing domain	Domain similar to official meeting URL	Phishing infrastructure staging	WHOIS & TLS reuse check	Detect employee's resolving lookalike domain	Internal DNS queries to fake meeting domain	Block domain immediately	Lookalike domains support silent access.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) OR Phishing (T1566.002)	Compromise conferencing account or obtain link	Successful login to conferencing platform from rare ASN	Account takeover or link leakage	MFA enforcement & device fingerprint	Correlate login with impossible travel	Executive conferencing login from foreign ASN	Revoke sessions immediately	Executive accounts are high-value intelligence targets.

Execution	Audio Capture (T1123) + Screen Capture (T1113)	Join meeting silently & record session	Unknown participant joined meeting	Unauthorized presence	Validate participant list & IP address	Compare join IP vs registered employee location	Anonymous participant in restricted meeting	Remove participant & rotate link	Silent participants often overlooked in large meetings.
Persistence	Account Manipulation (T1098)	Enable automatic cloud recording	Recording setting modified	Ensuring capture of future meetings	Platform audit logs	Detect recording enabled without approval	Recording toggled outside baseline	Disable recording & review logs	Recording misuse enables ongoing espionage.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Grant attacker co-host privileges	Host role transferred unexpectedly	Expanded meeting control	Role change audit logs	Correlate host change with suspicious login	Co-host role assigned to unknown participant	Revoke privileges immediately	Co-host access enables recording & participant control.
Defense Evasion	Obfuscated Files or Information (T1027 contextual hidden display name)	Join meeting under disguised name	Participant named similar to internal employee	Identity spoofing	Compare email domain vs display name	Validate SSO identity mapping	Mismatch between display name & account domain	Increase monitoring	Display name spoofing bypasses casual review.
Discovery	Permission Group Discovery (T1069.003 Cloud Groups)	Identify additional high-value meetings	Access to executive calendar events	Mapping strategic sessions	Calendar audit logs	Detect unusual calendar access queries	Calendar accessed outside role baseline	Increase monitoring	Calendar reconnaissance signals espionage.
Collection	Data from Information	Download meeting	Transcript export event	Intelligence harvesting	Transcript export logs	Correlate export	Transcript exported post-	Suspend export rights	Transcripts often contain

	Repositories (T1213)	transcripts & chat logs				with login anomaly	suspicious login		sensitive decisions.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain platform access	Repeated conferencing platform sessions	Active operator monitoring meetings	Session duration analysis	Detect recurring joins from rare ASN	Same foreign IP joining multiple meetings	Block source IP	Repeated meeting joins indicate ongoing espionage.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer recordings externally	Large download of recorded meeting file	Intelligence exfiltration	NetFlow & DLP alerts	Correlate recording download with external IP	Multi-GB recording transfer	Notify legal & executive team	Executive meeting leakage has strategic impact.
Impact	Data Exfiltration (T1041) + Impersonation (T1656 contextual)	Strategic corporate intelligence exposed	Confidential discussion appears externally	Competitive or geopolitical impact	Incident timeline reconstruction	Assess which meetings were accessed	Confirm unauthorized recording of board-level session	Activate enterprise crisis response	Meeting compromise affects strategic decision integrity.

PLAYBOOK 76 — Zero-Click Mobile Exploit

Attack Theme: Exploit via Message/Push/VoIP/Media Parsing → No User Interaction → Silent Spyware Implant → Credential & Data Theft → Executive Surveillance

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Identity Information (T1589) + Gather Victim Org Information (T1591)	Identify executive mobile numbers & messaging platforms	OSINT shows exec contact details leaked	Target profiling	Confirm which exec devices are at risk	Check if number/e mail appears in breach data	Executive contact info exposed publicly	Increase monitoring	Zero-click attacks are targeted and selective.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare zero-click exploit chain	Threat intel indicates active exploit campaign targeting platform	Capability staging	Verify platform/version exposure	Cross-check device OS versions vs known vulnerable ranges	Executive device on outdated OS	Accelerate patching	Zero-click success depends heavily on device version.
Initial Access	Exploit Public-Facing	Trigger exploit via iMessage/WhatsApp/VoIP/media parsing	No user click; device shows	Silent initial	Mobile EDR health, crash logs	Review messaging app crash	Repeated crash of messagin	Isolate device from	Crashes can be the only

	Applicati on (T1190 contextu al mobile app parser)		brief service crash	compro mise		patterns & timestam ps	g service on exec device	sensitive apps	early signal.
Execution	Comman d and Scripting Interpret er (T1059 contextu al mobile shell)	Execute spyware payload in memory	Suspicious process spawn by system service	Payload executio n	Mobile EDR telemetry	Identify unusual child process of messaging service	System service spawning unknown binary	Contain device	Zero- click often executes under trusted services.
Persistence	Create or Modify System Process (T1543 contextu al mobile persisten ce)	Maintain persistence after reboot	New privileged service installed/profil e added	Long- term implant	MDM profile inventory	Check for unknown configurati on profiles or certificate s	New profile installed without IT approval	Remove profile & re- enrol device	Profiles can grant deep control on mobile.
Privilege Escalation	Exploitati on for Privilege Escalatio n (T1068)	Break out to higher privilege (kernel/root)	Mobile EDR reports privilege escalation attempt	Deep compro mise	OS integrity status	Validate jailbreak/r oot indicators	Root/jailbr eak indicators appear suddenly	Full device wipe & rebuild	Root- level access enables full surveillan ce.
Defense Evasion	Impair Defenses (T1562.0 01	Disable mobile EDR or hide implant	Mobile EDR stops reporting	Stealth mode activated	MDM health checks	Detect telemetry gap from	Device stops checking in	Treat as confirmed compromis e	Telemetr y loss on a single exec

	Disable Security Tools)					single device	unexpectedly		device is critical.
Discovery	System Information Discovery (T1082)	Enumerate device data & apps	Access to contacts/calendar increases	Target mapping	App permission changes	Detect new permission grants without user action	Messaging app requests new permissions	Increase monitoring	Permissions drift signals malicious control.
Collection	Audio Capture (T1123) + Screen Capture (T1113)	Capture calls, messages, screenshots	Unusual microphone/camera access events	Active surveillance	Device privacy indicators & logs	Correlate sensor access with network beacons	Mic/camera accessed during idle hours	Isolate device immediately	Executive surveillance is often the primary objective.
Command & Control	Application Layer Protocol (T1071.001 Web) + Encrypted Channel (T1573)	Maintain covert communications	Small encrypted beacons at fixed intervals	C2 active	DNS logs (if available), mobile proxy logs	Identify beacon pattern & destination ASN	Beaconing to known spyware infra	Block C2 after scoping	Mobile C2 often uses low-bandwidth stealth.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Upload chats, documents, tokens	Outbound data from device while idle	Data theft	NetFlow / VPN client logs	Correlate exfil bursts with device beacons	Repeated upload bursts from exec device	Notify legal & exec protection	Mobile exfil often bypasses enterprise DLP.

Impact	Data Exfiltration (T1041) + Collection (T1005 contextual on-device data)	Intelligence loss & account compromise	Executive accounts compromised after device anomaly	Strategic breach	Reset executive credentials	Assess downstream access from mobile tokens	Executive cloud sessions created from rare ASN	Activate enterprise crisis response	Mobile compromise can cascade into cloud takeover.
--------	--	--	---	------------------	-----------------------------	---	--	-------------------------------------	--

PLAYBOOK 77 — Executive Travel Wi-Fi Compromise

Attack Theme: Rogue/Compromised Public Wi-Fi → Evil Twin / Captive Portal Phishing → Credential & Token Theft → Cloud & VPN Account Takeover

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Identity Information (T1589) + Network Service Discovery (T1046 contextual SSID spoofing)	Identify executive travel itinerary & target hotel/airport SSID	Executive connects to SSID similar to venue Wi-Fi	Potential Evil Twin exposure	Confirm SSID/BSSID & venue	Compare BSSID vs known legitimate access points	SSID match but different BSSID & open auth	Instruct device to disconnect immediately	SSID similarity alone is insufficient validation.
Resource Development	Acquire Infrastructure (T1583.003 Virtual Private Server)	Stand up rogue AP + captive portal	Captive portal requesting corporate credentials	Phishing infrastructure in place	Portal URL & TLS certificate	Inspect certificate issuer & domain age	Portal uses lookalike SSO domain	Block domain & warn exec	Captive portal phishing common on travel Wi-Fi.
Initial Access	Phishing (T1566.002 Spearphishing Link)	Harvest SSO/VPN credentials or	Executive SSO login from public ASN	Credential/token capture achieved	Verify device posture & MFA event	Correlate login with travel timeline	SSO login from airport ASN + new device fingerprint	Force password reset &	Travel + new device + public

	contextual captive portal) OR Adversary-in-the-Middle (T1557.001)	session tokens						revoke sessions	ASN is high-risk combo.
Execution	Use of Alternate Authentication Material (T1550.004 Web Session Cookie)	Replay stolen session cookie	New cloud session without MFA prompt	Token replay	Review session issuance & refresh tokens	Compare session ID vs device posture check	Session created without MFA challenge	Revoke all refresh tokens	Token replay bypasses password change impact.
Persistence	Account Manipulation (T1098)	Add new MFA method or app password	New MFA device/app password added	Ensuring continued access	Account security settings audit	Correlate MFA change with travel Wi-Fi login	MFA method added from public ASN	Remove new factors immediately	MFA change during travel is decisive red flag.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Grant self elevated cloud role	Role assignment in cloud IAM	Expanding access	IAM audit logs	Trace role grant to compromised session	Exec account granted admin role unexpectedly	Revoke role immediately	Exec accounts often have high baseline privileges.
Defense Evasion	Obfuscated Files or Information (T1027 contextual proxying)	Proxy traffic to blend with venue network	Cloud access appears from hotel ASN	Blending with legitimate travel	Compare ASN risk score & historical travel	Detect abnormal access outside meeting schedule	Off-hours cloud access from hotel ASN	Increase monitoring	Legitimate travel can mask malicious activity.

Discovery	Permission Group Discovery (T1069.003 Cloud Groups)	Enumerate accessible resources	Cloud resource listing spike	Mapping assets	API activity logs	Detect broad Describe/List API calls	Enumeration across multiple subscriptions/projects	Increase monitoring	Enumeration signals post-compromise expansion.
Collection	Data from Information Repositories (T1213)	Access executive email/docs	Large file access/download	Data staging	DLP & access logs	Correlate downloads with travel Wi-Fi login	Multi-GB download during travel window	Enable heightened monitoring	Exec mailboxes contain strategic intel.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain access via stolen tokens	Repeated sessions from public ASN	Active operator control	Session duration & IP clustering	Identify persistent session reuse pattern	Same ASN accessing multiple services	Revoke tokens & block ASN	Public ASN persistence suggests adversary control.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Upload stolen data to external storage	Outbound transfer from exec device/cloud	Data theft	NetFlow / CASB alerts	Correlate download → upload sequence	Download spike followed by external upload	Notify legal & exec protection	Rapid data pivot typical after token theft.
Impact	Valid Accounts (T1078) + Data Exfiltration (T1041)	Strategic intel leak or downstream compromise	Executive account used to approve changes	Enterprise-wide exposure	Full timeline reconstruction	Assess token scope & affected systems	Exec cloud session created from rare ASN post-travel	Activate enterprise IR & executive protection plan	Travel scenarios require Zero Trust + device posture enforcement.



PLAYBOOK 78 — E-Signature Workflow Manipulation

Attack Theme: Compromised Business Email / SaaS Account → Modification of E-Signature Routing Rules → Fraudulent Document Approval → Financial / Legal Impact

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Org Information (T1591) + Account Discovery (T1087)	Identify finance approvers & e-sign workflow owners	Enumeration of e-sign workflow settings	Mapping approval chain	Source ASN & SaaS login history	Correlate enumeration with email compromise	Workflow viewed by non-finance user	Increase monitoring immediately	Approval chain visibility precedes manipulation.
Resource Development	Acquire Infrastructure (T1583.001 Domains)	Create lookalike signer email domain	New signer email similar to CFO	Fraud staging	WHOIS & MX record analysis	Detect internal resolution to lookalike domain	Signer email domain recently registered	Block domain & alert finance	Lookalike signers are common fraud tactic.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) OR Phishing (T1566.002)	Compromise e-sign SaaS account	Successful SaaS login from rare ASN	Account takeover	MFA status & device fingerprint	Correlate login with impossible travel	E-sign admin login outside baseline	Revoke sessions & reset password	E-sign accounts often weakly monitored.
Execution	Data Manipulation	Modify document routing or	Workflow rule edited	Approval chain altered	SaaS audit logs	Compare workflow	Signer order changed to	Restore approved workflow	Workflow change is

	(T1565.001 Stored Data Manipulation)	approval sequence	without CAB			version history	attacker email		decisive fraud pivot.
Persistence	Account Manipulation (T1098)	Add alternate email or delegate approver	Delegate signer added	Ensuring continued fraud access	Account settings audit	Detect delegate addition post-login anomaly	Delegate added outside business hours	Remove delegate immediately	Delegation allows silent long-term manipulation.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Promote compromised user to admin	Role changed to super-admin	Expanded control over workflows	SaaS role audit logs	Trace role assignment origin	Non-IT account promoted to admin	Revoke elevated role	Admin rights enable cross-department fraud.
Defense Evasion	Obfuscated Files or Information (T1027 contextual document rename)	Rename document to appear legitimate	Slight document title modification	Conceal fraudulent contract	Compare document metadata	Detect hash mismatch vs approved template	Template modified without review	Increase monitoring	Minor naming changes hide material fraud.
Discovery	Permission Group Discovery (T1069.003 Cloud Groups)	Identify high-value contracts	Access to contract repository	Expanding fraud scope	Document access logs	Detect bulk access to finance/legal folder	Sensitive contracts viewed unexpectedly	Increase monitoring	Contract reconnaissance signals financial targeting.
Collection	Data from Information Repositories (T1213)	Download signed contracts	Export of signed PDF files	Document harvesting	SaaS export logs	Correlate export with login anomaly	Bulk download of signed contracts	Notify legal immediately	Signed contracts contain binding obligations.

Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain SaaS session control	Repeated SaaS logins from foreign ASN	Active operator	Session frequency & ASN correlation	Identify recurring sessions outside business hours	Persistent SaaS login post-reset	Block IP & enforce conditional access	SaaS access blends into legitimate traffic.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer signed contracts externally	Encrypted upload to cloud storage	Legal data theft	CASB & DLP alerts	Correlate download → upload chain	Multi-GB upload after document export	Notify compliance & regulator if needed	Legal exposure may exceed financial loss.
Impact	Financial Fraud (T1657 contextual) + Data Manipulation (T1565.001)	Fraudulent contract approval or fund transfer	Contract executed without CFO approval	Financial & legal liability	Immediate contract validation review	Identify altered routing & impacted documents	Payment released based on manipulated signature	Activate enterprise crisis & legal response	Workflow integrity is critical control in digital approval era.

BYE

PLAYBOOK 79 — Treasury System Manipulation

Attack Theme: Compromised Finance Credentials / Privileged Access → Manipulation of Payment Rules / Beneficiary Details → Large-Value Fund Diversion → Financial & Regulatory Impact

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Org Information (T1591) + Account Discovery (T1087)	Identify treasury approvers & payment workflow owners	Multiple access attempts to treasury portal	Targeting high-value finance users	Source ASN & login pattern	Correlate access attempts with phishing alerts	Enumeration of finance user accounts	Increase monitoring immediately	Finance accounts are high-impact targets.
Resource Development	Acquire Infrastructure (T1583.003 VPS)	Prepare mule accounts & external payment endpoints	New external beneficiary bank account prepared	Fraud infrastructure staging	Validate beneficiary onboarding logs	Check if beneficiary linked to recent email anomaly	Beneficiary created outside finance workflow	Alert fraud & treasury immediately	Mule accounts prepared before manipulation.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) OR Phishing (T1566.002)	Compromise treasury system account	Successful login from rare ASN	Account takeover	MFA logs & device fingerprint	Correlate login with impossible travel	Treasury login from foreign ASN	Force password reset & revoke sessions	Treasury login anomaly is critical severity.

Execution	Data Manipulation (T1565.001 Stored Data Manipulation)	Modify beneficiary details or payment limits	Beneficiary bank account edited	Payment diversion setup	Review audit trail of change	Compare new bank details vs historical baseline	High-value beneficiary edited shortly before payment	Suspend pending payments	Beneficiary change near payment date is decisive signal.
Persistence	Account Manipulation (T1098)	Add secondary approver controlled by attacker	New approver added to workflow	Long-term fraud capability	Treasury workflow audit logs	Correlate approver addition with suspicious login	Approver added outside CAB process	Remove new approver	Workflow manipulation enables repeated fraud.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Elevate compromised account to super-approver	Role upgraded in treasury system	Expanded financial authority	Role change logs	Trace role assignment source session	Non-senior user promoted to super-approver	Revoke elevated role immediately	Elevated finance privileges magnify impact.
Defense Evasion	Obfuscated Files or Information (T1027 contextual transaction description change)	Alter payment description to avoid suspicion	Payment memo field altered subtly	Conceal fraud	Compare transaction metadata vs template	Detect unusual formatting or character anomalies	Transaction description deviates from template	Increase monitoring	Minor description change can hide major diversion.
Discovery	Permission Group Discovery (T1069.003 Cloud Groups)	Identify high-limit accounts	Access to limit configuration panel	Mapping financial authority	Audit limit access logs	Detect browsing of limit configuration pages	Limit panel accessed outside finance team	Increase monitoring	Limit reconnaissance precedes fraud escalation.

	contextual finance roles)								
Collection	Data from Information Repositories (T1213)	Extract transaction history & balances	Bulk export of treasury reports	Intelligence gathering	Export logs	Correlate export with login anomaly	Large export before suspicious payment	Notify compliance	Historical data aids strategic manipulation.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain control of compromised account	Repeated treasury sessions from foreign ASN	Active operator in system	Session duration & ASN correlation	Identify recurring session reuse	Persistent foreign ASN access	Block source & rotate credentials	Continuous session indicates ongoing fraud attempt.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer financial reports externally	Encrypted upload from treasury endpoint	Data leak	DLP & NetFlow alerts	Correlate report export with outbound spike	Financial report uploaded externally	Notify regulator if required	Financial reporting data is sensitive & regulated.
Impact	Financial Fraud (T1657 contextual) + Data Manipulation (T1565.001)	Unauthorized fund transfer executed	High-value transfer to new beneficiary	Direct financial loss & regulatory exposure	Immediate transaction recall attempt	Trace approval chain & timestamp	Payment executed after beneficiary change	Activate crisis management & regulator notification	Timing between beneficiary change & payment is critical detection factor.

PLAYBOOK 80 — RDP Exposure Exploitation

Attack Theme: Internet-Exposed RDP Service → Credential Brute Force / Credential Stuffing → Successful Login → Internal Lateral Movement → Ransomware or Data Theft

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Network Service Discovery (T1046) + Active Scanning (T1595.002)	Identify exposed RDP servers (TCP 3389)	Repeated connection attempts to 3389	Internet scanning for RDP exposure	Source ASN & scan frequency	Correlate scan IP with known brute-force campaigns	Same ASN scanning multiple external IPs	Restrict RDP exposure immediately	Public RDP exposure is high-risk baseline issue.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare brute-force or credential stuffing tool	Multiple failed RDP login attempts	Automated password attack	Windows Security Event 4625	Detect spray pattern across usernames	>50 failed logins in short timeframe	Enable account lockout policy	Password spray often precedes success.
Initial Access	Valid Accounts (T1078) + Brute Force (T1110.001)	Gain RDP access to server	Successful Event ID 4624 (Logon Type 10) from foreign ASN	Credential compromise achieved	Validate source IP & geo	Correlate success after failure burst	Successful login after >20 failures	Disable compromised account	Logon Type 10 from foreign ASN is decisive.

Execution	Command and Scripting Interpreter (T1059.001 PowerShell)	Execute commands post-login	PowerShell launched immediately after RDP login	Interactive attacker activity	Process creation logs (4688)	Analyse command-line arguments	Encoded PowerShell execution post-login	Isolate host	Immediate script execution indicates malicious intent.
Persistence	Create Account (T1136.001 Local Account)	Create new local admin account	New local admin created	Ensuring re-entry	Event ID 4720 / 4732	Correlate account creation with RDP session	Admin account created outside CAB	Remove account	Local admin persistence common in RDP breaches.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	Escalate to SYSTEM or Domain Admin	Token manipulation or exploit detected	Expanded control	EDR privilege escalation alert	Identify exploit or UAC bypass	Domain Admin privileges assigned unexpectedly	Remove elevated privileges	Privilege escalation marks major turning point.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable AV/EDR	Security service stopped	Concealment attempt	EDR health status	Detect service stop events	EDR agent stopped post-RDP login	Treat as confirmed compromise	Disabling EDR signals active adversary.
Discovery	Account Discovery (T1087) + Network Service Discovery (T1046)	Enumerate domain users & servers	net group "Domain Admins" executed	Internal reconnaissance	PowerShell 4104 logs	Detect LDAP query spikes	Enumeration from newly compromised account	Increase monitoring	Enumeration indicates preparation for lateral move.

Lateral Movement	Remote Services (T1021.001 RDP / T1021.002 SMB)	Pivot to additional servers	Multiple RDP/SMB logins across hosts	Spreading control	Event 4624 across multiple hosts	Correlate login chain sequence	>3 hosts accessed within short window	Disable account & isolate endpoints	Speed of spread determines blast radius.
Collection	Data from Information Repositories (T1213)	Access file shares or database	Large file copy from file server	Data staging	File access logs	Detect abnormal \\server\share access	Sensitive share accessed post-RDP login	Monitor outbound traffic	File access may precede ransomware or exfiltration.
Command & Control	Application Layer Protocol (T1071.001 Web)	Deploy remote management tool	Installation of AnyDesk/ScreenConnect	Establish external control	Process & network telemetry	Detect outbound to known RMM infrastructure	RMM installed after RDP compromise	Remove tool & block outbound	Attackers use legitimate RMM for persistence.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Upload stolen data	Large outbound HTTPS transfer	Data theft	NetFlow & DLP alerts	Correlate file staging with outbound spike	Multi-GB transfer post-RDP access	Notify compliance immediately	RDP breach often leads to data exfiltration.
Impact	Data Encrypted for Impact (T1486) + Valid Accounts (T1078)	Deploy ransomware across environment	Shadow copies deleted (Event 524), mass encryption	Business disruption	Check VSS deletion & encryption pattern	Identify first encrypted host & spread pattern	Multiple hosts encrypt within minutes	Activate enterprise IR & DR plan	RDP exposure frequently leads to ransomware

BYZANTINE

PLAYBOOK 81 — SaaS Admin API Abuse

Attack Theme: Compromised SaaS Admin Account / API Token → Abuse of Administrative API Endpoints → Bulk Data Extraction / Privilege Changes → Enterprise-Wide Exposure

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Account Discovery (T1087) + Permission Group Discovery (T1069.003 Cloud Groups)	Identify SaaS global admin accounts & API scopes	API calls to list users/roles	Mapping SaaS privilege structure	Source ASN & API token ID	Correlate enumeration with login anomaly	Non-admin user calling admin endpoints	Increase monitoring immediately	Admin API enumeration precedes abuse.
Resource Development	Obtain Capabilities (T1588.001 Tooling)	Prepare automated API extraction script	High-frequency API requests from single token	Automation staging	API rate logs	Detect abnormal request rate vs baseline	API calls exceed normal admin activity	Throttle API & investigate	Automation indicates potential mass abuse.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) OR Steal Application	Compromise SaaS admin account or token	New API token generated	Credential/token compromise	Token creation logs & IP address	Correlate token creation with rare ASN login	Admin API token created outside CAB	Revoke token immediately	API tokens bypass interactive MFA.

	Access Token (T1528)								
Execution	Data from Information Repositories (T1213)	Extract user data / documents via API	Bulk export endpoint accessed	Data staging	SaaS audit & export logs	Identify scope of data accessed	Full tenant user list downloaded	Suspend API access	Admin APIs can dump entire tenant quickly.
Persistence	Account Manipulation (T1098)	Add new API key or secondary admin	New admin account created	Long-term SaaS control	Role & token audit logs	Correlate admin creation with suspicious API activity	Secondary global admin added unexpectedly	Remove account & rotate credentials	Admin proliferation increases blast radius.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Elevate compromised user to global admin	Role assignment API call	Expanded SaaS control	Role change audit logs	Trace assignment to originating session/token	Non-IT user promoted to global admin	Revoke elevated role	Role escalation inside SaaS is decisive signal.
Defense Evasion	Impair Defenses (T1562.001 Disable Logging)	Disable SaaS audit logging or alerts	Audit policy modified	Concealment attempt	Audit configuration logs	Detect changes to logging retention	Logging disabled after token creation	Restore logging immediately	Loss of SaaS audit logs increases investigation difficulty.
Discovery	Cloud Infrastructure Discovery (T1580)	Enumerate connected integrations & apps	API call listing connected OAuth apps	Mapping integration landscape	OAuth app audit logs	Detect access to integration inventory	Enumeration of API connectors	Increase monitoring	Connected apps may be pivot points.

Collection	Data from Information Repositories (T1213)	Export mailboxes / files / HR data	Multiple export jobs triggered	Data harvesting	Export job logs	Correlate export volume with token anomaly	Tenant-wide export initiated	Notify compliance immediately	SaaS exports often bypass traditional DLP.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain API session control	Repeated API calls from same foreign ASN	Active operator via API	API session & IP clustering	Identify persistent off-hours API activity	API activity continues after password reset	Rotate all tokens & enforce re-auth	Tokens remain valid after password change unless revoked.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Upload exported data to attacker storage	Outbound transfer spike post-export	Data leak	CASB & NetFlow alerts	Correlate export completion with outbound upload	Multi-GB upload from SaaS-connected endpoint	Notify regulator if applicable	SaaS data often contains PII & regulated info.
Impact	Data Exfiltration (T1041) + Valid Accounts (T1078)	Tenant-wide data breach	Customer/employee data exposed	Regulatory & reputational impact	Full timeline reconstruction	Identify scope of API access & affected data	Entire tenant exported via admin API	Activate enterprise IR & crisis communication	Admin API abuse can bypass endpoint detection entirely.

PLAYBOOK 82 — Data Destruction Wiper Malware

Attack Theme: Initial Compromise → Privileged Access Gained → Deployment of Wiper Malware → Irreversible Data Destruction → Operational Shutdown

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Network Service Discovery (T1046) + Account Discovery (T1087)	Identify high-value servers & backup systems	Enumeration of file servers & DCs	Target selection for destruction	Source host & account legitimacy	Correlate enumeration with prior login anomaly	Discovery from newly compromised account	Increase monitoring immediately	Wiper campaigns map environment before detonation.
Resource Development	Develop Capabilities (T1587 contextual malware staging)	Prepare custom wiper payload	Suspicious binary uploaded to admin share	Malware staging	File hash & signer validation	Check if binary matches known wiper families	Unsigned binary staged in admin share	Quarantine file immediately	Wipers often staged quietly before execution.
Initial Access	Valid Accounts (T1078) OR Exploit Public-Facing Application (T1190)	Gain privileged access to deploy wiper	Successful Domain Admin login from rare ASN	Privileged compromise	Validate source IP & device posture	Correlate with brute-force/phishing alerts	Domain Admin login after suspicious activity	Disable account immediately	Privileged access marks imminent destructive risk.
Execution	Inhibit System Recovery (T1490) + Data	Delete backups &	vssadmin delete shadows executed	Preparation for	Event ID 4688 /	Detect deletion of shadow	Backup service stopped	Isolate host immediately	Shadow copy deletion is

	Destruction (T1485)	overwrite files		irreversible damage	command logs	copies & backup agents	before file deletion		decisive red flag.
Persistence	Scheduled Task/Job (T1053.005 Scheduled Task)	Schedule delayed wiper execution	New scheduled task created	Timed detonation setup	Task scheduler logs	Identify task linked to suspicious binary	Scheduled task running at off-hours	Remove task & isolate endpoints	Delayed execution enables coordinated destruction.
Privilege Escalation	Exploitation for Privilege Escalation (T1068)	Ensure SYSTEM-level control	Token manipulation alert	Full system control	EDR privilege telemetry	Trace exploit or UAC bypass method	SYSTEM shell spawned before wiper run	Contain host immediately	SYSTEM-level wiper spreads rapidly.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable EDR/AV prior to wipe	Security service stopped	Concealment before detonation	EDR health status	Detect tamper protection disable events	EDR agent disabled across multiple hosts	Treat as active destructive campaign	Coordinated EDR disablement is critical escalation.
Discovery	Remote System Discovery (T1018)	Identify lateral targets	Ping sweep or SMB scan	Expanding destruction scope	NetFlow & SMB logs	Correlate scan with admin token usage	Scan from compromised admin host	Increase monitoring	Wipers often propagate via admin shares.
Lateral Movement	Remote Services (T1021.002 SMB / T1021.001 RDP)	Deploy wiper to multiple hosts	Binary copied via ADMIN\$ share	Multi-host infection	File share access logs	Detect simultaneous file copy to servers	Binary deployed to >5 hosts rapidly	Disconnect network segments	Rapid spread signals coordinated wipe.
Collection	Data from Information Repositories	Identify critical	Access to sensitive directories	Target prioritisation	File access baseline comparison	Detect unusual enumeration	Backup directories	Secure backups offline	Backup targeting precedes

	(T1213 contextual pre-wipe reconnaissance)	data paths				of backup folders	accessed pre-wipe		destruction .
Command & Control	Application Layer Protocol (T1071.001 Web)	Receive final execution trigger	Outbound beacon to C2 before wipe	Awaiting detonation signal	DNS & proxy logs	Correlate C2 beacon with scheduled task	C2 contact shortly before mass file deletion	Block C2 after containment	Wipers may wait for coordinated trigger.
Exfiltration	Exfiltration Over Web Services (T1567.002 contextual double-impact model)	Optional data theft before destruction	Outbound spike before wipe	Double-impact campaign	NetFlow & DLP alerts	Correlate exfil spike with shadow deletion	Data transfer immediately before wipe	Notify regulator immediately	Some wipers combine exfil + destruction .
Impact	Data Destruction (T1485) + Inhibit System Recovery (T1490)	Irreversible data loss & business outage	Files overwritten , systems unbootable	Operational shutdown	Identify first impacted host	Determine spread pattern & restore scope	>30% servers impacted within minutes	Activate full DR & crisis response	Wiper impact often more severe than ransomware.

PLAYBOOK 83 — Insider Privilege Misuse

Attack Theme: Legitimate Employee with Elevated Access → Abuse of Privileges → Data Extraction / System Manipulation → Financial, Regulatory, or Strategic Damage

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Permission Group Discovery (T1069.003 Cloud Groups) + Account Discovery (T1087)	Identify accessible high-value systems	Employee queries access rights repeatedly	Privilege boundary testing	User role & recent HR context	Correlate queries with resignation or HR case	Access enumeration by employee under investigation	Increase monitoring immediately	Insider misuse often follows behavioural trigger.
Resource Development	Obtain Capabilities (T1588.001 Tooling contextual scripting tools)	Prepare scripts to automate data extraction	PowerShell or API script testing	Preparing bulk extraction	Endpoint process logs	Identify new scripts in user profile	New automation script created in finance directory	Flag for review	Insiders often automate extraction for scale.
Initial Access	Valid Accounts (T1078)	Use legitimate credentials to access	Normal login from corporate IP	Legitimate access used maliciously	Baseline behaviour vs anomaly	Check access time vs normal	Access at unusual hours without	Increase monitoring	Insider threats blend into legitimate access.

		sensitive system				work pattern	business need		
Execution	Data from Information Repositories (T1213)	Access restricted files or databases	Large file access from privileged user	Data staging	File access logs & database audit	Correlate spike in SELECT queries or file reads	Sensitive dataset accessed outside project scope	Notify manager & HR discreetly	Context is key in insider investigations.
Persistence	Account Manipulation (T1098)	Create backdoor access (secondary account)	New service account created by insider	Ensuring future access	AD & IAM audit logs	Check if new account linked to insider	Service account created without ticket	Disable account immediately	Insiders may create sleeper accounts.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Self-assign additional privileges	User added to privileged group	Expanded authority	AD event logs 4728/4732	Trace approval chain for privilege change	Privilege granted without approval workflow	Revoke privilege	Privilege escalation signals deliberate abuse.
Defense Evasion	Impair Defenses (T1562.001 Disable Logging)	Attempt to disable audit logging	Audit policy modified	Concealment attempt	Group Policy & audit logs	Detect reduction in logging verbosity	Logging reduced after large data access	Restore logging immediately	Audit manipulation by insider is high-confidence misuse.
Discovery	System Information Discovery (T1082)	Identify sensitive systems	Internal documentation accessed repeatedly	Mapping critical assets	DLP & document access logs	Detect unusual browsing of security runbooks	Access to DR/backup documentation	Increase monitoring	Access to DR docs may signal sabotage planning.
Collection	Archive Collected Data	Compress	Large ZIP/RAR file created	Preparing data exfiltration	Endpoint file creation logs	Identify compression tool	Multi-GB archive	Isolate endpoint	Compression often

	(T1560.001)	sensitive files				usage pattern	created in user folder		precedes exfiltration.
Command & Control	Application Layer Protocol (T1071.001 Web contextual cloud upload)	Upload data to personal cloud account	HTTPS upload to unsanctioned storage	Data exfiltration	CASB & proxy logs	Correlate archive creation with upload spike	Upload to personal drive immediately after archive	Block upload & notify compliance	Personal cloud storage common insider exfil path.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer sensitive data externally	Multi-GB outbound transfer	Confirmed data leak	NetFlow & DLP alerts	Determine exact dataset exfiltrated	Sensitive data exfil confirmed	Notify legal & regulator if required	Insider exfil often focused and strategic.
Impact	Data Exfiltration (T1041) + Data Manipulation (T1565.001 contextual sabotage)	Financial loss / regulatory breach / operational sabotage	Critical data deleted or leaked	Business disruption	Incident reconstruction	Identify motive & scope of access	Evidence of deliberate data deletion	Activate executive response & HR/legal coordination	Insider cases require legal precision and evidence preservation .

PLAYBOOK 84 — Cloud Cross-Tenant Access Exploit

Attack Theme: Misconfigured Cross-Tenant Trust / B2B Federation / OAuth Consent Abuse → Unauthorized Access to External Tenant Resources → Data Theft & Lateral Cloud Pivot

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Cloud Infrastructure Discovery (T1580) + Permission Group Discovery (T1069.003 Cloud Groups)	Identify cross-tenant trust relationships	API calls listing external tenants / B2B connections	Mapping federation links	Source ASN & user context	Correlate enumeration with abnormal login	External tenant relationship queried by unusual user	Increase monitoring immediately	Federation mapping precedes cross-tenant abuse.
Resource Development	Obtain Capabilities (T1588.001 Tooling contextual OAuth app prep)	Prepare malicious OAuth app or consent link	New multi-tenant OAuth app registered	Staging cross-tenant abuse	App registration audit logs	Inspect app permissions & redirect URIs	OAuth app requesting high-privilege Graph scopes	Flag for review	Multi-tenant apps expand blast radius.
Initial Access	Steal Application Access Token	Gain access to federated tenant	Consent granted to external app	Cross-tenant access enabled	Check consent approval	Correlate consent with	High-privilege API consent granted	Revoke consent immediately	OAuth consent abuse bypasses

	(T1528) OR Valid Accounts (T1078.004 Cloud Accounts)				source & MFA	suspicious login	unexpectedly		password controls.
Execution	Data from Cloud Storage (T1530)	Access external tenant data	Cross-tenant API calls retrieving mail/files	Data access across boundary	Review audit logs in both tenants	Identify scope of accessed resources	Bulk data access via cross-tenant token	Suspend token & isolate account	Cross-tenant access often invisible without unified logging.
Persistence	Account Manipulation (T1098)	Maintain access via persistent app consent	App permission remains active	Long-term federation abuse	Consent inventory review	Detect long-lived refresh tokens	Consent valid beyond incident timeline	Revoke app & rotate credentials	OAuth refresh tokens extend persistence.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Assign external identity elevated role	Guest account promoted to admin	Expanded cross-tenant control	Role assignment audit logs	Trace approval path for guest elevation	External guest assigned admin privileges	Remove privilege immediately	Guest role elevation is decisive red flag.
Defense Evasion	Impair Defenses (T1562.001 Disable Logging contextual audit policy change)	Reduce logging visibility	Audit retention modified	Concealment attempt	Check audit configuration changes	Detect logging retention reduced	Logging altered after consent event	Restore logging immediately	Logging manipulation signals deliberate abuse.

Discovery	Account Discovery (T1087)	Enumerate users in external tenant	API calls to list users/groups	Mapping targets	Cross-tenant API logs	Correlate enumeration with new app token	External user listing spike	Increase monitoring	Enumeration often precedes targeted exfil.
Collection	Data from Information Repositories (T1213)	Download external tenant documents	Bulk export of SharePoint/Drive data	Data staging	Export logs & file access events	Identify high-value dataset accessed	Sensitive site collections accessed	Notify compliance if regulated data	Cross-tenant data may contain shared regulated info.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain remote access via API	Persistent Graph API calls from foreign ASN	Active cross-tenant control	IP clustering & token reuse analysis	Detect repeated API calls after password reset	API activity continues post-credential reset	Revoke all tokens & block app	OAuth tokens survive password resets.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer data externally	Large data transfer via API export	Confirmed data leak	CASB & cross-tenant logs	Correlate export → external upload	Multi-GB export via federated app	Notify regulator & affected partner tenant	Cross-tenant breach may impact partner organisations.
Impact	Valid Accounts (T1078) + Data Exfiltration (T1041)	Breach across organisational boundary	Partner data exposed	Regulatory & contractual liability	Joint incident response coordination	Determine which tenant initiated exploit	Admin consent abused to access partner data	Activate joint IR & legal response	Cross-tenant abuse introduces third-party liability risk.

PLAYBOOK 85 — AI Chatbot Prompt Injection Data Leak

Attack Theme: Malicious Prompt Injection → Override of System Instructions → Retrieval of Sensitive Internal Data via LLM → Data Exfiltration Through Chat Interface or API

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Org Information (T1591) + Search Open Technical Databases (T1596)	Identify chatbot capabilities & connected data sources	Repeated probing questions about internal systems	Mapping chatbot data access scope	Source IP & session ID	Correlate unusual queries with anonymous sessions	Queries asking for system prompt or hidden instructions	Increase monitoring immediately	Attackers probe model boundaries before injection.
Resource Development	Develop Capabilities (T1587 contextual crafted prompt payload)	Craft malicious prompt to override guardrails	Long structured prompt attempting role override	Injection staging	Inspect full prompt content	Identify attempts to bypass system role constraints	Prompt includes “ignore previous instructions” pattern	Flag session for review	Prompt structure often reveals intent.
Initial Access	Exploit Public-Facing Application (T1190 contextual	Inject prompt to extract hidden data	Chatbot responds with internal reference data	Guardrail bypass achieved	Confirm if chatbot connected to internal KB	Review retrieval logs & context window	Sensitive internal document referenced in response	Disable session & investigate	LLM misuse may not trigger traditional alerts.

	application logic abuse)								
Execution	Data from Information Repositories (T1213)	Retrieve internal documents via RAG integration	Multiple document retrieval calls triggered	Data exposure in progress	RAG retrieval logs	Identify which documents were accessed	Retrieval of HR/finance docs via chat query	Suspend chatbot access to sensitive index	RAG integration expands data exposure surface.
Persistence	Account Manipulation (T1098 contextual API key reuse)	Reuse chatbot API token for repeated extraction	API key used across multiple sessions	Ongoing extraction attempt	API usage logs	Detect token reuse from multiple IPs	Same API key used from foreign ASN	Rotate API key immediately	API keys often lack user-level MFA.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment contextual model admin panel)	Elevate user to chatbot admin role	Admin console accessed unexpectedly	Expanded model configuration control	Admin access audit logs	Trace role elevation source	Non-IT user promoted to AI admin	Revoke elevated access	Admin access enables guardrail modification.
Defense Evasion	Obfuscated Files or Information (T1027 contextual encoded prompt injection)	Encode malicious instructions to evade detection	Base64 or encoded prompt content	Conceal injection intent	Decode prompt payload	Identify hidden override instructions	Encoded instructions within chat input	Increase monitoring	Encoded prompts attempt detection bypass.

Discovery	Permission Group Discovery (T1069.003 Cloud Groups contextual vector index access)	Identify connected data connectors	API call listing vector store sources	Mapping sensitive data connectors	Integration configuration logs	Detect enumeration of connectors	Enumeration of finance/HR data index	Increase monitoring	Connector visibility determines blast radius.
Collection	Data from Information Repositories (T1213)	Extract multiple documents via iterative prompting	Repeated document references in session	Systematic data harvesting	Chat transcript analysis	Identify pattern of structured extraction queries	Sequential extraction of sensitive fields	Suspend session & notify compliance	Iterative extraction indicates deliberate exfil.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain automated extraction via API	High-volume chatbot API requests	Automated scraping	API rate & token analysis	Detect bot-like request interval	API calls every few seconds	Throttle API & enforce CAPTCHA	Automation indicates scale attempt.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Copy extracted content externally	Chat session exported or copied via API	Data leak	CASB & outbound logs	Correlate chatbot export with cloud upload	Large transcript download post-session	Notify regulator if required	Chat transcripts may contain regulated data.
Impact	Data Exfiltration (T1041) + Data from Information Repositories (T1213)	Sensitive internal knowledge leaked	Confidential policy appears externally	Reputational & regulatory exposure	Full transcript review & index audit	Identify which documents were accessible	Exposure of PII / financial records	Activate executive & legal response	LLM-connected systems require strict data segmentation.

BYZEMER

PLAYBOOK 86 — CI/CD Secrets Exposure

Attack Theme: Hardcoded / Logged Secrets in CI/CD Pipeline → Attacker Harvests Credentials → Cloud / Production Access Compromise → Lateral Expansion

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Search Open Technical Databases (T1596) + Cloud Infrastructure Discovery (T1580)	Identify exposed repositories or CI logs	Public repo scan finds API keys	Secret discovery opportunity	Repository visibility & commit history	Validate if repo is public or forked	CI log accessible without authentication	Restrict access immediately	Public CI logs frequently leak secrets.
Resource Development	Obtain Capabilities (T1588.001 Tooling contextual scanning scripts)	Automate scanning for secrets	High-frequency clone/pull of repos	Automated secret harvesting	IP reputation & request pattern	Detect mass repo access from same ASN	Multiple repos accessed within minutes	Throttle & monitor	Automation indicates opportunistic scraping.
Initial Access	Unsecured Credentials (T1552.001 Credentials in Files)	Harvest API keys from pipeline logs	CI log shows plaintext AWS/GCP key	Credential exposure	Identify exposed key scope	Check key last-used timestamp &	Key used shortly after exposure	Revoke key immediately	Speed of abuse determines impact.

						permissions			
Execution	Valid Accounts (T1078.004 Cloud Accounts)	Use exposed secret to access cloud	Successful API login using CI key	Credential abuse	Source ASN & API activity	Correlate key use with prior CI exposure	Cloud access from foreign ASN using CI key	Disable key & isolate account	CI keys often have broad privileges.
Persistence	Account Manipulation (T1098)	Create new access key or backdoor user	New IAM key created	Long-term cloud control	IAM audit logs	Detect key creation by CI credential	Access key created outside CAB	Remove new key	Backdoor keys extend compromise duration.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Attach admin policy to compromised identity	Policy change event	Expanded cloud control	IAM policy logs	Trace privilege escalation path	CI service account granted admin rights	Revoke policy immediately	Service accounts should follow least privilege.
Defense Evasion	Obfuscated Files or Information (T1027 contextual secret masking bypass)	Modify logs to hide secret use	CI logs truncated or redacted	Concealment attempt	CI pipeline configuration history	Detect change in log retention settings	Log retention shortened after exposure	Restore logging immediately	Log tampering signals deliberate concealment.
Discovery	Permission Group Discovery (T1069.003 Cloud Groups)	Enumerate accessible cloud roles	API calls listing roles/resources	Mapping blast radius	Cloud API logs	Detect describe/list role spikes	Broad role enumeration via CI key	Increase monitoring	Enumeration signals expansion phase.

Collection	Data from Cloud Storage (T1530)	Access sensitive buckets or databases	S3/GCS bucket listing & download	Data staging	Storage access logs	Identify object access anomalies	Sensitive bucket accessed by CI service account	Enable DLP & alert compliance	CI credentials rarely need direct data access.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain API-based cloud control	Continuous API calls via exposed key	Active cloud compromise	API frequency & ASN clustering	Detect persistent off-hours API activity	Key usage continues after revocation attempt	Rotate all related secrets	Keys embedded in code may auto-redeploy.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Download cloud data externally	Large outbound transfer from storage service	Data theft	NetFlow & cloud egress logs	Correlate bucket download with external IP	Multi-GB download via CI credential	Notify regulator if required	Cloud egress may bypass on-prem DLP.
Impact	Data Exfiltration (T1041) + Valid Accounts (T1078)	Production compromise or data breach	Production system modified via CI key	Operational & regulatory impact	Full credential inventory review	Identify all pipelines containing exposed secret	CI secret reused across environments	Activate enterprise IR & key rotation campaign	Secret reuse across environments multiplies damage.

PLAYBOOK 87 — Third-Party MSP Compromise

Attack Theme: Managed Service Provider (MSP) Breach → Abuse of Remote Management Access → Multi-Client Lateral Spread → Widespread Data Breach / Ransomware

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Org Information (T1591) + Trusted Relationship (T1199)	Identify MSP remote access methods & client list	Enumeration of VPN/RMM endpoints tied to MSP	Mapping trust relationships	Source ASN & MSP identity	Confirm if access originates from legitimate MSP IP range	MSP account accessing unusual client environment	Increase monitoring immediately	MSP trust creates amplified blast radius.
Resource Development	Obtain Capabilities (T1588.001 Tooling contextual RMM abuse)	Prepare scripts via MSP RMM platform	Script staged in RMM console	Coordinated multi-client attack prep	RMM audit logs	Detect newly uploaded script across tenants	Same script pushed to multiple clients	Suspend script execution	RMM script abuse enables mass deployment.
Initial Access	Valid Accounts (T1078) OR Exploit Public-Facing	Compromise MSP admin account	Successful MSP admin login from rare ASN	MSP account takeover	Verify MFA enforcement & device posture	Correlate login with impossible travel	MSP admin login outside baseline	Disable compromised MSP account	MSP admin compromise equals supply chain risk.

	Application (T1190)								
Execution	Remote Services (T1021.001 RDP / T1021.002 SMB)	Execute payload across client networks	Remote execution event via RMM	Active deployment phase	Endpoint process logs across tenants	Correlate execution timestamp across multiple clients	Identical process hash launched across clients	Isolate affected endpoints	Synchronized execution indicates coordinated campaign.
Persistence	Account Manipulation (T1098)	Add new MSP technician account	New RMM admin created	Long-term MSP-level access	MSP platform audit logs	Check if new account linked to suspicious login	Technician account added outside CAB	Remove account immediately	MSP admin proliferation increases systemic risk.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Elevate compromised MSP user to global admin	Role upgrade within MSP platform	Expanded multi-client control	Role assignment audit logs	Trace approval workflow for elevation	MSP user promoted without approval	Revoke privileges	MSP global admin controls multiple environments.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools)	Disable EDR across client endpoints	EDR disabled via RMM policy	Concealment before ransomware	EDR health telemetry across clients	Detect policy change pushed to multiple clients	EDR disabled across >3 clients	Treat as confirmed coordinated compromise	Cross-client EDR disablement is critical escalation.
Discovery	Network Service Discovery (T1046)	Scan internal client environments	SMB/RDP scans originating from MSP jump host	Mapping high-value systems	NetFlow & IDS logs	Correlate scanning pattern across tenants	MSP jump host scanning multiple clients	Increase monitoring	MSP jump hosts must be Tier-0 monitored assets.

Collection	Data from Information Repositories (T1213)	Access client file shares & databases	Large file copy via RMM session	Data staging	File access & audit logs	Identify common dataset accessed across clients	Sensitive share accessed in multiple tenants	Notify compliance & affected clients	Multi-client data exposure increases regulatory impact.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain remote control via MSP infrastructure	Persistent RMM sessions across clients	Active coordinated control	Session duration & ASN clustering	Detect off-hours remote sessions across tenants	Same ASN accessing multiple client tenants	Block source & enforce MFA reset	Cross-tenant persistence signals systemic compromise.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Upload data externally from multiple clients	Simultaneous outbound transfers	Data breach at scale	NetFlow & CASB across clients	Correlate timeline across affected tenants	Multi-client exfil within short timeframe	Notify regulator & affected partners	Third-party breaches introduce cascading liability.
Impact	Trusted Relationship (T1199) + Data Encrypted for Impact (T1486 contextual)	Multi-client ransomware or data breach	Simultaneous encryption events across clients	Supply-chain scale incident	Identify patient-zero (MSP)	Assess lateral spread vector via MSP platform	>3 clients impacted simultaneously	Activate joint IR with MSP & clients	MSP compromise multiplies impact exponentially.

PLAYBOOK 88 — SIM Farm OTP Harvesting

Attack Theme: Large-Scale SIM Farm Infrastructure → OTP Interception via SIM Swap / Social Engineering / Compromised Telco Channel → Account Takeover → Financial Fraud

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Identity Information (T1589) + Account Discovery (T1087)	Identify users relying on SMS OTP	Repeated login attempts requesting OTP	Target profiling for SMS-based MFA	Source ASN & target user profile	Correlate OTP requests across multiple accounts	OTP triggered for >5 accounts from same IP	Increase monitoring immediately	SMS OTP users are high-risk identity tier.
Resource Development	Acquire Infrastructure (T1583.003 VPS) + Acquire Access (T1650 contextual SIM acquisition)	Operate SIM farm hardware for OTP capture	High volume of SMS traffic routed to controlled numbers	Fraud infrastructure staging	Telco partner coordination	Identify number porting anomalies	Bulk SIM activations linked to same KYC details	Alert fraud & telco liaison	SIM farms rely on scale & automation.
Initial Access	Valid Accounts (T1078) + Credential	Trigger OTP to compromise d number	Successful login after OTP verification	OTP interception successful	Verify SIM swap or number change	Check recent phone number	Phone number changed	Lock account & suspend transactions	Phone number change + login is

	Stuffing (T1110.004)					update events	shortly before login		decisive signal.
Execution	Use of Alternate Authentication Material (T1550.003 Pass the Ticket contextual OTP replay)	Replay intercepted OTP	Multiple OTP attempts within seconds	Automated OTP brute entry	Authentication logs & timing pattern	Detect OTP submitted immediately after issuance	OTP verified from foreign ASN	Force password reset & revoke sessions	Timing correlation critical in OTP fraud.
Persistence	Account Manipulation (T1098)	Change phone number or disable MFA alerts	MFA settings modified	Long-term account control	Account security audit logs	Correlate MFA change with OTP anomaly	SMS MFA removed after login	Restore MFA & verify identity	Removing SMS MFA indicates intent to persist.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment contextual finance role abuse)	Elevate privileges in financial platform	Role changed to higher transaction limit	Expanded fraud capability	Role change audit logs	Trace approval workflow bypass	Privilege increased post-OTP login	Revoke privilege immediately	Limit escalation magnifies financial loss.
Defense Evasion	Obfuscated Files or Information (T1027 contextual transaction splitting)	Split transactions to avoid detection	Multiple smaller transfers instead of one large	Fraud concealment	Transaction pattern analysis	Detect unusual burst of micro-transactions	>10 transfers in short window	Suspend transactions	Transaction structuring hides fraud pattern.
Discovery	Account Discovery (T1087	Identify high-	Login attempts across	Target prioritisation	Correlate with breached	Identify pattern across	Targeted accounts	Increase monitoring	High-balance targeting

	contextual financial app user list)	balance accounts	multiple high-value accounts		credential list	similar password reuse	with large balances		indicates strategic fraud.
Collection	Data from Information Repositories (T1213 contextual account info harvest)	Extract personal & account data	Profile information accessed post-login	Data harvesting	Profile access logs	Detect unusual browsing of account details	PII accessed prior to transaction	Enable DLP monitoring	Data may support identity resale.
Command & Control	Application Layer Protocol (T1071.001 Web)	Automate login + OTP replay via bot	High-frequency login attempts via API	Active fraud automation	API rate & ASN clustering	Detect consistent automation timing	Requests at fixed intervals across accounts	Block IP & enforce CAPTCHA	Automation indicates SIM farm coordination.
Exfiltration	Exfiltration Over Web Services (T1567.002 contextual transaction redirection)	Transfer funds externally	Funds moved to mule accounts	Financial exfiltration	Beneficiary account analysis	Correlate mule accounts across victims	Same destination IBAN across victims	Notify regulator & freeze accounts	Mule reuse indicates organised fraud network.
Impact	Financial Fraud (T1657 contextual) + Valid Accounts (T1078)	Direct financial loss & regulatory exposure	Spike in disputed transactions	Customer & compliance impact	Fraud loss assessment & recall attempt	Identify scale & coordinated accounts	Multiple victims within same timeframe	Activate crisis & regulator notification	SMS OTP is weak control in 2026 threat landscape.

PLAYBOOK 89 — Payment Processor Logic Abuse

Attack Theme: Exploitation of Business Logic Flaw in Payment Workflow → Manipulation of Validation / Reconciliation Rules → Unauthorized Transaction Approval → Financial Loss

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Org Information (T1591) + Cloud Infrastructure Discovery (T1580 contextual API mapping)	Identify payment API endpoints & validation flow	Repeated low-value test transactions	Testing business logic boundaries	Source ASN & transaction pattern	Correlate small transactions with parameter manipulation	Sequential small-value transactions from same account	Increase monitoring immediately	Test transactions often precede exploit attempt.
Resource Development	Develop Capabilities (T1587 contextual API fuzzing script)	Craft request to bypass validation logic	Abnormal API parameter combinations	Exploit staging	Inspect raw API payload	Identify unusual field manipulation (e.g., negative amount, currency mismatch)	API requests deviating from normal schema	Rate-limit & monitor	Business logic abuse often bypasses WAF.

Initial Access	Exploit Public-Facing Application (T1190 contextual application logic abuse)	Trigger logic flaw to bypass checks	Transaction approved without required OTP	Validation control bypass	Confirm authentication & risk scoring result	Review risk engine logs for anomaly	Approval without MFA for high-risk transaction	Suspend affected account	Logic flaw exploited successfully.
Execution	Data Manipulation (T1565.001 Stored Data Manipulation contextual transaction status change)	Manipulate transaction state (e.g., refund loop)	Multiple refunds processed for same transaction ID	Revenue leakage	Payment processor audit logs	Identify mismatch between ledger & processor	Same transaction ID reused multiple times	Halt processing flow	Refund loop abuse signals logic weakness.
Persistence	Account Manipulation (T1098 contextual merchant profile change)	Modify merchant configuration	Change in settlement account	Long-term financial diversion	Merchant config audit logs	Correlate config change with test transaction pattern	Settlement account modified without approval	Restore original config	Settlement account changes are decisive red flags.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment contextual merchant	Elevate merchant privileges	Merchant role upgraded unexpectedly	Expanded transaction authority	Role assignment logs	Trace privilege change workflow	Non-admin merchant elevated to admin	Revoke privilege immediately	Role escalation enables broader exploitation.

	role elevation)								
Defense Evasion	Obfuscated Files or Information (T1027 contextual transaction structuring)	Split large fraud into micro-transactions	Multiple low-value transactions below alert threshold	Threshold evasion	Transaction frequency analysis	Detect burst of micro-transactions	>20 micro-transactions in short timeframe	Flag & suspend processing	Structuring hides large aggregate fraud.
Discovery	Permission Group Discovery (T1069.003 contextual payment roles)	Identify high-limit transaction pathways	Access to configuration panel	Mapping control thresholds	Admin panel audit logs	Detect browsing of fraud threshold settings	Configuration page accessed before exploit	Increase monitoring	Threshold reconnaissance precedes bypass.
Collection	Data from Information Repositories (T1213 contextual transaction export)	Extract payment reports	Bulk export of reconciliation report	Intelligence gathering	Export logs	Correlate export with abnormal transaction spike	Report downloaded immediately before exploit	Notify finance & compliance	Data extraction aids fraud planning.
Command & Control	Application Layer Protocol (T1071.001 Web)	Automate repeated exploit attempts	API calls at fixed intervals	Automated abuse	API request timing analysis	Detect bot-like pattern in transaction calls	Consistent 2–3 second interval between calls	Block source & enforce CAPTCHA	Automation indicates organised attack.
Exfiltration	Exfiltration Over Web Services (T1567.002 contextual	Divert funds to attacker account	Funds routed to new beneficiary	Financial exfiltration	Beneficiary account analysis	Correlate mule accounts across cases	Same destination account used repeatedly	Freeze accounts & notify regulator	Mule clustering reveals organised fraud ring.

	fund transfer)								
Impact	Financial Fraud (T1657 contextual) + Data Manipulation (T1565.001)	Direct financial loss & reputational damage	Surge in disputed or reversed transactions	Customer & regulatory impact	Full transaction reconciliation	Assess logic flaw root cause & exposure window	Fraud executed without required validation	Activate crisis response & regulatory reporting	Business logic flaws often invisible to signature-based detection.

PLAYBOOK 90 — Fraudulent Insurance Claims via System Access

Attack Theme: Compromised Claims Processing Account → Manipulation of Claim Records → Approval of Fraudulent Payout → Financial & Regulatory Impact

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Org Information (T1591) + Account Discovery (T1087)	Identify claims adjusters & approval workflows	Multiple access attempts to claims module	Target profiling of claims handlers	Source ASN & user role	Correlate enumeration with HR status (resignation / role change)	Non-claims user accessing claims dashboard	Increase monitoring immediately	Claims systems contain high-value financial data.
Resource Development	Obtain Capabilities (T1588.001 Tooling contextual scripted submission)	Prepare automated claim submission script	Repeated draft claim creations	Testing workflow manipulation	Application logs & request pattern	Detect scripted behaviour vs human interaction	Claims submitted at fixed intervals	Flag session for investigation	Automation indicates scaled fraud attempt.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) OR Phishing (T1566.002)	Compromise claims processing account	Successful login from rare ASN	Account takeover	MFA logs & device fingerprint	Correlate login with impossible travel	Claims admin login outside baseline	Revoke sessions & reset password	Claims admin access enables payout manipulation.

Execution	Data Manipulation (T1565.001 Stored Data Manipulation)	Modify claim details (amount, beneficiary)	Claim value edited after approval stage	Payout inflation	Claims audit logs	Compare previous vs modified claim values	High-value modification shortly before payout	Suspend claim processing	Late-stage modification is decisive red flag.
Persistence	Account Manipulation (T1098)	Add alternate payout account	Beneficiary bank account updated	Ensuring fraud continuation	Beneficiary update logs	Correlate change with suspicious login	Bank account modified outside workflow	Restore original account	Beneficiary modification drives direct financial loss.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Elevate adjuster to approval authority	Role upgraded to senior approver	Expanded approval control	Role change audit logs	Trace approval chain bypass	Adjuster promoted without management sign-off	Revoke elevated role immediately	Role escalation bypasses dual-control process.
Defense Evasion	Obfuscated Files or Information (T1027 contextual claim description edits)	Modify claim narrative subtly	Claim description updated with minor wording change	Conceal fraud indicators	Document version history	Detect metadata inconsistency	Description changed shortly before payout	Increase monitoring	Minor edits can conceal major payout manipulation.
Discovery	Permission Group Discovery (T1069.003 contextual workflow roles)	Identify high-limit claim pathways	Access to policy limit configuration	Mapping maximum payout levels	Config audit logs	Detect browsing of payout thresholds	Policy limits viewed before large claim	Increase monitoring	Threshold reconnaissance precedes fraud attempt.

Collection	Data from Information Repositories (T1213 contextual policyholder data)	Extract personal & policy data	Bulk export of policyholder records	Identity harvesting	Export logs	Correlate export with suspicious login	Policyholder list downloaded before claims spike	Notify compliance if PII involved	Insurance data contains regulated personal info.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain session control in claims portal	Persistent session from foreign ASN	Active operator	Session timing & ASN clustering	Identify off-hours login patterns	Session continues post-password reset	Rotate credentials & enforce step-up auth	Continuous portal access indicates ongoing fraud.
Exfiltration	Exfiltration Over Web Services (T1567.002 contextual payout diversion)	Transfer payout to mule accounts	Multiple payouts to same IBAN	Financial exfiltration	Beneficiary clustering analysis	Correlate mule accounts across cases	Same account used in multiple fraudulent claims	Freeze payouts & notify regulator	Mule reuse reveals organised fraud network.
Impact	Financial Fraud (T1657 contextual) + Data Manipulation (T1565.001)	Fraudulent claim payouts executed	Spike in disputed claims	Financial & regulatory impact	Full claim audit & recovery attempt	Identify affected policies & loss window	Fraudulent payouts processed without dual approval	Activate crisis response & regulator notification	Dual-control bypass signals systemic control weakness.

PLAYBOOK 91 — Critical Infrastructure ICS Manipulation

Attack Theme: Compromise of Engineering Workstation / ICS Network → Manipulation of PLC / SCADA Logic → Operational Disruption → Physical Process Impact

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Network Service Discovery (T1046) + Gather Victim Org Information (T1591)	Identify PLCs, HMIs, and engineering workstations	Scanning activity on ICS protocols (Modbus/DNP3)	Mapping industrial assets	Source host & VLAN	Confirm if scan originated from IT or OT zone	ICS protocol scan from IT segment	Increase monitoring immediately	ICS networks must be segmented from IT.
Resource Development	Obtain Capabilities (T1588.001 Tooling contextual PLC programming tools)	Prepare malicious PLC logic	Engineering project file staged on workstation	Logic manipulation staging	File hash & project comparison	Compare PLC logic against golden baseline	New ladder logic file introduced unexpectedly	Restrict workstation access	ICS logic modification often subtle.
Initial Access	Valid Accounts (T1078) OR Exploit Public-	Gain access to engineering workstation	Successful VPN login to OT jump host from rare ASN	OT boundary breached	Validate MFA & device posture	Correlate login with prior IT compromise	OT VPN access outside maintenance window	Disable account & isolate host	OT access outside schedule is critical severity.

	Facing Application (T1190 contextual VPN into OT)								
Execution	Modify Control Logic (T0831 ICS Modify Control Logic)	Upload altered PLC configuration	PLC program upload event logged	Active manipulation of process logic	PLC change audit logs	Compare logic hash vs approved configuration	PLC logic modified without change ticket	Halt process & revert to baseline	PLC logic change directly impacts physical systems.
Persistence	Create Account (T1136 contextual local engineering account)	Create hidden engineering user	New local user on engineering workstation	Long-term OT access	Local account audit logs	Detect account not tied to HR record	Engineering account created outside process	Remove account	Hidden OT accounts increase systemic risk.
Privilege Escalation	Exploitation for Privilege Escalation (T1068 contextual local admin exploit)	Gain admin on OT workstation	Privilege escalation alert on engineering PC	Expanded OT control	EDR telemetry on OT host	Trace exploit used	SYSTEM shell on engineering station	Isolate workstation	Admin access enables unrestricted PLC manipulation.
Defense Evasion	Impair Defenses (T1562.001 Disable Logging)	Disable OT monitoring/historian logging	Historian data gaps	Concealment attempt	Check logging continuity	Identify timestamp gaps in sensor data	Logging disabled before PLC change	Restore logging immediately	Historian manipulation signals deliberate sabotage.

	contextual historian/log tampering)								
Discovery	Remote System Discovery (T1018 contextual PLC enumeration)	Identify additional PLCs & RTUs	ICS device enumeration commands	Mapping full control environment	OT network logs	Correlate enumeration with compromised workstation	PLC enumeration outside maintenance schedule	Increase monitoring	Enumeration often precedes coordinated manipulation.
Collection	Data from Information Repositories (T1213 contextual process data extraction)	Access sensitive operational parameters	Bulk export of SCADA configuration	Intelligence gathering	SCADA export logs	Identify configuration file downloads	Critical configuration exported unexpectedly	Notify OT leadership	Operational blueprints can enable future sabotage.
Command & Control	Application Layer Protocol (T1071.001 Web contextual VPN beacon)	Maintain remote control of OT system	Repeated VPN sessions to OT zone	Active operator presence	VPN & firewall logs	Detect persistent OT access from foreign ASN	OT VPN sessions during non-operational hours	Block access & enforce re-authentication	OT C2 channel often blends with maintenance traffic.
Exfiltration	Exfiltration Over Web Services (T1567.002 contextual	Transfer industrial configs externally	Large outbound data from OT network	Potential espionage	NetFlow from OT segment	Correlate export with PLC changes	OT segment data transfer spike	Notify regulator if critical infra	ICS data may be classified under

	ICS config transfer)								national law.
Impact	Impact to Physical Process (T0831 ICS) + Inhibit Response Function (T0814 ICS)	Operational shutdown or unsafe condition	Unexpected process anomaly / equipment malfunction	Physical impact	Review process telemetry & alarms	Correlate anomaly timestamp with PLC modification	Process deviation immediately after logic upload	Activate emergency & crisis response	ICS manipulation can cause safety and national security risk.

PLAYBOOK 92 — Backup Retention Policy Deletion

Attack Theme: Compromised Backup Admin / Cloud Account → Retention Policy Reduction or Deletion → Backup Expiry / Purge → Ransomware or Destructive Impact Without Recovery Option

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Cloud Infrastructure Discovery (T1580) + Account Discovery (T1087)	Identify backup vaults & retention settings	API calls listing backup policies	Mapping recovery posture	Source ASN & account role	Correlate enumeration with privileged login anomaly	Backup policy viewed by non-backup admin	Increase monitoring immediately	Backup mapping precedes destruction phase.
Resource Development	Obtain Capabilities (T1588.001 Tooling contextual API scripting)	Prepare script to modify retention	High-frequency backup policy API calls	Automation staging	Audit logs of backup platform	Detect abnormal API request burst	Backup API accessed from foreign ASN	Increase monitoring	Automation indicates mass policy change attempt.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) OR Steal Application	Compromise backup administrator account	Successful login to backup console from rare ASN	Backup admin compromise	Verify MFA & device posture	Correlate login with impossible travel	Backup admin login outside maintenance window	Disable account immediately	Backup admin accounts are Tier-0 assets.

	Access Token (T1528)								
Execution	Inhibit System Recovery (T1490)	Delete or reduce retention policy	Retention days changed from 90 → 1	Recovery window reduction	Compare policy baseline vs current state	Identify policy changes across multiple vaults	Multiple backup vaults modified within minutes	Revert policy immediately	Retention reduction often precedes ransomware detonation.
Persistence	Account Manipulation (T1098)	Create secondary backup admin	New admin added to backup vault	Long-term control of recovery environment	Backup IAM audit logs	Trace account creation origin	Backup admin created without CAB	Remove account	Backup admin proliferation increases irreversible risk.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Elevate compromised user to vault owner	Role upgraded to full vault control	Expanded destructive capability	Role assignment audit logs	Validate approval workflow for role change	Non-backup user granted vault owner role	Revoke elevated role	Vault owner role enables policy purge & deletion.
Defense Evasion	Impair Defenses (T1562.001 Disable Logging contextual backup audit disablement)	Disable backup auditing	Backup audit logs disabled	Concealment attempt	Audit configuration logs	Detect retention of audit logs shortened	Audit logging turned off post-login anomaly	Restore logging immediately	Backup audit loss signals imminent destructive act.

Discovery	Remote System Discovery (T1018 contextual backup repository enumeration)	Identify all backup repositories	Enumeration of on-prem & cloud backup targets	Expanding destruction scope	Cross-platform backup logs	Detect listing across hybrid backup infrastructure	Enumeration beyond assigned scope	Increase monitoring	Hybrid environments expand blast radius.
Collection	Data from Information Repositories (T1213 contextual backup export)	Identify sensitive datasets within backups	Access to backup content preview	Recon for targeted destruction	Backup content access logs	Detect browsing of critical system backups	Core banking / ERP backup accessed	Secure offline copies	Backup content reconnaissance signals intent.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain API-based control of backup system	Persistent API calls to backup service	Active destructive operator	IP clustering & API timing analysis	Identify continuous policy modification attempts	Repeated policy change attempts after revert	Block IP & enforce step-up auth	Persistent modification indicates active campaign.
Exfiltration	Exfiltration Over Web Services (T1567.002 contextual backup copy theft)	Download full backup copies externally	Large data export from backup vault	Data theft + destruction	NetFlow & backup export logs	Correlate export with retention deletion	Backup export before purge	Notify regulator if regulated data	Backup theft compounds destructive attack.
Impact	Inhibit System Recovery (T1490) + Data Destruction	No recoverable backups during ransomware	Backup restore fails	Catastrophic recovery failure	Validate restore test immediately	Identify earliest intact backup copy	Backup vault retention < 1 day before	Activate crisis & disaster recovery plan	Retention deletion is often precursor to full

(T1485
contextual
follow-up
ransomwar
e)

ransomwar
e

ransomware
impact.

BYZANTINE

PLAYBOOK 93 — Database Integrity Manipulation

Attack Theme: Compromised DBA / Application Account → Subtle Data Alteration (Balances, Limits, Records) → Fraud / Operational Corruption → Delayed Detection

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Account Discovery (T1087) + Database Schema Discovery (T1046 contextual SQL metadata enumeration)	Identify critical tables (balances, limits, claims)	SELECT * FROM information_schema queries	Mapping database structure	Source account & host	Correlate schema queries with login anomaly	Schema enumeration by non-DBA account	Increase monitoring immediately	Integrity attacks require deep schema knowledge.
Resource Development	Develop Capabilities (T1587 contextual SQL script crafting)	Prepare manipulation SQL statements	SQL scripts uploaded to DB admin console	Staging alteration logic	Review script content & signer	Detect unusual UPDATE/DELETE statements	Script references financial or identity fields	Suspend execution & investigate	Script-based modification enables bulk impact.
Initial Access	Valid Accounts (T1078) OR Exploit	Gain privileged DB access	Successful DBA login from rare ASN	Database account compromise	Verify MFA & access method	Correlate login with app anomalies	DBA login outside maintenance window	Disable account immediately	DBA accounts are Tier-0

	Public-Facing Application (T1190 contextual SQLi → DB access)								integrity assets.
Execution	Data Manipulation (T1565.001 Stored Data Manipulation)	Modify sensitive fields (balance, status, flags)	Large UPDATE query executed	Active data corruption	Query logs & row count affected	Compare before/after record values	>1000 rows updated outside approved change	Roll back transaction if possible	Mass UPDATE outside CAB is decisive red flag.
Persistence	Account Manipulation (T1098)	Create hidden DB user or backdoor trigger	New DB user created	Long-term manipulation capability	DB user audit logs	Trace user creation to session source	User created without approval workflow	Remove user immediately	Hidden DB users enable silent future corruption.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Grant compromised account sysadmin role	GRANT sysadmin executed	Expanded DB control	Role assignment logs	Validate change ticket & approval chain	Non-DBA account granted sysadmin	Revoke elevated role	Role escalation allows full DB manipulation.
Defense Evasion	Impair Defenses (T1562.001 Disable Logging contextual	Disable or truncate DB audit logs	Audit logging configuration modified	Concealment attempt	DB audit policy logs	Detect retention reduction or log deletion	Audit logs cleared after mass update	Restore logging & isolate DB	Audit manipulation indicates deliberate corruption.

	audit trail tampering)								
Discovery	System Information Discovery (T1082 contextual server config discovery)	Identify replication & backup settings	Queries against replication config tables	Mapping recovery mechanisms	Check replication & backup logs	Detect enumeration beyond normal DBA activity	Replication topology accessed by suspicious session	Increase monitoring	Attacker may target replicas next.
Collection	Data from Information Repositories (T1213 contextual data sampling)	Extract sample records before modification	SELECT queries on high-value tables	Recon for targeted corruption	Query frequency & pattern analysis	Detect repetitive sampling across financial tables	SELECT spike before UPDATE spike	Increase monitoring	Sampling often precedes precise manipulation.
Command & Control	Application Layer Protocol (T1071.001 Web contextual DB over VPN)	Maintain remote DB session control	Persistent DB connection from foreign ASN	Active operator presence	Session duration & IP clustering	Identify off-hours DB sessions	Continuous session beyond maintenance window	Block source & enforce step-up auth	DB sessions rarely need long idle duration.
Exfiltration	Exfiltration Over Web Services (T1567.002 contextual DB export)	Export corrupted or original data externally	Large data export from DB server	Data theft or preparation for extortion	NetFlow & DB export logs	Correlate export with manipulation timeline	Data export before corruption event	Notify regulator if PII involved	Data theft may accompany integrity corruption.
Impact	Data Manipulation	Financial misstatement /	Account balances inconsistent	Regulatory &	Full integrity validation &	Compare DB against	Widespread inconsistent	Activate crisis, audit &	Integrity attacks may remain

	(T1565.001) + Impact to Business Process (T1489 contextual service disruption)	operational corruption		reputational damage	reconciliation	backup snapshot	cy across financial records	regulator reporting	undetected longer than ransomware.
--	---	---------------------------	--	------------------------	----------------	--------------------	-----------------------------------	------------------------	--

BYZANTIUM

PLAYBOOK 94 — HR Payroll System Breach

Attack Theme: Compromised HR / Payroll Account → Salary / Bank Detail Manipulation → Bulk PII Exposure → Financial & Regulatory Impact

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Identity Information (T1589) + Account Discovery (T1087)	Identify payroll admins & approval workflows	Enumeration of payroll user roles	Targeting high-impact HR accounts	Source ASN & role baseline	Correlate enumeration with unusual login attempts	Non-HR user browsing payroll module	Increase monitoring immediately	Payroll systems contain high-value financial + PII data.
Resource Development	Develop Capabilities (T1587 contextual scripted payroll edits)	Prepare automation for bulk bank detail change	Repeated access to bank detail fields	Staging manipulation	Application access logs	Detect scripted navigation patterns	Rapid access to multiple employee profiles	Flag session for investigation	Automation enables large-scale payroll fraud.
Initial Access	Valid Accounts (T1078.004 Cloud Accounts) OR Phishing (T1566.002)	Compromise HR payroll administrator	Successful HR admin login from rare ASN	Payroll account takeover	Verify MFA & device fingerprint	Correlate with impossible travel or MFA fatigue	HR admin login outside business hours	Revoke sessions & reset credentials	HR payroll admin is Tier-0 financial role.

Execution	Data Manipulation (T1565.001 Stored Data Manipulation)	Modify employee bank account numbers	Bulk update of direct deposit details	Salary diversion	Payroll change logs	Compare previous vs updated bank details	>10 employee bank accounts modified	Suspend payroll batch immediately	Bank detail modification before payroll cycle is decisive red flag.
Persistence	Account Manipulation (T1098)	Add secondary HR admin or recovery email	New admin added to payroll system	Long-term control of payroll platform	HR system audit logs	Validate approval chain for new admin	Admin added without HR director approval	Remove unauthorized admin	Persistence enables repeated fraud cycles.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Elevate HR user to super-admin	Role changed to payroll super-admin	Expanded manipulation authority	Role assignment audit logs	Trace privilege elevation workflow	Non-senior HR promoted to super-admin	Revoke elevated privileges	Privilege escalation bypasses segregation of duties.
Defense Evasion	Impair Defenses (T1562.001 Disable Logging contextual payroll audit reduction)	Reduce audit retention or disable alerts	Payroll alerting turned off	Concealment attempt	Audit configuration logs	Detect retention policy changes	Logging modified shortly after HR login anomaly	Restore logging & isolate account	Audit suppression signals deliberate fraud.
Discovery	Permission Group Discovery (T1069.003 contextual approval	Identify payroll approval thresholds	Access to payroll configuration panel	Mapping dual-control bypass	Configuration logs	Detect browsing of salary approval limits	Approval threshold accessed before bulk edit	Increase monitoring	Workflow reconnaissance precedes abuse.

	workflow mapping)								
Collection	Data from Information Repositories (T1213 contextual employee PII export)	Export employee data (IC, salary, bank info)	Bulk CSV export from payroll module	PII harvesting	Export logs & CASB	Correlate export with suspicious login	Employee database exported in full	Notify compliance (PDPA / GDPR)	Payroll systems hold regulated personal data.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain session control in payroll portal	Persistent session from foreign ASN	Active operator manipulating records	Session duration & IP clustering	Detect prolonged payroll session beyond work hours	Session continues after password reset attempt	Block source & enforce step-up auth	Persistent session indicates live manipulation.
Exfiltration	Exfiltration Over Web Services (T1567.002 contextual salary diversion)	Divert salary payments to mule accounts	Multiple salaries sent to same IBAN	Financial exfiltration	Beneficiary clustering analysis	Identify reused mule bank accounts	Same destination IBAN across multiple employees	Freeze transactions & notify bank	Mule account reuse signals organised payroll fraud.
Impact	Financial Fraud (T1657 contextual) + Data Exfiltration (T1041)	Salary diversion + PII breach	Payroll discrepancies reported by staff	Financial, legal & reputational impact	Full payroll reconciliation & breach assessment	Identify affected employees & loss window	Multiple employees unpaid or mispaid	Activate crisis management & regulator reporting	Payroll breaches damage employee trust rapidly.

PLAYBOOK 95 — VPN Configuration Export Theft

Attack Theme: Compromised Network Admin / VPN Appliance Access → Export of Full VPN Configuration (PSKs, Certificates, Topology) → Credential Reuse / Network Pivot → Long-Term Remote Access Risk

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Network Service Discovery (T1046) + Gather Victim Org Information (T1591)	Identify VPN appliance & admin portal	Repeated access to /admin or VPN config pages	Mapping VPN infrastructure	Source ASN & role baseline	Correlate enumeration with unusual admin login	Non-network user accessing VPN console	Increase monitoring immediately	VPN appliances are Tier-0 perimeter assets.
Resource Development	Obtain Capabilities (T1588.001 Tooling contextual automated config scraping)	Prepare script to download configuration	High-frequency GET requests to config endpoints	Automation staging	VPN audit logs	Detect scripted interaction vs normal admin UI pattern	Multiple config-related API calls in short timeframe	Flag session for review	Automation suggests intent to harvest full config.
Initial Access	Valid Accounts (T1078.004 Cloud/Domain Accounts)	Gain VPN admin access	Successful VPN admin login from rare ASN	Admin credential compromise	Verify MFA & device fingerprint	Correlate login with impossible travel or recent phishing	VPN admin login outside change window	Disable account & enforce credential reset	VPN admin compromise exposes full remote access posture.

	OR Exploit Public-Facing Application (T1190)								
Execution	Unsecured Credentials (T1552.004 Private Keys)	Export VPN configuration file	Config export/download event logged	Extraction of PSKs, certificates, topology	Confirm export timestamp & file size	Review contents: PSKs, certs, site-to-site keys	Full configuration downloaded by non-primary admin	Rotate all VPN secrets immediately	VPN config contains sensitive cryptographic material.
Persistence	Account Manipulation (T1098)	Create new VPN admin account	New local admin added on VPN appliance	Long-term control of VPN	VPN user management logs	Validate approval workflow for new admin	Admin added without CAB	Remove unauthorized admin	Local VPN admins bypass central IAM controls.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Elevate read-only user to full admin	Role changed to super-admin	Expanded VPN configuration authority	Role change audit logs	Trace privilege change approval chain	Non-network user granted super-admin	Revoke elevated privileges	Super-admin role allows certificate export & policy change.
Defense Evasion	Impair Defenses (T1562.001 Disable Logging contextual VPN audit disablement)	Disable or reduce logging	Audit logging disabled on VPN	Concealment attempt	Logging configuration history	Detect retention reduction or log purge	Logging disabled post-admin login anomaly	Restore logging & isolate device	VPN log tampering signals deliberate preparation.

Discovery	Remote System Discovery (T1018 contextual internal subnet mapping via VPN config)	Identify internal network topology	Access to routing and subnet tables	Mapping lateral movement paths	Review config access logs	Identify which topology elements were accessed	Full routing table viewed before export	Increase monitoring	VPN config reveals full internal architecture.
Collection	Data from Information Repositories (T1213 contextual credential harvesting from config)	Extract stored PSKs & certificates	Certificate/private key download events	Credential harvesting	Check if private keys exported	Validate if keys are reused elsewhere	Multiple key exports in one session	Initiate enterprise-wide key rotation	PSK reuse across tunnels multiplies impact.
Command & Control	Application Layer Protocol (T1071.001 Web contextual VPN session persistence)	Maintain remote control via VPN access	Repeated VPN admin logins	Active operator presence	Session timing & ASN clustering	Detect persistent access beyond maintenance window	Admin logins during non-operational hours	Enforce step-up authentication	Persistent VPN access signals staging for pivot.
Exfiltration	Exfiltration Over Web Services (T1567.002 contextual config download)	Transfer configuration externally	Large outbound data from VPN appliance	Config theft completed	NetFlow & firewall logs	Correlate export with external upload	Config export immediately followed by outbound transfer	Notify security leadership	Config export enables future stealth access.

Impact	Valid Accounts (T1078) + Modify Authentication Process (T1556 contextual future VPN abuse)	Long-term VPN compromise & lateral movement	Increase in unauthorized VPN sessions later	Strategic perimeter breach	Monitor for certificate-based logins	Detect reuse of exported certificates	VPN access using rotated but previously valid cert	Activate perimeter hardening response	VPN config theft may not cause immediate impact but enables future intrusion.
--------	--	---	---	----------------------------	--------------------------------------	---------------------------------------	--	---------------------------------------	---

PLAYBOOK 96 — DevOps Token Privilege Escalation

Attack Theme: Compromised DevOps Personal Access Token (PAT) / CI Token → Abuse of Over-Permissioned Token → Privilege Escalation in Repository / Pipeline → Infrastructure Manipulation

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Account Discovery (T1087) + Permission Group Discovery (T1069.003 Cloud/DevOps Groups)	Identify DevOps accounts with elevated permissions	API calls listing repository collaborators	Mapping privilege landscape	Source IP & token ID	Correlate token usage with normal developer baseline	Token enumerating multiple projects unexpectedly	Increase monitoring immediately	DevOps tokens often have broader access than users realise.
Resource Development	Obtain Capabilities (T1588.001 Tooling contextual API scripting)	Prepare automated API requests using stolen token	High-frequency API calls via PAT	Automation staging	DevOps audit logs	Detect non-interactive token usage pattern	Token used from foreign ASN	Flag token for investigation	Tokens rarely require cross-region access.
Initial Access	Unsecured Credentials (T1552.001 Credentials in Files) OR Steal Application Access	Obtain DevOps PAT from repo/log	Successful API authentication via PAT	Token compromise	Identify token owner & scope	Check last-used timestamp & scopes granted	Token with admin:org or pipeline:write used abnormally	Revoke token immediately	PAT scope determines blast radius.

	Token (T1528)								
Execution	Modify Authentication Process (T1556 contextual pipeline trust abuse)	Use token to alter pipeline or repository settings	Pipeline configuration modified	Manipulation of CI/CD trust chain	Review pipeline change logs	Compare pipeline config with baseline	Unauthorized change to deployment script	Disable pipeline & revert config	Pipeline control equals production control.
Persistence	Account Manipulation (T1098)	Create new access token or SSH key	New PAT created for compromised account	Long-term DevOps control	Token creation audit logs	Correlate new token with suspicious session	Multiple tokens created in short timeframe	Revoke all active tokens	Token sprawl increases persistence risk.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Elevate repository access to admin	User added to Owners or Admin group	Expanded DevOps authority	Org membership logs	Validate role elevation approval workflow	Developer promoted to org owner without CAB	Revoke elevated role	Org owner role enables cross-repo manipulation.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools contextual branch protection removal)	Disable branch protection or required reviews	Branch protection disabled	Removal of code integrity controls	Repository settings logs	Detect protection removal followed by commit	Branch rules disabled before code push	Restore branch protection immediately	Disabling branch protection signals malicious intent.
Discovery	Repository Discovery (T1213)	Identify high-value repositories	API call listing private repositories	Mapping critical projects	Repo access logs	Detect enumeration across	Access to repos outside normal	Increase monitoring	Broad repo access signals lateral

	contextual repo listing)					all org repos	project scope		DevOps movement.
Collection	Data from Information Repositories (T1213 contextual code export)	Download source code or secrets	Bulk clone of private repositories	Intellectual property theft	Clone/downlo ad logs	Correlate large clone event with foreign ASN	Multiple private repos cloned in minutes	Notify legal & IP team	Source code theft may enable supply chain attack.
Command & Control	Application Layer Protocol (T1071.001 Web)	Maintain automated API interaction	Persistent API calls via PAT	Active DevOps abuse	API timing & IP clustering	Detect continuous off-hours API activity	Token used continuously over several hours	Block source & enforce token rotation	Automation suggests scaling exploitation .
Exfiltration	Exfiltration Over Web Services (T1567.002 contextual repo export)	Transfer code externally	Large outbound data transfer post-clone	IP & secret leakage	NetFlow & CASB logs	Correlate clone with cloud upload	Multi-GB upload shortly after repo access	Notify regulator if regulated code/data	Code exports may contain embedded secrets.
Impact	Modify Authenticati on Process (T1556) + Valid Accounts (T1078)	Production compromi se via manipulat ed pipeline	Unauthorize d deployment to production	Operationa l & security breach	Identify malicious commit & rollback	Compare deployed artifact hash vs approved build	Production deployment without PR approval	Activate IR & supply chain containment	DevOps token abuse bridges code to production compromis e.

PLAYBOOK 97 — E-Commerce Cart Manipulation

Attack Theme: Exploitation of Pricing / Discount Logic Flaw → Manipulation of Cart Parameters → Underpayment or Free Purchase → Revenue Loss & Fraud

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Org Information (T1591) + Exploit Public-Facing Application Recon (T1595 contextual app probing)	Identify pricing and discount logic endpoints	Repeated cart updates with small price variations	Testing pricing logic boundaries	Source ASN & session ID	Correlate cart modification attempts with same account	Multiple cart recalculations within seconds	Increase monitoring immediately	Cart logic probing often precedes exploitation.
Resource Development	Develop Capabilities (T1587 contextual API manipulation script)	Craft request to modify price or discount field	Abnormal API payload altering price parameter	Staging logic abuse	Inspect raw API request payload	Identify tampered fields (price, quantity, discount)	API request includes unexpected negative or zero value	Rate-limit & monitor	Logic flaws often bypass WAF signature rules.

Initial Access	Exploit Public-Facing Application (T1190 contextual business logic abuse)	Manipulate cart total before checkout	Order processed at unusually low price	Validation bypass achieved	Verify pricing engine response logs	Compare client-side vs server-side calculation	Order value inconsistent with SKU pricing	Suspend order fulfillment	Client-side price trust is common vulnerability.
Execution	Data Manipulation (T1565.001 Stored Data Manipulation contextual order value change)	Modify cart value in database	Cart total updated directly via API	Active pricing manipulation	Review DB update logs	Detect abnormal UPDATE to order_total field	>20 orders placed below cost price	Halt checkout endpoint	Bulk underpriced orders indicate automated fraud.
Persistence	Account Manipulation (T1098)	Create secondary buyer account to repeat abuse	Multiple new accounts from same ASN	Fraud continuation setup	Account creation logs	Detect email pattern similarity & IP clustering	>5 accounts created within minutes	Block IP & enforce CAPTCHA	Account farming enables repeated exploitation.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment contextual promo admin abuse)	Elevate account to promo administrator	User granted coupon management role	Expanded pricing control	Role change audit logs	Validate privilege elevation workflow	Non-staff account assigned promo privileges	Revoke elevated privileges	Promo admin role enables discount abuse at scale.

Defense Evasion	Obfuscated Files or Information (T1027 contextual transaction structuring)	Split purchases into small transactions	Multiple small-value orders	Threshold evasion	Transaction frequency analysis	Detect burst orders below fraud alert threshold	>10 underpriced orders in short timeframe	Suspend account & review orders	Structuring hides total revenue impact.
Discovery	Permission Group Discovery (T1069.003 contextual promo rule mapping)	Identify discount rule engine behavior	Access to promo configuration endpoints	Mapping validation thresholds	Config access logs	Detect browsing of pricing logic rules	Promo rule accessed before underpriced orders	Increase monitoring	Threshold mapping precedes abuse.
Collection	Data from Information Repositories (T1213 contextual customer data access)	Extract shipping & customer data	Bulk export of order list	Intelligence gathering	Export logs	Correlate export with abnormal order activity	Customer list downloaded before fraud wave	Notify compliance if PII involved	Fraud may pair with identity harvesting.
Command & Control	Application Layer Protocol (T1071.001 Web)	Automate cart manipulation via bot	High-frequency cart API calls	Automated exploitation	API rate & ASN clustering	Detect fixed interval API calls	Requests every 2 seconds across multiple SKUs	Block IP & enforce bot mitigation	Automation indicates organised exploitation.
Exfiltration	Exfiltration Over Web Services (T1567.002 contextual goods	Divert goods to mule shipping addresses	Multiple shipments to same address	Physical goods exfiltration	Shipping address clustering	Identify repeated address or freight forwarder	Same delivery address across many accounts	Cancel shipments & notify logistics	Freight forwarders often used as mule hubs.

	shipment diversion)								
Impact	Financial Fraud (T1657 contextual) + Data Manipulation (T1565.001)	Revenue loss & reputational damage	Surge in chargebacks or inventory discrepancies	Business & financial impact	Full transaction reconciliation	Identify exploit window & affected SKUs	Orders processed below cost for extended period	Activate fraud response & patch logic flaw	Business logic flaws cause silent large-scale loss.

PLAYBOOK 98 — Data Broker Aggregation Attack

Attack Theme: Compromised Low-Sensitivity Datasets → Aggregation Across Multiple Systems → Identity Enrichment → High-Value Targeting / Fraud / Espionage

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Identity Information (T1589) + Search Open Technical Databases (T1596)	Identify publicly exposed or low-tier datasets	Repeated access to “non-sensitive” reporting endpoints	Mapping available data fragments	Source ASN & API key usage	Correlate access pattern across multiple datasets	Same user accessing multiple unrelated datasets	Increase monitoring immediately	Aggregation often starts with “low-risk” data.
Resource Development	Obtain Capabilities (T1588.001 Tooling contextual data scraping scripts)	Prepare automated scraping & enrichment workflow	High-frequency API pulls from reporting endpoints	Automation staging	API rate & request headers	Detect bot-like behaviour across endpoints	Sequential API access across departments	Throttle API & monitor	Aggregation requires volume and consistency.
Initial Access	Valid Accounts (T1078.004	Access internal	Successful login to	Data extraction channel	Validate MFA & role scope	Correlate login anomaly	Analytics login outside	Enforce step-up	Reporting portals often overlooked in

	Cloud Accounts) OR Exploit Public-Facing Application (T1190 contextual reporting abuse)	data sources	analytics/reporting portal	established		with unusual report export	business hours	authentication	security design.
Execution	Data from Information Repositories (T1213)	Extract structured datasets	Bulk CSV/JSON exports from reporting module	Active dataset harvesting	Export logs & file size	Identify repeated exports with slight variations	>5 exports within short timeframe	Suspend account & investigate	Multiple partial exports indicate aggregation attempt.
Persistence	Account Manipulation (T1098)	Create secondary reporting user	New reporting-only account created	Long-term data access channel	IAM & application audit logs	Trace approval path for new account	Reporting user created without business justification	Remove account	Reporting accounts can evade monitoring focus.
Privilege Escalation	Account Manipulation (T1098.003 Role Assignment)	Expand read-only role to broader data access	Role expanded to include HR/Finance data	Enlarged dataset scope	Role change audit logs	Validate approval workflow	User granted cross-department read privileges	Revoke elevated role	Cross-department access accelerates aggregation value.
Defense Evasion	Obfuscated Files or Information (T1027 contextual	Extract selective fields to avoid large	Numerous small field-level queries	Stealth aggregation	Query pattern analysis	Detect consistent partial extraction	Multiple small exports across days	Increase monitoring	Small consistent extraction is harder to detect.

	field-level extraction)	export alerts				across tables			
Discovery	Permission Group Discovery (T1069.003 contextual data classification roles)	Identify datasets with PII or financial metadata	Access to data classification tags	Mapping high-value enrichment targets	Data catalog access logs	Detect classification browsing before export	PII-tagged datasets accessed unexpectedly	Increase monitoring	Data classification reconnaissance signals intent escalation.
Collection	Data from Information Repositories (T1213)	Aggregate HR + CRM + Transaction data	Combined export events across systems	Identity enrichment in progress	Cross-system export correlation	Identify time-aligned exports from multiple apps	Same account exporting from 3+ systems	Notify compliance	Cross-platform extraction multiplies risk.
Command & Control	Application Layer Protocol (T1071.001 Web)	Automate cross-platform data pulls	API calls at regular intervals	Centralised data harvesting	IP clustering & timing pattern	Detect 24/7 API activity	Continuous API calls beyond work hours	Block source & rotate credentials	Automation signals data broker behaviour.
Exfiltration	Exfiltration Over Web Services (T1567.002)	Transfer aggregated dataset externally	Large encrypted upload to cloud storage	Data broker aggregation completed	NetFlow & CASB logs	Correlate export + outbound transfer	Multi-GB upload post multi-system export	Notify regulator if PII involved	Aggregated datasets may exceed original system sensitivity.
Impact	Data Exfiltration (T1041) + Gather Victim Identity	High-fidelity identity profiles created	Increase in targeted phishing or fraud later	Strategic exploitation risk	Monitor downstream fraud patterns	Identify affected data categories & volume	Combined HR + financial + contact data exposed	Activate legal & regulator reporting	Aggregated “low-risk” data can become high-risk when combined.

BYZIMMER

PLAYBOOK 99 — Quantum-Safe Migration Delay Exploitation

Attack Theme: Continued Use of Quantum-Vulnerable Cryptography (RSA/ECC) → Adversary Harvests Encrypted Traffic → Store Now, Decrypt Later (SNDL) → Future Decryption & Strategic Exposure

MITRE TACTIC	TECHNIQUE (ID) + SUB-TECH	ATTACKER OBJECTIVE	TYPICAL SOC ALERT EXAMPLE	WHAT IT USUALLY MEANS	WHAT ANALYST MUST CHECK IMMEDIATELY	DEEP ANALYSIS STEPS (L2/L3)	ESCALATION TRIGGER	CONTAINMENT PRIORITY	KEY FOCUS / CRITICAL THINKING POINT
Reconnaissance	Gather Victim Org Information (T1591) + Search Open Technical Databases (T1596 contextual TLS fingerprinting)	Identify services still using RSA-2048 / ECC-P256	External scan detects legacy TLS cipher suites	Mapping quantum-vulnerable assets	Validate TLS configuration & cert details	Correlate exposed services with sensitive data flows	Critical system still using legacy cipher	Increase monitoring immediately	Cryptographic inventory gaps signal migration delay risk.
Resource Development	Obtain Capabilities (T1588.001 Tooling contextual traffic capture infrastructure)	Prepare infrastructure to capture encrypted traffic	Persistent passive traffic monitoring detected	SNDL preparation	Inspect network taps & monitoring endpoints	Identify unusual mirroring or span config changes	Unexpected traffic mirroring to external sensor	Remove unauthorised monitoring point	Traffic capture enables long-term exploitation.
Initial Access	Exploit Public-Facing Application (T1190 contextual passive interception) OR Adversary-in-the-Middle (T1557)	Capture encrypted sessions	High-volume TLS session logging	Traffic harvesting underway	Identify destination of captured traffic	Analyse packet capture anomalies	Repeated connections to same external collector	Block suspicious traffic path	Passive interception often invisible without deep inspection.

Execution	Exfiltration Over Unencrypted/Obfuscated Channel (T1041 contextual encrypted traffic harvesting)	Store encrypted sensitive communications	Large outbound encrypted data transfers	Data hoarding for future decryption	NetFlow & packet size analysis	Identify repeated full-session transfers	Multi-GB TLS streams to unknown ASN	Investigate & isolate path	Harvesting does not cause immediate impact.
Persistence	Account Manipulation (T1098 contextual certificate lifecycle neglect)	Maintain weak crypto configuration	Expired or unrotated certificates remain active	Weak crypto posture	Certificate lifecycle logs	Identify outdated keys reused across services	Same RSA key used across multiple systems	Initiate certificate rotation campaign	Key reuse amplifies SNDL exposure.
Privilege Escalation	Exploitation for Privilege Escalation (T1068 contextual crypto downgrade attack)	Force downgrade to weaker cipher	TLS handshake shows downgrade to legacy cipher	Increased decryptability	TLS handshake logs	Detect downgrade attack patterns	Sudden shift from ECDHE to RSA key exchange	Enforce strong cipher policy	Downgrade increases future decrypt feasibility.
Defense Evasion	Impair Defenses (T1562.001 Disable Security Tools contextual crypto monitoring disablement)	Disable TLS inspection or crypto monitoring	TLS inspection disabled on gateway	Concealment of harvesting	Security policy change logs	Detect unexpected crypto policy changes	TLS inspection disabled without CAB	Restore policy immediately	Crypto monitoring removal signals deliberate action.
Discovery	System Information Discovery (T1082 contextual cryptographic inventory scan)	Identify key storage locations	Access to HSM or key vault metadata	Mapping sensitive key assets	HSM audit logs	Detect enumeration of key IDs	HSM key listing accessed unexpectedly	Increase monitoring	Key vault access precedes potential theft.

Collection	Data from Information Repositories (T1213 contextual key backup access)	Access key backup files	Key export or backup access event	Sensitive key exposure	Check HSM export logs	Validate if private key exported	Private key accessed outside maintenance window	Immediately rotate affected keys	Private key theft eliminates need for quantum break.
Command & Control	Application Layer Protocol (T1071.001 Web contextual persistent harvesting endpoint)	Maintain long-term encrypted traffic capture	Recurrent connection to external collector	Active harvesting infrastructure	ASN clustering & timing analysis	Detect long-duration encrypted sessions	Continuous nightly data transfer	Block endpoint & isolate device	Harvesting may persist quietly for months.
Exfiltration	Exfiltration Over Web Services (T1567.002 contextual bulk encrypted capture transfer)	Transfer stored encrypted archives externally	Large periodic encrypted uploads	Archive export completed	NetFlow & storage audit logs	Correlate archive file creation with transfer	Multi-GB archive upload monthly	Notify executive leadership	Exposure may not be visible until years later.
Impact	Data Exfiltration (T1041) + Gather Victim Identity Information (T1589)	Future decryption of historic sensitive data	Exposure of archived contracts or PII years later	Long-term strategic breach	Inventory all quantum-vulnerable crypto assets	Identify high-sensitivity data transmitted over weak crypto	Sensitive data transmitted via RSA-only key exchange	Accelerate PQC migration & crypto agility	SNDL risk is delayed but strategic and regulatory in nature.

PLAYBOOK 100 — Coordinated Hybrid Attack (Multi-Vector Campaign)

Attack Theme: Simultaneous Multi-Vector Campaign (Phishing + API Abuse + Insider Access + Ransomware + Data Leak) → Overwhelm Detection & Response → Strategic Financial, Operational & Reputational Impact

Mitre Tactic	Technique (ID) + Sub-Tech	Attacker Objective	Typical SOC Alert Example	What it usually means	What Analyst must check immediately	Deep Analysis Steps (L2/L3)	Escalation Trigger	Containment Priority	Key Focus / Critical Thinking Point
Reconnaissance	Gather Victim Org Information (T1591) + Network Service Discovery (T1046) + Search Open Technical Databases (T1596)	Map organisation across identity, API, cloud & OT surfaces	Parallel probing across VPN, API, and email gateway	Coordinated pre-attack mapping	Correlate alerts across security stacks	Identify common source ASN or infrastructure	Same ASN touching multiple attack surfaces	Elevate monitoring to campaign level	Hybrid campaigns show cross-domain correlation.
Resource Development	Obtain Capabilities (T1588.001 Tooling) + Acquire Infrastructure (T1583.003 VPS)	Stage phishing infra, botnet, and C2 servers	Domain registration + C2 infra detection	Multi-layer staging	Check threat intel & passive DNS	Correlate infra reuse across campaigns	Infra linked to known APT/RaaS group	Pre-emptive blocking & intel alert	Infrastructure reuse reveals campaign fingerprint.
Initial Access	Phishing (T1566.002)	Gain foothold	MFA fatigue alert + API	Multi-vector initial	Confirm which	Build unified	Successful login aligned	Treat as enterprise-	Multi-vector entry

	+ Valid Accounts (T1078) + Exploit Public-Facing Application (T1190)	via multiple entry points	anomaly + VPN login	compromise	access path succeeded first	attack timeline	with phishing click	wide compromise	increases attack resilience.
Execution	Command and Scripting Interpreter (T1059) + Modify Authentication Process (T1556)	Deploy scripts & manipulate trust mechanisms	PowerShell execution + SSO config change	Active expansion of control	Endpoint + IAM logs correlation	Identify simultaneous script execution across hosts	Script execution in >5 endpoints	Isolate affected segments	Execution across domains signals coordination.
Persistence	Account Manipulation (T1098) + Create Account (T1136)	Establish redundant backdoors	Multiple new admin accounts created	Multi-layer persistence	Check identity system & local admins	Identify pattern of distributed persistence	Accounts created across cloud + on-prem	Remove backdoors & rotate credentials	Hybrid attacks build layered persistence.
Privilege Escalation	Exploitation for Privilege Escalation (T1068) + Role Assignment (T1098.003)	Achieve enterprise-level control	Domain Admin + Cloud Global Admin assigned	Cross-domain dominance	Correlate AD & cloud role changes	Detect simultaneous escalation across platforms	Privilege escalation in multiple environments	Immediate privilege revocation	Dual escalation indicates strategic objective.
Defense Evasion	Impair Defenses (T1562.001) +	Disable monitoring & conceal payloads	EDR disabled + SIEM	Concealment phase	Check telemetry continuity	Detect log tampering across systems	Logging disabled across IT + Cloud	Treat as confirmed enterprise compromise	Defense suppression across layers is

	Obfuscated Files (T1027)		ingestion gap						decisive signal.
Discovery	Permission Group Discovery (T1069.003) + System Information Discovery (T1082)	Identify crown jewels	Access to financial DB + HR + OT panel	Target prioritisation	Cross-platform log review	Identify which systems accessed in short window	Crown jewel systems accessed sequentially	Increase monitoring & restrict access	Target convergence signals final objective focus.
Collection	Data from Information Repositories (T1213)	Stage sensitive data	Parallel exports from DB, SharePoint & backups	Coordinated data harvesting	Correlate export timestamps	Identify common operator or infrastructure	Multi-system export within same hour	Enable DLP & executive notification	Simultaneous data staging indicates strategic extortion.
Command & Control	Application Layer Protocol (T1071.001) + Multi-hop Proxy (T1090)	Maintain distributed control channels	DNS beacon + HTTPS C2 + VPN sessions	Redundant C2 infrastructure	Correlate C2 infra across domains	Identify shared JA3 fingerprint	Multiple C2 protocols active simultaneously	Block after scoping full infrastructure	Hybrid C2 increases resilience against takedown.
Exfiltration	Exfiltration Over Web Services (T1567.002) + Exfiltration Over C2 Channel (T1041)	Transfer data through multiple channels	Outbound spike + cloud upload + encrypted archive	Data theft at scale	NetFlow + CASB + EDR correlation	Identify overlapping exfil paths	Exfiltration from on-prem + cloud simultaneously	Notify regulator & legal immediately	Multi-channel exfil complicates containment.
Impact	Data Encrypted for Impact	Combine ransomware	Encryption event + unauthorised	Maximum disruption strategy	Assess operational, financial &	Build consolidated enterprise	Ransomware + fraud +	Activate crisis & national-	Hybrid attacks aim to

	(T1486) + Financial Fraud (T1657 contextual) + Data Manipulation (T1565.001)	e, fraud & leak	ed transaction s		reputational impact	incident map	data leak concurrent	level response	overwhelm detection and response capacity.
--	--	-----------------	------------------	--	---------------------	--------------	----------------------	----------------	--

BYZANTIUM